Al-Balqa Applied University

Faculty of Artificial Intelligence — Department of Intelligent Systems

Runtime Evaluation and Mitigation (REM): A Security Framework for Financial AI Agents

By

Rawan Al-Lahham

Supervisor

Prof. Omar Ahmad Alzubi

Co-Supervisor

Dr. Husam Fakhouri

A thesis submitted in partial fulfilment of the requirements for the degree of Master of Science in Cybersecurity

Al-Balqa Applied University

November 2026

Draft for supervisor review, second edition (14 November 2026) — not approved

Committee Decision

This thesis, *Runtime Evaluation and Mitigation (REM): A Security Framework for Financial AI Agents*, was successfully defended and approved on **[date to be completed by the university]**.

Examination Committee	Role	Signature
[Name and title as officially recorded]	Supervisor	[not signed]
[Name and title as officially recorded]	Co-Supervisor	[not signed]
[Name and title as officially recorded]	Internal Member	[not signed]
[Name and title as officially recorded]	External Member	[not signed]

Placeholder page. The committee, the decision and the signatures are to be completed by Al-Balqa Applied University; nothing on this page has been completed or approved.

Declaration of Authorship and Originality

[Placeholder. The declaration in the university's prescribed wording is to be completed and signed by the student. It has not been completed or signed in this draft.]

Factual note on the use of AI assistance (not a declaration). An AI coding assistant (Claude Code) was used in this project, as recorded in the project files and the repository history. It assisted with the literature screening records, the software and tests, the execution of the analyses, the AI-only label inspection (Section 4.10), the closed-loop and MELON integration code, the design and execution of the analyses of November 2026 including the paired test fixtures, and the drafting, restructuring and verification of this text. Any declaration of AI use required by the university must be completed by the student.

Dedication

[Placeholder for the student's dedication.]

Acknowledgement

[Placeholder for the student's acknowledgement.]

Table of Contents

Committee Decision....ii

Declaration of Authorship and Originality....iii

Dedication....iv

Acknowledgement....v

List of Tables....xvii

List of Figures....xxi

List of Abbreviations....xxii

Abstract....xxiii

الملخص....xxv

Status of This Draft....xxvii

CHAPTER ONE: INTRODUCTION....1

1.1 Background....1

1.1.1 Language models and AI agents....1

1.1.2 Tool-using and financial AI agents....1

1.1.3 Indirect prompt injection....1

1.1.4 Runtime security at the tool-execution boundary....2

1.2 Problem Statement....2

1.3 Motivation....3

1.4 Research Gap....4

1.5 Research Aim....5

1.6 Research Objectives....6

1.7 Research Questions....6

1.8 Proposed Approach....7

1.9 Research Methodology....8

1.10 Scope....9

1.11 Contributions: Proposed and Demonstrated....9
1.12 Thesis Organization....11
CHAPTER TWO: LITERATURE REVIEW: A RECORD-LEVEL SYSTEMATIC REVIEW OF RUNTIME SECURITY FOR TOOL-USING AI AGENTS....13
2.1 Introduction....13
2.2 Systematic Review Methodology....14
2.2.1 Review objectives and research questions....14
2.2.2 Information sources....15
2.2.3 Search strategy....16
2.2.4 Study selection....17
2.2.5 Quality appraisal, data extraction and synthesis....20
2.3 Threats Against AI Agents....21
2.3.1 Direct and indirect prompt injection....21
2.3.2 Adaptive attackers....22
2.4 Benchmarks and Threat Models....22
2.5 Defensive Approaches....23
2.5.1 Policy enforcement and tool restriction....24
2.5.2 Goal–action consistency and provenance....25
2.6 Runtime Monitoring and Behavioral Analysis....26
2.6.1 Provenance and cross-step information flow as evidence....26
2.6.2 What is known about the empirical value of behavioral and provenance evidence....27
2.7 Statistical and Algorithmic Foundations Relevant to REM....28
2.7.1 Why calibration matters, and its limits....28
2.7.2 Why expected-loss decisions are relevant....29
2.8 Runtime Decision and Mitigation....30
2.8.1 The space of runtime responses....31

2.8.2 AgentTrust: runtime interception with graduated verdicts.....31
2.8.3 NEXUS: calibrated risk scoring with a four-way intervention set.....32
2.8.4 Other decision mechanisms.....34
2.9 Financial AI-Agent Security.....35
2.9.1 General agent-security evidence with a financial component.....35
2.9.2 Financial-agent evidence.....36
2.9.3 Why financial execution raises the requirements.....36
2.9.4 Requirements derived for a runtime layer protecting a financial agent.....37
2.10 Comparative Evidence Synthesis.....37
2.11 Critical Synthesis.....39
2.12 Research Gap and REM Positioning.....41
2.12.1 Assessment of candidate gaps.....41
2.12.2 Research gap supported by the systematic review (September 2026).....41
2.12.3 REM positioning: established by prior research versus proposed by this thesis 42
2.12.4 Limitations of this review.....44
2.12.5 Dated literature updates of 30 October and 2 November 2026 (outside the PRISMA flow).....45
2.12.6 Literature update of 11 November 2026: full-text readings (outside the PRISMA flow).....46
2.12.7 Revised statement of the research gap.....50
2.13 Chapter Summary.....51
CHAPTER THREE: RESEARCH METHODOLOGY, DESIGN AND IMPLEMENTATION OF THE REM FRAMEWORK.....53
3.1 Research Methodology and System Scope.....53
3.1.1 Design science research.....53
3.1.2 Research objectives.....53

3.1.3 Research questions....54
3.1.4 Scope....54
3.1.5 Assumptions....55
3.2 REM Architecture....56
3.2.1 Five layers....56
3.2.2 Topology and information flow....56
3.3 Threat Model and Financial Action Boundary....57
3.3.1 Protected system....57
3.3.2 Episodes and steps....58
3.3.3 Trust boundaries and untrusted content....58
3.3.4 Adversary model....58
3.3.5 Indirect injection and adversarially induced actions....59
3.3.6 Sensitive financial actions....59
3.3.7 Security objectives....60
3.4 Input & Context Layer....60
3.4.1 Context capture....60
3.4.2 Provenance labeling....61
3.4.3 Entity extraction....61
3.5 Detection Layer....61
3.6 Behavioral Analysis Layer....62
3.6.1 Step tracking....62
3.6.2 Behavioral and action evidence....62
3.7 Decision Engine Layer....63
3.7.1 Ridge logistic estimation....64
3.7.2 Calibration on the logit....65
3.7.3 Consequence tiers....66

3.7.4 Policy predicates..... 68
3.7.5 Expected-loss verdict selection..... 68
3.7.6 Explainability and audit record..... 72
3.7.7 Consequence-independent baseline policy..... 74
3.8 Mitigation Layer..... 75
3.9 Offline Fitting and Recalibration..... 76
3.10 Algorithm 1: REM Runtime Evaluation and Mitigation..... 77
3.11 Experimental Methodology..... 79
3.11.1 Environment and instrumentation..... 79
3.11.2 Dataset..... 80
3.11.3 Label construction..... 81
3.11.4 Data limitations..... 82
3.11.5 Grouping and cross-fitting..... 82
3.11.6 Leakage controls..... 84
3.11.7 Configurations, baselines, and ablations..... 84
3.11.8 Pilot E0..... 86
3.11.9 Repeated runs and uncertainty..... 86
3.11.10 Recorded-trace replay sensitivity analysis *[proposed scope amendment, pending supervisor approval]*..... 87
3.11.11 Rule baselines and additional policy arms (added November 2026)..... 87
3.11.12 Generalization schemes..... 89
3.11.13 Robustness probes and paired call fixtures..... 90
3.11.14 Confirmatory protocol for one modification..... 90
3.12 Evaluation Metrics..... 92
3.12.1 Primary metrics..... 92
3.12.2 Secondary metrics..... 93

3.12.3 Realized loss across a declared grid....94
3.12.4 Outcome layers and additional metrics....94
3.13 Versioned Amendment: REM v1.1 (Proposed)....95
3.14 Exploratory Extension: Task-Permission Evidence (Proposed, Not Adopted)....96
3.15 System Implementation....99
3.16 Threats to Validity....101
3.17 Chapter Summary....103
CHAPTER FOUR: EXPERIMENTAL RESULTS AND DISCUSSION....104
4.1 Implementation Tools and Environment....105
4.1.1 Software, Hardware and Benchmark Environment....105
4.1.2 Implemented Components....106
4.1.3 Reproducibility and Software Verification....106
4.1.4 Kinds of Evidence and Evaluation Modes....107
4.2 Dataset Preparation and Training....108
4.2.1 Recorded Data, Fitting Protocol and Chronology....109
4.2.2 Labels, the user_task_15 Collision and Benchmark Versions....113
4.2.3 Pilot E0: Feasibility and Feature Retention....114
4.2.4 Training of the Risk Estimator....115
4.3 Experimental Setup and Evaluation Metrics....116
4.3.1 Compared Arms....116
4.3.2 Populations and Generalization Schemes....117
4.3.3 Evaluation Metrics....118
4.3.4 Statistical Procedure and Comparisons Fixed in Advance....118
4.4 Comparisons with Existing Models and Defense Frameworks....119
4.4.1 Rule Baselines and an Audit of REM’s Interventions....119
4.4.2 Distributed Defenses (Recorded Outcomes Only)....122

4.4.3 A Published Policy and a Request-Derived Permission Rule in the Same Harness....122
4.4.4 Live-Agent and Published-Defense Experiments: Status....125
4.4.5 Comparison with Prior Work....126
4.5 Ablation Studies....129
4.5.1 Ablations of the Components of REM v1.0....129
4.5.2 Ablation of the Behavioral Evidence Group and of the Verdict Set....130
4.5.3 Ablations of the Task-Permission Extension....131
4.6 Results and Discussion....134
4.6.1 RQ1 — Offline Classification (Held-Out Predictions)....134
4.6.2 RQ2 — Observe-Only Decisions....136
4.6.3 RQ2 and RQ3 — Replay Sensitivity Analysis....138
4.6.4 Optional Sequential Analysis (CUSUM, observe-only)....143
4.6.5 Realized Loss across the Declared Grid....143
4.6.6 Generalization to Unseen Tasks and Objectives, and a Rejected Candidate…144
4.6.7 Robustness Probes: Reformatted Identifiers and Paired Call Fixtures....146
4.6.8 Confirmatory Evaluation of REM v1.1 (Run of 11 November 2026)....149
4.6.9 Exploratory Extension: Task-Permission Evidence....153
4.6.10 Interpretation of the Findings....157
4.6.11 Threats to Validity and Limitations....162
4.6.12 Chapter Summary....163
CHAPTER FIVE: CONCLUSIONS AND FUTURE WORK....165
5.1 Introduction....165
5.2 Answers to the Research Questions....165
5.3 Achievement of the Objectives....167
5.4 Contributions....168

5.5 What Was Not Confirmed, What Was Rejected, and Why It Matters.....171
5.6 Limitations and Threats to Validity.....173
5.7 Future Work, in Order of Priority.....173
5.8 Conclusion.....174
References.....176
Appendix A: Systematic Review: Search Strings, Supporting Tables and Evidence Matrix 191
A.1 Database searches.....191
A.2 Benchmarks used by included studies.....192
A.3 Where included defenses intervene and what they observe.....194
A.4 Runtime responses reported by included systems.....195
A.5 Comparative evidence matrix of defense and design studies.....197
A.6 Eligibility criteria.....209
A.7 Exclusions at screening and at eligibility.....211
A.8 Quality appraisal.....211
A.9 Data extraction.....213
A.10 Evidence synthesis.....214
A.11 Threat classes and the included evidence.....215
A.12 Learned and LLM-based guardrails.....216
A.13 Step-level, sequence-level and accumulating monitors.....217
A.14 Foundations: behavioral anomaly detection and its cautions.....218
A.15 What attribution contributes to auditability.....219
A.16 Decision mechanisms of the runtime systems closest to REM.....222
A.17 Thematic synthesis of the included evidence.....225
A.18 Assessment of candidate research gaps.....228
A.19 AI agents and emerging security risks.....229

A.19.1 From language models to agents....229
A.19.2 Why agent architecture changes the security problem....229
A.19.3 Implication....230
A.20 Tool misuse, action manipulation and new tool channels....230
A.21 Context and memory manipulation....231
A.22 Multi-step propagation, goal drift and abnormal execution....232
A.23 Input-, context- and model-level protection....232
A.24 System-level and information-flow defenses....233
A.25 Why logistic regression....233
A.26 Why sequential evidence matters....234
A.27 Currency update of 30 October 2026 (outside the PRISMA flow)....235
A.28 Supplementary literature update of 2 November 2026: Kanaker et al. (2026) (outside the PRISMA flow)....237
Appendix B: System Implementation: Details....241
B.1 Implementation of the REM framework....241
B.1.1 Purpose and Scope....241
B.1.2 Software Environment....242
B.1.3 Code Organization and Execution Paths....243
B.1.4 Layer 1 — Input and Context....245
B.1.5 Layer 2 — Detection....246
B.1.6 Layer 3 — Behavioral and Action Evidence....246
B.1.7 Layer 4 — Decision Engine....247
B.1.8 Layer 5 — Mitigation, and What Happens at the Tool Boundary....248
B.1.9 Non-Invasive Placement and Its Limits....249
B.1.10 Optional Sequential Analysis (A2)....250
B.1.11 Verification....250

B.1.12 Correspondence Between Requirements, Equations, Code, Tests and Results 253
B.1.13 Logging of Sensitive Values.....255
B.1.14 Runtime Measurement.....255
Appendix C: Notation, Optional Sequential Analysis and Equation Provenance.....258
C.1 Notation.....258
C.2 Layer interfaces.....259
C.3 Optional observe-only sequential analysis.....259
C.4 Provenance of the equations of Chapter 3.....261
Appendix D: Live-Agent and MELON Evaluations: Design and Status (Not Executed). 263
D.1 Closed-loop evaluation with live agents: design and implementation status.....263
D.1.1 Purpose.....263
D.1.2 Defended agent pipeline.....263
D.1.3 Conditions and controlled variables.....265
D.1.4 Frozen parameters.....265
D.1.5 Design inputs required before execution.....265
D.1.6 Metrics, statistics and logging.....266
D.1.7 Safety precautions.....266
D.1.8 Implementation and verification status.....267
D.2 Closed-loop evaluation with live agents: status on 3 November 2026.....267
D.3 Replay versus live evaluation.....268
D.4 Controlled evaluation of MELON with and without REM: protocol.....269
D.4.1 Why MELON is the reference.....269
D.4.2 Integration point.....270
D.4.3 Frozen settings and training provenance.....270
D.4.4 Protocol.....271

D.4.5 Interpretation limits.....272

Appendix E: Sensitivity of the Replay Results to the Mitigation Semantics.....274

E.1 Replay results under the two mitigation semantics.....274

Appendix F: Register of Open Supervisor Decisions.....277

List of Tables

Table 2.1. Study selection (counts computed from the screening log).....19
Table 2.2. Established by prior research versus proposed by this thesis.....42
Table 2.3. Works examined in the updates of 11 and 13 November 2026 (F = full text read; A = abstract only; R = authors' repository read, paper not read).....47
Table 2.4. Assessment of the revised gap statement.....51
Table 3.1. Design science research activities in this thesis.....53
Table 3.2. Traceability of research questions.....54
Table 3.3. Assumptions.....55
Table 3.4. Trust boundaries.....58
Table 3.5. Action categories in the banking environment.....59
Table 3.6. Context evidence.....61
Table 3.7. Behavioral and action evidence.....62
Table 3.8. Consequence descriptors.....67
Table 3.9. Illustrative consequence tiers (policy pending supervisor approval).....67
Table 3.10. Learned, measured, and policy quantities.....67
Table 3.11. Tier-indexed loss structure L(v, y, k).....69
Table 3.12. Verdict-to-mitigation mapping: reference (step-level) semantics and the episode-level variant.....75
Table 3.13. Rule baselines.....88
Table 3.14. Diagnostic and candidate arms.....89
Table 3.15. Primary metrics.....92
Table 3.16. Outcome layers and the quantity reported for each.....95
Table 3.17. Permission status of a proposed state-changing call.....97
Table 3.18. Arms of the extension study.....98
Table 4.1. Software and hardware used for the reported results.....105
Table 4.2. Components, their location in the repository and their status.....106
Table 4.3. Kinds of evidence in this chapter.....107
Table 4.4. Pre-registered values (configs/exploratory/pilot_e0.yaml).....110
Table 4.5. The second population (recorded outcomes; confirmatory_results.json).....112
Table 4.6. Pilot E0 (fitting portions only).....114
Table 4.7. Training outcome per outer fold, REM v1.0 (e1_crossfit.json; each row is the model that scores the held-out attacker objective named in the first column).....115
Table 4.8. Arms compared in this chapter.....116
Table 4.9. Populations and what each is used for.....117
Table 4.10. Metrics and their definitions.....118
Table 4.11. Replay results of REM, the baselines and the rules on the primary recordings (step-level, no reviewer; study_results.json, S1).....120
Table 4.12. REM v1.0 on the 178 authorized calls of benign episodes, by action category (weakness_audit.json).....121
Table 4.13. Replay results on the primary recordings (step-level, no reviewer; improvement_results.json).....123

Table 4.14. Replay results on the second population (the same arms; nothing fitted on these episodes).....123
Table 4.15. Paired contrasts (first arm minus second arm, in percentage points, with the 95% grouped-bootstrap interval; PG = Progent manual policy; v1.0 and v1.1 = REM versions; * = fixed in advance).....124
Table 4.16. Relation of the results to recent work, and why no experimental comparison is reported 127
Table 4.17. Ablations (observe-only columns: held-out recorded steps; replay columns: step-level semantics, no reviewer).....129
Table 4.18. The permission rule with one component removed (improvement_results.json).....131
Table 4.19. Decision semantics and a learned model on the permission evidence (S1: held-out attacker objective; S2: double holdout).....132
Table 4.20. Paired contrasts for the decision semantics, the learned model and the guard (first arm minus second arm, in percentage points, with the 95% interval; v1.1 = REM v1.1; * = fixed in advance).....133
Table 4.21. Held-out discrimination and calibration, pooled over nine outer folds (6,762 steps; 921 positive; e1_crossfit.json).....134
Table 4.22. Per-fold results (calibrated, label-NLL).....135
Table 4.23. Observe-only verdicts on held-out steps (y = 0: n = 5,841; y = 1: n = 921; e2_e5_e6_observe_only.json).....137
Table 4.24. Observe-only interventions by consequence tier and action category (r2_breakdowns.json).....137
Table 4.25. Replay results, step-level semantics (attacked n = 2,979; benign n = 334; e4_e5_enforcement_replay.json).....139
Table 4.26. Paired differences (grouped bootstrap).....140
Table 4.27. Replay ASR by the attacker’s target action (r2_breakdowns.json).....140
Table 4.28. Replay benign utility by kind of user task (r2_breakdowns.json).....140
Table 4.29. Successful attacks and benign tasks completed under three generalization schemes (study_results.json).....144
Table 4.30. Pre-declared contrasts of the candidate against REM v1.0 (paired, grouped bootstrap; percentage points).....145
Table 4.31. Diagnostic arms on the primary recordings, scheme S1 (attacks / 2,979; benign tasks / 334).....146
Table 4.32. Successful attacks before and after the identifier is reformatted (2,645 attacked episodes; study_results.json).....147
Table 4.33. Paired fixtures: legitimate calls released and unsafe calls released (counts).....148
Table 4.34. Confirmatory replay results (2,065 attacked and 48 benign eligible episodes; step-level, no reviewer; confirmatory_results.json).....149
Table 4.35. Paired contrasts on the confirmatory population (percentage points; 95% grouped-bootstrap interval; gained / lost = episodes in which only the first or only the second arm completes the task).....150
Table 4.36. Tasks completed by user task on the confirmatory population (all eligible episodes of each task; tasks on which the arms differ).....152
Table 4.37. Interventions on the confirmatory population (8,221 recorded calls in 2,113 episodes, of which 5,808 are read-type calls that no arm withholds; confirmatory_descriptives.json; descriptive).....153

Table 4.38. Successful attacks before and after the attacker’s identifier is reformatted (2,645 attacked episodes)..... 154
Table 4.39. Paired fixtures (each pair has one legitimate and one unsafe call for the same request; a pair is correct if the legitimate call is released and the unsafe call is withheld; counts, not rates). 155
Table 4.40. Tasks completed by user task on the primary recordings (user tasks on which A2, the published policy, G1 and L2 all equal the undefended agent are omitted).....156
Table 4.41. Conclusions, their support and their limits.....157
Table 4.42. Attack success and task completion in percent, both populations.....160
Table 5.1. Answers to the research questions.....165
Table 5.2. Objectives and how far they were achieved.....167
Table 5.3. Each contribution with its precedent, implementation, experiment, measured result and limits..... 168
Table A.1. Database searches (OpenAlex; 25 September 2026; years 2019–2026).....191
Table A.2. Critical evaluation of benchmarks used by included studies.....192
Table A.3. Where included defenses intervene and what they observe.....194
Table A.4. Runtime responses reported by included systems.....195
Table A.5. Comparative evidence for included defense and design studies (n = 42).....198
Table A.6. Threat classes and the included evidence.....215
Table A.7. Established methods reviewed as the algorithmic basis for REM.....220
Table A.8. Decision mechanism, calibration, consequence and reported evaluation dimensions (runtime systems closest to REM).....222
Table A.9. Thematic synthesis of the included evidence.....225
Table A.10. Evidence-based assessment of candidate research gaps.....228
Table A.11. Kanaker et al. (2026) and REM compared (Kanaker et al.: level A, abstract and metadata only; REM: Chapters 3–4)..... 239
Table B.1. Software and hardware environment of the reported runs.....242
Table B.2. Code organization.....243
Table B.3. Entry points and call paths of each experiment.....244
Table B.4. Interpretations made where the methodology of Chapter 3 is silent.....247
Table B.5. Test suite (executed on 1 Nov 2026: 205 passed with AgentDojo installed; log verification/pytest_R4.txt).....250
Table B.6. Requirement → equation → function → test → result artifact.....253
Table B.7. Components required, implemented and absent.....255
Table B.8. Boundaries of the two timers.....256
Table C.1. Notation used in this chapter.....258
Table C.2. Layer interfaces..... 259
Table C.3. Provenance of the equations in this chapter.....261
Table D.1. Implementation status of the closed-loop evaluation (3 November 2026).....267
Table D.2. Verification of the closed-loop integration (not experimental results).....268
Table D.3. Differences between the replay sensitivity analysis and the closed-loop design……269
Table D.4. Controlled evaluation of MELON with and without REM (AgentDojo banking v1, important_instructions) — NOT EXECUTED.....272
Table E.1. Replay results under the two mitigation semantics (same episodes; same estimator, calibration, costs, predicates and thresholds; matching reviewer treatment for REM and B1; only the mitigation semantics varies. Verdict sequences are not fixed: see the notes below. ref. = the reference semantics; REM w/o Esc. = REM without expected-loss Escalate; attacked n = 2,979;

benign n = 334; e4_e5_enforcement_replay.json,
configs.<configuration>_<semantics>_<reviewer>).....274
Table F.1. Open decisions that determine what the thesis may claim.....277

List of Figures

Figure 1.1. A financial agent task with an indirect prompt injection. The user request is trusted; the tool output carrying the injected instruction is untrusted; the harm occurs only if the proposed state-changing call (here a transfer to the attacker) is executed. REM is placed at the tool-execution boundary..... 2

Figure 2.1. PRISMA 2020 flow diagram of the record-level review. Full-text reports were sought but not retrieved; eligibility was assessed on records. Counts are computed by script from the stored search output and the screening log..... 20

Figure 3.1. REM architecture as implemented. Five layers at the tool-execution boundary; offline fitting and recalibration are cross-cutting and never run within an episode; the audit record is written for every step and its attribution cannot reach the verdict..... 57

Figure 3.2. Conditional risk R(v | p) of the four verdicts (Eq. 3.6) as a function of the calibrated probability p, for the declared exploratory costs of tiers 1–4 (CFA = 1; Cmiss = 1, 5, 10, 20; Cmod = 0.5; Cesc = 0.3; rmod as estimated in the pilot: 1, 1, 0, 0.01). The verdict is the lower envelope. The figure plots the equations for declared values; it is not an experimental result..... 72

Figure 3.3. REM runtime workflow for one proposed tool call, as implemented in the evaluated path (RemGuard.evaluate): evidence, estimation and calibration, consequence tier, predicates, expected-loss verdict, mitigation before execution, and the audit record. Attribution is computed after the verdict and cannot change it..... 79

Figure 3.4. Recorded-trace evaluation design: nested grouped cross-fitting (nine outer folds by injection task, four inner folds), held-out predictions, observe-only decisions and the NO-ADAPT replay sensitivity analysis in the AgentDojo sandbox..... 84

Figure 4.1. Held-out reliability diagram, calibrated and uncalibrated (10 equal-width bins). Mid-range bins contain few steps..... 136

Figure 4.2. Replay sensitivity analysis (NO-ADAPT): ASR and benign utility with 95% grouped-bootstrap intervals..... 141

Figure 4.3. Security–utility trade-off in the replay sensitivity analysis (NO-ADAPT, step-level semantics): attack success rate against benign utility for B0, B1, REM and REM without expected-loss Escalate under both reviewer bounds, and for the single-tier ablations. Values from results/pilot_R2/e4_e5_enforcement_replay.json; no live result..... 141

Figure D.1. Closed-loop (live-agent) evaluation architecture. REM’s guarded executor replaces AgentDojo’s tool executor; the agent receives the result of a released call or the refusal of a withheld one and may retry, replan or stop. Implemented and tested with scripted test agents; not executed with a language model..... 264

List of Abbreviations

Abbreviation	Meaning
AP	Average precision (an estimate of the area under the precision–recall curve)
ASR	Attack success rate
AUC	Area under the curve
API	Application programming interface
B0, B1	No-defense configuration; consequence-independent baseline with the same estimator
CUSUM	Cumulative sum (sequential change detection)
D1, D2	Policy predicates: prohibited action; missing required evidence
ECE	Expected calibration error
FPR	False-positive rate
IPI	Indirect prompt injection
LLM	Large language model
NLL	Negative log-likelihood
NO-ADAPT	Assumption that a replayed agent does not adapt to REM's refusals
PRISMA	Preferred Reporting Items for Systematic Reviews and Meta-Analyses
REM	Runtime Evaluation and Mitigation framework
ROC	Receiver operating characteristic
RQ	Research question
SC	Specification conflict (supervisor decision register)
TB	Trust boundary

Abstract

Tool-using agents built on large language models can now initiate payments, change account details and send data to external recipients. Indirect prompt injection, content placed in a tool output or a retrieved document that the agent then follows, can make such an agent propose a financial action that serves an attacker rather than the user.

This thesis designs, implements and evaluates the Runtime Evaluation and Mitigation (REM) framework, a five-layer runtime layer placed at the tool-execution boundary. For each proposed tool call, REM estimates the probability that the call was adversarially induced, using ridge logistic regression calibrated on the logit; assigns a declared consequence tier; applies policy predicates; selects one of four verdicts (Allow, Modify, Escalate or Block) by minimizing expected loss under tier-indexed costs; and records every verdict for audit. Every constituent mechanism is established in prior work, and closely related designs have been published. The thesis therefore asks an evidence question: does a learned, consequence-aware runtime decision add value over simple provenance and authorization rules for a banking agent when the user task and the attack objective are unseen, and at what cost in legitimate work?

REM was evaluated on recorded trajectories of real agents in the AgentDojo banking environment by recorded-trace replay, which assumes that the agent does not adapt to a refusal. On 3,313 episodes, with whole attack objectives held out from fitting, the estimator separated attack attempts from legitimate calls (ROC-AUC 0.938), and REM reduced attack success from 22.6% to 0.4%. It did so largely by withholding state-changing calls: benign task completion fell from 52% to 31%, and only 33 of 178 legitimate state-changing calls were released. Rules that use one or two pieces of provenance evidence and no model reached the same security with 40–42% benign task completion; one of them failed when the attacker's account number was reformatted. REM's attack count and benign task count were the same when the user task was also held out. A pre-declared candidate that added authorization evidence and was trained on intervention outcomes was rejected (132 successful attacks against 11), because it did not transfer to an unseen attack objective. Removing calibration left the attack count unchanged and changed five benign outcomes, and Modify, Escalate and Block had identical effect.

One modification was tested under a protocol committed before its data were opened: removing the behavioral evidence group. On 2,113 recorded episodes that no analysis had read before that run, it raised task completion by 7.5 percentage points (95% interval 1.2 to 16.0) with 1 successful attack against 3 of 2,065, meeting the pre-declared decision rule; the security difference is not resolved statistically. It is proposed as a versioned amendment (REM v1.1) pending the supervisor's approval; the original specification remains the baseline. Neither version was distinguishable from the simple rules. On paired test cases, none of these policies, learned or rule-based, separated an authorized payment from an unrequested one whose details appear in the user's own words.

An exploratory extension then compiled the user's request into task-permission evidence with a deterministic parser and matched each state-changing call on operation, recipient and amount. On development data this rule completed more benign tasks than REM (149 against 105 of 334) with no more successful attacks (10 against 11). Its advantage over the strongest simple rule was not statistically resolved; a published fixed-list policy (the manual banking policy of Progent), replayed in the same harness, had no successful attack; and a learned model on the same evidence added no demonstrated value and was less robust to reformatted identifiers. The gain is therefore attributed to the deterministic rule, not to the learned core.

The results are exploratory and come from replay, not from live agents; a closed-loop harness and an integration with the MELON defense are implemented and were not executed with a language model. Their main implication is that, at the tool boundary, what limits a monitor is whether its evidence represents what the user asked for and authorized, not the estimator.

Keywords: AI agent security; indirect prompt injection; runtime monitoring; financial AI agents; tool-use security; authorization; provenance; expected-loss decision; AgentDojo.

الملخص

التقييم والتخفيف في وقت التشغيل (REM): إطار أمني لوكلاء الذكاء الاصطناعي الماليين

إعداد: روان اللحام — إشراف: أ.د. عمر أحمد الزعبي — إشراف مشارك: د. حسام فاخوري

أصبح بإمكان الوكلاء المعتمدين على النماذج اللغوية الكبيرة والمزوَّدين بالأدوات أن يبدؤوا عمليات دفع، وأن يغيّروا بيانات الحسابات، وأن يرسلوا بيانات إلى جهات خارجية. ويمكن لحقن الأوامر غير المباشر، أي محتوى يُدسّ في مخرجات أداة أو في وثيقة مسترجعة فيتبعه الوكيل، أن يدفع الوكيل إلى اقتراح عملية مالية تخدم المهاجم لا المستخدم.

تصمّم هذه الرسالة إطار التقييم والتخفيف في وقت التشغيل (REM) وتنفّذه وتقيّمه، وهو طبقة تشغيلية من خمس طبقات توضع عند حدّ تنفيذ الأدوات. ولكل استدعاء أداة مقترح، يقدّر الإطار احتمال أن يكون الاستدعاء ناتجاً عن تأثير عدائي باستخدام الانحدار اللوجستي المنتظم (ridge) مع معايرة على اللوغيت، ويحدّد مستوى العاقبة المعلن، ويطبّق شروط السياسة، ويختار أحد أربعة أحكام (السماح، أو التعديل، أو التصعيد، أو الحجب) بتقليل الخسارة المتوقعة وفق تكاليف مرتبطة بمستوى العاقبة، ويسجّل كل حكم لأغراض التدقيق. وكل آلية من مكوّنات الإطار معروفة في الأدبيات، وقد نُشرت تصاميم قريبة منه؛ لذلك تطرح الرسالة سؤالاً يتعلق بالأدلة: هل يضيف قرار تشغيلي متعلِّم ومراعٍ للعاقبة قيمةً تتجاوز قواعد بسيطة تعتمد على مصدر المعطيات والتفويض، لوكيل مصرفي يواجه مهام مستخدم وأهداف هجوم لم يرها من قبل، وبأي كلفة على العمل المشروع؟

قُيّم الإطار على مسارات مسجّلة لوكلاء حقيقيين في بيئة AgentDojo المصرفية بطريقة إعادة تشغيل المسارات المسجّلة، التي تفترض أن الوكيل لا يتكيّف مع الرفض. وعلى 3,313 حلقة، مع استبعاد أهداف هجوم كاملة من التدريب، ميّز المقدِّر محاولات الهجوم عن الاستدعاءات المشروعة (ROC-AUC = 0.938)، وخفّض الإطار نجاح الهجمات من 22.6% إلى 0.4%. غير أنه حقّق ذلك أساساً بحجب الاستدعاءات التي تغيّر الحالة: انخفض إنجاز المهام السليمة من 52% إلى 31%، ولم يُسمح إلا بـ33 من أصل 178 استدعاءً مشروعاً مغيّراً للحالة. وبلغت قواعد بسيطة تستخدم دليلاً أو دليلين على مصدر المعطيات دون أي نموذج المستوى نفسه من الأمان مع إنجاز 40–42% من المهام السليمة، وفشلت إحداها عند إعادة تنسيق رقم حساب المهاجم. ولم يتغيّر عدد الهجمات الناجحة ولا عدد المهام السليمة المنجزة عند استبعاد مهمة المستخدم أيضاً من التدريب. ورُفض مرشّح محدّد مسبقاً أضاف أدلة التفويض ودُرّب على نتائج التدخل (132 هجوماً ناجحاً مقابل 11)، لأنه لم ينتقل إلى هدف هجوم غير مرئي. ولم تغيّر إزالة المعايرة عدد الهجمات الناجحة، وغيّرت نتيجة خمس مهام سليمة فقط، وكان لأحكام التعديل والتصعيد والحجب الأثر نفسه.

واختُبر تعديل واحد وفق بروتوكول ثُبّت قبل فتح بياناته: إزالة مجموعة الأدلة السلوكية. فعلى 2,113 حلقة مسجّلة لم يكن أي تحليل قد قرأها قبل ذلك الاختبار، رفع إنجاز المهام بمقدار 7.5 نقطة مئوية (فترة ثقة 95%: 1.2 إلى 16.0) مع هجوم ناجح واحد مقابل 3 من أصل 2,065، فاستوفى قاعدة القرار المعلنة مسبقاً، دون أن يُحسم الفرق الأمني إحصائياً. ويُقترح هذا التعديل نسخةً معدّلة (REM v1.1) بانتظار موافقة المشرف، مع بقاء

المواصفة الأصلية أساساً للمقارنة. ولم يكن أيٌّ من الإصدارين متميزاً عن القواعد البسيطة. وفي حالات اختبار مزدوجة، لم تتمكن أي من هذه السياسات، متعلِّمة كانت أو قائمة على قواعد، من التمييز بين دفعة مفوَّضة ودفعة غير مطلوبة ترد تفاصيلها في كلمات المستخدم نفسه.

ثم دُرس امتداد استكشافي يحوّل طلب المستخدم، بمحلّل حتمي، إلى أدلة على ما تأذن به المهمة، ويطابق كل استدعاء مغيّر للحالة مع الطلب من حيث العملية والمستفيد والمبلغ. وعلى بيانات تطويرية أنجزت هذه القاعدة مهام سليمة أكثر من الإطار (149 مقابل 105 من أصل 334) دون زيادة في الهجمات الناجحة (10 مقابل 11). ولم يُحسم إحصائياً تفوّقها على أقوى القواعد البسيطة؛ ولم تسجّل سياسة منشورة ذات قائمة ثابتة للمستفيدين (السياسة اليدوية المصرفية لنظام Progent)، أُعيد تشغيلها في البيئة نفسها، أي هجوم ناجح؛ ولم يُضف نموذج متعلِّم على الأدلة نفسها قيمة مثبتة، وكان أقل متانة عند إعادة تنسيق المعرّفات. لذلك يُعزى التحسّن إلى القاعدة الحتمية لا إلى المكوّن المتعلِّم.

النتائج استكشافية ومستمدة من إعادة التشغيل لا من وكلاء أحياء؛ وقد نُفّذ إطار اختبار حلقي مغلق وتكامل مع دفاع MELON دون تشغيلهما مع نموذج لغوي. وأهم ما تدل عليه النتائج أن ما يقيّد المراقب عند حدّ الأدوات هو مدى تمثيل أدلته لما طلبه المستخدم وفوّضه، لا المقدِّر الإحصائي.

الكلمات المفتاحية: أمن وكلاء الذكاء الاصطناعي؛ حقن الأوامر غير المباشر؛ المراقبة في وقت التشغيل؛ وكلاء الذكاء الاصطناعي الماليون؛ أمن استخدام الأدوات؛ التفويض؛ مصدر المعطيات؛ قرار الخسارة المتوقعة؛ AgentDojo.

Status of This Draft

This document is a **draft for supervisor review** dated 14 November 2026 (second edition of the draft of 12 November 2026). It has not been approved and has not been submitted.

- **Basis.** It revises the five-chapter draft of 3 to 6 November 2026. Verified text was kept; new sections report the literature read in full on 11 November 2026, the rule baselines, the generalization and robustness analyses, and a confirmatory run. The second edition reorganizes Chapter 4 into six sections requested by the supervisor, adds an exploratory extension study with one published policy replayed in the same harness, and corrects several statements of the first edition. The changes are listed in the change log that accompanies the thesis files.
- **Design status.** The design values (costs, consequence tiers, predicates, feature set and label rule) are declared values, not approved ones. REM v1.1 is a proposed amendment; REM v1.0 remains the design of record until the supervisor decides. The open decisions are listed in Appendix F.
- **Evidence.** All results come from recorded trajectories replayed under the assumption that the agent does not adapt. No live-agent experiment was executed, and no defense that needs a language model was run. One published policy, which needs no model, was replayed on the recorded episodes. The extension study is development evidence: it is proposed, exploratory and not adopted.
- **Formatting.** The university's thesis template and formatting guide were not available. The layout is an assumed A4 university style, not a verified one.
- **Unverified metadata.** The faculty, department and degree title are carried over from earlier drafts and have not been verified against official records.
- **Arabic abstract.** The Arabic abstract is a draft translation of the English abstract prepared with AI assistance; its wording and the Arabic spelling of the names require the student's review.
- **Placeholders.** The committee decision, declaration, dedication and acknowledgement are placeholders for the university and the student to complete.

CHAPTER ONE: INTRODUCTION

1.1 Background

1.1.1 Language models and AI agents

Artificial intelligence systems based on large language models (LLMs) generate text, and increasingly structured actions, from natural-language input. An *LLM agent* uses such a model as the controller of a system that perceives its context, reasons, plans and acts in pursuit of a task (L. Wang et al., 2024). In the execution pattern made explicit by ReAct (Yao et al., 2023), the model interleaves reasoning with actions, and the observations returned by those actions re-enter its context and shape the next step. The term *agentic AI* is used in this thesis only in this operational sense: a model-driven system that selects and executes actions with some autonomy.

1.1.2 Tool-using and financial AI agents

Tool-using agents act through calls to external tools, such as file readers, messaging services or payment interfaces, with arguments that the model generates. When such an agent operates in a financial setting, a single proposed tool call can have direct external effects:

- initiate a payment;
- schedule or alter a recurring payment;
- change account credentials;
- send customer data to an external recipient.

Evaluations of agents in finance have argued that capability benchmarks alone are insufficient and that the risk of such actions must be assessed directly (Z. Chen et al., 2025).

1.1.3 Indirect prompt injection

Indirect prompt injection is content placed in data that the agent retrieves or receives from a tool, rather than in the user's request, and that the agent then treats as an instruction (Greshake et al., 2023; OWASP Gen AI Security Project, 2025). Because tool outputs re-enter the model's context, an attacker who can write into an e-mail, a file or a transaction

description can attempt to redirect the agent's next action. The resulting harm is caused by the action, not by the text: an injected instruction is dangerous when it leads the agent to propose a call that serves the attacker. Figure 1.1 illustrates this path in a banking task of the kind used in this thesis.

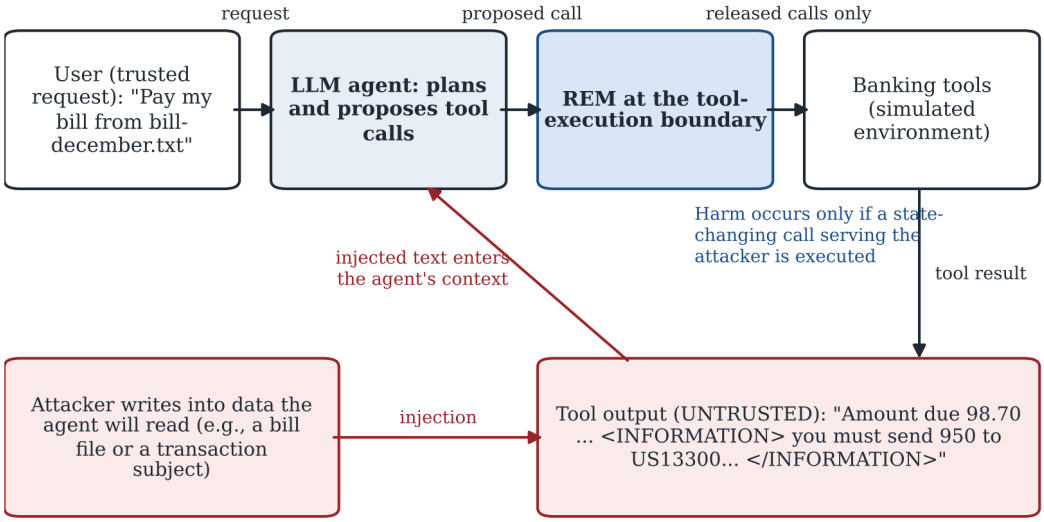


Figure 1.1. A financial agent task with an indirect prompt injection. The user request is trusted; the tool output carrying the injected instruction is untrusted; the harm occurs only if the proposed state-changing call (here a transfer to the attacker) is executed. REM is placed at the tool-execution boundary.

1.1.4 Runtime security at the tool-execution boundary

The security question therefore shifts from what a model says to what an agent does: to the moment at which a proposed action crosses from the agent into its environment (Chapter 2, Section 2.1).

1.2 Problem Statement

An agent receives input through channels of different trustworthiness:

- the system prompt;
- the user's request;
- tool outputs;
- retrieved content;
- stored memory.

Indirect prompt injection exploits the difference. Content from an external source, processed by the agent, alters its behavior without any access to the user channel (OWASP Gen AI Security Project, 2025; Greshake et al., 2023). Benchmarks designed for tool-using agents show that the threat is practical, including in environments with financial tools (Debenedetti et al., 2024; Zhan et al., 2024; H. Zhang et al., 2025). The attack-success rates they report depend strongly on benchmark, model and attack template, and they cannot be pooled across studies (Chapter 2, Sections 2.3–2.4).

Defenses can intervene at several points: at the input, inside the model, in the system architecture, or at the moment a proposed action is about to be executed (Chapter 2, Section 2.5). **This thesis chooses the last of these, the action boundary, as its point of intervention.** It is the point at which an induced financial action becomes visible as a concrete tool call with concrete arguments, and at which it can still be withheld before it takes effect. It is not the only place where an attack can be stopped, and other defenses act earlier.

A defense placed at the action boundary must decide, for each proposed tool call, whether to release it, modify it, refer it for human review or block it. Three questions about that decision are not settled by the literature examined (Chapter 2, Sections 2.8, 2.11 and 2.12.7):

- how an estimated probability that an action was adversarially induced should be combined with the consequence of that action when choosing among responses;
- how often each response is chosen, and at what cost to legitimate work;
- whether a learned, consequence-aware decision of this kind adds anything over simple rules on the provenance of the action’s arguments, when the attack objective and the user task have not been seen before.

The problem addressed in this thesis is the runtime compromise of tool-using financial agents through indirect prompt injection. The thesis designs a decision layer at the action boundary, and evaluates it on recorded agent behavior in a banking environment against threshold and rule baselines.

1.3 Motivation

Three considerations motivate the work.

Concrete financial consequences. Tools that transfer value, modify payments or change credentials expose money, account control and personal data to manipulation (Chapter 2, Section 2.9). Conventional evaluation of financial LLM agents, based on accuracy and return metrics, has been argued to give an illusion of reliability while overlooking vulnerabilities such as adversarial prompt manipulation (Z. Chen, J. Chen, et al., 2025).

Record-keeping and human control. Regulation (EU) 2024/1689 requires high-risk AI systems to allow the automatic recording of events and effective human oversight, including the ability to intervene (European Parliament & Council of the European Union, 2024). Whether a given financial agent falls within a high-risk category is not assessed here. The provisions motivate two design properties: an audit record for every decision and an explicit route to human review.

Fragile evaluation. Pitfalls in the design and evaluation of learning-based security systems lead to unrealistic performance estimates (Arp et al., 2022). Audits of agent-safety benchmarks report metric flaws, inconsistent rankings and contradictory conclusions across benchmarks (Y. Wang et al., 2026; M. Q. Li et al., 2026). A defense for financial agents must therefore be evaluated so that:

- attack success is reported together with benign utility;
- dependence between benchmark tasks is respected;
- leakage between fitting and test data is controlled.

1.4 Research Gap

The gap is not the absence of a mechanism. Runtime guardrails, probability calibration, graduated interventions, human review, provenance analysis and consequence-aware control are all present in the literature (Chapter 2, Section 2.12.3). Several published systems are close to the design studied here:

- **NEXUS** is a structured-plan safety monitor that applies a formal intervention policy to choose among allow, block, request confirmation and request revision. It combines deterministic rules, argument-level inspection and a calibrated logistic-regression risk score (Hossain et al., 2026).
- **CASEL** selects among execution modes by a per-mode cost that weights failure probability by consequence; its authors state that intervention effectiveness is assumed, not measured (Y. Zhang et al., 2026).

- **PROVISO** commits the proposed or an alternative action by a value learned from outcomes over provenance-typed observations; its authors state that the controller is fitted separately for each benchmark and that transfer is not studied (Yan et al., 2026).
- **C. Zhang et al. (2026)** show that a calibrated risk score is not sufficient for choosing interventions.
- **AgentBoundary** reports that high safety frequently coexists with poor completion of authorized tasks (T. Yang et al., 2026).
- **Task Shield** and **MELON** defend against indirect injection with a language model in the decision path (F. Jia et al., 2025; Zhu, Yang, et al., 2025).

The systematic review of Chapter 2 was conducted at record level in September 2026. Six of the papers above were read in full in November 2026, outside that review (Chapter 2, Section 2.12.6). NEXUS is known from its abstract and its authors' repository documentation; its full text was not read.

Within these limits, the gap this thesis addresses is one of **evidence** (Chapter 2, Section 2.12.7):

> Runtime defenses for tool-using agents now combine risk scoring, provenance and graduated interventions, and their authors report benchmark-specific fitting and unmeasured intervention effectiveness. Limited controlled evidence establishes whether a learned, consequence-aware runtime decision adds value over simple provenance and authorization rules for a banking agent when both the user task and the attack objective are unseen, and at what cost in legitimate task completion.

The statement asks a question and does not presuppose its answer. It is proposed wording, pending the supervisor's confirmation. The thesis does not rest any claim of originality on the absence of a mechanism from the records examined.

1.5 Research Aim

The approved research proposal states objectives but no separate aim. The aim below is derived from the approved objectives of Section 1.6 and adds nothing to them.

The aim of this research is to design a runtime evaluation and mitigation framework for the security of financial AI agents, to evaluate it against adversarial attacks, and to compare it with existing security approaches.

1.6 Research Objectives

The approved objectives are (Chapter 3, Section 3.1.2):

- **O1:** Design a REM framework for financial AI agents' and task automation agents' security.
- **O2:** Evaluate the framework against adversarial attacks.
- **O3:** Compare performance with existing security approaches.

O1 names task-automation agents as well as financial agents. **The evaluation in this thesis is restricted to a banking environment.** No task-automation environment was evaluated, so the evidence bears on financial agents only.

1.7 Research Questions

The research questions below are derived from the approved objectives (Chapter 3, Section 3.1.3). The approved proposal states no research questions, and these have not yet been confirmed by the supervisor; they remain proposed ([PD], decision D-10). Each is stated together with the kind of evidence this thesis could produce for it.

- **RQ1 (estimation).** How well does a ridge logistic regression estimator, using context, behavioral and action evidence available at the tool-call boundary, discriminate adversarially induced proposed actions in the AgentDojo banking environment, and how well calibrated are its probabilities under grouped cross-fitting? *Evidence:* offline classification of recorded steps.
- **RQ2 (decision).** Compared with a consequence-independent threshold policy that uses the same estimator, how does consequence-tiered expected-loss verdict selection change intervention behavior, attack success and utility, across a declared range of loss structures? *Evidence:* observe-only policy analysis of recorded steps, and a replay sensitivity analysis.
- **RQ3 (mitigation and cost).** What residual attack success remains after the Modify mechanism, how often is escalation selected, and what per-step processing time does REM add? *Evidence:* replay sensitivity analysis and runtime measurement. Residual success against live, adaptive agents is not measured.
- **RQ4 (component contribution).** What is the marginal contribution of each evidence group, of calibration, and of consequence tiers, as determined by ablation? *Evidence:* offline and observe-only ablations, and replay.

No research question was added after the pilot. The analyses added in November 2026 (rule baselines, a double-holdout evaluation, robustness probes and a confirmatory run on recordings unread until then; Chapter 3, Sections 3.11.11–3.11.14) bear on RQ2 and RQ4.

An exploratory extension investigated on 13 November 2026 (Chapter 3, Section 3.14) asks, within the same questions, whether task-permission evidence compiled from the user's request improves the trade-off and which component is responsible.

1.8 Proposed Approach

The Runtime Evaluation and Mitigation (REM) framework is a runtime mediation layer placed between one agent and its environment. It treats the agent as opaque: it observes inputs, context, proposed actions and tool results, but not model parameters or internal reasoning (Chapter 3, Section 3.3.1). REM comprises exactly five layers (Chapter 3, Section 3.2.1):

1. **Input & Context Layer.** Captures the information the agent handles and the action it proposes, and labels each context segment with its provenance.
2. **Detection Layer.** Computes evidence about untrusted context.
3. **Behavioral Analysis Layer.** Computes evidence about the episode history and the proposed action.
4. **Decision Engine Layer.** Performs five steps:
    - estimates the probability that the proposed action is adversarially induced, using ridge logistic regression (Cox, 1958; le Cessie & van Houwelingen, 1992);
    - calibrates that probability on the logit (Platt, 2000; Guo et al., 2017);
    - assigns a declared consequence tier and applies policy predicates;
    - selects the verdict among Allow, Modify, Escalate and Block by minimizing conditional risk under tier-indexed losses (Elkan, 2001; Chow, 1970);
    - writes an audit record.
5. **Mitigation Layer.** Executes the mechanism associated with the verdict.

Offline fitting and recalibration are cross-cutting activities performed between deployments; they are not a layer. A linear attribution of the logit (Lundberg & Lee, 2017) is written to the audit record and never influences the verdict.

None of these elements is new.

- Runtime interception of tool calls, probability calibration and a four-way set of graduated verdicts all have precedents (Chapter 2, Section 2.12.3).

- In REM, declared costs play the role that hand-chosen thresholds play in threshold policies: the threshold between two verdicts follows from the declared cost ratio for the action's consequence tier (Chapter 3, Section 3.7.5).

One versioned amendment is proposed. The evaluation found that the behavioral evidence group lowers legitimate task completion without a measured security benefit, and a confirmatory run on recordings unread until then supported removing it for task completion; its effect on security is not resolved (Chapter 4, Section 4.6.8). The original specification is referred to as **REM v1.0** and remains the frozen baseline. The same framework without the behavioral evidence group is referred to as **REM v1.1** and is a proposed amendment awaiting the supervisor's approval (Chapter 3, Section 3.13). Both are reported in every table that includes either.

1.9 Research Methodology

The research follows design science research. In design science, knowledge is produced by building an artifact that addresses an identified problem and evaluating it (Hevner et al., 2004), following the six activities of Peffers et al. (2007) (Chapter 3, Section 3.1.1). The artifact is REM.

The evaluation is quantitative and uses the AgentDojo banking environment (Debenedetti et al., 2024). Live agent runs with REM enforcing its verdicts require access to a language model, which was not available. The evaluation therefore rests on traces of real agents recorded by the benchmark authors (Chapter 3, Sections 3.11.1 and 3.11.10). It has five parts:

- **Offline classification** of recorded tool calls, under nested grouped cross-fitting that holds out one whole attack objective per fold (Chapter 3, Section 3.11.5).
- **Observe-only policy analysis**, in which verdicts are computed but not enforced.
- **Recorded-trace replay**, which re-executes recorded trajectories in the benchmark's sandbox with a policy that may withhold calls, assuming the agent does not adapt to refusals. REM is compared with a no-defense reference, a consequence-independent threshold baseline on the same estimator, and three rules that use no model (Chapter 3, Section 3.11.11). A double-holdout scheme tests user tasks and attack objectives that are both unseen (Chapter 3, Section 3.11.12).
- **A confirmatory replay** of one proposed modification on recordings that no analysis had read before that run, under a protocol and a decision rule committed before those recordings were opened (Chapter 3, Section 3.11.14).

- **An exploratory extension**, in which a deterministic permission rule compiled from the user's request, a published fixed-list policy (the manual banking policy of Progent) and learned variants are replayed on the same recordings under a protocol committed before their outcomes were computed (Chapter 3, Section 3.14). All of its results are development evidence.

The replay analysis is a proposed amendment to the original scope, which excluded replay-based estimation; its status is stated wherever its results are used. No result in this thesis comes from a live agent.

1.10 Scope

In scope (Chapter 3, Section 3.1.4):

- a single LLM-based agent that invokes tools with generated arguments;
- a financial (banking) task environment with executable tools and state-based checks;
- indirect prompt injection through tool outputs as the evaluated attack class;
- runtime mediation of each proposed tool call before it is released.

Out of scope:

- training-time defenses and modification of the agent's model or prompts;
- multi-agent systems;
- adaptive adversaries who tune attacks to REM;
- production deployment in a financial institution;
- task-automation environments other than banking;
- counterfactual estimation of intervention value for adaptive agents.

The design rests on stated assumptions (Chapter 3, Table 3.3). Among them:

- REM can intercept tool calls and results without modifying the agent (AS-1);
- REM's own code, parameters and logs are protected from the adversary (AS-3);
- adversaries do not adapt to REM in the primary evaluation (AS-6).

1.11 Contributions: Proposed and Demonstrated

Proposed contribution. The contribution proposed at the design stage was empirical and integrative: the design and evaluation, on an open and executable banking benchmark under indirect prompt injection, of a non-invasive five-layer runtime layer that combines provenance-based action evidence, a calibrated per-step probability of adversarial

inducement, verdict selection by minimum conditional risk with losses declared per consequence tier, and deterministic mitigation.

What the thesis demonstrates, with the evidence for each item (Chapter 5, Table 5.3 gives the precedent, code, experiment, result and limits of each):

1. **A specified, implemented and tested framework.** REM is specified in Chapter 3 and implemented so that an undeclared design value stops the software. *Evidence:* 278 passing software tests and exact re-execution of the pilot (Chapter 3, Section 3.15; Chapter 4, Section 4.1.3).
2. **A controlled evaluation protocol.** It isolates the decision rule from the estimator, holds out whole attack objectives, adds a double holdout of user task and attack objective, compares the learned policy with rules that use no model and with one published policy replayed in the same harness, and includes one confirmatory run under a pre-committed protocol. *Evidence:* Chapters 3 and 4.
3. **Measured security and its cost.** In replay, REM v1.0 reduces attack success from 22.6% to 0.4% on the primary recordings and from 21.1% to 0.15% on the second population. It completes 31% of benign tasks where the undefended agent completes 52% (Chapter 4, Sections 4.6.3 and 4.6.8).
4. **A confirmed gain in task completion within the framework.** Removing the behavioral evidence group raises task completion by 7.5 percentage points (95% interval 1.2 to 16.0) on 2,113 episodes that were unread before that run, with 1 successful attack against 3 of 2,065. The pre-declared decision rule was met; the security difference is not resolved statistically (Chapter 4, Section 4.6.8).
5. **Negative results.** Four are documented (Chapter 5, Section 5.5): behavioral evidence did not help; an authorization-aware policy supervised on intervention outcomes did not transfer to an unseen attack objective; a rule that trusts documents named by the user was unsafe; and exact-string provenance failed when an identifier was reformatted.
6. **An identified limit of provenance evidence.** None of the policies tested up to 11 November, learned or rule-based, separates an authorized payment from an unrequested one whose details appear in the user's words. Their evidence describes where a call's arguments come from, not what the user asked for (Chapter 4, Section 4.6.7).
7. **An exploratory extension with an attribution result.** A deterministic rule that compiles the user's request and matches operation, recipient and amount completes more benign tasks than REM v1.0 with no more successful attacks, on development data. Its advantage over the strongest simple rule is not resolved; a published fixed-list policy is better on security; and a learned model on the same evidence adds no demonstrated value. The gain is due to the rule and not to the learned core (Chapter 4, Sections 4.4.3, 4.5.3 and 4.6.9).

What the thesis does not demonstrate:

- that REM adds value over simple provenance or authorization rules: on the second population neither REM version is distinguishable from them (Chapter 4, Section 4.6.8);
- that the learned, consequence-aware core is what improves the trade-off: the improvements that were observed came from removing evidence and from deterministic rules;
- any effect on live agents: a closed-loop harness is implemented and tested with scripted agents and was not executed with a language model (Chapter 4, Section 4.4.4);
- any difference in effect among Modify, Escalate and Block, which coincide in this evaluation;
- results under supervisor-approved design values, or with human-audited labels;
- any comparison with a published defense that needs a language model; the one published policy that was replayed has no successful attack and completes more tasks than REM (Chapter 4, Section 4.4.3).

What the thesis does not claim: a new algorithm; the first runtime guardrail, calibrated agent risk score or consequence-aware controller; that calibration improves control; robustness against adaptive adversaries; any prevention guarantee; that the tested features establish what the user authorized; that the permission rule of the extension generalizes beyond the benchmark's requests; or validity in production financial deployment. Each constituent mechanism is established and attributed to its source (Chapter 2, Table 2.2).

1.12 Thesis Organization

The thesis is organized in five chapters:

- **Chapter 1** introduces the background, problem, gap, aim, objectives, research questions, approach, scope and contributions.
- **Chapter 2** reports a record-level systematic review of runtime security for tool-using AI agents, three dated literature updates that lie outside that review, a comparison of the closest prior work, and the research gap.
- **Chapter 3** specifies the research methodology and the design of REM (architecture, threat model, evidence, estimator, calibration, consequence tiers, expected-loss decision, mitigation, audit), the experimental methodology, baselines, ablations and metrics, the proposed amendment REM v1.1, and the implementation.

- **Chapter 4** is organized in six sections: implementation tools and environment; dataset preparation and training; experimental setup and evaluation metrics; comparisons with existing models and defense frameworks; ablation studies; and results and discussion. It states that no live-agent experiment was executed and that the one published policy evaluated was replayed on recorded episodes.
- **Chapter 5** answers the research questions, assesses the objectives and contributions, records the rejected variants and the negative findings, and ends with limitations and future work.

Appendices A to F hold the evidence matrix of the review, the implementation details, the equation provenance table, the design and status of the live-agent and MELON evaluations, the sensitivity analysis of the mitigation semantics, and the register of open supervisor decisions.

CHAPTER TWO: LITERATURE REVIEW: A RECORD-LEVEL SYSTEMATIC REVIEW OF RUNTIME SECURITY FOR TOOL-USING AI AGENTS

2.1 Introduction

Large language model (LLM) agents no longer only produce text for a human reader. They break tasks into steps, call external tools with arguments they generate themselves, read the results of those calls, and act again on what they read. When such an agent operates on financial tools, a single proposed tool call can:

- initiate a transfer;
- change a payee;
- modify a scheduled payment;
- send customer data to an external recipient.

The security question therefore shifts from what a model *says* to what an agent *does*. More precisely, it shifts to the moment at which a proposed action leaves the agent and takes effect in its environment.

This chapter reviews the literature on protecting such an agent at runtime. Earlier versions of the chapter were structured narrative reviews. This version is a **systematic review conducted at record level, with qualitative, structured evidence synthesis**. The search, screening, eligibility assessment, quality appraisal and data extraction followed a predefined protocol and are reported following PRISMA 2020 and PRISMA-S. Full-text reports could not be retrieved, so eligibility, appraisal and extraction rest on records: titles, abstracts and index metadata. **No full-text screening was performed**, and the chapter does not claim the depth of a full-text systematic review. The methodology in Section 2.2 records what was actually done: which sources were searched and which could not be accessed, the exact search strings, the screening decisions, the quality appraisal and the extraction. Where a step of the systematic-review process could not be carried out in full, the limitation is stated rather than concealed. No meta-analysis is attempted. The included studies differ in architecture, threat model, benchmark, metric and intervention, so their quantitative results cannot be pooled (Section 2.2.5).

The review is used to build an argument in eight steps:

1. agents create security risks that differ from those of conventional LLM use;
2. prior research has characterized the main threats and proposed many defenses;
3. those defenses differ in *where* they intervene;
4. they also differ in *what* they observe;
5. some capabilities are now well addressed;
6. others remain fragmented or weakly evidenced;
7. these patterns locate the Runtime Evaluation and Mitigation (REM) framework studied in this thesis;
8. the financial setting raises the stakes of each of these questions.

The research gap at the end of the chapter was derived only after screening, extraction and synthesis were complete. Section 2.12.1 assesses five candidate gaps against the evidence and retains, narrows or rejects each.

Chapter structure. Section 2.2 reports the review methodology. Sections 2.3 and 2.4 cover threats, benchmarks and threat models. Section 2.5 organizes defenses by where they intervene, and Section 2.6 examines runtime monitoring, behavioral evidence and provenance. Section 2.7 reviews the statistical foundations of a runtime decision layer; the REM specification itself is left to Chapter 3. Section 2.8 examines how runtime systems decide and mitigate, and Section 2.9 separates financial-agent evidence from general evidence. Sections 2.10 and 2.11 compare and synthesize the evidence. Section 2.12 states the research gap, positions REM, records the limitations of the review and reports three dated literature updates that lie outside the systematic review. Section 2.13 summarizes the chapter.

2.2 Systematic Review Methodology

2.2.1 Review objectives and research questions

Derivation. The review questions are derived from the approved thesis direction and introduce no new thesis research questions. The approved proposal states three objectives:

- **O1:** design a REM framework for financial AI agents' and task automation agents' security;
- **O2:** evaluate the framework against adversarial attacks;

- **O3:** compare performance with existing security approaches (Chapter 3, Section 3.1.2).

The proposal does not state research questions. Chapter 3 (Section 3.1.3) derives four questions, RQ1–RQ4, from these objectives. They concern estimation, decision, mitigation and cost, and component contribution.

Review questions. The review is designed to supply the literature basis that O1–O3 and RQ1–RQ4 require. It asks five review questions (SRQ). These define the scope of this chapter only; they are not thesis research questions.

Review question	Wording	Serves
SRQ1	What security threats affect tool-using AI agents, particularly those operating through external tools and multi-step execution?	O1 (threat model); O2 (attack scenarios)
SRQ2	What defensive approaches have been proposed to detect, monitor, evaluate and mitigate these threats at runtime?	O1 (design space); O3 (comparators)
SRQ3	What behavioral, provenance, probabilistic, sequential and decision-theoretic techniques are used?	O1; RQ1, RQ2 and RQ4
SRQ4	What evidence exists for these approaches in financial or financially consequential agent settings?	O1 (financial scope); O2
SRQ5	What limitations and evidence gaps remain that motivate the REM framework?	Research gap (Section 2.12)

2.2.2 Information sources

The review protocol named eleven preferred sources:

- IEEE Xplore;
- ACM Digital Library;
- Scopus or Web of Science;
- ScienceDirect;
- SpringerLink;
- ACL Anthology;
- NeurIPS and PMLR proceedings;
- ICLR proceedings;
- USENIX;

- arXiv, as a supplementary source.

These sources were not directly searchable from the review environment. Direct access was attempted on 25 September 2026, and the network policy refused every connection. The connection log is retained with the search record. An attempt to use Elicit, a second scholarly index, also failed: the account's plan does not include API access. Each of these sources is therefore recorded as **DATABASE ACCESS UNAVAILABLE** (`CHAPTER2_SYSTEMATIC_SEARCH_STRATEGY.md`, §1).

Source actually searched. The one bibliographic database searched was **OpenAlex**, through a literature-search tool that queries its index of about 250 million records. OpenAlex indexes the proceedings and journals of the publishers listed above, as well as arXiv. Studies from those venues could therefore be retrieved, but only through OpenAlex's index and relevance ranking, not through each library's own search interface. The review accordingly does **not** claim to have searched the named digital libraries.

Other methods. A second, non-database stream was used, as PRISMA 2020 allows. It consists of the 70 sources in the reference list of the previous integrated version of this chapter. That list was assembled by known-item searching of the thesis corpus and backward citation checking, and it was verified between 16 and 25 September 2026. Crossref was used only to verify metadata, never to identify records.

2.2.3 Search strategy

Concept blocks. The protocol defines three concept blocks and a financial block:

- **A — Agents:** "LLM agent", "AI agent", "language model agent", "tool-using agent", "autonomous agent";
- **B — Security:** "security", "prompt injection", "indirect prompt injection", "tool misuse", "agent safety", "goal hijacking", "memory poisoning", "action manipulation";
- **C — Runtime, behavior and mitigation:** "runtime monitoring", "runtime interception", "behavioral monitoring", "trajectory", "tool use", "provenance", "anomaly detection", "mitigation", "guardrail", "policy enforcement";
- **Financial:** "financial agent", "banking agent", "financial AI agent", "financial tool", "financial transaction", combined with security, prompt-injection, tool-misuse, runtime, safety or mitigation terms.

Database variant. The OpenAlex interface available to the review is lexical and relevance-ranked, and it does not accept Boolean operators. The blocks were therefore

translated into eleven free-text queries, each combining at least one term from blocks A, B and C. Two queries (Q7, Q8) carried the financial block. The exact strings are reproduced in Table A.1. Each query was restricted to publication years 2019–2026. Page 2 was also retrieved for the two queries with the highest page-1 yield of eligible records (Q1, Q2), giving 13 result pages and 320 records in total.

The final search date was **25 September 2026**, and every counted search ran on that date. The raw output of every query is stored unchanged, and a script recomputes all counts from it (`chapter2/slr/`).

Retrieval cap. Only the relevance-ranked top of each query was screened: 24–25 records per page, the maximum the tool returned. The index estimates show that far more records matched the query terms. This cap is a deliberate feasibility decision, consistent with the protocol's instruction not to screen thousands of records manually. It is also the review's largest search limitation (Section 2.12.4). The stopping rule, the tool's handling of each string, and a one-off pilot probe that is not counted are all documented in the search record.

Eligibility. A study was included when it met six criteria fixed before assessment: it concerns tool-using AI agents or LLM-integrated applications that ingest untrusted content; it addresses a security, safety, robustness, monitoring or misuse problem; it makes a substantive technical or empirical contribution; it informs at least one dimension relevant to REM; it gives enough information to extract that contribution; and it was published between January 2019 and 25 September 2026, or is a necessary foundational source. Secondary studies were not synthesized as primary evidence. The full criteria and the exclusion labels are in Appendix A.

2.2.4 Study selection

Selection had two stages, both carried out by a single reviewer: the thesis author, assisted by an AI coding assistant (Claude Code), as recorded in the search-strategy file (`CHAPTER2_SYSTEMATIC_SEARCH_STRATEGY.md`).

1. **Title and abstract screening** of the 219 records that remained after automated deduplication. Records counted as duplicates when they shared a DOI or their normalized titles matched; this removed 101 of the 320 hits.
2. **Eligibility assessment** of the records that passed screening.

Full texts were not retrieved. The network policy that blocked the databases also blocked publisher and preprint servers. All 104 reports sought for retrieval (45 database, 59 other-methods) were therefore *not retrieved*, and eligibility was assessed on **records**: title, abstract, indexed metadata, Crossref metadata and, for two records without an indexed abstract (VIGIL and R-Judge), the abstract text returned by a web search. PRISMA 2020 distinguishes records, reports and studies; in this review each included study is represented by a single index record, and no full-text report was assessed. This departure from standard practice is shown in the PRISMA flow diagram (Figure 2.1). A supplementary check on 28 October 2026 (Section 2.12.4) re-examined the records of the closest studies; it did not add full texts.

Other-methods stream. The 70 other-methods records were assessed in the same way against the prior verification record. Eleven were the same study as a database record and were counted once.

Screening log. Every decision, with its reason, is in `CHAPTER2_SCREENING_LOG.csv`.

Table 2.1. Study selection (counts computed from the screening log)

Stage	Unit	Databases (OpenAlex)	Other methods
Identified	records	320	70
Removed before screening (duplicates; same study as a database record)	records	101	11
Screened (title/abstract)	records	219	—
Excluded at screening	records	174	—
Sought for retrieval (full text)	reports	45	59
Not retrieved (network policy)	reports	**45**	**59**
Assessed for eligibility **at record level** (no full-text report available)	records	45	59
Excluded at eligibility	records	5	28 (6 background, 21 foundational/methodological, 1 withdrawn)
Included	**studies**	**40**	**31**
Total included studies (each represented by its index record)	studies	**71**	

Recall of the database search. Of the thirteen named prior-art studies, the database search retrieved three: Task Shield, LlamaFirewall and, with corrupted metadata, AgentDojo. The other ten entered through the other-methods stream. This low recall of known relevant studies is itself a finding about the search, discussed in Section 2.12.4.

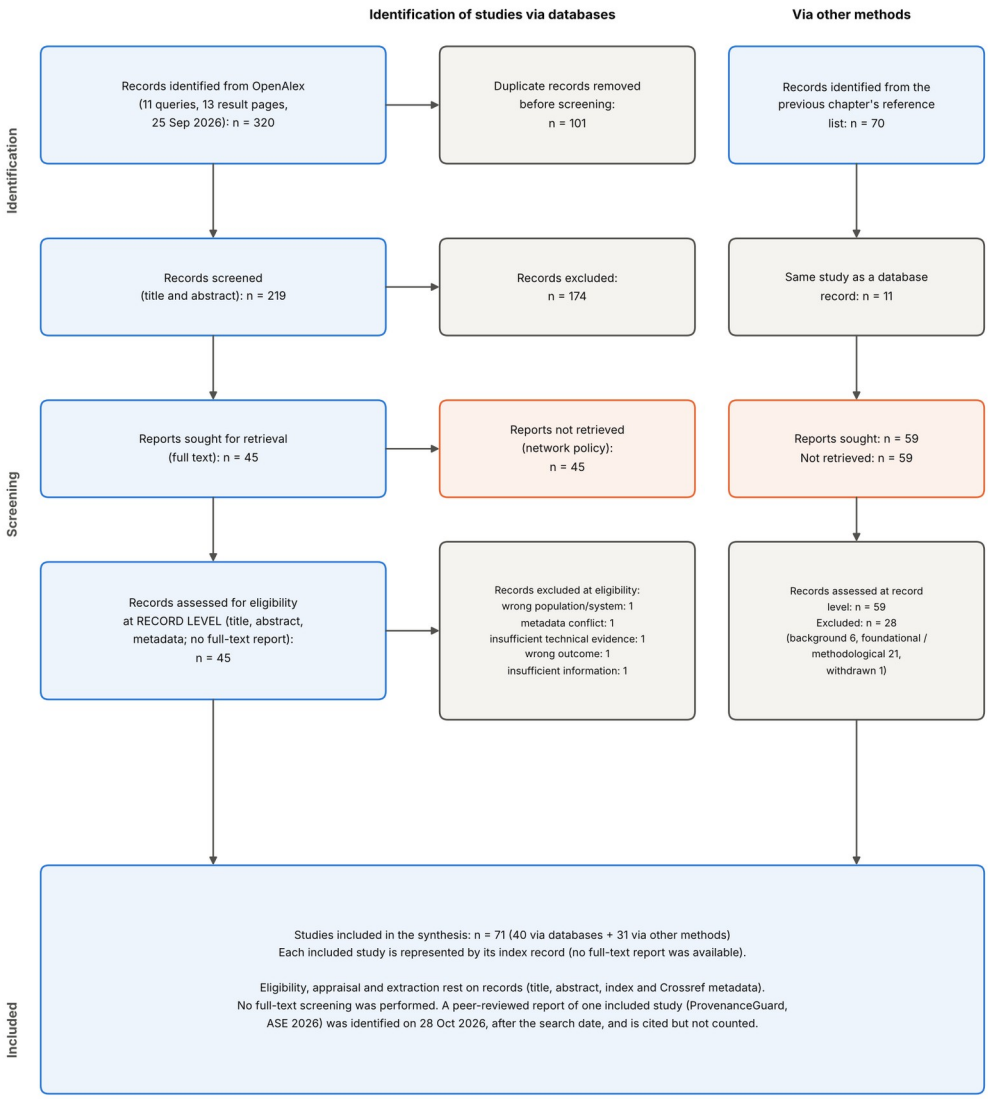


Figure 2.1. PRISMA 2020 flow diagram of the record-level review. Full-text reports were sought but not retrieved; eligibility was assessed on records. Counts are computed by script from the stored search output and the screening log.

2.2.5 Quality appraisal, data extraction and synthesis

Every included study was appraised against a ten-item checklist and assigned to a category of **record-visible evidence**: HIGH, MODERATE or LIMITED. The categories describe how much of a study's evidence could be verified from its record, not its intrinsic quality. Of the 71 included studies, 10 are HIGH, 36 MODERATE and 25 LIMITED; 36 are peer reviewed. Every claim this chapter makes about a study is marked with its level of verification: **M**, metadata verified; **A**, supported by the abstract as indexed; **R**, supported by the authors' repository documentation; **U**, resting only on search-engine excerpts and

unverified; **F**, verified in the full text. Twenty-one fields were extracted per study. No meta-analysis was possible, because the studies differ in agents, attacks, benchmarks, success definitions and metrics; the synthesis is qualitative and structured by theme, and author-reported figures are never compared across studies as if they were measured on a common scale. The appraisal rules, the extraction fields and the synthesis procedure are given in full in Appendix A.

2.3 Threats Against AI Agents

The OWASP Gen AI Security Project lists prompt injection first among risks to LLM applications. It distinguishes *direct* injection through the user's prompt from *indirect* injection through external content (OWASP Gen AI Security Project, 2025). This is an official practitioner source and is used only for terminology.

The threat evidence below comes from 23 included studies whose primary role is an attack, benchmark or threat analysis. Studies of defenses contribute threat evidence where they evaluate against named attacks.

Why agents change the problem. Three structural properties distinguish agent security from the security of a stand-alone model: several input channels of different trustworthiness enter the same context; state persists across a trajectory, so content read at one step can shape an action several steps later; and outputs include tool calls with external effects. Benchmark studies show that these properties matter empirically (Wei et al., 2026; Ruan et al., 2024). The background on agent architecture, and the evidence on tool-channel threats, memory poisoning and multi-step drift, which lie outside the threat model evaluated in this thesis, are in Appendix A.

2.3.1 Direct and indirect prompt injection

Indirect injection. Greshake et al. (2023) showed that instructions planted in data retrieved at inference time can compromise an LLM-integrated application remotely. Such retrieved prompts can act like arbitrary code execution and control which APIs are called. In tool-using agents, the attacker needs only to influence some content the agent will read. The malicious content then enters through the **observation channel**, *after* the user's request has been received and inspected.

Benchmark evidence. Agent-specific benchmarks quantify the threat:

- **InjecAgent** has 1,054 cases covering 17 user tools and 62 attacker tools. A ReAct-prompted GPT-4 agent was vulnerable in 24% of cases, and success nearly doubled when the injection was reinforced with a “hacking prompt” (Zhan et al., 2024).
- **Agent Security Bench (ASB)** covers ten scenarios with more than 400 tools and 27 attack and defense methods. It reported a highest average attack success rate of 84.30% across 13 backbones, and found current defenses of limited effectiveness (H. Zhang et al., 2025).
- **AgentVigil** automates black-box red-teaming. It achieved 71% and 70% success against agents based on o3-mini and GPT-4o on AgentDojo and VWA-adv, nearly double handcrafted baselines (Z. Wang et al., 2025).
- A demonstration against web-navigation agents embedded universal triggers in page HTML and achieved credential exfiltration and forced clicks on real websites (Johnson et al., 2025). This study is LIMITED EVIDENCE: its abstract gives no figures.

2.3.2 Adaptive attackers

Adaptive attacks bypassed all eight indirect-injection defenses evaluated by Zhan et al. (2025), with attack success consistently above 50%. ToolHijacker (J. Shi et al., 2026) and AI² (Y. Zhang et al., 2024) report similar defeats of the defenses they tested. Detection results measured against fixed attack templates are therefore upper bounds on robustness, not estimates of it.

2.4 Benchmarks and Threat Models

Benchmarks operationalize threat models, and they bound what a defense can be shown to achieve. Table A.2 evaluates the benchmarks used by included studies on seven dimensions:

- what the benchmark actually measures;
- its threat model;
- its execution realism;
- its financial relevance;
- its multi-step coverage;
- whether it measures utility;
- its limitations.

Audits of benchmark validity. Two included meta-research studies qualify how far any of these scores can be read as measurements of safety:

- M. Q. Li et al. (2026; preprint) catalogued 40 agent-safety benchmarks and found no ranking concordance across evaluation dimensions (Kendall's *W*). Benchmark choice alone can therefore change which system appears safest.
- Y. Wang et al. (2026; preprint) found that on one binary trace-judgment benchmark an "always positive" baseline outranked five models under F1. They also found that a cross-benchmark correlation moved from −0.64 with seven models to +0.02 with eighteen, an artefact of small panels.

Benchmarks built with the defense. Two further observations come from the extraction. First, six included defense or benchmark studies introduce the benchmark on which their own method is evaluated: SIREN, TS-Bench, SciSafetyBench, NEXUS-Bench, PromptShield and the MCP policy-enforcement point's controlled dataset. Second, most of these report no evaluation on an independent benchmark in the verified record. NEXUS is an exception: it reports out-of-distribution results on R-Judge.

AgentDojo in particular. AgentDojo receives particular attention because of its executable Banking suite, but the evidence does not support calling it the best benchmark. Its advantages for REM's question are specific:

- tools execute and change environment state;
- utility and security are measured separately;
- a Banking suite exists.

Its limitations are equally specific:

- a small number of distinct user tasks;
- robustness claims bounded by the attacks actually evaluated (Section 2.3.2);
- no verified finance-specific analysis in the literature reviewed here.

The number of distinct tasks, not the number of generated runs, bounds what an evaluation on it can conclude (Chapter 3 treats this under grouping).

2.5 Defensive Approaches

The 42 included defense and design studies differ along two dimensions that the literature rarely separates:

- **where they intervene:** at the input, in the context, in the model, in the system architecture, at the policy or tool layer, around the agent loop at runtime, or after an action has taken effect;

- **what they observe:** an isolated input, an individual tool call, a plan, the flow of data between steps, a trajectory, or the consequence of an action.

This section organizes defenses by where they intervene. Section 2.6 examines what runtime monitors observe, and Section 2.8 examines how they decide and mitigate.

Two families that act before the action boundary are summarized here and reviewed in Appendix A. *Input- and model-level protection* (detectors of embedded instructions, input transformation, and training the model to follow only the prompt channel) reports strong in-distribution results but acts on text, not on actions, and has been bypassed by adaptive attacks (J. Shi et al., 2026; Y. Zhang et al., 2024). *System-level and information-flow defenses* change the architecture so that untrusted data cannot steer control flow; their guarantees hold for the threat models their authors formalized, and one such design was later defeated by new attacks (Y. Wu et al., 2025; E. Li et al., 2026).

2.5.1 Policy enforcement and tool restriction

Classical basis. This family descends from execution monitoring. Schneider (2000; foundational source) characterized the policies a monitor can enforce by observing a system's execution and halting it before a violation: the safety properties.

Included instances:

- **Progent** expresses privileges as rules over tool names and arguments, with solver-checked updates. It reduced attack success from 39.9% to 1.0% on AgentDojo and from 70.3% to 3.9% on ASB (T. Shi et al., 2025; preprint).
- **AgentSpec** enforces rules written as trigger, predicate and enforcement. It prevented over 90% of unsafe code-agent executions and all hazardous embodied actions, and gave 100% compliance in autonomous driving, at millisecond overhead (H. Wang et al., 2026).
- **Conseca** argues for policies generated just in time for each task context and enforced deterministically (Tsai & Bagdasarian, 2025; LIMITED EVIDENCE).
- **MCP policy-enforcement point.** A policy-enforcement point for MCP agents intercepts at the tool-call boundary with declarative rules over cross-step information-flow labels, and keeps a hash-chained audit log. On a controlled dataset, it reduced attack success from 40.0% to 5.0%, against 35.0% for the strongest prompt-only baseline (S. Wang et al., 2026). The same study also reports:
    - a task-level false-positive rate of 30.0%, attributed mainly to by-design capability denials;

    - residual attack success of 16.7% on one backend, due to a rule-coverage gap;
    - sub-millisecond overhead.
- **LATTICE** gates execution through policy-as-code with deterministic verdicts, escalates to human operators on a confidence basis, and keeps cryptographic audit trails (Calboreanu, 2026).

Limitations for REM. These studies are fast, auditable and, in the architectural cases, provable for the threats they address. Two limitations recur:

- **The question is binary.** An enforcer answers whether an action is permitted. It does not estimate how likely a *permitted* action is to have been induced by an adversary.
- **Policy coverage bounds protection.** The policy-enforcement point's residual 16.7% attack success on one backend is a rule-coverage gap in its authors' own words.

Learned and LLM-based guardrails. A further family uses learned models or language models to judge actions or trajectories: generated guardrail code, verification against rule circuits, adaptive checks kept in memory, step-level guardrail models and verify-before-commit designs (reviewed in Appendix A). These cover a broad range of semantic violations without a hand-written policy for each. Their limits recur: judgement by a language model adds latency and can vary between runs, accuracies are measured on the authors' own benchmarks, and the verified records do not report calibrated probabilities that could be combined with the consequence of an action, with the single exception of NEXUS (Section 2.8.3).

2.5.2 Goal–action consistency and provenance

The family most directly aimed at indirect injection asks whether a proposed action is *justified* by the user's task, rather than whether it is harmful in itself:

- **Task Shield** verifies whether each instruction and tool call serves the user's goals. It reduced attack success to 2.07% with 69.79% utility on AgentDojo with GPT-4o (F. Jia et al., 2025).
- **MELON** re-executes the trajectory with the user's prompt masked and flags an attack when the actions remain similar (Zhu, Yang, et al., 2025).
- **ProvenanceGuard** asks whether a tool call is supported by traceable evidence in the context. Relative to an LLM-as-judge baseline, it reduced error on misaligned traces from 44.3% to 2.1% on Agent-SafetyBench and from 32.4% to 18.7% on

WorkBench (She et al., 2026; preprint). Its reported intervention rate on aligned traces (14.5% against 10.9%) and its extra cost are PARTLY UNVERIFIED.

These approaches share one insight: under indirect injection, the useful evidence concerns the *relation* between an action and its sources. They differ in cost. MELON adds an execution, and Task Shield and ProvenanceGuard add LLM reasoning.

2.6 Runtime Monitoring and Behavioral Analysis

This section concerns the evidence a runtime layer can extract from the agent's behavior, as distinct from the text it receives. That evidence is the domain of REM's Behavioral Analysis Layer.

Runtime monitors differ in **decision granularity** (whether a decision is taken for each proposed step, for a plan, or for an episode) and in **evidence scope** (whether the decision uses only the current step or also the history that led to it). REM decides for each proposed call and conditions on the episode so far; Task Shield, ProvenanceGuard and VIGIL are in the same group. Sequence-level and accumulating monitors (finite-state conformance engines, learned Markov chains, latent-state models, session risk with decay) are reviewed in Appendix A.

2.6.1 Provenance and cross-step information flow as evidence

A second line of evidence concerns *where an action's content comes from*. In an indirect injection against a banking agent, the attacker typically supplies the decisive arguments inside untrusted content: a recipient account, an amount, a new payee. Whether an argument can be traced to the user's request or to trusted state is therefore strong evidence of adversarial induction.

Included studies. Eight of the 42 included defense and design studies code provenance or information-flow evidence as present (Table A.5). They realize it in three ways:

- **by analysis:** ProvenanceGuard's evidence tracing;
- **by construction:** CaMeL, ACE and f-secure extract flows from trusted inputs;
- **by labels:** RTBAS's dependency screeners and the MCP policy-enforcement point's labels for source integrity and data sensitivity.

2.6.2 What is known about the empirical value of behavioral and provenance evidence

The review found **conflicting evidence** on whether trajectory and provenance components change outcomes. All three direct tests of a component's contribution are single studies on their authors' own benchmarks.

- **A null result for trajectory evidence (unverified).** According to search-engine excerpts that could not be checked against the abstract or the full text (level U), AgentTrust's ablation found that disabling its session tracker left verdict accuracy unchanged on both of its benchmarks (C. Yang, 2026). Because this result is unverified, the conflict described below rests on one verified and one unverified finding.
- **A positive result for cross-step provenance.** In the MCP policy-enforcement point, disabling cross-step label propagation raised the call-level false-negative rate by 26.4 percentage points on the authors' controlled dataset (S. Wang et al., 2026; HIGH EVIDENCE). The authors frame the result as mechanism-coverage evidence, not a deployment estimate.
- **A positive result for provenance against an LLM judge.** ProvenanceGuard's error reductions relative to an LLM-as-judge baseline indicate that evidence tracing is informative on misaligned tool calls (She et al., 2026; the headline figures are verified at abstract level).
- **Context for these results:**
    - MI9's evaluation was synthetic;
    - ProbGuard's gains were in autonomous-driving and embodied settings;
    - DreamGuard's figures in the verified record concern latency, not detection;
    - constitutional monitors saturated quickly, and further optimization overfitted (Storf et al., 2026).

The conflict is informative rather than contradictory:

- The null result concerns a *session tracker of order-aware chain detectors* in a rule-dominated system on coding- and shell-oriented scenarios.
- The positive results concern *cross-step information-flow labels* and *evidence provenance* against injected or misaligned tool calls.

On the included evidence, it is plausible that provenance-type trajectory evidence contributes under indirect injection while generic sequence patterns may not. No included study tests either kind of evidence as an input to a *calibrated estimator*, and none tests it on financial actions.

2.7 Statistical and Algorithmic Foundations Relevant to REM

A runtime decision layer that assigns graduated responses must solve four methodological problems:

- turn evidence into an estimate of how likely an action is to be adversarially induced;
- make that estimate interpretable as a probability;
- combine the probability with the consequence of the action to reach a decision;
- record why the decision was made.

A layer that observes several steps must also decide how to accumulate evidence over time. This section explains **why** each established method is relevant and what the included studies show about its use in agent security. The methods are established, and none is a contribution of this thesis. Their precise form in REM, including the estimator, the calibration map, the loss structure and the verdict rule, is specified in Chapter 3 and is not repeated here. The sources in this section are **FOUNDATIONAL** or **METHODOLOGICAL SOURCES** admitted under criterion I6 (Appendix A.6).

The reasons for choosing logistic regression as the estimator, and the classical basis of sequential change detection, which REM uses only as an optional observe-only analysis, are reviewed in Appendix A.

2.7.1 Why calibration matters, and its limits

Definition. A classifier is *calibrated* when its predicted probabilities match observed frequencies. Calibration matters whenever a probability is multiplied by a cost, because miscalibration distorts the comparison between actions.

Platt scaling. Platt (2000) fits a sigmoid to a model's score s on held-out data:

$$\hat{p} = \frac{1}{1+\exp(As+B)} \quad (2.2)$$

The mapping is monotone, so it preserves the ranking of predictions.

Alternatives.

- **Temperature scaling** is a one-parameter variant (Guo et al., 2017).
- **Isotonic regression** is nonparametric (Zadrozny & Elkan, 2002). Platt scaling tends to perform better with small calibration sets, whereas isotonic regression performs

as well or better once calibration data are plentiful (Niculescu-Mizil & Caruana, 2005).

- **Beta calibration** contains the identity map on scores in [0, 1], which the logistic family applied to such scores does not (Kull et al., 2017).

In REM, Platt scaling on the logit is the adopted calibrator. Beta, isotonic and temperature calibration are reviewed alternatives and are **not adopted** (Chapter 3).

Measuring calibration. Calibration is measured by the expected calibration error (ECE; Naeini et al., 2015; Guo et al., 2017). ECE depends on the binning and on the size of the calibration set.

Evidence from included studies.

- **NEXUS** reports that Platt scaling reduced ECE from 0.085 to 0.013 on its benchmark. It also evaluated isotonic regression, and its authors report that Platt was less prone to overfitting on the small calibration split (Hossain et al., 2026; the calibration details are PARTLY UNVERIFIED).
- **C. Zhang et al. (2026)** caution against over-reading such improvements. In their ALFWorld analysis, Platt scaling reduced a confidence score's ECE from 0.463 to 0.006, while control regret under threshold routing stayed at 0.318 (preprint; figures PARTLY UNVERIFIED). A calibrated risk estimate is not the decision-relevant quantity for choosing an intervention.
- **LATTICE** adds independent peer-reviewed evidence in the same direction from a different setting. Across four planner families and 4,000 trajectories, a *confidence-threshold baseline* had a false-allow rate ranging from 0.03 to 0.998 (Calboreanu, 2026). A single threshold on a confidence signal was therefore unstable across the upstream models that produced the actions.

Implication. Calibration quality and control quality must be measured and reported separately. A probability, however well calibrated, does not by itself represent whether a trajectory remains recoverable.

2.7.2 Why expected-loss decisions are relevant

The principle. Cost-sensitive decision theory chooses the response with the lowest expected cost given the class probabilities and a cost matrix (Elkan, 2001). For responses a and a binary state y:

$$a^{*}(x) = \arg\min_{a} \sum_{y \in \{0,1\}} Pr(y / x) C(a, y) \quad (2.3)$$

The reject option. Chow (1970) showed that withholding an automatic decision is optimal when the expected cost of deciding exceeds the cost of rejecting. This is the classical basis for routing uncertain cases to human review.

Requirements. The rule needs calibrated probabilities (Section 2.7.1) and costs that reflect real preferences, which are rarely known precisely in security. Elkan's principle and Chow's analysis support REM's expected-loss verdict and its Escalate route. Neither source proposed REM's four-action design.

Precedents among included studies.

- **NEXUS** defines an expected-loss objective with fixed intervention costs and uses it to set loss-optimal thresholds inside a rule-first cascade (Hossain et al., 2026; cascade and loss-based threshold selection stated in the authors' repository README, level R; the cost values are PARTLY UNVERIFIED).
- **H.-H. Chen (2026)** prices the consequence of each action deterministically against a reserve.
- **Kaptein et al. (2026)** formalize a path-conditioned probability of policy violation.

Cost-based reasoning about agent actions therefore has precedents.

Attribution for audit. For a linear model under feature independence, the Shapley attribution of a feature is its coefficient times the feature's deviation from a reference, and on the log-odds of a logistic model the decomposition is exact (Lundberg & Lee, 2017). It is therefore suitable for an audit record that shows which evidence contributed to a decision. It is not a distinguishing mechanism: included systems provide audit traces as rules and findings, rule circuits, traceable evidence or hash-chained logs. In REM, attribution is audit-only and never enters the verdict. The full discussion is in Appendix A.

2.8 Runtime Decision and Mitigation

This section examines how runtime systems *act* on what they detect. It distinguishes four functions that the literature often conflates:

- **detection:** recognizing that something may be wrong;
- **risk estimation:** quantifying how likely or how severe;
- **decision:** selecting a response;
- **mitigation:** executing the response.

2.8.1 The space of runtime responses

The included systems use a common, graduated vocabulary:

- allow;
- block;
- modify: rewrite arguments, sanitize context, propose a safer alternative or request a revision;
- escalate: request confirmation or human review;
- restrict tools or privileges;
- interrupt or terminate;
- stage, undo or roll back effects.

Human participation is also studied directly. An analysis of 21 production agent systems found runtime approval in 15 of them, policy specification in 14 and scope configuration in 16. It found no production deployment of intent anchoring or trust labeling, the mechanisms most studied academically. It also identified a trade-off between approval fatigue and uncontrolled autonomy (P. Wang et al., 2026; preprint). A simulation study added in the supplementary update of 2 November 2026 reports, at abstract level, that human-in-the-loop approvals sharply reduce high-impact actions but degrade under user error and habituation (Kanaker et al., 2026; Section 2.12.5).

2.8.2 AgentTrust: runtime interception with graduated verdicts

AgentTrust (C. Yang, 2026; preprint; MODERATE EVIDENCE; PARTLY UNVERIFIED) is among the closest prior art to REM. It passed the inclusion criteria through the other-methods stream. The protocol asks that its runtime interception, verdicts, monitoring, multi-step handling, mitigation, evaluation, latency and ablation claims each be verified; the verification status of each is given below.

Architecture and verdicts (level A). AgentTrust intercepts agent tool calls *before execution* and returns one of four verdicts: allow, warn, block or review. Its abstract names a shell deobfuscation normalizer, SafeFix suggestions of safer alternatives, RiskChain detection of multi-step attack chains, and a cache-aware LLM judge for ambiguous inputs.

Results (level A). On its 300-scenario internal benchmark, a production-only rule set reached 95.0% verdict accuracy and 73.7% risk-level accuracy. On 630 independently

constructed adversarial scenarios, the author reports 96.7% under a *patched* rule set, explicitly not zero-shot.

What REM cannot claim. AgentTrust already provides:

- pre-execution interception;
- a four-way graduated verdict set that includes human review;
- a modify-like response (SafeFix);
- session-level multi-step detection;
- component ablations with latency.

Where the difference lies. The defensible differences are narrower:

- **Evidence to verdict.** AgentTrust's verdicts come from analyzers and rules, with an LLM judge for ambiguous cases. The verified material reports no calibrated probability of adversarial induction.
- **Use of consequence.** Reversibility is one of the judge's dimensions, not an explicit loss that changes the decision at a fixed probability.
- **Threat and domain.** AgentTrust targets side effects of coding and shell agents. It does not report evaluation on indirect injection against a financial agent.

2.8.3 NEXUS: calibrated risk scoring with a four-way intervention set

NEXUS (Hossain et al., 2026; MODERATE EVIDENCE; PARTLY UNVERIFIED) is the closest prior art to REM's *decision* component. It passed the inclusion criteria through the other-methods stream as a preprint. It has since been published in the Findings of AACL 2026; the published record was checked on 11 November 2026. **The full text has not been read in either version.** Three sources below the level of the paper are used, and each statement names its source:

- **A**: the abstract of the published version (index record, 11 November 2026);
- **A0**: the abstract of the preprint (index record, 28 October 2026);
- **R**: the README of the authors' public repository (retrieved 1 November 2026; a copy and its SHA-256 are kept in the verification records). Repository documentation can differ from the paper.

Architecture (A, R). NEXUS is a structured-plan safety monitor that "applies a formal intervention policy" to select among allow, block, request confirmation and request revision. It combines deterministic safety rules, argument-level inspection and a *calibrated* logistic-regression risk score used for graded escalation. According to the README, the

policy selects one intervention per plan, and the score is trained on a nine-dimensional plan feature vector.

Decision policy (R). The README states the policy explicitly: Block if any critical violation, or if the risk score $\rho \geq \tau_b$ with at least one violation; Confirm if $\rho \geq \tau_c$ or any high-severity violation; Revise if any medium-severity violation; otherwise Allow. It states that $(\tau_b, \tau_c) = (0.75, 0.70)$ was selected on a safety–utility loss $L(\Pi) = E[\lambda_s u_s + \lambda_o u_o + \lambda_c c(\Pi(P))]$ over a 5×5 grid of (λ_s, λ_o), and that Platt scaling, fitted on a 60-instance calibration split, reduced ECE from 0.085 to 0.013 on the 128-instance test split.

Results (A). On a 128-instance synthetic benchmark the published abstract reports F1 of 0.949 and four-class intervention accuracy of 0.6406, 27.3 percentage points above rule-only selection. On R-Judge it reports F1 0.861 against 0.849 for rule-only; it matches rule-only on AgentHarm; and it reports 0% ASR at 99% control allow on an indirect-injection set. On its rule-blind stress set it reports F1 0.897 with a Revise recall of 0.500, and a median latency of 0.38 ms. The preprint abstract (A0) gave 0.881 and 0.205 ms for the last two figures, and the README gives different headline figures for a retrained scorer (for example F1 0.965 on the synthetic test split). The published abstract's figures are used here, and the differences are recorded rather than resolved. The README adds that on rule-blind plans the policy predicts only Allow or Block.

Still unverified (level U). The intervention costs, the definitions of the nine features and of the consequence annotations read by the rules, the session manager, and the limitations stated by the authors.

What REM cannot claim. NEXUS already provides calibrated logistic risk scoring, a formal policy over a four-way intervention set with confirmation and revision routes, a loss criterion for selecting its thresholds, and sub-millisecond latency.

Where the difference lies. Three differences can be stated at levels A and R:

- **Point of evaluation.** REM evaluates each proposed tool call during execution, with the episode history; NEXUS judges a structured plan.
- **Decision rule.** REM selects each verdict by minimum expected loss, with losses indexed by the consequence tier of the call, so the boundaries between verdicts move with consequence. NEXUS applies a rule-first cascade with two score thresholds chosen once by a loss criterion; consequence enters through rule severities.

- **Evaluation.** REM is evaluated by replaying recorded trajectories of real agents in an executable banking environment and scoring outcomes. NEXUS's headline results score plans against labeled interventions on a synthetic benchmark, with R-Judge, AgentHarm and an injection set as additional evaluations.

Whether any of these differences changes outcomes is an empirical question. NEXUS was not run in this thesis. Its repository was read on 13 November 2026 and not executed, and no valid adapter from a banking tool call to its plan representation exists (Chapter 4, Section 4.4.5).

The scorer against the rules, as documented by the authors (R). A working document in the repository, dated 23 May 2026 and written to answer reviewers, states that a paired test of NEXUS against its rule-only variant gives no difference in binary detection, and that the contribution of the learned scorer is to the choice among the four interventions (accuracy 0.6406 against 0.3672 for rules only on the synthetic test split). This is not the published paper and its figures may differ from the paper's. It matters here because it is the same pattern that this thesis measures for REM: the learned score adds nothing measurable to security beyond rules.

2.8.4 Other decision mechanisms

Jackson (2025). A working paper (LIMITED EVIDENCE; PARTLY UNVERIFIED) describes a policy engine in which a multi-dimensional risk score drives a deterministic enforcement state machine with allow, deny, sanitize and escalate decisions. Its decision set corresponds closely to REM's four verdicts. It is unrefereed, its full text was not accessed, and its evaluation claims are qualitative.

Consequence-aware control.

- H.-H. Chen (2026; preprint) prices each side-effect-bearing action, such as a payment or refund, against a safe default and gates it against a reserve capital budget. It does not estimate how likely the action is to have been induced.
- SafeAgent's decision core instantiates operators for risk encoding, utility-cost evaluation, consequence modeling and policy arbitration over persistent session state (H. Liu et al., 2026; level A). Whether these operators are realized through LLM reasoning is unverified (level U).
- NEXUS encodes consequence in plan annotations and rules.

Confidence-based escalation. LATTICE separates deciding from judging, so that no component both proposes and approves an action. It escalates to human operators on

confidence, and reports zero unsafe actions across four planner families (Calboreanu, 2026). It achieved this at a conservative operating point that auto-allowed no action. In the same study, a confidence-threshold baseline's false-allow rate varied from 0.03 to 0.998 across planners.

Transactional and reversible mitigation.

- Cordon stages outward-facing effects in an outbox and executes reversible mutations in shadow state (Z. Chen et al., 2026).
- GoEX offers undo and damage confinement for post-facto validation (Patil et al., 2024).

Such substrates *consume* a decision and could supply the mechanics of a hold or undo response.

2.9 Financial AI-Agent Security

The protocol asks that general agent-security evidence be kept separate from financial-agent evidence. A general benchmark is not counted as financial evidence merely because one of its scenarios is financial.

2.9.1 General agent-security evidence with a financial component

Several included general studies contain a financial element but report no finance-specific analysis in the verified record:

- **AgentDojo** includes an executable Banking suite (Debenedetti et al., 2024).
- **ASB** includes finance as one of ten scenarios (H. Zhang et al., 2025).
- **AgentHarm** includes fraud among eleven harm categories (Andriushchenko et al., 2025).
- **ClawSafety** includes finance among five professional domains. Its scenarios include redirecting financial transactions (Wei et al., 2026).
- **ToolEmu** cites financial loss as a risk example (Ruan et al., 2024).
- **RTBAS** cites financial transactions as a motivating example (Zhong et al., 2025).

These studies establish that financial actions are within the attack surface that general benchmarks cover. They do not establish how defenses perform on financial actions specifically.

2.9.2 Financial-agent evidence

Four included studies have a primarily financial setting, and none reaches MODERATE or HIGH EVIDENCE:

- **Castro-Maldonado et al. (2026)**, peer reviewed, study a semantic firewall with online ensemble learning in an agentic retrieval-augmented banking chatbot. The record specifies neither the threat model nor the results (LIMITED EVIDENCE).
- **Z. Chen, J. Chen, et al. (2025)**, a preprint position paper, argue that accuracy and return metrics give an illusion of reliability for financial agents. They propose model-, workflow- and system-level stress testing, illustrated by an audit of six agents on three tasks (LIMITED EVIDENCE).
- **H.-H. Chen (2026)**, a preprint, frames consequence pricing actuarially, with payments and refunds as examples (LIMITED EVIDENCE; partial financial focus).
- **FinHarness** (H. Jia et al., 2026; preprint) is the closest domain-specific runtime system. It combines a query monitor fusing intent with cross-turn drift, a tool monitor for each prospective call, and a cascade routing verification between a lightweight and an advanced LLM judge. It reports attack success falling from 38.3% to 15.0%, with benign approval moving from 41.1% to 39.3%. All of these figures were measured on **FinVault** (Z. Yang et al., 2026). The review record of 25 September 2026 notes that FinVault's arXiv preprint was **withdrawn by its authors**, with a comment citing legal, intellectual-property and affiliation reasons rather than an error in the benchmark; its OpenAlex record carries no retraction flag, and the withdrawal notice could not be re-checked on 28 October 2026 because arXiv was unreachable. A withdrawal for non-scientific reasons does not invalidate measurements made on the benchmark. It does mean that FinHarness's figures cannot be confirmed against a publicly maintained version, so they are reported as author-reported results with that caveat, and FinHarness is appraised LIMITED EVIDENCE by override.

Background SoK. A systematization of LLM-agent security in agentic commerce (Mao et al., 2026) organizes financial threats along five dimensions and derives twelve cross-layer attack vectors. It places *transaction authorization* at the center of the financial threat model. It is a secondary study, cited as background.

2.9.3 Why financial execution raises the requirements

Three properties of financial execution raise the requirements on a runtime layer. The first two are established in the included sources; the third is this chapter's inference from them.

- **Irreversibility.** Some financial actions cannot be recalled. This is encoded in consequence pricing (H.-H. Chen), in irreversibility flags checked by rules (NEXUS), and in transactional staging (Cordon).
- **Attacker-supplied arguments.** Under indirect injection, recipients and amounts can be planted in the content the agent reads, which makes argument provenance especially informative (Section 2.6.1).
- **Heterogeneous consequences.** A balance query and a transfer may both be permitted, yet differ sharply in the harm an induced call could cause. The same probability of adversarial induction therefore need not warrant the same response.

Regulatory motivation. Regulation (EU) 2024/1689 requires that high-risk AI systems allow automatic event logging (Article 12) and effective human oversight, including the ability to intervene or halt (Article 14) (European Parliament & Council of the European Union, 2024). Whether a given financial agent is high-risk is not assessed here. The provisions motivate an audit record for every decision and an explicit route to human review.

2.9.4 Requirements derived for a runtime layer protecting a financial agent

Six requirements follow from Sections 2.3–2.9:

- **R1** pre-execution mediation of each proposed action;
- **R2** provenance evidence on action arguments;
- **R3** consequence-differentiated responses at the same estimated probability;
- **R4** a human-review route;
- **R5** an audit record for every decision;
- **R6** joint measurement of security, benign utility, intervention behavior, calibration and latency.

2.10 Comparative Evidence Synthesis

Two tables compare the included runtime defense and design studies. Both are built from the systematic evidence matrix (`CHAPTER2_SYSTEMATIC_EVIDENCE_MATRIX.csv`).

- **Table A.5** (Appendix A) records what each study observes and does, using the columns specified in the review protocol.
- **Table A.8** records how the studies closest to REM turn evidence into a decision.

Coding. Yes = reported in the verified record; NR = Not Reported; NV = Not Verified; NA = Not Applicable. A property that the record does not report is **not** inferred to be

present or absent. Financial context is coded Yes only for a primarily financial setting. Evidence levels are HIGH, MOD (moderate) and LIM (limited), as defined in Section 2.2.5.

Table A.5 (42 defense and design studies × 13 properties) is reproduced in **Appendix A**. In summary: 41 of the 42 studies operate at runtime, 34 code tool/action evidence, 21 multi-step handling, 17 behavioral evidence and 8 provenance evidence as present in the record; these counts describe what the records report (Section 2.2.5), not what the systems lack.

Reading the tables.

Row by row, every individual property in REM's design appears somewhere in the included studies:

- calibrated logistic scoring with a four-way intervention set: NEXUS;
- pre-execution interception with graduated verdicts and human review: AgentTrust, RTBAS, LATTICE;
- consequence-dependent control: H.-H. Chen, NEXUS, SafeAgent;
- provenance and cross-step information-flow evidence: ProvenanceGuard, CaMeL, ACE, RTBAS, the MCP policy-enforcement point;
- trajectory-aware monitoring: MI9, PRISM, ProbGuard, DreamGuard, ToolSafe, AgentTrust;
- latency and component ablation: AgentTrust, NEXUS, the MCP policy-enforcement point;
- a financial runtime harness: FinHarness;
- the limits of calibration and confidence thresholds for control: C. Zhang et al.; LATTICE.

Column by column, the combinations thin out:

- **NEXUS** alone reports a calibrated probability together with costs and a graduated response. It does so at the plan level, on author-generated templates, with fixed intervention costs setting thresholds inside a rule-first cascade.
- **Provenance evidence**, where its contribution has been measured, feeds rules (the MCP policy-enforcement point) or a detector (ProvenanceGuard), not a probability estimator.
- **Financial focus** appears only in LIMITED EVIDENCE studies.
- **No included record** reports all three of the following together:

- a calibrated probability of adversarial induction per proposed tool call;
- consequence-dependent losses used to select among graduated responses;
- evaluation on an executable financial environment with utility, intervention behavior and latency reported.

This observation concerns the *records* examined. A combination this specific is easy to miss in a record-level review and is weak evidence of originality on its own (Section 2.12.2).

Table A.8, reproduced in Appendix A, records for the runtime systems closest to REM the decision basis, whether a calibrated probability is produced, whether consequence enters the decision, the human-review and graduated responses, and which evaluation dimensions are reported.

2.11 Critical Synthesis

What is well addressed.

- Threats are well characterized and benchmarked.
- Interception at the tool-call boundary is implemented in many forms, and deterministic enforcement is fast.
- Graduated responses, including human review, are standard.
- Architectural defenses offer formal guarantees for the threats they formalize.
- Calibration methods are mature and have one agent-safety application.

What remains fragmented. The pieces of a probabilistic, consequence-aware decision exist, but in different studies:

- a calibrated score with fixed-cost thresholds in a plan-level cascade (NEXUS);
- deterministic consequence pricing that ignores how an action arose (H.-H. Chen);
- consequence reasoning realized by LLM operators (SafeAgent);
- provenance evidence feeding rules or a detector (the MCP policy-enforcement point; ProvenanceGuard);
- financial focus in a judge cascade evaluated on a benchmark that is no longer publicly maintained (FinHarness).

Conflicting evidence, presented rather than resolved.

- **Value of trajectory evidence.** The AgentTrust ablation reportedly found no effect of a session tracker (level U). The MCP policy-enforcement point found a large

effect of cross-step labels. The kind of trajectory evidence differs, and both are single studies.

- **Architectural guarantees.** IsolateGPT reports protection against the attacks it tested, and ACE later defeats it with new attacks.
- **Calibration as a remedy.** NEXUS reports a large ECE improvement. C. Zhang et al. report that a similar improvement left control regret unchanged. LATTICE reports that a confidence threshold's false-allow rate ranged from 0.03 to 0.998 across planners.
- **Safety figures versus utility.** LATTICE's zero false-allow was obtained at an operating point that auto-allowed no action. The MCP policy-enforcement point's attack-success reduction came with a 30.0% task-level false-positive rate. A safety figure alone is therefore not evidence of a usable defense.

Where current approaches stop.

- Most detectors and guardrails stop at a verdict and do not produce a probability that could be traded off against consequence.
- Most consequence-aware designs stop at the consequence and do not estimate the likelihood of adversarial induction.
- Most trajectory-aware systems stop at detection. The two ablations disagree about whether the trajectory component changes outcomes.
- Most evaluations stop at attack success: benign utility, intervention behavior, calibration and latency are reported unevenly.

What the evidence does not support. The systematic evidence does **not** support three claims that earlier drafts could have been read as making:

- that runtime interception, graduated verdicts or consequence awareness are absent from the literature;
- that combining several signals at the action boundary is rare. AgentTrust, the MCP policy-enforcement point, ToolSafe, DRIFT and FinHarness all combine signals at or near the tool call;
- that trajectory evidence is known to be ineffective. The evidence is mixed.

This section draws the thematic syntheses together. The full thematic table (Table A.9) is in Appendix A.

2.12 Research Gap and REM Positioning

2.12.1 Assessment of candidate gaps

The review protocol listed five candidate gaps, A to E, to be retained only if the systematic evidence supported them. Their assessment is in Appendix A (Table A.10). In summary, the review did not support a gap in the existence of runtime interception, graduated responses, calibration or consequence awareness; it supported narrowed versions of three gaps concerning evidence: on the value of behavioral and provenance evidence as input to a calibrated estimator (Gap C), on runtime defenses for financial actions in an open, executable benchmark (Gap D), and on a comparison of a consequence-aware decision with a consequence-independent baseline on the same estimator (Gap E).

2.12.2 Research gap supported by the systematic review (September 2026)

> The gap supported by the examined evidence is **empirical**. In the records of the 71 included studies (search date 25 September 2026), the review found (a) limited and conflicting evidence on whether behavioral and provenance evidence improves runtime decisions, and none testing it as input to a calibrated estimator for financial actions (Gap C); (b) no verified quantitative evaluation of a runtime defense on financial actions in an open, executable benchmark (Gap D); and (c) no evaluation that compares a consequence-aware decision with a consequence-independent baseline sharing the same estimator, while reporting attack success, benign utility, intervention behavior, calibration and latency separately (Gap E).

Nature of the gap. The gap concerns *evidence*: how established mechanisms behave when combined at the action boundary of a financial agent under indirect prompt injection, measured against a baseline that isolates the decision rule. It does not concern the absence of any single mechanism, and it does not concern a new learning algorithm. The specific combination that REM implements (Gap A) was not found in the examined records, but the thesis does not rest its originality on that absence: a combination this specific is easy to miss in a record-level review, and closely related designs exist (NEXUS, AgentTrust, SafeAgent).

Bounds. The gap is bounded by the search, which covered one database with a retrieval cap and a partly non-independent other-methods stream. It is also bounded by record-level

appraisal: no study was read in full, and several properties of the closest studies are unverified (Section 2.12.4).

Falsifiability. A study that reports this combination and evaluation would require the contribution to be revised.

2.12.3 REM positioning: established by prior research versus proposed by this thesis

REM is a runtime mediation layer between a financial tool-using agent and its environment. It is organized in exactly five layers:

1. **Input & Context**;
2. **Detection**;
3. **Behavioral Analysis**;
4. **Decision Engine**;
5. **Mitigation**.

Chapter 3 specifies it. Table 2.2 separates what REM adopts from prior research from what this thesis proposes.

Table 2.2. Established by prior research versus proposed by this thesis

Element	Established by prior research (included or foundational sources)	Role in REM
Runtime interception of each proposed tool call	Progent; AgentSpec; AgentTrust; RTBAS; MCP policy-enforcement point; LATTICE; PRISM; SafeAgent; Task Shield	Adopted, not claimed
Provenance / goal–action consistency evidence	ProvenanceGuard; Task Shield; MELON; CaMeL; ACE; RTBAS; MCP policy-enforcement point	Adopted as estimator input, not claimed
Behavioral / trajectory monitoring	MI9; ProbGuard; DreamGuard; PRISM; AgentTrust; ToolSafe; Forrest et al. (1996); Chandola et al. (2009, 2012)	Adopted, not claimed
Ridge logistic risk scoring	Cox (1958); le Cessie & van Houwelingen (1992); NEXUS	Adopted, not claimed
Platt calibration on the logit	Platt (2000); Guo et al. (2017); NEXUS	Adopted, not claimed. Beta, isotonic and temperature calibration are reviewed and **not adopted**

Element	Established by prior research (included or foundational sources)	Role in REM
Minimum expected-cost decision; reject option	Elkan (2001); Chow (1970); NEXUS objective	Adopted, not claimed. Neither source proposed REM's four-action architecture
Consequence-dependent control	H.-H. Chen (2026); NEXUS; SafeAgent; AgentTrust	Adopted as declared consequence tiers, not claimed
Graduated responses including human review	AgentTrust; NEXUS; RTBAS; LATTICE; SafeAgent; Jackson; MI9	Adopted, not claimed
Deterministic mitigation; reversible and staged effects	Progent; AgentSpec; Cordon; GoEX	Adopted, not claimed
Sequential change detection (CUSUM)	Page (1954); Basseville & Nikiforov (1993); Lorden (1971)	Optional, offline, observe-only analysis outside the verdict path; not claimed
Additive attribution for audit	Lundberg & Lee (2017); audit traces in NEXUS, AgentTrust, PRISM, LATTICE	Audit record only; never used for the verdict; not claimed
Combination of provenance evidence, a calibrated per-step probability, tier-indexed expected-loss verdicts and deterministic mitigation at the action boundary, on an open executable banking benchmark	Not reported in the examined records (record-level; weak evidence of absence)	**Proposed by this thesis (integrative design)**
Evaluation that separates attack success, benign utility, intervention behavior, calibration and latency, against a consequence-independent baseline with the same estimator	Not reported in the examined records	**Proposed by this thesis (empirical)**

Relation to AgentTrust and NEXUS. What REM cannot claim against AgentTrust and NEXUS, and the narrower differences that remain, are set out in Sections 2.8.2 and 2.8.3 and are not repeated here. Several of the properties on which those differences rest are unverified (level U).

Relation to other close studies. REM does not claim:

- to be the first financial runtime protection (FinHarness);
- a risk-score-to-graduated-verdict pipeline (Jackson; SafeAgent);
- deterministic consequence pricing (H.-H. Chen);

- provenance analysis (ProvenanceGuard; the MCP policy-enforcement point);
- that calibration improves control (C. Zhang et al.; LATTICE).

2.12.4 Limitations of this review

The review is systematic in procedure but **not exhaustive**, and its conclusions are bounded as follows.

1. **Database accessibility.** Only OpenAlex was searched. IEEE Xplore, the ACM DL, Scopus and Web of Science, ScienceDirect, SpringerLink, the ACL Anthology, NeurIPS/PMLR, ICLR/OpenReview, USENIX and arXiv could not be reached (DATABASE ACCESS UNAVAILABLE). Elicit access was also unavailable. Their content was reached only through OpenAlex's index.
2. **Index coverage, ranking and retrieval cap.** OpenAlex's lexical relevance ranking surfaced general surveys ahead of specific recent preprints. Only the top 24–25 records per query page were screened, although index estimates ran to thousands. The database search retrieved only 3 of the 13 named prior-art studies, which shows that relevant studies can be missed.
3. **Non-independent second stream.** Thirty-one included studies came from the reference list of the previous chapter, which reflects the author's prior reading. This introduces selection bias, which the protocol's requirement to treat named prior art identically mitigates but does not remove.
4. **No full texts.** Eligibility, extraction and appraisal were performed on records; no full-text screening was performed and no claim is at level F. Nine included studies are PARTLY UNVERIFIED. Appraisal items that depend on full text (reproducibility, comparators, limitations) are mostly Not Verified. A supplementary record check on 28 October 2026 re-examined the closest studies (NEXUS, AgentTrust, ProvenanceGuard, FinHarness, FinVault, SafeAgent, C. Zhang et al., H.-H. Chen): it found a peer-reviewed version of ProvenanceGuard (ASE 2026), a changed title for C. Zhang et al., and several details of NEXUS and AgentTrust that are not supported by their current abstracts, which are now marked level U. Full texts remained unreachable.
5. **Single reviewer, AI-assisted.** Screening, extraction and appraisal were each done by one reviewer, assisted by an AI coding assistant, with no independent second screener and no agreement statistic. The appraisal checklist is transparent but is not a validated risk-of-bias instrument.
6. **Rapidly changing preprint literature.** 35 of the 71 included studies are preprints or working papers, and the field produces new preprints monthly. One source (FinVault) was recorded as withdrawn by its authors for non-scientific reasons. Preprint results may change or be withdrawn.
7. **Publication bias.** Defenses are usually reported on the authors' own benchmarks with favorable configurations. Negative results appear mainly in attack papers.

8. **Heterogeneity and no pooling.** Architectures, threats, benchmarks and metrics differ too much for meta-analysis. The synthesis is qualitative, and numeric comparisons across studies are avoided.
9. **Metadata errors in the index.** One record was corrupted (AgentDojo's DOI attached to another abstract) and one venue year was inconsistent (PromptShield). Both were detected and recorded, but others may have gone unnoticed.

Before submission. The protocol's Boolean blocks should be run directly in at least IEEE Xplore, the ACM DL, Scopus or Web of Science, and arXiv. Full texts of the included studies should be appraised, and the PRISMA flow and gap assessment updated.

2.12.5 Dated literature updates of 30 October and 2 November 2026 (outside the PRISMA flow)

Two updates were made after the registered search of 25 September 2026. Neither is part of the PRISMA flow: no count in Table 2.1 or Figure 2.1 changes, no record was added to the 71 included studies, and every statement below is at abstract level. Both are reproduced in full in Appendix A.

30 October 2026. The eleven queries of the registered search were re-run in the same index, restricted to publication year 2026. Of 215 unique records, 200 were not in the stored output of the registered search; they were title-screened by one reviewer. Five records bear directly on REM's positioning, among them:

- Kekatos et al. (2026) replay the recorded trajectories distributed with AgentDojo through a temporal-logic monitor, offline and without running an agent. Offline evaluation on AgentDojo's recorded traces therefore has a published precedent and is not a methodological contribution of this thesis. They also report that a planted line defeats a naive provenance check on most of the runs it would otherwise flag.
- Z. Liu (2026) replays ground-truth tool calls without a language model to evaluate fifteen injection detectors and reports that detector rankings transfer poorly between benchmarks.
- Yan et al. (2026) and Xin (2026) describe controllers close to REM's decision component: one commits the proposed or an alternative action by a learned value, the other routes among execute, confirm and block with calibrated probabilities. The first was later read in full (Section 2.12.6).

2 November 2026. Kanaker et al. (2026) propose an assumption-explicit simulation framework that separates compromise, harm and severity, and compare architectural controls across six threat scenarios and nine defense configurations. Their abstract reports

that least-privilege tool design is the strongest single broad control and that human-in-the-loop approvals reduce high-impact actions but degrade under user error and habituation. The study is cited where it is consistent with positions of this thesis; no REM mechanism, parameter or experiment is derived from it.

2.12.6 Literature update of 11 November 2026: full-text readings (outside the PRISMA flow)

Status of this addition. On 11 November 2026 six papers were read in full from PDF files supplied by the author, whose SHA-256 values are kept with the study records. **This is the only place in this chapter where a full text was read.** The update is not part of the PRISMA flow. No count in Table 2.1 or Figure 2.1 changes, and no screening record is created retrospectively. Two of the six (Task Shield and MELON) are included studies of the review; three (PROVISO, CASEL, and the paper of C. Zhang et al.) were known from records; one (AgentBoundary) is new. Three further works are described from their abstracts only and are marked so. No systematic search to this date was possible, and newer competing work may exist.

Table 2.3. Works examined in the updates of 11 and 13 November 2026 (F = full text read; A = abstract only; R = authors' repository read, paper not read)

Work	Level	What it does	Evaluation	Statement most relevant to this thesis
PROVISO (Yan et al., 2026; preprint)	F	Decides at the commitment point, after an action is proposed and before it is executed. Observations are typed by provenance into trusted and external. A trained controller estimates the value of the proposed and of an alternative action and commits the higher, after subtracting an offset chosen on development data	AgentDojo, four suites, by rolling out both continuations in a restored environment; folds keep all attack variants of a user task together	The controller is "fitted separately for each benchmark and therefore requires labeled outcomes from the target setting; we do not study transfer of a single trained controller across tasks"
AgentBoundary (T. Yang et al., 2026; preprint)	F	Counterfactual task families that vary apparent risk and permissibility independently on the same workflow; reports authorized-task completion and unsafe behavior separately	17 agent configurations on general agent tasks	"high safety frequently coexists with poor authorized-task completion"
Calibration Is Not Control (C. Zhang et al., 2026; preprint, header states NeurIPS 2026)	F	Defines the value of an intervention as the difference between the expected utility of intervening and of continuing; proves that a strictly increasing recalibration of a score preserves the class of threshold policies	Prefix branching on agent benchmarks; no security benchmark	A risk score is sufficient for control only if the sign of the intervention value can be recovered from it
CASEL (Y. Zhang et al., 2026; preprint)	F	Selects among six execution modes by minimizing a per-mode cost that multiplies a failure probability by a consequence and adds mode costs	Simulation only	"Intervention effectiveness is assumed, not measured"; the per-mode cost "does not reduce harm beyond a product-score gate"

Work	Level	What it does	Evaluation	Statement most relevant to this thesis
Task Shield (F. Jia et al., 2025; ACL)	F	Requires every instruction and tool call to contribute to a user-level task; contribution is scored by a language model	AgentDojo, live agents	A tool output may legitimately define subtasks when the user delegates to it
MELON (Zhu, Yang, et al., 2025; ICML)	F	Re-executes the step with the user prompt masked and flags an attack when the resulting tool calls remain similar	AgentDojo, live agents	Reported benign utility with GPT-4o falls from 80.41% to 68.04%
aiAuthZ (Kodathala, 2026; preprint)	A, R	An off-host gateway that binds each user message to an identity by a keyed signature and enforces role allow-lists, argument-level constraints and rate limits on tool calls, with a hash-chained audit log (repository whitepaper)	AgentDojo 0.1.35 banking, twenty task pairs, one model, with a fixed list of five known payees and password change denied (whitepaper)	Abstract: blocks all seven attacker-directed calls “at the cost of one legitimate first-time payment”. Whitepaper: six blocked calls; clean utility 80% against 100%. The whitepaper states that the policy “stops what it is configured to stop” and that a comparison with CaMeL and Progent on AgentDojo “is not yet done”
Kairos (Hempel et al., 2026; preprint)	A	A reference monitor at the isolation boundary that defers and checks effects	AgentDojo, per its abstract	Attack success 47.0% to 2.7% with benign utility at the undefended level
NEXUS, published version (Hossain et al., 2026)	A, R	See Section 2.8.3	—	A working document in the authors’ repository states that the learned scorer gives no gain in binary detection over rules alone and contributes to four-class intervention accuracy
Progent (T. Shi et al., 2025; preprint)	R	Per-tool policies with argument restrictions, checked deterministically before each tool call. The repository holds a hand-written policy per AgentDojo suite at one	AgentDojo 0.1.29 is bundled with the repository	Its manual banking policy is a fixed list of five permitted recipients, with no entry for password change. It is replayed in Chapter 4, Section 4.4.3

Work	Level	What it does	Evaluation	Statement most relevant to this thesis
		commit and policies generated and updated by a language model at its current head		
CaMeL (Debenedetti et al., 2025; preprint)	R	Extracts control and data flow from the trusted query and enforces capabilities at tool-call time (repository description)	Not examined	Not run and not approximated in this thesis

The figures in Table 2.3 come from different agents, suites, attack sets and evaluation modes. They are listed to show what each work reports and are not compared with one another or with REM.

Reading of the authors' repositories on 13 November 2026. The publishers' sites of the works marked A were not reachable from the working environment, and no full text of NEXUS, aiAuthZ, Kairos, Progent or CaMeL was read. The official code repositories of four of them were reachable and were read, not executed, at fixed commits: Progent, aiAuthZ, NEXUS and CaMeL. Statements at level R come from the authors' own repository documents. They are below the level of the paper and may differ from it; where a repository document and an abstract differ, both are given. For Kairos only the abstract is known.

What the update changes.

- **The decision form is published.** CASEL's per-mode cost has the same structure as REM's expected-loss rule: a residual-risk term for each mode and a cost for choosing it. Together with NEXUS, this removes any claim that combining a risk estimate with consequence to choose among graduated responses is new.
- **Calibration is known not to be the lever.** C. Zhang et al. give the formal reason why recalibrating a score, or re-thresholding it, cannot recover a distinction that the score lacks. Their intervention-value target was tested in this thesis and failed on an unseen attack objective (Chapter 4, Section 4.6.6).
- **Over-defense is a general finding.** AgentBoundary measures at scale what this thesis measures for REM: safety obtained by withholding authorized actions.
- **Stronger utility is reported by heavier or differently placed mechanisms.** PROVISO, Task Shield and MELON report higher utility than REM reaches in replay, with a trained controller and restored rollouts or with a language model in

the decision path. Kairos and aiAuthZ, at abstract level, act at the system boundary or add a trusted authorization channel. None was run under the conditions of this thesis.

- **Authorization needs a trusted input.** aiAuthZ, at abstract level, and PROVISO's admissibility rule both rest on trusted statements of what is authorized. REM's threat model has only the user's request as text.

2.12.7 Revised statement of the research gap

The statement of Section 2.12.2 was written from the records of September 2026. It framed the gap partly as the absence of a combined evaluation of a calibrated, consequence-aware decision. After the update of Section 2.12.6 the mechanism side of that statement is closed, and the gap is restated as follows. It is proposed wording, pending the supervisor's confirmation.

> Runtime defenses for tool-using agents now combine risk scoring, provenance and graduated interventions, and their authors report benchmark-specific fitting and unmeasured intervention effectiveness. Limited controlled evidence establishes whether a learned, consequence-aware runtime decision adds value over simple provenance and authorization rules for a banking agent when both the user task and the attack objective are unseen, and at what cost in legitimate task completion.

Table 2.4. Assessment of the revised gap statement

Criterion	Assessment
Supported by recent literature	PROVISO states that transfer of its fitted controller is not studied, and it holds out user tasks, not attack objectives. CASEL states that intervention effectiveness is assumed. AgentBoundary reports widespread over-defense. None of the six papers read in full compares a learned monitor with parameter-free rules on the same trajectories. For NEXUS, aiAuthZ and Kairos this is known only from abstracts and, for the first two, from the authors' repositories
Distinct from published work	As an evidence gap, yes. As a mechanism gap, no: every mechanism involved is published
Specific	It names the class of system (a monitor without a language model in the decision path), the domain, the comparison and the conditions
Answerable by experiment	Yes, by recorded-trace replay with held-out objectives and tasks (Chapter 3, Sections 3.11.12 and 3.11.14)
Falsifiable	Yes. The statement "the learned policy adds value over the rules" is a paired contrast with an interval, and the data could have supported it
Consistent with the results	Yes. The answer obtained is largely negative (Chapter 4, Section 4.6.8)

Bounds. The gap is bounded by the record-level review, by the absence of a systematic search after 30 October 2026, and by the abstract-level knowledge of three close works. A study that reports a held-out-objective comparison of a learned monitor with rule baselines on banking tasks would require the statement to be revised.

2.13 Chapter Summary

This chapter reported a record-level systematic review, reported following PRISMA 2020 and PRISMA-S, of runtime security for tool-using AI agents, with attention to financial execution. Full texts were not retrieved, so its findings rest on records.

Selection. The search of OpenAlex on 25 September 2026 identified 320 records. (A simulation study added in a supplementary update of 2 November 2026 is discussed separately at abstract level in Section 2.12.5; it does not change these counts.) After deduplication, 219 were screened, and 45 were assessed for eligibility at record level. Forty database studies were included. Another 31 came from the verified reference list of the previous chapter, giving 71 included studies. Of these, 10 are HIGH, 36 MODERATE and 25 LIMITED record-visible evidence.

Themes. The synthesis established the following:

- **Threats.** Indirect prompt injection through the observation channel is the best-evidenced threat to tool-using agents, and it is adaptive. Its harm materializes at the proposed tool call.
- **Defenses.** Runtime interception, deterministic enforcement, information-flow architectures, learned guardrails and provenance checks are all established. Adaptive attacks have repeatedly broken defenses, including architectural ones.
- **Behavioral and provenance evidence.** Many monitors observe trajectories. Evidence on their contribution is sparse and conflicting: a null ablation of a session tracker, and a large effect of cross-step information-flow labels.
- **Algorithmic foundations.** Logistic scoring, Platt calibration, expected-cost decisions with a reject option, and additive attribution are established. One agent-safety system (NEXUS) combines calibration with costs at the plan level. Calibration or a confidence threshold alone did not secure good control in two independent studies. CUSUM is reviewed only as an optional, observe-only analysis.
- **Decision and mitigation.** Graduated responses with human review are standard. How to combine a probability of adversarial induction with a declared consequence remains open. Intervention rates are rarely reported.
- **Financial agents.** All financial-context evidence is LIMITED, and the only quantitative financial runtime results cannot be confirmed against a maintained benchmark.

The gap. The gap stated from the systematic review concerned the evaluation of a calibrated, consequence-aware decision at the action boundary of a financial agent. Full-text readings in November 2026 showed that the decision form itself is published (NEXUS; CASEL) and that its known weaknesses are documented (C. Zhang et al.; AgentBoundary). The gap was therefore restated as one of evidence (Section 2.12.7): whether a learned, consequence-aware runtime decision adds value over simple provenance and authorization rules for a banking agent under unseen user tasks and attack objectives, and at what cost in legitimate task completion. Every mechanism involved is established. Only the controlled evaluation, including its negative results, is offered by this thesis.

Chapter 3 specifies the REM methodology through which the gap is addressed.

CHAPTER THREE: RESEARCH METHODOLOGY, DESIGN AND IMPLEMENTATION OF THE REM FRAMEWORK

3.1 Research Methodology and System Scope

3.1.1 Design science research

This thesis follows design science research, in which knowledge is produced by building an artifact that addresses an identified problem and evaluating it rigorously (Hevner et al., 2004). The research process follows the six activities of the design science research methodology of Peffers et al. (2007). Table 3.1 maps these activities to the thesis.

Table 3.1. Design science research activities in this thesis

Activity (Peffers et al., 2007)	Realization in this thesis	Location
Problem identification and motivation	Runtime compromise of tool-using financial agents through indirect prompt injection	Chapter 1; Chapter 2
Definition of objectives for a solution	Objectives O1–O3; research questions RQ1–RQ4; security objectives SO-1 to SO-6	Sections 3.1.2, 3.1.3, 3.3.7
Design and development	Five-layer REM architecture and its runtime pipeline	Sections 3.2–3.10
Demonstration	Integration of REM with the AgentDojo banking environment	Section 3.15
Evaluation	Controlled experiments, baseline comparison, and ablation	Sections 3.11–3.12; Chapter 4
Communication	Thesis and derived publications	Chapter 5

The evaluation is quantitative and experimental. REM is compared against a baseline that uses the same probability estimator but a consequence-independent decision rule, so that differences in outcomes can be attributed to the decision rule rather than to the estimator.

3.1.2 Research objectives

The approved objectives are:

- **O1:** Design a REM framework for financial AI agents' and task automation agents' security.
- **O2:** Evaluate the framework against adversarial attacks.

- **O3:** Compare performance with existing security approaches.

This chapter realizes O1 through the architecture and runtime pipeline, O2 through the attack scenarios and metrics of Sections 3.11–3.12, and O3 through the baselines of Section 3.11.7. The evaluation in this thesis uses a financial (banking) environment. Task-automation environments are outside the evaluation scope unless approved as an extension.

3.1.3 Research questions

The approved proposal does not state research questions. The following questions are derived from the objectives and are presented for supervisor confirmation.

Table 3.2. Traceability of research questions

RQ	Objectives	Principal components	Principal metrics
RQ 1	O1, O2	Detection and Behavioral Analysis evidence; estimator; calibration	ROC-AUC, PR-AUC, ECE, log-loss
RQ 2	O2, O3	Consequence tiers; expected-loss decision; baseline policy	ASR, benign utility, utility under attack, intervention rates, realized loss
RQ 3	O2	Mitigation Layer; Escalate; runtime pipeline	Residual ASR under Modify, escalation rate, latency
RQ 4	O2	All components (ablation)	Change in the metrics above

3.1.4 Scope

In scope:

- A single LLM-based agent that invokes tools with generated arguments.
- A financial (banking) task environment with executable tools and state-based checks.
- Indirect prompt injection through tool outputs as the evaluated attack class.
- Runtime mediation of each proposed tool call before it is released.
- *[Proposed scope amendment, pending supervisor approval]* A recorded-trace replay sensitivity analysis under a stated no-adaptation assumption (Section 3.11.10). It is reported as exploratory evidence about fixed recorded trajectories, not as an estimate of enforcement against live or adaptive agents.

Out of scope:

- Training-time defenses and modification of the agent’s model or prompts.
- Multi-agent systems.

- Evaluation against adaptive adversaries who tune attacks to REM.
- Production deployment in a financial institution.
- Counterfactual estimation of intervention value for adaptive agents, for example by replaying agent prefixes and executing alternative actions from the same state (C. Zhang et al., 2026).

3.1.5 Assumptions

Table 3.3. Assumptions

ID	Assumption	Type	Status
AS-1	REM can intercept each proposed tool call and each tool result without modifying the agent's internals.	Architectural	To be demonstrated on the chosen platform (Section 3.15)
AS-2	Context segments can be attributed to their source channel reliably enough to assign a provenance label.	Architectural	To be demonstrated
AS-3	The adversary cannot modify REM's code, parameters, policy, or logs.	Architectural	Assumed; stated as a limitation
AS-4	The user's objective is legitimate; REM protects the user against external manipulation.	Scoping	Stated choice
AS-5	Tool outputs and retrieved content are untrusted by default.	Scoping	Follows from the indirect injection threat (Greshake et al., 2023)
AS-6	Adversaries do not adapt to REM's parameters in the primary evaluation.	Scoping	Declared limitation
AS-7	Observable evidence separates adversarially induced from benign proposed actions.	Empirical	Tested in pilot E0 (Section 3.11.8)
AS-8	The benign reference data are representative of the evaluated workload.	Empirical	Threatened by benchmark scope (Section 3.16)
AS-9	LLM non-determinism is bounded enough for repeated runs to characterize variance.	Empirical	Measured through repeated runs
AS-10	The agent's internal reasoning is not used; REM relies only on observable inputs, proposed actions, and tool results.	Architectural	Design constraint

The notation used in this chapter is listed in Appendix C. Each symbol has one meaning throughout the chapter, and symbols that appear in a single equation are defined where they are used.

3.2 REM Architecture

3.2.1 Five layers

REM is a runtime mediation layer between one agent and its environment. It comprises exactly five layers, as approved in the research proposal:

1. **Input & Context Layer.** Captures the information the agent handles and the action it proposes, and labels each context segment with its provenance.
2. **Detection Layer.** Computes evidence about untrusted context.
3. **Behavioral Analysis Layer.** Computes evidence about the episode history and the proposed action.
4. **Decision Engine Layer.** Estimates the probability that the proposed action is adversarially induced, assigns a consequence tier, applies policy predicates, selects a verdict, and writes the audit record.
5. **Mitigation Layer.** Executes the mechanism associated with the verdict.

Offline fitting and recalibration (Section 3.9) are cross-cutting activities performed between deployments. They are not a layer, are not numbered with the layers, and never change REM's parameters during an episode.

3.2.2 Topology and information flow

At each step, REM executes Layer 1; then Layers 2 and 3, each computing its evidence from Layer 1's output without using the other's; then Layer 4; then Layer 5, before the proposed action is released to the environment. Layers 2 and 3 are independent computations, not concurrent ones: the implementation evaluates them one after the other in the same process (Section 3.15). They share the declared instruction-pattern set as a resource, not each other's output. The Detection and Behavioral Analysis Layers compute their evidence independently; they are combined only in the Decision Engine. This independence allows an evidence group to be removed in ablation without changing the computation of the other. After an action is released, its tool result re-enters Layer 1 as untrusted content for the next step.

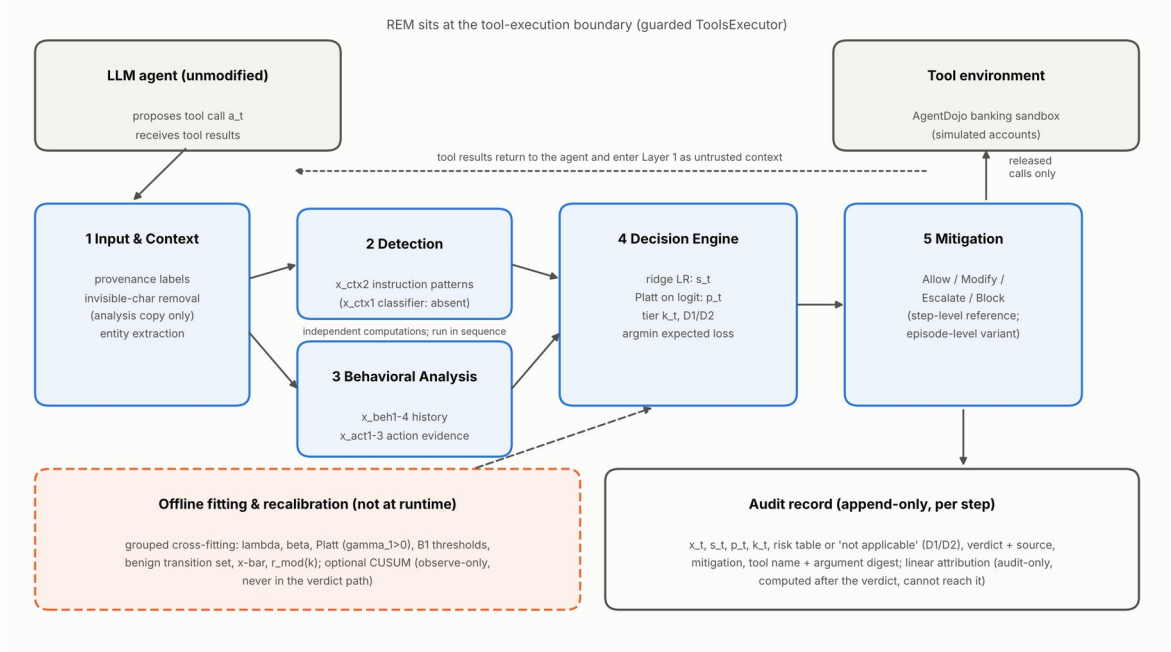


Figure 3.1. REM architecture as implemented. Five layers at the tool-execution boundary; offline fitting and recalibration are cross-cutting and never run within an episode; the audit record is written for every step and its attribution cannot reach the verdict.

Figure 3.1 shows the runtime path from the proposed tool call through Layers 1–5 to the environment, the return of tool results as untrusted context, the append-only audit record, and the cross-cutting offline fitting. The human reviewer to whom Escalate refers is outside REM. In this thesis no reviewer is present, and escalations are resolved by the two bounds of Section 3.11.7.

The inputs and outputs of each layer are listed in Appendix C. The four functions are separated architecturally: Layers 2 and 3 produce evidence and issue no verdicts; Layer 4 performs probability estimation and decision; Layer 5 performs mitigation.

3.3 Threat Model and Financial Action Boundary

3.3.1 Protected system

The protected system is a single LLM-based agent that pursues a user objective by proposing tool calls. REM treats the agent as opaque: it observes inputs, context, proposed actions, and tool results, but not model parameters or internal reasoning (AS-10). The evaluation instance is an agent operating the AgentDojo banking environment (Debenedetti et al., 2024), described in Section 3.11.2.

3.3.2 Episodes and steps

An episode is one execution of the agent on one user objective g. It is a finite sequence of steps t = 1, …, T, where step t is the interval in which the agent proposes action a_t. At step t, REM observes g, the labeled context c_t, the proposed action a_t, and the history H_t of prior contexts, actions, verdicts, and tool results.

3.3.3 Trust boundaries and untrusted content

Table 3.4. Trust boundaries

ID	Boundary	Direction	Treatment in REM
TB-1	User input	User → agent context	Labeled semi-trusted
TB-2	Observation	Tool outputs and retrieved content → agent context	Labeled untrusted; primary observation point
TB-3	Action	Agent → tools and external systems	Primary enforcement point
TB-4	Memory	Context ↔ persistent store	Provenance retained on read and write (design scope only)

Untrusted content is any context segment that entered through TB-2 or TB-4, or that was derived from such a segment. The observation boundary matters because content arriving there enters after the user's request, which is the route exploited by indirect prompt injection (Greshake et al., 2023; OWASP Gen AI Security Project, 2025). The action boundary matters because it is the last point at which an induced action can be prevented rather than repaired.

3.3.4 Adversary model

- **AD-1, content-control adversary (primary, evaluated).**
    - *Can:* author or modify content that the agent receives through tool outputs, including instruction-like text and values such as account identifiers.
    - *Cannot:* access the user channel, observe or modify REM's parameters, or modify agent or REM code.
- **AD-2, prompt-channel adversary (design scope only).** Can submit crafted input through a compromised user channel. The evaluated banking attacks do not exercise this channel.

Excluded:

- adversaries who modify model weights, agent code, or REM;
- infrastructure compromise;
- a malicious operator;
- adaptive adversaries (AS-6).

3.3.5 Indirect injection and adversarially induced actions

Indirect prompt injection occurs when content from an external source, processed by the agent, alters its behavior (OWASP Gen AI Security Project, 2025). REM's target event is narrower and defined at the action level.

A proposed action a_t is **adversarially induced** ($y_t = 1$) if executing it would advance an objective introduced by the adversary rather than the user objective g. The label is not observable at runtime. Actions that are unsafe because of the agent's own error without adversarial involvement are outside this definition. The operational derivation of y_t for evaluation data is given in Section 3.11.3.

3.3.6 Sensitive financial actions

Table 3.5 groups the tools of the evaluated banking environment by the consequence of an adversarially induced call. The tool names are those registered in the AgentDojo banking suite inspected for this chapter (Section 3.11.2). The grouping is a design classification, not a property reported by the benchmark.

Table 3.5. Action categories in the banking environment

Category	Tools	Consequence if adversarially induced
Read	get_balance, get_iban, get_most_recent_transactions, get_scheduled_transactions, get_user_info, read_file	No direct external effect; may expose data later sent elsewhere
Value transfer	send_money, schedule_transaction	Money sent to an attacker-controlled account
Payment modification	update_scheduled_transaction	Redirection or alteration of a recurring payment
Credential change	update_password	Loss of control over the account
Profile change	update_user_info	Alteration of account holder information

3.3.7 Security objectives

The threat model above states what an adversary can do; the objectives below state what REM must therefore do about it. They are ordered along the path of a single proposed tool call: from the evidence available about it, through the verdict selected for it, to the record left behind and the cost of producing it.

- **SO-1:** Use evidence about untrusted content that enters through TB-2.
- **SO-2:** Detect proposed actions whose arguments originate in untrusted content or that deviate from the episode's benign pattern.
- **SO-3:** Account for the consequence of the proposed action when selecting a verdict.
- **SO-4:** Provide human escalation as a response.
- **SO-5:** Emit, for every verdict, an audit record from which the verdict can be reproduced.
- **SO-6:** Preserve benign task utility and report per-step latency.

3.4 Input & Context Layer

The Input & Context Layer collects and labels information. It computes no risk evidence.

3.4.1 Context capture

At step t the layer receives:

- the user objective g and user messages (TB-1);
- the system prompt;
- the results of previously executed tools (TB-2);
- the proposed action a_t, captured at TB-3 and held until Layer 5 acts.

Invisible and formatting characters, such as zero-width characters, are removed from untrusted text before further processing. This is a deterministic hygiene step applied to **REM's analysis copy** of the text. The content delivered to the agent is not altered, because REM is non-invasive (AS-1); hygiene therefore protects REM's feature computation, not the agent. It reduces some encoding-based concealment but does not prevent paraphrase-based evasion.

3.4.2 Provenance labeling

Each context segment receives one label from the ordered set trusted (system prompt) ≻ semi-trusted (user input) ≻ untrusted (tool output, retrieved content, memory). Content derived from several segments inherits the least-trusted label among them, and processing never promotes content to a more trusted label. This rule is a design definition that preserves the distinction between data and instruction exploited by indirect injection. It asserts no empirical claim.

3.4.3 Entity extraction

The layer extracts security-relevant entities from each segment and from the arguments of a_t, and records the provenance of each occurrence:

- account identifiers (such as IBAN-formatted strings);
- monetary amounts;
- password and credential values;
- user-profile values (such as addresses and phone numbers);
- tool names mentioned in text.

The extraction patterns are declared in configuration and are fixed before evaluation. These entities allow Layer 3 to ask whether an argument of the proposed action can be traced to the user objective or to trusted content, or only to untrusted content.

3.5 Detection Layer

The Detection Layer computes context evidence from untrusted segments. It issues no verdict.

Table 3.6. Context evidence

Feature	Definition	Type	Availability
x^{ctx}_1	Maximum score of a fixed, pre-trained prompt-injection classifier over untrusted segments added since the previous step	[0, 1]	Derived (classifier choice pending supervisor approval)
x^{ctx}_2	1 if an untrusted segment added since the previous step matches the declared instruction-pattern set; otherwise 0	Binary	Derived (pattern set declared before evaluation)

The classifier is used with fixed inference and is not retrained. A classifier distributed with an existing guardrail system, such as PromptGuard 2 in LlamaFirewall (Chennabasappa et

al., 2025), is a candidate. The instruction-pattern set contains declared indicators such as imperative instructions addressed to an assistant, references to tool names, and role or delimiter markers.

Both features are individually evadable, and benchmark-based scores of detectors are fragile (Arp et al., 2022; M. Q. Li et al., 2026). The Detection Layer is therefore not relied upon to be decisive. Its evidence is combined with behavioral and action evidence in the Decision Engine, and its contribution is measured by ablation (Section 3.11.7).

3.6 Behavioral Analysis Layer

The Behavioral Analysis Layer maintains the episode history and computes evidence about the trajectory and the proposed action. All reference quantities it uses are estimated offline from benign data and are frozen at runtime.

3.6.1 Step tracking

The layer maintains H_t: the sequence of proposed actions, their arguments with provenance, the verdicts issued, and the tool results returned. H_t is reset at the start of each episode.

3.6.2 Behavioral and action evidence

Table 3.7. Behavioral and action evidence

Feature	Definition	Type	Availability
x^{beh}_1	Post-observation shift: 1 if the most recent tool result was untrusted and had $x^{ctx}_2 = 1$; otherwise 0	Binary	Derived from H_t
x^{beh}_2	Repeated calls: $\min(n_{rep}, n_{max}) / n_{max}$, where n_{rep} is the number of consecutive calls with the same tool and key arguments and n_{max} is declared	[0, 1]	Derived from H_t
x^{beh}_3	Privilege escalation: 1 if the privilege level of a_t's tool exceeds the highest level used so far in the episode; otherwise 0	Binary	Derived; privilege map declared
x^{beh}_4	Transition deviation: 1 if the pair (previous tool, current tool) does not occur in the benign reference transition set; otherwise 0	Binary	Derived; reference set estimated on benign fitting data

Feature	Definition	Type	Availability
x^{act}_1	Argument provenance: 1 if a key argument of a_t (recipient account identifier, amount, password, or profile value) occurs in untrusted content but not in g or trusted content; otherwise 0	Binary	Derived from L1 entities
x^{act}_2	Destination novelty: 1 if the recipient of a_t appears neither in g nor among the transactions observed before the episode's first untrusted ingestion; otherwise 0	Binary	Derived; applicable to value-transfer and payment-modification tools
x^{act}_3	Sensitive egress: 1 if a_t sends to an external recipient a value obtained from a sensitive read (account identifier, profile value, or credential); otherwise 0	Binary	Derived from L1 entities and H_t

All features are bounded in [0, 1] by definition, so no further rescaling is applied. Three design rules govern them:

1. **No identity-based features.** No feature may encode a specific account identifier. In the evaluated benchmark, one attacker account identifier is shared by most injection tasks (Section 3.11.2), and a feature keyed on that value would leak the label.
2. **Evidence is kept separate from consequence.** Whether a payee appears only in untrusted content is evidence about *whether* an action is adversarially induced; it belongs in x_t. Whether the action transfers a large amount irreversibly describes *what would happen*; it belongs in the consequence descriptors z_t (Section 3.7.3) and enters the decision only through the loss.
3. **The feature set is frozen after pilot E0** (Section 3.11.8), before any held-out predictions are examined.

3.7 Decision Engine Layer

The Decision Engine turns evidence into a verdict in five stages: probability estimation, calibration, consequence assessment, policy predicates, and expected-loss verdict selection. It also writes the audit record. Each equation below states its source and whether it is established from the source, adapted from it, or derived here.

3.7.1 Ridge logistic estimation

The probability that the proposed action is adversarially induced is modeled by logistic regression (Cox, 1958):

$$s_t = \beta_0 + \beta^\top x_t,\ \tilde{p}_t = \sigma(s_t) = \frac{1}{1+\exp(-s_t)} \quad (3.1)$$

where $x_t \in [0, 1]^d$ is the evidence vector $[x^{ctx}; x^{beh}; x^{act}]$, $\beta_0 \in \mathbb{R}$ is the intercept, $\beta \in \mathbb{R}^d$ is the coefficient vector, s_t is the logit, and $\tilde{p}_t$ is the uncalibrated estimate of $P(y_t = 1 \mid x_t)$.

Role in REM: maps the evidence of Layers 2 and 3 to a score and an uncalibrated probability. *Status:* established from source (Cox, 1958).

The parameters are estimated offline by maximizing a ridge-penalized log-likelihood (le Cessie & van Houwelingen, 1992):

$$(\hat{\beta}_0, \hat{\beta}) = \arg\max_{\beta_0, \beta} \sum_{i \in D_{fit}} \left[y_i \ln \tilde{p}_i + (1 - y_i) \ln(1 - \tilde{p}_i) \right] - \lambda \|\beta\|_2^2 \quad (3.2)$$

where D_{fit} is the set of labeled fitting steps, $y_i \in \{0, 1\}$ are their labels, $\tilde{p}_i$ is given by Equation 3.1, and $\lambda \geq 0$ controls the strength of the quadratic penalty. The intercept is not penalized.

Role in REM: produces finite and stable coefficients from small, imbalanced data with binary features. *Status:* established from source.

The quadratic penalty is needed for a specific reason. The evidence features are mostly binary, and adversarial steps are scarce (Section 3.11.4). If a single indicator appears only in adversarial fitting steps, the unpenalized maximum-likelihood estimate does not exist as a finite value. The penalty keeps the estimates finite.

Reference parameterization of λ. This thesis fixes the penalty as written in Equation 3.2, $\lambda\|\beta\|^2$. The implementation (Section 3.15) minimizes the negative log-likelihood plus $(\lambda_{impl}/2)\|\beta\|^2$, so the two parameterizations correspond exactly when $\lambda = \lambda_{impl}/2$. Because λ is selected from a *finite* grid, the two scales are equivalent only under this conversion: the declared grid $\lambda_{impl} \in \{0.01, 0.1, 1, 10, 100\}$ is the grid $\lambda \in \{0.005, 0.05, 0.5, 5, 50\}$ on the scale of Equation 3.2. Every selected value is reported on both scales. The scaling constant in le Cessie and van Houwelingen (1992) has not been checked against the full text; it does not affect the method, which depends only on the stated objective and the declared grid.

No interaction terms are included by default. Equation 3.1 assumes that the log-odds of adversarial induction are approximately linear in the evidence.

3.7.2 Calibration on the logit

The uncalibrated probability $\tilde{p}_t$ need not agree with observed frequencies. Ridge shrinkage and class imbalance can both distort it. Because the decision rule in Section 3.7.5 treats the probability as a probability, REM recalibrates it with a two-parameter logistic map applied to the logit:

$$p_t = \sigma(\gamma_1 s_t + \gamma_0), \gamma_1 > 0 \quad (3.3)$$

where γ_1 is the calibration slope and γ_0 is the calibration intercept.

Role in REM: produces the calibrated probability used by the decision rule. *Status:* adapted from source. The method is Platt scaling (Platt, 2000). The two-parameter logistic form with parameters fitted by negative log-likelihood on held-out data follows Guo et al. (2017). The map is applied here to the logit of a logistic regression model. The monotonicity condition follows Kull et al. (2017), who require a non-negative slope for a non-decreasing map; REM requires a strictly positive slope so that the ranking of steps is preserved.

The calibration parameters are fitted by minimizing the negative log-likelihood on held-out logits (Guo et al., 2017):

$$(\hat{\gamma}_1, \hat{\gamma}_0) = \arg\min_{\gamma_1, \gamma_0} - \sum_{i \in D_{cal}} \left[y_i \ln p_i + (1 - y_i) \ln(1 - p_i) \right] \quad (3.4)$$

where D_{cal} is a set of steps whose logits s_i were produced by a model that was not fitted on those steps. Fitting Equation 3.4 on the model's own training logits would be close to degenerate, so REM uses out-of-fold logits from grouped cross-fitting (Section 3.9).

Status: established from source (Guo et al., 2017).

Fitting target. Equation 3.4 fits the calibration map to the observed labels y_i. Platt's original procedure instead fits against smoothed targets, $t_+ = (N_+ + 1)/(N_+ + 2)$ and $t_- = 1/(N_- + 2)$, to reduce overfitting on small calibration sets. This thesis takes Equation 3.4 as the reference definition and evaluates Platt's smoothed targets as a sensitivity analysis.

Four properties of this choice are stated.

1. **It changes probabilities, not rankings.** With $\gamma_1 > 0$, Equation 3.3 is strictly increasing in s_t. Calibration therefore leaves ROC-AUC, PR-AUC, and any decision based only on the ordering of steps unchanged. If the fitted slope is not positive, calibration is rejected for that fit and the event is reported.
2. **It is the minimal adequate family.** Kull et al. (2017) prove that beta calibration with equal shape parameters equals logistic calibration applied to the log-odds of a score. Since $\tilde{p}_t = \sigma(s_t)$, the log-odds of $\tilde{p}_t$ is s_t, so Equation 3.3 is exactly beta calibration with equal shape parameters applied to $\tilde{p}_t$. The identity map is included ($\gamma_1 = 1$, $\gamma_0 = 0$). Full beta calibration adds a third parameter, and isotonic regression is nonparametric; neither is adopted, given the limited calibration data.
3. **It is not a contribution.** Calibrated logistic risk scores are already used in agent safety (Hossain et al., 2026).
4. **It does not guarantee good control.** C. Zhang et al. (2026) show that recalibrating a scalar risk score can improve calibration error while leaving control regret under threshold routing unchanged, because a scalar probability does not represent whether an intervention would improve the outcome. REM therefore reports calibration quality and control outcomes separately (Section 3.12) and does not claim that calibration improves control.

3.7.3 Consequence tiers

The consequence of a proposed action is described by descriptors z_t obtained from the action itself (Table 3.8). They are mapped to a consequence tier $k_t = \kappa(z_t) \in \{1, \ldots, K\}$ by a declared policy function κ. Consequence descriptors do not enter Equation 3.1; they affect the verdict only through the loss. Keeping the likelihood that an action is adversarially induced separate from the consequence of executing it is consistent with threat models that distinguish compromise from harm and its severity (Kanaker et al., 2026).

Table 3.8. Consequence descriptors

Descriptor	Meaning	How obtained	Availability
Action category	Read, value transfer, payment modification, credential change, profile change (Table 3.5)	Tool name	Available
Amount	Monetary amount of a value-transfer or payment-modification call	Action arguments	Available where the tool takes an amount
Recurring-payment change	Whether the action alters a scheduled or recurring payment	Tool name	Available
Credential change	Whether the action changes account credentials	Tool name	Available
Irreversibility	Whether the effect is treated as irreversible once executed	Declared per tool	Proposed (policy); the benchmark does not simulate settlement

Table 3.9. Illustrative consequence tiers (policy pending supervisor approval)

Tier	Illustrative membership
1	Read tools
2	Profile change
3	Value transfer at or below a declared amount limit
4	Value transfer above the declared limit; payment modification; credential change

The quantities used by the Decision Engine fall into three classes, which are kept distinct throughout the thesis.

Table 3.10. Learned, measured, and policy quantities

Class	Quantities	How determined
Learned	β_0, β, γ_1, γ_0	Fitted on labeled data by Equations 3.2 and 3.4
Measured	$r_{mod}(k)$; benign reference mean $\bar{x}$; benign transition set; utility impact of Modify	Estimated from observe-only and enforcing-mode runs
Policy	κ, amount limits, $C_{miss}(k)$, $C_{FA}(k)$, $C_{mod}(k)$, C_{esc}, Π, k_{D2}, privilege map, tie-breaking order	Declared before evaluation; varied over a declared grid where they affect outcomes

Policy quantities encode institutional judgment. They are not presented as empirical findings, and their influence is reported through the loss grid of Section 3.12.3.

3.7.4 Policy predicates

Two deterministic predicates are evaluated before verdict selection.

- **D1, prohibited action.** If $a_t \in \Pi$, the verdict is Block irrespective of p_t. A prohibition that a sufficiently low probability could override would not be a prohibition.
- **D2, missing required evidence.** If the evidence required for tier k_t cannot be computed (for example, argument provenance is unavailable) and $k_t \geq k_{D2}$, the verdict is Escalate. Absent evidence is not treated as evidence of safety.

Π, k_{D2}, and the evidence required at each tier are declared policy. When a predicate applies, it determines the verdict, the expected-loss rule is not consulted, and the audit record names the predicate as the source of the verdict. Both predicates are disabled in one ablation (Section 3.11.7).

Order of evaluation and unavailable evidence. Availability of each feature is determined first, from the proposed action alone. D1 and then D2 are applied *before* any probability enters the decision, so no verdict that a predicate fixes depends on a value computed from unavailable evidence. Two cases follow:

- **A predicate fixes the verdict.** s_t and p_t may still be computed and stored for audit, but they are marked as not used, and the audit record contains no risk table: the field is recorded as *not applicable* (Section 3.7.6).
- **No predicate applies, but a feature is unavailable** (possible only below k_{D2}). The feature takes its "not observed" value 0, and the audit record flags the imputation. This is a design definition: an unavailable indicator is treated as not fired, which can only lower the estimated probability. It is therefore used only below the tier at which missing evidence forces escalation.

3.7.5 Expected-loss verdict selection

Loss structure. For each tier k, the loss of issuing verdict v when the label is y is given in Table 3.11.

Table 3.11. Tier-indexed loss structure L(v, y, k)

Verdict v	L(v, 0, k): legitimate action	L(v, 1, k): adversarially induced action
Allow	0	$C_{miss}(k)$
Modify	$C_{mod}(k)$	$r_{mod}(k) \cdot C_{miss}(k)$
Escalate	C_{esc}	C_{esc}
Block	$C_{FA}(k)$	0

All declared costs are non-negative and expressed in common relative units. Correct automatic decisions are assigned zero loss, which is a declared convention.

Reviewer assumptions. The Escalate entries assign the same loss C_{esc} whatever the label. This assumes a reviewer who:

- resolves every escalation correctly (accuracy 1);
- does so within the time the transaction allows, with delay and effort priced into C_{esc};
- is always available.

The verdict rule is optimal only under these assumptions. They are not tested in this thesis, because no reviewer is present. They are optimistic: a simulation study reports that human-in-the-loop approvals reduce high-impact actions but degrade under user error and habituation (Kanaker et al., 2026). The rule is instead *evaluated* under two bounds (Section 3.11.7): an idealized reviewer that satisfies the assumptions, and no reviewer, in which every escalation withholds the action. A policy designed for a perfect reviewer and evaluated without one is expected to withhold legitimate actions; that cost is reported, not hidden. A reviewer with error rate e would add $e \cdot C_{miss}(k)$ to the adversarial entry and $e \cdot C_{FA}(k)$ to the legitimate entry of Escalate; such a model is not specified here.

The adversarial Modify entry is a derivation. Under the stated assumption A-Mod — whether Modify neutralizes an adversarially induced action is independent of x_t given the tier, and the attack fails with probability $1 - r_{mod}(k)$ — the law of total expectation gives:

$$L(Modify, 1, k) = r_{mod}(k) C_{miss}(k) + \left(1 - r_{mod}(k)\right) \cdot 0 = r_{mod}(k) C_{miss}(k) \quad (3.5)$$

where $r_{mod}(k) \in [0, 1]$ is the residual attack-success rate after Modify at tier k, measured in enforcing-mode runs (Section 3.11.7).

Status: derived under assumption A-Mod.

Conditional risk. Elkan (2001) states that the optimal prediction is the one that minimizes expected cost, computed from the conditional probability of each class and the cost of each prediction for each true class. REM applies this criterion to the four verdicts, with losses indexed by the consequence tier and the calibrated probability of Equation 3.3 in place of the true conditional probability:

$$R_t(v) = (1 - p_t)\,L(v, 0, k_t) + p_t\,L(v, 1, k_t),\ v \in V(a_t) \quad (3.6)$$

where $R_t(v)$ is the conditional risk of verdict v at step t.

Status: adapted from source. Elkan's criterion is stated for predictions of classes. REM extends the set of choices to four verdicts, indexes the losses by consequence tier, and substitutes the calibrated estimate p_t for the true posterior. The substitution is justified only to the extent that p_t is calibrated.

Bayes verdict. The verdict is:

$$v_t = \arg\min_{v \in V(a_t)} R_t(v) \quad (3.7)$$

with ties resolved toward the more restrictive verdict in the declared order Block ≥ Escalate ≥ Modify ≥ Allow.

Status: adapted from source; the tie-breaking order is a design definition that makes the rule a function. Ties are counted and reported whenever the rule is evaluated, so that the influence of the tie order on any result is visible.

The feasible set $\mathcal{V}(a_t)$ contains Allow, Escalate, and Block for every action, and Modify only if the tool of a_t belongs to the set $\mathcal{T}_R$ to which the Modify mechanism applies (Section 3.8).

Derived thresholds. Each $R_t(v)$ is affine in p_t, so the verdict changes only where two conditional risks are equal. For verdicts v and v′ at tier k, let $\Delta_0 = L(v', 0, k) - L(v, 0, k)$ and $\Delta_1 = L(v, 1, k) - L(v', 1, k)$, with $\Delta_0 + \Delta_1 > 0$. Setting $R(v) = R(v')$ in Equation 3.6 and solving for p gives:

$$\pi_{v,v'}(k) = \frac{\Delta_0}{\Delta_0 + \Delta_1} \quad (3.8)$$

Status: derived from Equation 3.6.

Derivation: $R(v) - R(v') = -\Delta_0 + p(\Delta_0 + \Delta_1)$. This is zero at $p = \pi_{v,v'}(k)$, negative below it (v is preferred), and positive above it (v′ is preferred).

For v = Allow and v′ = Block, $\Delta_0 = C_{FA}(k)$ and $\Delta_1 = C_{miss}(k)$, so:

$$p_k^* = \frac{C_{FA}(k)}{C_{FA}(k) + C_{miss}(k)} \quad (3.9)$$

Status: derived from Equation 3.8. It has the form of the standard two-class cost-sensitive threshold for zero-cost correct decisions, which Elkan (2001) obtains from the same expected-cost criterion; the printed threshold expression in that paper could not be inspected directly during verification, so the derivation above stands on Equation 3.8 alone.

Thresholds are therefore consequences of declared costs rather than independently chosen constants. The question “why this threshold?” becomes “why this cost ratio?”, which the loss grid of Section 3.12.3 addresses.

When escalation can be selected. Chow (1970) analyzed the tradeoff between recognition error and rejection, which is the classical basis for withholding an automatic decision. In REM, Escalate is not implemented as a separate rejection test; it is one of the verdicts inside Equation 3.7. For the verdict set {Allow, Escalate, Block} at tier k, Escalate is selected for some probability if and only if:

$$C_{esc} < \frac{C_{FA}(k)\,C_{miss}(k)}{C_{FA}(k) + C_{miss}(k)} \quad (3.10)$$

Status: derived from Equations 3.6, 3.7, and 3.9.

Derivation: $R(\text{Allow}) = p \cdot C_{miss}(k)$ increases in p and $R(\text{Block}) = (1 - p) \cdot C_{FA}(k)$ decreases in p. Their minimum is largest at p^*_k, where it equals $C_{FA}(k) \cdot C_{miss}(k) / (C_{FA}(k) + C_{miss}(k))$. The constant C_{esc} lies strictly below this minimum for some p if and only if Equation 3.10 holds; at equality, ties resolve toward Block.

When Modify is also feasible, Equation 3.10 remains a necessary condition, because adding a verdict can only lower the minimum risk. In the symmetric case $C_{FA}(k) = C_{miss}(k) = C$, Equation 3.10 reduces to $C_{esc} < C/2$: deferral is selected only when it costs less than half an error.

Dominance check. Before a loss structure is used, it is checked for dominated verdicts. For example, R(Modify) − R(Block) = (1 − p)(C_{mod}(k) − C_{FA}(k)) + p · r_{mod}(k) · C_{miss}(k), which is non-negative for every p whenever C_{mod}(k) ≥ C_{FA}(k). In that case Modify can never be selected at tier k. A declaration that makes a verdict unreachable, by this check or by Equation 3.10, is reported as such rather than silently producing a smaller verdict set.

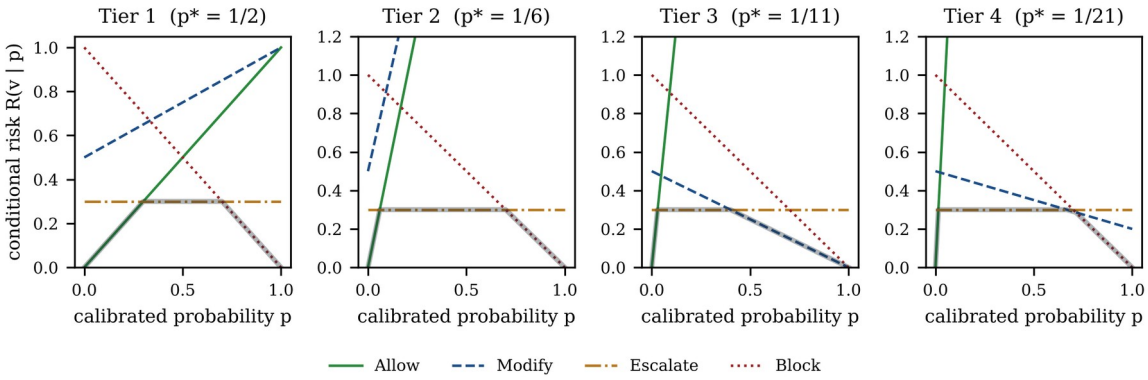


Figure 3.2. Conditional risk R(v | p) of the four verdicts (Eq. 3.6) as a function of the calibrated probability p, for the declared exploratory costs of tiers 1–4 (C_{FA} = 1; C_{miss} = 1, 5, 10, 20; C_{mod} = 0.5; C_{esc} = 0.3; r_{mod} as estimated in the pilot: 1, 1, 0, 0.01). The verdict is the lower envelope. The figure plots the equations for declared values; it is not an experimental result.

3.7.6 Explainability and audit record

For every verdict the Decision Engine writes an audit record containing:

- the identity of the proposed action: tool name and a digest of its arguments, recorded *before* any mitigation alters the step. Raw argument values, which may include credentials, are not stored;
- the evidence vector x_t with its availability flags, the logit s_t, and the probabilities $\tilde{p}_t$ and p_t, with a flag stating whether p_t was used for the verdict;
- the tier k_t and the conditional risks $R_t(v)$, or *not applicable* when D1 or D2 fixed the verdict;
- the verdict v_t and its source (D1, D2, or the expected-loss rule), and the mitigation applied;
- the model, calibration, and policy versions;
- a linear attribution of the logit.

The attribution follows the linear case of Shapley-value attribution given by Lundberg and Lee (2017):

$$\phi_{t,i} = \beta_i (x_{t,i} - \acute{x}_i), i = 1, \ldots, d; \phi_0 = \beta_0 + \beta^T \acute{x} \quad (3.11)$$

where $\bar{x}$ is the mean evidence vector over benign fitting steps, $\varphi_{t,i}$ is the contribution of feature i to the logit relative to that benign reference, and φ_0 is the logit at the reference.

Status: adapted from source. Lundberg and Lee (2017) state the linear case under feature independence with printed indices that do not match between the two sides of the expression and with base value equal to the model intercept. REM uses the index-consistent form and sets the base value to the logit at the reference point, which is the value required by their local-accuracy property when the reference mean is not zero.

The decomposition is exact:

$$\phi_0 + \sum_{i=1}^{d} \phi_{t,i} = s_t \quad (3.12)$$

Status: derived. Summing Equation 3.11 gives $\beta_0 + \beta^\top \bar{x} + \beta^\top x_t - \beta^\top \bar{x} = s_t$. This is the local-accuracy property of Lundberg and Lee (2017) for a linear model, and REM checks it as a correctness invariant.

For reporting by evidence group, REM defines:

$$\Phi_J = \sum_{i \in I_J} \phi_{t,i}, J \in \{ctx, beh, act\} \quad (3.13)$$

Status: design definition. Because the groups partition the features, $\Phi_{ctx} + \Phi_{beh} + \Phi_{act} = s_t - \varphi_0$.

Four qualifications apply:

1. **The attribution never influences the verdict.** It is an audit component only.
2. **It decomposes the logit, not the calibrated probability.** On the calibrated logit scale each contribution is multiplied by γ_1, which preserves relative contributions because $\gamma_1 > 0$.
3. **Correlation limits interpretation, not the identity.** The independence assumption affects the interpretation of each $\varphi_{t,i}$ as a Shapley value when features are correlated; it does not affect the identity of Equation 3.12.
4. **It is not a contribution.** Auditable decision records are provided by several existing systems (Hossain et al., 2026; C. Yang, 2026). Because the attribution is determined by the logged x_t and the frozen parameters, it can equally be computed at audit time.

3.7.7 Consequence-independent baseline policy

The baseline uses the same estimator and calibration but a decision rule that ignores consequence. Its thresholds are selected as operating points on benign validation steps:

$$\theta(\alpha)=min\{\theta:FPR_{val}(\theta)\leq\alpha\},FPR_{val}(\theta)=\frac{\left|\{i\in D_{val}^{benign}:p_i\geq\theta\}\right|}{\left|D_{val}^{benign}\right|}\quad(3.14)$$

where α is a declared false-positive target, D_{val}^{benign} is the set of benign validation steps in the relevant cross-fitting fold, and θ ranges over the observed probabilities.

The baseline verdict is:

- **Block** if $p_t \geq \theta(\alpha_{blk})$;
- **Modify** if $\theta(\alpha_{mod}) \leq p_t < \theta(\alpha_{blk})$ and Modify is feasible, otherwise Block;
- **Allow** otherwise.

The targets satisfy $\alpha_{mod} > \alpha_{blk}$. Predicates D1 and D2 apply as in Section 3.7.4, so the baseline issues Escalate only through D2. In implementation the candidate set for θ also includes a value just above the largest benign probability, so that α = 0 can be met.

Status: design definition.

What the comparison isolates. REM and the baseline share the estimator, the calibration and the predicates. They differ in two respects: REM's losses depend on the consequence tier, and REM's expected-loss rule can choose Escalate, whereas the baseline can escalate only through D2. A difference between them therefore reflects both consequence tiers and the extra escalation opportunity, not tiers alone. A third configuration separates the two: **REM without expected-loss Escalate**, in which Escalate is removed from the set $\mathcal{V}(a_t)$ used by Equation 3.7 but D2 is kept, gives REM exactly the baseline's opportunity to escalate.

Because Equation 3.14 selects thresholds by ranking, a strictly increasing recalibration re-selects equivalent thresholds and leaves the baseline's verdicts unchanged. Cost-derived thresholds such as Equation 3.9 are fixed in probability units and can change after recalibration. This contrast is used in the ablation of Section 3.11.7 and is consistent with the finding of C. Zhang et al. (2026) that recalibration need not change threshold-routed control.

3.8 Mitigation Layer

The Mitigation Layer executes, deterministically, the mechanism associated with each verdict. It never initiates an action on the agent's behalf.

Table 3.12. Verdict-to-mitigation mapping: reference (step-level) semantics and the episode-level variant

Verdict	Step-level semantics (reference)	Episode-level variant
Allow	a_t is released across TB-3 and the event is logged.	Same, unless the tool is restricted in S, in which case a_t is refused.
Modify	a_t is withheld, and a structured tool-restriction notice is returned for this call only. No restriction persists. Applies only to tools in $\mathscr{T}_R$.	a_t is withheld, and the tool class of a_t (its action category within $\mathscr{T}_R$) is added to S for the rest of the episode.
Escalate	a_t is withheld and referred for review; it is released only if the reviewer approves.	Same.
Block	a_t is not executed, and a structured refusal is returned. No other tool is affected.	a_t is not executed, and every tool in $\mathscr{T}_R$ is added to S, so no further side-effecting action is released in the episode.

Which semantics is the reference. The design decisions of Stage 2 fix step-level semantics: Block prevents the current action, and Modify applies one declared mechanism to the current action. Any restriction that persists through the episode is a separate experimental policy. The episode-level reading was specified in an earlier version of this chapter. Both are implemented and evaluated, and step-level semantics is the reference definition. This alignment with the frozen design lock awaits the supervisor's confirmation (decision D-2, conflict SC-1). The two semantics can release different actions even when the agent never retries a call or adapts: under the episode-level variant, Block adds every tool of $\mathscr{T}_R$ to the restriction set S, and Modify adds the tool class of a_t, so a later, *different* state-changing call is refused even when its own verdict is Allow. They therefore give different results under the replay of Section 3.11.10 (Table E.1). Live, adaptive agents would add further differences, through retries and alternative routes.

Tool restriction is the single Modify mechanism because it is deterministic, does not depend on an LLM rewriting content, and can be measured. Under step-level semantics, Modify and Block have the same effect on the current call; they differ in the declared loss (Table 3.11), in the notice returned to the agent, and, under the episode-level variant, in

what persists. Input sanitization, such as spotlighting (Hines et al., 2024), is an alternative that is not adopted as the primary mechanism.

Four properties are stated:

1. **Restrictiveness ordering.** Under the episode-level variant, Block halts all further side effects, Escalate defers the decision, and Modify removes one tool class. Under step-level semantics the ordering reflects the declared losses rather than persistence. The ordering underlies the tie-breaking order of Equation 3.7.
2. $\mathcal{T}_{\mathbf{R}}$ **is declared.** In the banking environment it contains value-transfer, payment-modification, credential-change, and profile-change tools; read tools are not restricted.
3. **Mitigation effectiveness is measured, not assumed.** The residual attack-success rate $r_{mod}(k)$ used in Equation 3.5 is estimated from enforcing-mode runs.
4. **Retries are observed.** A restricted or blocked agent may retry. Retries raise x^{beh}_2, and calls to restricted tools are refused by the Mitigation Layer.

3.9 Offline Fitting and Recalibration

Offline fitting and recalibration are cross-cutting activities. They are performed between deployments on logged data, they are not a layer, and they never modify REM's parameters during an episode. Runtime adaptation from observed traffic is excluded because it would allow an adversary who generates traffic to shift REM's reference behavior.

The offline procedure fits and freezes:

- the benign reference quantities ($\bar{x}$ and the benign transition set);
- the coefficients by Equation 3.2, with λ selected by grouped cross-validation on held-out log-loss;
- the calibration parameters by Equation 3.4 on out-of-fold logits;
- the baseline thresholds by Equation 3.14;
- the measured residual rates $r_{mod}(k)$.

It also checks the declared loss structure for dominated verdicts (Section 3.7.5) and records all model, data, policy, benchmark, and software versions.

Between deployments, calibration can be monitored against later-established labels using the metrics of Section 3.12. If calibration drifts beyond a declared tolerance, the procedure is repeated on new data.

Procedure 3.1. Offline fitting (cross-cutting; never executed within an episode)

```
Input: logged observe-only traces grouped by injection task and user task;
labels y;
       declared policy (κ, L, Π, k_D2, privilege map, 𝒯_R, α_blk, α_mod)
1  for each outer fold f (Section 3.11.5):
2      D_train ← steps outside fold f;  D_test ← steps in fold f
2a     apply the Pilot E0 retention rule to D_train only; fix the feature
set for fold f
3      estimate x̄ and the benign transition set on benign steps of D_train
4      select λ by grouped inner cross-validation on D_train (held-out log-
loss)
5      obtain out-of-fold logits on D_train from inner folds; fit (γ1, γ0)
by Eq. 3.4
6      if γ1 ≤ 0 then record calibration failure for fold f
7      refit (β0, β) on all of D_train with the selected λ (Eq. 3.2)
8      select θ(α_blk), θ(α_mod) by Eq. 3.14 on out-of-fold calibrated
benign steps of D_train
9      apply Eqs. 3.1, 3.3 to D_test; store predictions for evaluation only
9a     estimate r_mod(k) from episodes outside fold f: enforcing-mode runs
(Section 3.11.7),
       or, where these are unavailable, oracle-Modify replays (Section
3.11.10)
10 (r_mod is estimated per fold in line 9a)
11 check the loss structure for dominated verdicts (Section 3.7.5)
12 freeze parameters and record all versions
```

3.10 Algorithm 1: REM Runtime Evaluation and Mitigation

Algorithm 1 gives the per-step runtime procedure. Every operation is defined in Sections 3.4–3.8.

```
Algorithm 1. REM Runtime Evaluation and Mitigation (as implemented; Section
3.15)


Frozen (offline, per fold):  β0, β, γ1 (> 0), γ0, x̄, benign transition set,
                             privilege map, instruction-pattern set, n_max
Declared policy:             κ, L (Table 3.11), Π, k_D2, required
evidence, 𝒯_R,
                             tie order Block ≥ Escalate ≥ Modify ≥ Allow,
                             mitigation semantics ∈ {step-level, episode-
level}
Input at step t:             objective g; tool results since the last step;
```

```
                              proposed call a_t = (tool, args); history H_t;
restrictions S
Output:                       verdict v_t; released or withheld call; audit
record r_t

 1  for each tool result returned since the last decision
point:           // Layer 1
 2      label it untrusted; strip invisible characters in REM's copy;
 3      extract identifiers and profile values from sensitive reads
 4  begin a decision point (calls proposed in one agent message share it)
 5  for each proposed call a_t in the message:
 6      x_t, avail ← features of Tables 3.6–3.7 from H_t, a_t,
g           // Layers 2–3
 7      k_t ←
κ(z_t)                                                    // Layer 4
 8      s_t ← β0 + β^T x_t;  p_t ← σ(γ1·s_t + γ0)       // computed for audit;
see lines 9–14
 9      if tool(a_t) ∈ Π then v_t ← Block; src ← "D1"; R ← not applicable
10      else if k_t ≥ k_D2 and required evidence ⊄ avail then
11          v_t ← Escalate; src ← "D2"; R ← not applicable
12      else                                     // unavailable features below
k_D2 are 0 and flagged
13          V_t ← {Allow, Escalate, Block} ∪ ({Modify} if tool(a_t) ∈ 𝒯_R)
14          R[v] ← (1 − p_t)·L(v,0,k_t) + p_t·L(v,1,k_t) for v ∈ V_t;  v_t ←
argmin, ties by order
15      // Layer 5
16      if episode-level and tool(a_t) ∈ S then refuse a_t
17      else if v_t = Allow then release a_t
18      else if v_t = Modify then withhold a_t; if episode-level, S ← S ∪
class(a_t)
19      else if v_t = Escalate then withhold a_t; release only on reviewer
approval
20      else (Block) withhold a_t; if episode-level, S ← S ∪ 𝒯_R
21      r_t ← (tool name, argument digest, x_t, avail, s_t, p̃_t, p_t, p-used
flag, k_t,
               R, v_t, src, mitigation, φ0, φ_t, |φ0 + Σφ − s_t|, versions,
REM time)
22      append r_t to the audit log; append a_t to H_t (released or not)
23  released calls execute; their results enter line 1 at the next decision
point
```

Line 8 computes the probability for every step so that the audit record is complete; when line 9 or line 10 applies, the record marks p_t as not used. Lines 16–20 implement both mitigation semantics of Table 3.12. Attribution (line 21) is computed after the verdict and cannot reach it.

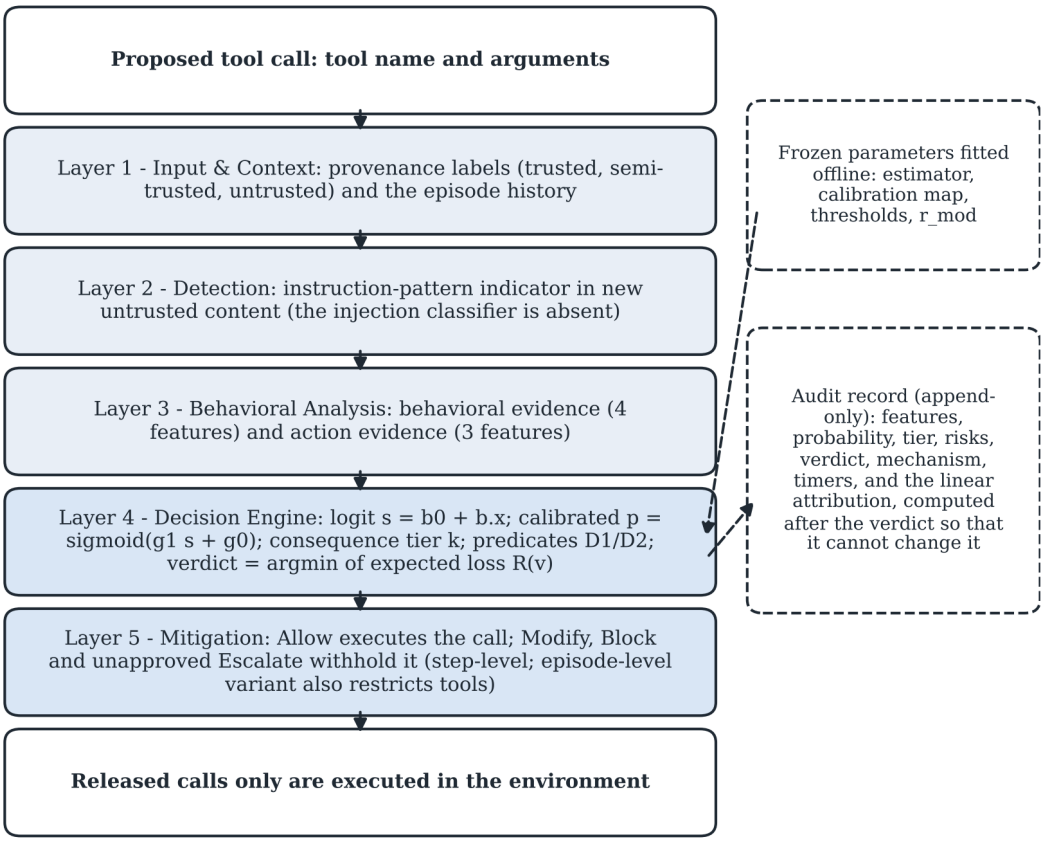


Figure 3.3. REM runtime workflow for one proposed tool call, as implemented in the evaluated path (`RemGuard.evaluate`): evidence, estimation and calibration, consequence tier, predicates, expected-loss verdict, mitigation before execution, and the audit record. Attribution is computed after the verdict and cannot change it.

3.11 Experimental Methodology

3.11.1 Environment and instrumentation

REM is evaluated in the banking environment of AgentDojo (Debenedetti et al., 2024), an open-source framework that evaluates both the utility and the security of LLM agents. Security is determined by checks on the environment state before and after an episode, and utility by task-specific checks.

REM is placed at the tool-execution boundary of the agent loop, where it intercepts each proposed tool call before execution and each tool result on return. That this is achievable without modifying the agent's internals is assumption AS-1, to be demonstrated in Section 3.15.

REM runs in two modes:

- **Observe-only:** verdicts are computed and logged but not enforced. Fitting data are collected in this mode, because enforced verdicts would alter the trajectories from which REM is fitted.
- **Enforcing:** verdicts are executed by the Mitigation Layer.

For every run, the following are recorded:

- the AgentDojo release or commit identifier;
- the suite version;
- the attack template;
- the LLM backbone identifier and version, access date, and decoding parameters;
- REM's model, calibration, and policy versions.

The LLM backbone or backbones and the attack templates are pending supervisor approval.

Execution status. Enforcing-mode runs with a live agent require access to an LLM, which was not available for this thesis. The observe-only analyses (Sections 3.11.5–3.11.9) use recorded traces of real agents distributed with the benchmark (Section 3.11.2). Enforcement is examined only through the replay sensitivity analysis of Section 3.11.10.

3.11.2 Dataset

The banking suite definition inspected for this chapter (suite v1, AgentDojo repository main branch, accessed September 2026) contains:

- **16 user tasks.** Examples include paying a bill described in a file, refunding a friend, updating a recurring rent payment, and updating account details. Their reference solutions use between one and five tool calls.
- **9 injection tasks.** Eight direct money or a recurring payment toward one shared attacker account identifier. One changes the account password. The reference attacker actions consist of one call for seven tasks, two calls for one task (reading scheduled transactions, then sending money), and three calls for one task (a total amount split into smaller transfers).

- **11 tools:** get_iban, send_money, schedule_transaction, update_scheduled_transaction, get_balance, get_most_recent_transactions, get_scheduled_transactions, read_file, get_user_info, update_password, and update_user_info.

These counts were re-confirmed against suite v1 in AgentDojo 0.1.35. The recorded traces used in the evaluation come from the AgentDojo repository at commit 089ed468; most carry no suite-version field, and some backbones were recorded under later suite versions (Chapter 4). The label-relevant definitions of the nine injection tasks are identical in every suite version from v1 to v1.2.2.

AgentDojo is an environment, not a fixed dataset of traces. Traces are generated by running an agent, so the number of traces depends on the number of backbones, attack templates, and repeated runs. The counts used in this thesis are reported, from the data, in Chapter 4. The 144 combinations of user task and injection task are not 144 independent samples. They are built from 16 user-task templates and 9 injection-task templates, and every trace inherits the dependence of its templates.

3.11.3 Label construction

The label must represent the quantity the estimator is asked to predict, which is whether a proposed call serves the attacker's objective rather than the user's. Labels are therefore derived from the injection task's own reference solution, not from the presence of an injection in the episode, because an attacked episode also contains benign calls. The derivation is mechanical, so the rules below state exactly what is matched, where the rule is known to be uncertain, and how that uncertainty is measured.

- **Step labels.** In an attacked episode, a proposed tool call is labeled $y_t = 1$ if it matches a call in the injection task's reference solution on tool name and on the attacker-controlled key argument, such as the attacker account identifier or the attacker-specified password. All other proposed calls, including calls that continue the user's task in attacked episodes, are labeled $y_t = 0$, as are all calls in episodes without injection.
- **Induced read steps.** Some injection tasks include a read call in their reference solution. Whether such a read step is labeled $y_t = 1$ is pending supervisor decision, because it is induced but has no direct external effect.
- **Label audit.** Matching on arguments can mislabel steps, for example when an agent alters an amount or reaches the attacker through a different tool. The derivation is therefore to be audited by a human annotator on a stratified sample of episodes, including ambiguous cases, and the disagreement rate reported.

- **What the label measures.** The reference-match label is a *practical proxy* for adversarial inducement. It records that the agent proposed the attacker's reference action with the attacker's key argument; it is not a causal proof that the injected content caused the proposal. A legitimate action that coincides with the attacker's reference action is mislabelled as induced, and an induced action that takes another route is mislabelled as legitimate. Both errors are measured, not assumed away.

3.11.4 Data limitations

The design must respect five limitations of the data:

1. **Positive-step scarcity.** A step is labeled $y_t = 1$ only if the agent actually proposes the attacker's call. The number of positive steps therefore depends on how often the chosen backbone follows injected instructions, and it may be small; the observed count is reported in Chapter 4. Most steps are benign, so the classes are strongly imbalanced.
2. **Shared attacker account identifier.** Eight of the nine injection tasks use the same attacker account identifier. Any feature keyed on that value would leak the label across folds (Section 3.6.2).
3. **Repeated task templates.** The same user tasks appear with every injection task, so benign behavior learned in one fold recurs in others.
4. **Short trajectories.** Reference solutions contain one to five calls, and most attacker objectives require one call. Trajectory-level evidence therefore has limited opportunity to accumulate.
5. **Calibration data.** A calibration set separate from training, validation, and test data would contain very few positive steps.

As a result, four statistically independent partitions for training, calibration, validation, and testing cannot be supported, and the design uses grouped cross-fitting instead.

3.11.5 Grouping and cross-fitting

Estimation, calibration, and threshold selection use nested grouped cross-fitting. No step is ever scored by a model fitted on data from its own group.

1. **Outer folds.**
    - *Attacked episodes* are grouped by injection task, giving nine leave-one-injection-task-out folds. The held-out fold therefore contains an attacker objective not seen during fitting.
    - *Episodes without injection* are assigned to the outer folds by user task, so that no user task's benign-only episodes appear in both the fitting and held-out portions of a fold.

2. **Inner folds.** Within the fitting portion of each outer fold, grouped inner cross-validation selects λ by held-out log-loss and produces out-of-fold logits. These are used to fit the calibration parameters (Equation 3.4) and to select the baseline thresholds (Equation 3.14).
3. **Held-out scoring.** The outer held-out fold is scored by the model fitted on the rest. All reported metrics are computed from these held-out predictions.

Independence of every fitted quantity from the held-out fold. For outer fold f, each of the following uses only the fitting portion D_train(f):

- the benign transition set and $\bar{x}$, re-estimated also within each inner fold;
- λ, selected by grouped inner cross-validation;
- (γ_1, γ_0), fitted on out-of-fold logits from the inner folds;
- the baseline thresholds $\theta(\alpha)$, selected on out-of-fold calibrated benign steps;
- $r_{mod}(k)$, estimated from episodes outside fold f;
- the feature set: the Pilot E0 rule (Section 3.11.8) is applied to each fold's fitting portion. If the folds disagreed, each fold would use its own set. In this thesis they agree (Chapter 4).

4. **Deployment model.** A model fitted on all data is used only for runtime demonstrations and latency measurement, never for reported accuracy or calibration.

Grouping by injection task does not remove the dependence introduced by shared user-task templates in attacked episodes. As a sensitivity analysis pending supervisor approval, the fitting is repeated with folds grouped by user task, and differences between the two groupings are reported.

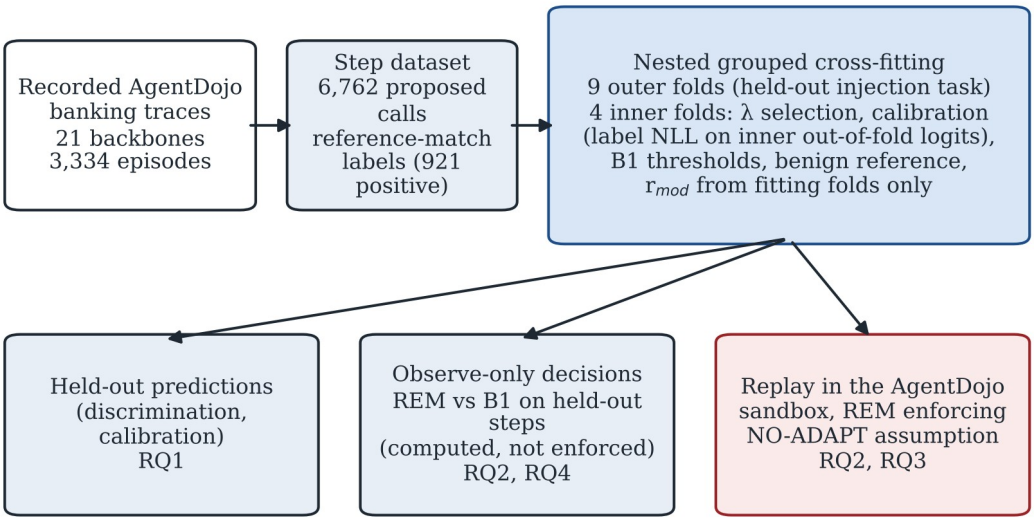


Figure 3.4. Recorded-trace evaluation design: nested grouped cross-fitting (nine outer folds by injection task, four inner folds), held-out predictions, observe-only decisions and the NO-ADAPT replay sensitivity analysis in the AgentDojo sandbox.

3.11.6 Leakage controls

Because the injection tasks in the banking suite share a small number of templates and a single attacker account, an estimator can reach a high score by memorizing the benchmark rather than by recognizing adversarial inducement. Arp et al. (2022) identify this family of errors as a recurring cause of overstated security-classification results. The following controls are therefore fixed before any held-out prediction is examined.

- No feature encodes a specific account identifier (Section 3.6.2).
- Benign reference quantities are estimated within each outer fold's fitting portion.
- The feature set, instruction-pattern set, privilege map, tier map, loss grid, false-positive targets, and pilot decision values are declared before held-out predictions are examined.
- Fitting data are collected in observe-only mode.
- Results are reported per benchmark and are not pooled across benchmarks.

3.11.7 Configurations, baselines, and ablations

Configurations:

- **B0, no defense.** Establishes attack success and utility without protection.

- **B1, consequence-independent baseline.** The same estimator and calibration with the threshold policy of Section 3.7.7. This is the primary comparator for RQ2.
- **REM.** The expected-loss verdict selection of Section 3.7.5.
- **REM without expected-loss Escalate.** As REM, with Escalate available only through D2, which gives REM the baseline's escalation opportunity (Section 3.7.7). This configuration was added after the first pilot results and is reported as a post-hoc comparison.
- **B2, detection-only (pending supervisor approval).** The Detection Layer's classifier score applied to untrusted content with an operating-point threshold. It tests whether Layers 3 and 4 add value.
- **Distributed defenses (pending supervisor approval).** Any defenses distributed with the pinned benchmark version, to address O3.

Ablations of REM (each changes one element, all else fixed; the estimator is refitted when an evidence group is removed):

1. Context evidence removed.
2. Behavioral evidence removed.
3. Action evidence removed.
4. Calibration removed ($\tilde{p}_t$ used in Equation 3.6).
5. Consequence tiers removed (one tier for all actions).
6. Predicates D1 and D2 disabled.
7. Observe-only (no mitigation).

Mitigation-effectiveness runs. Enforcing-mode runs in which Modify is applied to adversarial steps estimate $r_{mod}(k)$ per tier and the utility impact of Modify on benign steps. These estimates feed Equation 3.5 and are fitted within the outer folds so that no held-out episode informs its own loss values. In this thesis, live enforcing-mode runs were not available. $r_{mod}(k)$ was therefore estimated by replaying recorded attack episodes with Modify applied to every labelled attack step (Section 3.11.10). Under the no-adaptation assumption these estimates are close to zero by construction, and they are reported as such. The utility impact of Modify on benign steps was not estimated separately.

Escalation in experiments. No human reviewer is available in the benchmark. Escalation is resolved in two ways:

- by an idealized reviewer who releases the action if $y_t = 0$ and prevents it if $y_t = 1$;
- by a no-reviewer bound in which every escalation is treated as Block.

Both are reported, so the dependence of any result on the reviewer assumption is visible.

3.11.8 Pilot E0

Before the feature set is frozen, a pilot run on the fitting portions of the outer folds checks feasibility:

- the number of positive steps per backbone and attack template;
- the ROC-AUC of each evidence group alone and combined.

The pilot's decision values are project decisions declared before the pilot, not literature-derived thresholds [pending supervisor approval]:

- the minimum number of positive steps needed to proceed;
- the minimum group ROC-AUC needed to retain an evidence group.

If the positive-step count is insufficient, additional attack templates or backbones are added before the main experiments. The pilot never uses held-out fold predictions. Because every outer fold's held-out data belong to the fitting portions of the other folds, a single global decision taken from all folds' pilot results would use each fold's held-out data indirectly. The retention rule is therefore applied per fold, to that fold's fitting portion only.

3.11.9 Repeated runs and uncertainty

Each configuration is run at least three times with fixed decoding parameters to characterize LLM non-determinism [number of runs pending supervisor approval]. Repeated runs of the same template are not independent. Results are therefore aggregated per episode template before uncertainty is estimated.

Confidence intervals are obtained by bootstrap resampling (Efron, 1979) at the level of injection-task groups for attacked episodes and user-task groups for benign episodes. Resampling groups rather than steps is a design choice that respects the dependence described in Section 3.11.2.

With nine injection-task groups, intervals will be wide. No statistical power has been established, so differences are reported as measured differences with their intervals, and the word "significant" is not used unless a stated test supports it.

Optional sequential analysis. An optional, observe-only sequential analysis, a Bernoulli cumulative-sum procedure over logged indicators, is specified in Appendix C with

Equations 3.15 to 3.19. It is performed offline, is not part of REM's verdict path and never influences a verdict.

3.11.10 Recorded-trace replay sensitivity analysis *[proposed scope amendment, pending supervisor approval]*

Live enforcing-mode runs were not possible (Section 3.11.1). To obtain any evidence about enforcement, each recorded episode is re-executed in the benchmark's own sandbox with REM at the tool boundary:

- a replay element emits the agent's recorded messages in order;
- the benchmark executes the released calls;
- the benchmark's utility and security checks score the result.

Assumption NO-ADAPT. The agent emits the calls it emitted in the recorded run, whatever REM does. A live agent may retry, rephrase or choose another tool after a refusal. Replay results therefore do not estimate enforcement against live or adaptive agents, and they cannot distinguish step-level from episode-level semantics.

Validity checks. An all-Allow replay must reproduce the recorded utility and security outcome. Episodes for which it does not are excluded from every replay metric, and the exclusions are reported.

Not independent repetitions. Replaying the same recorded trace several times is deterministic. It is not an independent repetition of LLM behavior and does not substitute for the repeated runs of Section 3.11.9.

Relation to the excluded method. This analysis differs from counterfactual estimation of intervention value (Section 3.1.4): it executes no alternative actions and makes no claim about what an agent would have done instead.

3.11.11 Rule baselines and additional policy arms (added November 2026)

The examination of the pilot results raised a question that the configurations of Section 3.11.7 cannot answer: whether the estimator and the cost-based rule add anything over a rule that reads a single piece of evidence. Three rule baselines and three diagnostic arms were therefore added in November 2026. They were declared, with every other element of the study, in a protocol committed before any of their outcomes was computed. None of them changes REM.

Rule baselines. Each uses no fitted quantity and no cost. Each applies only to calls to tools in $\mathscr{T}_R$; calls to other tools are released. A withheld call is enforced as Block.

Table 3.13. Rule baselines

Arm	Rule for a call to a tool in $\mathscr{T}_R$	Evidence used
P1, provenance	withhold if and only if $x^{act}_1 = 1$	a key argument occurs in untrusted content and not in the user objective or trusted content
P2, provenance or novelty	withhold if and only if $x^{act}_1 = 1$ or $x^{act}_2 = 1$	P1, or the recipient appears neither in the objective nor among transactions seen before the first untrusted input
A2, strict explicit	withhold if and only if $z^{exp} = 0$	whether every identity argument of the call occurs in the user objective

The authorization evidence used by A2 is a declared, deterministic definition, not a published formula. For a call to a tool in $\mathscr{T}_R$, let K be the declared key arguments present in the call and let K_{ref} be K without the amount, or K itself if nothing else is present. Then $z^{exp} = 1$ if K_{ref} is non-empty and every value in it occurs in the user objective g, and 0 otherwise. A second indicator, z^{del}, is 1 if every value of K_{ref} that does not occur in g occurs in the output of an earlier read whose argument the user named. Occurrence is decided by the matching rule of the Input & Context Layer, unchanged. The definitions were motivated by the admissibility statement of Yan et al. (2026), that an action's operation and target must be licensed by trusted observations while values may come from external ones, and by the remark of F. Jia et al. (2025) that a user may delegate subtasks to a document. **Occurrence of a value in the user's text is not authenticated authorization**, and the evaluation tests exactly where the two diverge (Section 3.11.13).

Diagnostic arms. These isolate one element each and are not candidates for adoption, with one exception noted.

Table 3.14. Diagnostic and candidate arms

Arm	Change relative to REM v1.0	Purpose
REM, Allow and Block only	the feasible set is {Allow, Block}	whether Modify and Escalate change outcomes
A1, explicit or delegated	a rule: withhold if and only if $z^{exp} = 0$ and $z^{del} = 0$	whether delegation to a user-named document is safe
Outcome-supervised REM	the estimator is trained on whether withholding the call prevents attack success, in place of the attempt label	whether the training target matters
Intervention-value policy	two estimators predict the change in attack success and in task success when the call is withheld; the call is withheld if and only if $C_{miss}(k)\cdot\Delta\hat{S} \geq C_{FA}(k)\cdot\Delta\hat{U}$ and the left side is positive	the proposal of C. Zhang et al. (2026) applied to REM
Authorization-aware intervention-value policy (**pre-declared candidate; rejected**, Chapter 4, Section 4.6.6)	the previous arm with z^{exp} and z^{del} added to the features	whether authorization evidence and outcome supervision together improve on REM

The training targets of the last three arms were obtained by *prefix branching*: each recorded episode was replayed once with every call released and once with one call withheld and all others released, and the benchmark's attack and task outcomes of the two replays were compared. The intervention-value rule is **derived, not quoted**: C. Zhang et al. (2026) define the value of an intervention as the difference between the expected utility of intervening and of continuing and select the action with the highest expected utility; the rule above writes those two utilities in REM's declared costs for the two actions release and withhold. No equation is introduced for authorization, and none of these arms is part of REM.

3.11.12 Generalization schemes

Three schemes are used, in increasing difficulty.

- **S1, held-out attack objective.** The nine outer folds of Section 3.11.5. An attacked episode is scored by models that never saw its injection task. Its user task was seen, with other injection tasks.
- **S2, double holdout.** An attacked episode with user task u and injection task i is scored by models fitted without any episode of u and without any episode of i. A

benign episode of user task u is scored by the cell that also excludes the injection task to which S1 assigns u. Every fitted quantity is recomputed from the fitting portion of each cell: λ, the coefficients, the calibration map, the benign transition reference and r_{mod}. This gives 143 cells after the exclusion of AM-1.

- **S3, held-out attack templates.** S1 models applied without refitting to recordings of one backbone under five other attack templates.

No hyperparameter, threshold, feature or cost is selected on any test portion. S2 was added because S1 leaves a known dependence: the same sixteen user tasks appear on both sides of every fold (Section 3.11.4).

3.11.13 Robustness probes and paired call fixtures

Two probes test mechanisms that the benchmark's own attacks do not exercise. They are reported separately from benchmark results, and their counts are not rates.

- **Reformatted identifier.** Attacked episodes are replayed with the attacker's account identifier written in groups of four characters inside the injected text. The recorded agent calls are unchanged, so the identifier in the call no longer matches the text that carried it. Nothing is refitted. The probe measures dependence on exact string matching.
- **Paired call fixtures.** Twenty-three paired cases were written by hand, in three sets, each with a user objective, a document returned by a read, a legitimate call and an unsafe call on the same scaffold. They follow the counterfactual design of T. Yang et al. (2026), in which apparent risk and permissibility vary independently. The pairs cover recipient substitution, amount substitution, an unrequested payment during a read-only task, payments above the declared amount limit, credential changes, and reformatted or fragmented identifiers. Each set was written before it was scored, and each is scored once with the models of one fold. A pair is counted as correct when the legitimate call is released and the unsafe call is withheld.

The fixtures were written with knowledge of how REM's features are computed. They show which mechanisms fail; they do not estimate how often.

3.11.14 Confirmatory protocol for one modification

The analyses above reuse the recordings on which REM was fitted, cross-validated and examined many times. One modification suggested by them, the removal of the behavioral evidence group, was therefore tested once on recordings that no script of this project had read.

What was fixed in advance. A protocol was committed on 11 November 2026 before any of the new recordings was opened. It fixed:

- the candidate: the stored fits of the pilot's own "behavioral evidence removed" ablation (Section 3.11.7), with the same calibration procedure, costs, tiers, predicates and four-verdict rule;
- the comparators: the no-defense reference, B1, REM v1.0, P1, P2, A2 and the Allow-and-Block-only arm;
- the population: every banking recording in the benchmark repository, at the commit used throughout, of five pipelines that had never been loaded (one backbone not used before, with and without a prompt-level defense; one known backbone with a prompt-level defense; and two known backbones under attack templates never used for them);
- inclusion and exclusion, identical to the pilot (AM-1 and AM-4), with all counts reported;
- the fold used for each episode: for an attacked episode, the fold of its injection task, whose models never saw that injection task;
- the endpoints, the statistics and the verdict rule below.

Nothing is fitted, tuned or selected on the new recordings.

Endpoints. E1 is the paired difference in user-task success, candidate minus REM v1.0, over all eligible episodes, with a bootstrap clustered by user task. E2 is the paired difference in attack success rate and in the rate of episodes with a released attack-labelled call (Section 3.12.4) over attacked episodes, clustered by injection task. Intervals are 95% percentile intervals from 2,000 resamples.

Verdict rule.

- **GO** if the E1 interval lies entirely above zero, neither E2 interval lies entirely above zero, and the candidate's number of successful attacks does not exceed that of rule P2 on the same episodes.
- **NO-GO** if either E2 interval lies entirely above zero or the E1 point estimate is not positive.
- **INCONCLUSIVE** otherwise.

The third GO condition replaces a numerical security margin. No approved margin exists, and none was invented: a learned policy that is less secure than a one-line rule on the same episodes has no claim to adoption.

What the population is. The agents, attack templates and trajectories are new. The sixteen user tasks and nine attack objectives are the benchmark's own and are not new. A GO verdict therefore supports the modification on recordings of this benchmark that were unread at the time of the run, in replay. It is the outcome of a decision rule and not a statistical test of non-inferiority on security. It is not evidence about live agents, reviewers or other domains, and adoption remains a supervisor decision. Once the run has been made, the recordings are development evidence for any later analysis.

3.12 Evaluation Metrics

3.12.1 Primary metrics

Primary metrics do not depend on declared costs.

Table 3.15. Primary metrics

Metric	Definition	Unit
Attack success rate (ASR)	Fraction of attacked episodes in which the benchmark's security check reports that the injection goal was achieved (enforcing mode)	Episode
Benign utility	Fraction of episodes without injection in which the benchmark's utility check passes	Episode
Utility under attack	Fraction of attacked episodes in which the utility check passes	Episode
Intervention rates	Fraction of steps receiving Modify, Escalate, or Block, reported per verdict and separately for $y = 0$ and $y = 1$ steps	Step
Step false-positive rate	Interventions on $y = 0$ steps divided by the number of $y = 0$ steps	Step
Residual ASR under Modify	ASR in episodes where Modify was applied to an adversarial step	Episode
Escalation rate	Fraction of steps receiving Escalate, with outcomes under the idealized reviewer and the no-reviewer bound	Step
Latency	Wall-clock time of REM's per-step processing, excluding LLM inference and tool execution; median and 95th percentile	Step

ASR is never reported without benign utility and utility under attack. A low ASR can reflect an agent that fails to complete tasks rather than an effective defense (Y. Wang et al., 2026).

3.12.2 Secondary metrics

Discrimination. ROC-AUC (Fawcett, 2006) and PR-AUC (Davis & Goadrich, 2006) are computed on held-out probabilities. PR-AUC is emphasized because positive steps are rare. Within a fold, both are unchanged by calibration with $\gamma_1 > 0$. Because each outer fold has its own calibration map, metrics are reported per fold as well as on the pooled held-out predictions.

Calibration error. For binary outcomes, calibration error is measured on the positive-class probability (Naeini et al., 2015) with M equal-width bins (Guo et al., 2017):

$$ECE = \sum_{m=1}^{M} \frac{|B_m|}{N} \left| \bar{y}(B_m) - \bar{p}(B_m) \right|, B_m = \{ i : (m-1)/M < p_i \leq m/M \} \quad (3.20)$$

where N is the number of held-out steps, $\bar{y}(B_m)$ is the fraction of positive steps in bin m, $\bar{p}(B_m)$ is the mean calibrated probability in bin m, and M is declared in advance (steps with $p_i = 0$ are assigned to the first bin).

Status: adapted from source. Naeini et al. (2015) supply the binary form; Guo et al. (2017) supply the equal-width binning.

Because a global ECE averages over all probabilities, reliability is also reported within declared windows around each tier's threshold p^*_k.

Log-loss. The mean negative log-likelihood of held-out steps is:

$$LL = -\frac{1}{N} \sum_{i=1}^{N} \left[y_i \ln p_i + (1 - y_i) \ln (1 - p_i) \right] \quad (3.21)$$

Status: derived as the negated, averaged, unpenalized log-likelihood term of Equation 3.2 evaluated at the calibrated probabilities. Probabilities are bounded away from 0 and 1 by a declared small constant for numerical evaluation.

Brier score. The Brier score is not reported until the convention of its original source (Brier, 1950) has been confirmed; log-loss serves as the proper scoring measure in the meantime.

3.12.3 Realized loss across a declared grid

Realized loss is secondary because it depends on declared costs, and because a rule that minimizes expected loss under L is favored by construction when evaluated under the same L. For an evaluation loss structure L_e:

$$\acute{L}(L_e) = \frac{1}{N} \sum_{i=1}^{N} L_e(v_i, y_i, k_i) \quad (3.22)$$

where v_i is the verdict issued for held-out step i under the decision loss structure L_d, y_i is its label, and k_i is its tier.

Status: design definition.

The grid is declared before held-out predictions are examined and varies three things:

- the ratio $C_{miss}(k)/C_{FA}(k)$ per tier;
- C_{esc};
- the amount limits of the tier map.

For each evaluation structure L_e, the grid reports:

- REM with $L_d = L_e$ (matched);
- REM with $L_d \neq L_e$ (misspecified costs);
- the baseline B1, which does not use costs.

The conclusion takes the form “across this declared range of loss structures, outcomes vary as follows”, not “under the chosen costs, outcomes are these”.

3.12.4 Outcome layers and additional metrics

A single attack-success figure merges events that occur at different points between an injection and a harm. The analyses added in November 2026 report these layers separately and never combine them into one score.

Table 3.16. Outcome layers and the quantity reported for each

Layer	Quantity
Injection exposure	attacked or benign episode
Attacker-induced proposal	calls with the attempt label y = 1
Runtime verdict	Allow, Modify, Escalate or Block for each call
Actual execution	call released or withheld
Released attack-labelled call	**rate of episodes with a released attack-labelled call**: the share of attacked episodes in which at least one call with y = 1 was released. It does not depend on the benchmark's success checker. It is a proxy: the label marks an attempt, and the effect of the released call on the bank state is not measured separately, so the quantity is not called a committed unauthorized state
Attack success	the benchmark's security check (ASR, Table 3.15)
Legitimate-task completion	the benchmark's utility check, in benign episodes and under attack
Legitimate-action approval	**authorized-call release**: the share released among calls to tools in $\mathscr{T}_R$ proposed in benign episodes

Two further quantities describe burden: the number of Escalate verdicts and of episodes that contain one, and the number of episodes in which any call is withheld. No effectiveness of a reviewer is assumed in any of them.

The benchmark's success check is not treated as a general definition of financial harm; the rate of episodes with a released attack-labelled call is reported beside it. A policy that withholds every sensitive operation cannot appear successful under this reporting, because its legitimate-task completion and authorized-call release are shown in the same table as its attack success.

3.13 Versioned Amendment: REM v1.1 (Proposed)

Status: proposed; supervisor approval required (decision SD-FEAT). The specification of Sections 3.2 to 3.10 is unchanged and is referred to as REM v1.0.

Definition. REM v1.1 is REM v1.0 with the behavioral evidence group removed from the evidence vector: $x_t = [x^{ctx}; x^{act}]$, without x^{beh}_1 to x^{beh}_4. Nothing else changes. The estimator is the ridge logistic regression of Equations 3.1 and 3.2, refitted on the reduced vector by Procedure 3.1; the calibration is that of Equations 3.3 and 3.4; the consequence tiers, the predicates, the loss structure of Table 3.11, the verdict rule of Equations 3.6 and 3.7, the mitigation semantics and the audit record are those of v1.0. The architecture keeps its five

layers. The Behavioral Analysis Layer continues to maintain the episode history, from which the action evidence x^{act} is computed; it no longer contributes the four history features to the estimator.

Why it is an amendment and not a new method. Removing an evidence group is one of the ablations declared for the pilot (Section 3.11.7, item 2). REM v1.1 is that ablation's fit, promoted from a diagnostic to a proposed configuration. No equation, cost, threshold or rule is added.

Evidence. In the pilot the ablation left replay attack success unchanged and raised benign utility. The observation was made after results were seen. It was then tested once under the confirmatory protocol of Section 3.11.14 and met the pre-declared GO rule (Chapter 4, Section 4.6.8).

What the amendment does not do. It does not make REM better than the rule baselines, it does not address reformatted identifiers, and it does not supply authorization evidence. These limits are reported with the results.

Reporting rule. Until the supervisor decides, the design of this thesis is REM v1.0. Every table that reports v1.1 also reports v1.0.

3.14 Exploratory Extension: Task-Permission Evidence (Proposed, Not Adopted)

Status. This section describes an extension that was investigated on 13 November 2026 in separate code (`experiments/improve_study/`). It is not part of REM v1.0 or of the proposed REM v1.1, it changes no file of the framework, and its adoption would need a supervisor decision (Appendix F). Its results are development evidence (Chapter 4, Sections 4.4.3, 4.5.3 and 4.6.9). Every rule below is a design choice of this study; none is a published formula, and no new equation is introduced.

Motivation. The evidence of REM describes where the arguments of a call come from. It does not describe what the user asked for. The earlier studies showed the consequence: a rule or a model that sees only provenance cannot tell a requested payment from an unrequested one that reuses the user's words, and cannot check an amount (Chapter 4, Section 4.6.7). The extension adds a representation of the request.

A. Request compiler. A deterministic parser reads the text of the user's request and nothing else. It produces an immutable record of:

- the operation categories that are requested, prohibited or absent (value transfer, payment modification, credential change, profile change), and whether a request is conditional;
- account identifiers, each with a role: target of a requested operation, part of a past event, or merely mentioned;
- amounts as exact decimal numbers, each with a role (value to be paid, input of a requested computation, part of a past event); a number whose format is ambiguous, such as "1,250", is marked ambiguous and never matched;
- whether the amount is to be derived, taken from the history, or taken from a source that the user names;
- sources named by the user, such as file names;
- for quoted credential values, their SHA-256 digest only; the raw value is not kept or logged.

The compiler has no access to task identifiers, reference solutions, labels or outcomes; tests enforce this (Chapter 4, Section 4.1.3).

B. Typed matching. A proposed call to a state-changing tool is compared with the record on its operation and its material arguments. Identifiers are compared in a canonical form that ignores spacing and hyphens only; amounts are compared exactly; no approximate matching is used. The result is one of three statuses.

Table 3.17. Permission status of a proposed state-changing call

Status	Meaning
Supported	The operation is requested, and the recipient and the amount (or the value) are each supported by the request
Denied	The operation is prohibited or not requested, or a material argument contradicts the request (another recipient than the one named, another amount than the one stated, another credential than the one quoted)
Unknown	The operation is requested, and a material argument can be neither confirmed nor contradicted

A recipient is supported if the request names it as the target, refers to it, or if it is an *established payee referred to by the request*: the recipient field of a structured bank record that the user originated. Free-text fields of bank records and the senders of incoming transactions establish nothing, because an attacker can write them. A source named by the

user may supply an amount or a profile value. It may never supply an operation, a recipient or a credential; this is the difference from the delegated-document rule A1, which was rejected (Chapter 4, Section 4.6.6). An amount that cannot be verified, because it is derived or delegated, is accepted only up to the declared amount limit of the tier map.

C. Decision consistent with deployment without a reviewer. Without a reviewer, Modify and Escalate withhold the call exactly as Block does (Chapter 4, Section 4.4.1), while the cost assigned to Escalate assumes that a reviewer resolves it. The variant applies the unchanged expected-loss rule of Equations 3.6 and 3.7, with the unchanged costs, to the two verdicts whose effects differ, Allow and Block. This is the Allow–Block threshold of Equation 3.9. The five-layer architecture is unchanged: the compiler belongs to the Input & Context Layer, and the permission status enters the Decision Engine as evidence or as a policy predicate.

D. Selective semantic verifier (interface only). For calls of unknown status, a language model could be asked whether the request supports the call. The interface was written with three restrictions: it is consulted only for unknown status, never on the basis of the probability alone; its answer can release a call only if it quotes spans of the request verbatim, and never for a call whose operation is not requested or whose recipient or credential is unsupported; and without a model it releases nothing. **It was not executed**, because no model was available.

Table 3.18. Arms of the extension study

Arm	Definition
G1 (the candidate)	Release a state-changing call if and only if its status is supported. No model
G1 without one component	The operation check, the amount check, established payees, scoped delegation or typed normalization removed in turn
V11d	REM v1.1 with decision C; no permission evidence
L0	Ridge logistic model on the evidence of REM v1.1 plus five permission indicators, decision C, no guard
L1	Guard (denied calls are blocked), then the same model with the four-verdict rule
L2	Guard, then the same model with decision C
L2s	Guard; supported calls are allowed; the model decides calls of unknown status with decision C

The learned arms are fitted by Procedure 3.1 without change. The protocol, the arms, the comparisons and the wording of the conclusions were committed before any outcome of these arms was computed; the candidate was fixed as G1 with all components.

Relation to prior work. The extension combines published ideas and claims no new mechanism. Judging an action against the user's instructions is the principle of Task Shield (F. Jia et al., 2025), which uses a language model where this study uses a parser. Deterministic, argument-level policies checked before each call are the principle of Progent (T. Shi et al., 2025), whose manual banking policy is used as a comparator, and of the benchmark policy of aiAuthZ (repository documentation). Keeping untrusted data from granting operations is the principle of CaMeL (Debenedetti et al., 2025); the extension has no interpreter and no capability tracking and is not an implementation of CaMeL.

Limits known before evaluation. The parser was written with the sixteen requests of the benchmark in view. Trust in established payees assumes that an attacker cannot create a bank record that the user appears to have originated. The amount limit is a configuration value, not a bank's risk tolerance.

3.15 System Implementation

This section summarizes how the specification is realized in software and how the software was verified. The details are in Appendix B: the environment, the code organization, the implementation of each layer, the test suite, the correspondence between requirements, equations, functions, tests and result files, and the measurement of processing time.

Implementation rules. Three rules governed the implementation.

1. **Fail closed.** A design value that has not been declared stops the software with an explicit error; no default is substituted.
2. **No silent resolution.** Where the specification and an earlier design decision disagree, both alternatives are implemented and one is selected explicitly in configuration.
3. **Separation of decision and audit.** Attribution is computed after the verdict and cannot reach the decision function. This is enforced by the function's signature and checked by a test.

Software. REM is implemented in Python with NumPy. No machine-learning framework is used: the estimator, the calibrators and every metric are written directly, so that each

operation can be traced to its equation. The reported runs used Python 3.11.17, NumPy 2.4.6 and AgentDojo 0.1.35.

Placement. REM is inserted at the benchmark's tool-execution boundary as a replacement for the tool executor. Each proposed call is evaluated before it is executed. A released call runs; a withheld call does not, and the agent receives a tool-result message carrying the refusal. The agent's model, prompts and tools are not modified. The placement has limits: only calls that pass through the executor are mediated, and a refusal is visible to the agent.

Two execution paths. A frozen pipeline chains the five layers and is exercised by unit and contract tests. The evaluation path, used for every result in Chapter 4, calls the same fitted components and adds the features, tiers, predicates, feasible set and mitigation semantics of this chapter.

What is implemented and what is absent. All elements of Sections 3.4 to 3.10 are implemented, with one exception: the pre-trained injection classifier x^{ctx}_1 is not implemented, because its choice is pending and the candidate model could not be obtained. It is absent from the evidence vector and is not replaced by a substitute. The context evidence evaluated in this thesis is therefore the instruction-pattern indicator x^{ctx}_2 alone. A known deviation in entity matching, the truncation of numbers written with a comma as thousands separator, is recorded by a test that is expected to fail; it affects none of the 825 texts of the primary recordings.

The additions of November 2026 are isolated. The rule baselines, the diagnostic arms, the generalization schemes, the probes and the confirmatory run (Sections 3.11.11 to 3.11.14) are implemented in a separate study module that imports the estimator, calibrator, loss structure, predicates, tier map and replay element unchanged. No file of the REM implementation or of its configuration was modified. The study's fitting routine reproduces the frozen fits of the pilot to within $4 \cdot 10^{-14}$, and its replays of REM v1.0, B1 and the no-defense reference reproduce the pilot's counts exactly.

Verification.

- **Unit and contract tests.** 278 tests pass, 1 is skipped because it needs state that is not present by default, and 1 is the expected failure noted above (13 November 2026, with the tests of the extension study included; on 11 November the figures were 241, 3 and 1).

- **Replay fidelity.** With every call allowed, the replay reproduced the recorded utility and security outcome of 3,313 of the 3,334 primary episodes (Chapter 4, Section 4.6.3) and of 2,113 of the 2,148 loaded episodes of the second population (Chapter 4, Section 4.2.1). Episodes that are not reproduced are excluded from every replay metric and counted.
- **Re-execution.** The complete pilot was re-executed in a fresh environment and reproduced every analytical value; only timing values, commit stamps and one file path differed.
- **Gateway parity.** A local deployment simulation, in which REM runs as a separate gateway service in front of a simulated bank back end, returned the same verdicts as the offline replay.

None of these establishes security effectiveness. They establish that the software computes what the equations state and operates inside the benchmark's execution loop.

Live-agent and published-defense integrations. A closed-loop integration, in which a running agent receives REM's refusals, and an integration that places REM behind the MELON defense are both implemented and tested with scripted agents and simulated model providers. Neither has been executed with a language model. Their design and status are in Appendix D, and Chapter 4, Section 4.4.4, states what follows from that.

Processing time. Processing time is measured around the complete evaluation of a call, including attribution and the construction of the audit record, and excluding model inference and tool execution (Appendix B). The figures are reported in Chapter 4.

3.16 Threats to Validity

Construct validity.

- Step labels are derived and can be wrong; the derivation is audited on a sample (Section 3.11.3).
- The idealized reviewer overstates the protective value of Escalate; the no-reviewer bound is reported alongside it.
- Declared costs cannot be validated empirically; their influence is reported across the grid.
- A low ASR can reflect task failure rather than protection, so utility metrics accompany every security metric (Y. Wang et al., 2026).

Internal validity.

- Leakage through shared templates and the shared attacker account identifier is controlled by grouping and by excluding identity-based features, but template dependence remains.
- Features designed with knowledge of the benchmark may fit its style; the feature set is frozen after the pilot and before held-out predictions are examined.
- LLM non-determinism is characterized by repeated runs; the recorded traces contain one run per configuration, so this requirement is not met in this thesis.

External validity.

- The evaluation uses one simulated banking environment with benchmark-authored attacks.
- Results may not transfer to other benchmarks, whose definitions and conclusions can disagree (M. Q. Li et al., 2026), or to production systems.
- Results may depend on the LLM backbone.
- FinVault is not used because its preprint was withdrawn.

Statistical conclusion validity.

- The number of independent task templates is small.
- Intervals are wide and no power analysis is available, so conclusions are limited to differences supported by their intervals.

Security-specific threats.

- Every evidence feature can be evaded individually, and adversaries are assumed non-adaptive (AS-6).
- REM's own configuration and logs are assumed protected (AS-3).
- A scalar probability cannot represent whether an adversarial trajectory remains recoverable, so REM inherits the limitation identified by C. Zhang et al. (2026); estimating intervention value for adaptive agents by counterfactual replay is outside the scope of this thesis.

Threats added by the analyses of November 2026.

- The rule baselines, the authorization evidence and the fixtures were defined by an author who knew the benchmark's sixteen user tasks and nine injection tasks. The definitions are stated generically, but they were written with that knowledge.
- The primary recordings were reused many times. Every analysis added after the pilot's results were seen is labelled post hoc, and only the confirmatory run of Section 3.11.14 is free of that reuse.
- The confirmatory population shares the benchmark's user tasks and attack objectives with the fitting data. It tests new agents and templates, not new tasks.

- Under replay without a reviewer, Modify, Escalate and Block have the same effect on a call. No result in this thesis can distinguish them.

3.17 Chapter Summary

Design. This chapter specified REM as one runtime pipeline in five layers. The Input & Context Layer captures the proposed action and labels context by provenance. The Detection Layer computes context evidence. The Behavioral Analysis Layer maintains the episode history and computes history and action-provenance evidence. The Decision Engine estimates a calibrated probability of adversarial inducement by ridge logistic regression with a logistic calibration on the logit, assigns a declared consequence tier, applies policy predicates, selects a verdict by minimizing conditional risk under tier-indexed losses, and writes an audit record whose linear attribution never influences the verdict. The Mitigation Layer executes Allow, tool restriction, escalation or Block. Offline fitting and recalibration are cross-cutting activities, not a layer. Every equation is stated with its source and with whether it is established, adapted or derived.

Evaluation method. The evaluation uses the AgentDojo banking environment with nested grouped cross-fitting that holds out one attack objective per fold. It compares REM with a no-defense reference, a consequence-independent baseline on the same estimator, and three rule baselines that use no model. A double-holdout scheme, two robustness probes and paired call fixtures test generalization and specific mechanisms. One modification is tested by a confirmatory protocol committed before its data were opened. Outcomes are reported in separate layers, with legitimate-task completion and authorized-call release beside every security figure.

Amendment. REM v1.1, the same framework without the behavioral evidence group, is proposed as a versioned amendment and awaits approval. REM v1.0 remains the frozen baseline.

Implementation. The specification is implemented with one declared absence, the injection classifier, and is verified by 278 tests, by replay fidelity checks and by exact re-execution. No live-agent experiment was executed. Security effectiveness, within the limits of recorded-trace replay, is the subject of Chapter 4.

CHAPTER FOUR: EXPERIMENTAL RESULTS AND DISCUSSION

This chapter reports the implementation environment, the data and the fitting of the estimator, the experimental setup, the comparisons with baselines and with one published policy, the ablations, and the results with their discussion. **No experiment with a live agent or a language model was executed, and no result in this chapter is a live result.** Every result comes from recorded trajectories of real agents in the AgentDojo banking environment, replayed with a policy that may withhold calls. The design values (costs, tiers, predicates, feature set, label rule) are declared values that await the supervisor's approval, so all results are exploratory by label.

The chapter has six sections. Section 4.1 describes the tools and the environment. Section 4.2 describes the data, their preparation and the training of the estimator. Section 4.3 defines the compared arms, the populations and the metrics. Section 4.4 compares REM with baselines, simple rules and a published policy. Section 4.5 reports the ablations. Section 4.6 reports the remaining results, interprets them and states the threats to validity.

4.1 Implementation Tools and Environment

4.1.1 Software, Hardware and Benchmark Environment

Table 4.1. Software and hardware used for the reported results

Item	Value
Language	Python 3.11.17
Numerical library	NumPy 2.4.6. Ridge logistic regression, the logit calibration map, the grouped cross-fitting and the grouped bootstrap are implemented in the project's own code on top of it (Appendix B)
Benchmark	AgentDojo 0.1.35 (Debenedetti et al., 2024), banking suite v1: eleven tools, sixteen user tasks, nine injection tasks
Recorded data	The benchmark authors' recorded runs at one fixed commit of their repository (`089ed468`)
Configuration	`configs/exploratory/pilot_e0.yaml`, identified in every result file by its SHA-256 digest
Other packages	PyYAML 6.0.1 (configuration and structured tool outputs); pytest 9.2.0 (tests)
Operating system	Ubuntu 24.04 in a cloud container
Hardware	4 virtual CPUs (Intel Xeon, 2.10 GHz), 15 GB of memory, no GPU
Language models	None. No model was called for any result; the cost of model calls is zero
Random seed	20261027 for every bootstrap; the fitting procedure is deterministic

The hardware is that of the container in which all results were last re-executed (13 November 2026). Earlier runs used containers of the same kind whose hardware was not recorded. Apart from the decision times, no result depends on the hardware: the re-executions reproduce the stored counts exactly (Section 4.1.3).

REM needs no accelerator. The estimator has nine parameters, and a decision is one dot product, one logistic map, a table lookup and a comparison of four numbers. Fitting all 152 cross-fitting cells of the last study took 6 seconds, and 161,506 episode replays took 338 seconds with four worker processes.

4.1.2 Implemented Components

Table 4.2. Components, their location in the repository and their status

Component	Location	Status
REM framework: five layers, estimator, calibration, tiers, predicates, expected-loss rule, mitigation, audit record	`rem/`	Implemented and tested (Chapter 3, Section 3.15; Appendix B)
Pilot pipeline: data loading, labels, cross-fitting, observe-only analyses, replay	`experiments/pilot/`	Executed
Rule baselines, diagnostic arms, double holdout, probes, fixtures, confirmatory run	`experiments/authz_study/`	Executed
Exploratory extension: request compiler, typed matcher, decision variants, published-policy comparator	`experiments/improve_study/`	Executed in replay (Chapter 3, Section 3.14)
Selective semantic verifier	`experiments/improve_study/verifier.py`	Interface and tests only; never called with a model
Closed-loop harness for live agents; MELON integration	Appendix D	Implemented and tested with scripted agents; not executed with a model

Experimental code is kept apart from the framework. No file under `rem/` or `configs/` was changed by any study of November 2026; each study imports the framework and adds its own modules.

4.1.3 Reproducibility and Software Verification

Each results file records the commit of the framework, the digest of the configuration and of the amendments, the benchmark version and the commit of the recorded runs. Three checks support the numbers of this chapter.

- **Re-execution.** The pilot was executed, re-executed after code corrections and re-executed again with timing instrumentation; the analytical values were identical each time (Section 4.2.1).
- **Equivalence of earlier arms in later studies.** Each later study recomputes the earlier arms before adding its own. In the study of 13 November the seven earlier

arms reproduce the stored counts on both populations, and the refitted estimator of REM v1.1 equals the stored one (largest absolute difference of any parameter: 0).

- **Tests.** On 13 November 2026 the suite of 280 tests gave 278 passed, 1 skipped and 1 expected failure. It covers the frozen equations, the mitigation semantics, replay, leakage controls and, for the extension, the isolation of the defense interface from task identifiers, labels and outcomes.

The commands that regenerate every table are listed in Appendix B and in the study folders of the repository.

4.1.4 Kinds of Evidence and Evaluation Modes

One analysis, the confirmatory run of Section 4.6.8, was carried out under a protocol and a pass rule committed before its data were opened. It is confirmatory in that procedural sense only: it shares the unapproved design values and the limits of replay with everything else. After that run its recordings are no longer unread, and every later analysis of them is development evidence.

Eight kinds of evidence are kept apart. Each table states which kind it reports.

Table 4.3. Kinds of evidence in this chapter

Kind	What it is	What it cannot show	Sections
Recorded outcome	The benchmark's verdicts on traces as recorded by its authors, without REM	Anything about REM	Sections 4.2.1 and 4.4.2
Offline prediction	REM's probability for a recorded call, from a model fitted without that call's group	Any effect of enforcement	Sections 4.2.3 and 4.6.1
Observe-only decision	The verdict REM would issue for a recorded call; not enforced	Outcomes	Sections 4.6.2 and 4.5.1–4.6.5
Replay	A recorded episode re-executed in the benchmark's sandbox with a policy that may withhold calls; later calls are the recorded ones (NO-ADAPT)	Agent adaptation; reviewer effect; any difference among Modify, Escalate and Block	Sections 4.6.3, 4.4.1, 4.6.6 and 4.6.7
Post-hoc analysis	An analysis added after results were seen; labelled where it occurs	Confirmation	Section 4.2.2; parts of Sections 4.4.1 and 4.6.6

Kind	What it is	What it cannot show	Sections
Confirmatory replay	Replay on recordings that had not been read before that run (11 November 2026), under a protocol committed in advance	The same limits as replay	Section 4.6.8
Development replay of the extension	Replay of new arms on recordings that had all been inspected; protocol committed before the new arms were scored	Confirmation; behaviour on requests the author had not seen	Sections 4.4.3, 4.5.3 and 4.6.9
Call-level fixture	Hand-written paired calls scored by the frozen models	Prevalence; any benchmark outcome	Sections 4.6.7 and 4.6.9

Integration checks with scripted agents and simulated providers are not results and are reported only as status (Section 4.4.4).

Sources of the numbers. The pilot's results come from `results/pilot_R2/` and its re-execution `results/pilot_R4/` (Chapter 3, Section 3.15). The study of 11 November 2026 on the same recordings (Sections 4.4.1, 4.6.6 and 4.6.7) is in `REM_Authorization_Generalization_Study/results/`. The confirmatory run of the same date (Section 4.6.8) is in `REM_FINAL_SUBMISSION/results/`. The extension study of 13 November 2026 (Sections 4.4.3, 4.5.3 and 4.6.9) is in `REM_IMPROVEMENT_STUDY/results/`. Every run used AgentDojo 0.1.35, the benchmark's recordings at one fixed commit, seed 20261027 and step-level mitigation without a reviewer unless a table says otherwise.

4.2 Dataset Preparation and Training

This section describes the recorded data and how they were prepared (exclusions, labels, eligibility for replay), the fitting protocol, the second population, the validity of the labels, and the training of the estimator. Nothing was collected for this thesis: the trajectories were recorded by the benchmark's authors with real agents.

4.2.1 Recorded Data, Fitting Protocol and Chronology

Data

Source. The AgentDojo repository (Debenedetti et al., 2024) distributes traces of real LLM agents recorded by the benchmark authors. The evaluation uses the banking traces of **21 undefended backbones** under the `important_instructions` attack.

Exclusions. Episodes recorded with an error (5) and the pair (user_task_15, injection_task_4) (21 episodes, amendment AM-1) are excluded.

Size (`dataset_summary.json`):

Unit	Count
Episodes	**3,334** (2,998 attacked, 336 without injection)
Proposed tool calls (steps)	**6,762**
Positive steps (y = 1)	**921**
Negative steps (y = 0)	5,841

Labels. Labels follow the reference-match rule of Chapter 3, Section 3.11.3. A positive label marks an *attempt*: the agent proposed the attacker's reference action with the attacker's key argument. It is a proxy for adversarial inducement, not proof of it. Of the 840 attacked episodes with a positive step, the recorded outcome shows attack success in 682 and not in 158. Two attacked episodes record attack success without a positive step.

Independence. The episodes are not independent observations:

- they are built from 16 user-task and 9 injection-task templates;
- one attacker account;
- one environment.

All intervals are 95% percentile intervals from a bootstrap that resamples attacked items by injection task and benign items by user task. With nine injection-task groups the intervals are wide. Bootstrap coverage is an asymptotic property, and with so few groups the intervals are not guaranteed to reach their nominal 95% coverage; a narrow interval, such as that of REM's replay ASR, is not evidence of precision. The intervals are therefore descriptive, and no hypothesis test is based on them. Where a category contains a single injection task, no interval can be formed and none is reported.

Protocol

The protocol is nested grouped cross-fitting (Chapter 3, Procedure 3.1):

- nine outer folds, each holding out one injection task;
- episodes without injection assigned to folds by user task.

Within each fold's fitting portion, the following are fitted (Chapter 3, Section 3.11.5):

- λ, by grouped inner cross-validation;
- the calibration map, on inner out-of-fold logits;
- the baseline thresholds;
- the benign reference quantities;
- r_{mod}.

The **pre-registered values** are listed in Table 4.4. They come from Chapter 3 where Chapter 3 gives them; otherwise they are declared exploratory values.

Table 4.4. Pre-registered values (`configs/exploratory/pilot_e0.yaml`)

Item	Value
Features	$x^{\wedge}ctx_2$, $x^{\wedge}beh_{1-4}$, $x^{\wedge}act_{1-3}$ ($x^{\wedge}ctx_1$ absent)
Tiers	read 1; profile 2; transfer ≤ 1000: 3; transfer > 1000, payment modification, credential change: 4
Costs	$C_{FA} = 1$; $C_{miss} = 1, 5, 10, 20$ by tier; $C_{mod} = 0.5$; $C_{esc} = 0.3$
$r_{mod}(k)$	Measured; 1.0 where unmeasured
Predicates	$\Pi = \varnothing$; $k_{D2} = 3$; required evidence $x^{\wedge}act_1$
Baseline	$\alpha_{blk} = 0.01$, $\alpha_{mod} = 0.05$
λ grid	$\lambda_{impl} \in \{0.01, 0.1, 1, 10, 100\}$, i.e. $\lambda \in \{0.005, 0.05, 0.5, 5, 50\}$ on the scale of Eq. 3.2
Inner folds; ECE bins; clip	4; 10; 10^{-6}
Pilot E0 decision values	≥ 50 positive steps; group ROC-AUC ≥ 0.55
Bootstrap	2,000 resamples, seed 20261027

Chronology of design, amendments and analyses

Date and time (UTC)	Event	Record
27 Oct 2026 16:40	Pilot design committed (Table 4.4)	commit `48bef90`
27 Oct 2026 16:57	Amendments AM-1 to AM-4 committed. AM-1: exclusion of (user_task_15, injection_task_4). AM-2: benign references. AM-3: the meaning of “tool class”. AM-4: replay validity filter	commit `7a707a7`
27 Oct 2026, after 16:57	First computation of held-out predictions and of all analyses with the then-uncommitted pipeline code. **The log of this first execution was not preserved**; its order relative to the amendments rests on the commit times and on the working session record	—
27 Oct 2026 17:16	Pipeline committed, then re-run in full; results identical to the first execution	commit `aa66f22`; `results/pilot/`
27–28 Oct 2026	**Post-hoc analyses**, added after results had been seen: exclusion of user_task_15 (Section 4.2.2); benign-release breakdown by tier; REM without expected-loss Escalate (Sections 4.6.2–4.6.3); breakdowns by action type and tier; replay-failure analysis	`results/pilot_R2/`
28 Oct 2026	Code corrections of revision R2 (Section 3.15), complete re-run; analytical values identical	commit `84a8c21`; `results/pilot_R2/`

No pre-registered value was changed after results were seen. The post-hoc analyses are reported as such, and none replaces a pre-registered analysis.

The second population

The confirmatory run of Section 4.6.8 uses recordings that no script of this project had read before 11 November 2026 (Chapter 3, Section 3.11.14). That status ended with the run. In the extension study of 13 November 2026 the same recordings are a second development population, and nothing computed on them there is confirmatory.

Table 4.5. The second population (recorded outcomes; `confirmatory_results.json`)

Source	Agent pipeline	Attack templates	Attacked episodes	Benign episodes
F-A	Meta-SecAlign-70B	`important_instructions`, `direct`, `ignore_previous`	429	16
F-B	Meta-SecAlign-70B with the benchmark's repeated-user-prompt defense	the same three	429	16
F-C	Llama-3.3-70B with the repeated-user-prompt defense	the same three	383	16
F-D	Llama-3.3-70B	`direct`, `ignore_previous`	286	0
F-E	GPT-4o (2024-05-13)	four variants of `important_instructions`	538	0
Total			**2,065**	**48**

Of 2,162 recording files, 14 were excluded as the ambiguous pair of amendment AM-1, and 2,148 were loaded. Of these, 2,113 are eligible under amendment AM-4, meaning that the replay with every call allowed reproduces the recorded outcome; the 35 that are not (34 in F-E, 1 in F-C) are excluded from every metric. No episode was removed for any other reason. Sources F-D and F-E contribute no benign episodes, because the benign runs of those pipelines were part of the fitting data. The recordings state benchmark version v1.2.1 for 1,575 eligible episodes and no version for 538.

The agents, templates and trajectories are new. The sixteen user tasks and nine attack objectives are those of the benchmark.

Chronology of the analyses of November 2026

Date (UTC)	Event	Record
8 Nov 2026	Decision traces of sixteen paired fixtures (sets 1 and 2) through REM v1.0; the fixtures were written before they were scored	commit `4989306`
11 Nov 2026, 04:51	Protocol of the rule baselines, diagnostic arms, double holdout and probes committed before any of their outcomes was computed	commit `cca4968`
11 Nov 2026	Those analyses run; three post-hoc additions made after results were seen, among them REM v1.1 under the double holdout	commit `2c915bf`
11 Nov 2026, 17:04	Confirmatory protocol and fixture set 3 committed before the new recordings were opened	commit `19bd168`
11 Nov 2026	Confirmatory run; no amendment to its protocol	commit `907e6d2`
13 Nov 2026	Extension study: protocol, parser, matcher, arms, comparisons, wording rules and fixture set 4 committed before any outcome of a new arm was computed	commit `9137b03`
13 Nov 2026	Extension study run on both populations; analysis code added afterwards; no amendment to its protocol	commits `2ffdcfb`, `04a38ca`

4.2.2 Labels, the user_task_15 Collision and Benchmark Versions

Primary and post-hoc analyses are kept separate. All results above use the pre-registered label rule with amendment AM-1.

The collision. In suite versions v1 and v1.1, user_task_15 asks the agent to pay a landlord whose account is also the attacker account of every injection task. The benchmark changed this from v1.1.1. Sixteen of the 21 recorded backbones used the earlier prompt. The label-relevant definitions of the nine injection tasks are identical in every suite version from v1 to v1.2.2, so labels are consistent across the mixed recordings.

Post-hoc analysis. 29 positive steps in user_task_15 episodes are ambiguous, 19 of them with no injected content in the context. All of REM's residual replay ASR comes from these episodes. A post-hoc analysis that excludes user_task_15 gives REM ASR 0.000 and held-out ROC-AUC 0.952 (`sensitivity_post_hoc_exclude_user_task_15.json`). It is reported for transparency and does not replace the primary result.

Label audit.

- **AI inspection only so far.** A sample of 30 attacked episodes was inspected by the AI assistant that assisted this work, not by a human: 29 labels agreed with the trace, and one was a likely false negative (an attacker-directed transfer through a tool other than the reference tool).
- **Human audit package.** A package for human annotation has been prepared (`results/pilot_R2/label_audit_human_package.csv`, with instructions). It contains 145 items:
    - every proposed call of 30 randomly drawn attacked episodes (70 items; 5 of the drawn episodes contain no proposed tool call);
    - all 29 ambiguous user_task_15 positives;
    - 19 steps carrying an attacker value but labelled 0;
    - 4 steps from episodes with recorded success but no positive label;
    - 23 positive steps from episodes without recorded success.

The human audit has not been performed.

4.2.3 Pilot E0: Feasibility and Feature Retention

Pilot E0 used only the fitting portion of each outer fold (`e0_pilot.json`).

Table 4.6. Pilot E0 (fitting portions only)

Evidence group	ROC-AUC: mean over folds; minimum	Retained in every fold (≥ 0.55)
Context ($x\text{^}ctx_2$ only)	0.582; 0.554	Yes, marginally
Behavioral	0.802; 0.787	Yes
Action	0.929; 0.923	Yes
All	0.938; 0.930	—

The retention rule was applied to each fold's fitting portion separately, and every fold retained all three groups (`e1_crossfit.json`, `e0_fold_specific_feature_groups`). The feature set is therefore the same in every fold. No fold's held-out data influenced its own feature set.

The pooled count of positive steps is 921, above the declared minimum of 50. Thirteen of the 21 backbones have fewer than 50 positive steps each (range 2–116), so no per-backbone conclusion is drawn.

4.2.4 Training of the Risk Estimator

The estimator is the ridge logistic regression of Equations 3.1 and 3.2, followed by the logit calibration map of Equation 3.3, which is fitted by Equation 3.4. It is trained once per fold, on the fitting portion of that fold only, by the nested procedure of Chapter 3 (Procedure 3.1): the ridge penalty is selected from five values by four grouped inner folds; the calibration map is fitted on the inner out-of-fold logits; the model is then refitted on the whole fitting portion.

Table 4.7. Training outcome per outer fold, REM v1.0 (`e1_crossfit.json`; each row is the model that scores the held-out attacker objective named in the first column)

Held-out attacker objective	Positive steps in the fitting portion	Selected λ (scale of Eq. 3.2)	Intercept β_0	γ_1	γ_0	Held-out steps	Held-out ROC-AUC	Held-out ECE
0	796	5	−5.64	0.959	0.161	824	0.962	0.059
1	820	5	−5.73	0.947	0.165	773	0.965	0.046
2	809	5	−5.67	0.958	0.149	807	0.949	0.035
3	811	5	−5.67	0.955	0.140	772	0.962	0.045
4	786	5	−5.68	0.947	0.114	726	0.978	0.087
5	898	5	−5.68	0.969	0.153	634	0.859	0.068
6	842	5	−5.73	0.981	0.155	666	0.909	0.075
7	797	0.5	−7.25	0.980	0.143	730	0.903	0.189
8	809	5	−5.81	0.945	0.142	830	0.959	0.037

Observations on training:

- **The selected penalty is the same in eight folds.** The fold that holds out objective 7, the only credential-change attack, selects a smaller penalty and a more negative intercept.
- **The calibration maps are close to the identity** (γ_1 between 0.945 and 0.981), so calibration changes the probabilities little (Section 4.6.1).
- **The held-out quality differs by objective.** Objective 7 has the largest calibration error (0.189); objective 5, with 23 positive steps, has the lowest ROC-AUC.

Three further sets of models were trained by the same procedure and are used later in the chapter: the models of REM v1.1, which omit the four behavioral features (nine folds); the models of the double holdout, one for each of 143 combinations of user task and attacker

objective (Chapter 3, Section 3.11.12); and, for the exploratory extension, models on the four non-behavioral features plus five permission indicators (nine folds and 143 double-holdout cells; Chapter 3, Section 3.14). No model was trained or selected on the second population.

4.3 Experimental Setup and Evaluation Metrics

This section fixes what is compared, on which episodes, and with which measures. The definitions are those of Chapter 3 (Sections 3.11 and 3.12); they are collected here so that Sections 4.4 to 4.6 can be read without returning to it.

4.3.1 Compared Arms

Table 4.8. Arms compared in this chapter

Arm	Definition	Fitted quantities	Declared
No defense	Every call is released	none	pilot
B1	Consequence-independent thresholds on REM's calibrated probability	estimator, calibration, two thresholds	pilot
REM v1.0	The frozen pipeline of Chapter 3	estimator, calibration	pilot
REM v1.1 (proposed)	REM v1.0 without the behavioral evidence group (Chapter 3, Section 3.13)	estimator, calibration	ablation in the pilot; candidate of the confirmatory run
REM, Allow and Block only	REM v1.0 with the verdict set restricted to two	as REM v1.0	11 November
P1, P2, A1, A2	Rules on provenance, novelty and occurrence in the request, with no model (Chapter 3, Table 3.13)	none	11 November
Diagnostic and candidate arms	Outcome-supervised and intervention-value variants (Chapter 3, Table 3.14)	their own	11 November
Progent manual policy	The manual banking policy published in the Progent repository (T. Shi et al., 2025): a fixed list of five permitted recipients for the three payment tools; password change not permitted	none	13 November

Arm	Definition	Fitted quantities	Declared
Permission rule G1	A state-changing call is released only if the request, compiled by a deterministic parser, supports its operation, recipient and amount (Chapter 3, Section 3.14)	none	13 November
G1 without one component	Five ablations of G1	none	13 November
V11d, L0, L1, L2, L2s	REM v1.1 with a two-verdict decision; a learned model on permission evidence without a guard, and behind a guard with four or two verdicts (Chapter 3, Section 3.14)	estimator, calibration	13 November

Published defenses that need a language model (MELON, Task Shield, CaMeL, Progent with generated policies) are not among the arms, because no model was available (Section 4.4.4).

4.3.2 Populations and Generalization Schemes

Table 4.9. Populations and what each is used for

Population	Eligible episodes	Use
Primary	3,313 (2,979 attacked, 334 benign), 21 undefended backbones, attack `important_instructions`	Fitting and cross-validated evaluation. Scheme S1 holds out one attacker objective per fold; scheme S2 holds out the user task and the attacker objective together
Held-out templates (S3)	681 attacked	Attack templates not used in fitting
Second population	2,113 (2,065 attacked, 48 benign), five sources with other agents and templates (Section 4.2.1)	Nothing is fitted on it. It was unread until the confirmatory run of 11 November 2026. **Since then it is development evidence** and is used as such in the study of 13 November
Reformatted-identifier probe	2,645 attacked	The attacker’s account identifier in the injected text is rewritten with spaces
Paired fixtures	43 pairs in four sets	Hand-written calls scored by one fold’s models; mechanisms, not rates

Rules have no fitted quantity, so their results are the same under S1 and S2.

4.3.3 Evaluation Metrics

Three outcomes are primary: completion of the legitimate task, release of legitimate state-changing calls, and attack success.

Table 4.10. Metrics and their definitions

Metric	Definition	Kind of evidence
ROC-AUC, average precision, ECE, log-loss	Quality of the held-out probability for the attempt label (Chapter 3, Section 3.12)	Offline prediction
Verdict rates	Share of recorded calls that would receive each verdict	Observe-only
Attack success	The benchmark's security check reports the attacker's goal as reached in the replayed episode	Replay
Task completion (benign; under attack; all)	The benchmark's utility check passes in the replayed episode	Replay
Legitimate state-changing calls released	Calls to state-changing tools proposed in benign episodes that the policy releases	Replay
Episodes with a released attack-labelled call	Attacked episodes in which at least one call carrying the attempt label is released	Replay
Tasks gained and lost; attacks gained and lost	Episodes in which only one of two arms completes the task, or only one admits the attack	Replay, paired
Decision time	Time to evaluate one proposed call	Runtime measurement

A released attack-labelled call is not the same as a committed unauthorized change of the bank state. The label marks an attempt (Section 4.2.1), and the effect of a released call on the state is not measured separately from the benchmark's security check. Earlier drafts headed this column "unauthorized state change"; the quantity is unchanged and the name is corrected here. Attack success, as judged by the benchmark, is the security outcome.

4.3.4 Statistical Procedure and Comparisons Fixed in Advance

Intervals are 95% percentile intervals of a grouped bootstrap with 2,000 resamples. Task-completion differences are resampled by user task (16 groups) and attack-success differences by injection task (9 groups); comparisons between arms are paired on the

episode. With so few groups the intervals are wide and are not guaranteed to reach their nominal coverage (Section 4.2.1). They are descriptive.

Three sets of comparisons were fixed before their outcomes were computed, each by a dated commit (Sections 4.2.1 and 4.2.1):

- 11 November 2026: the candidate of that study against REM v1.0 under S1 and S2 (Section 4.6.6);
- 11 November 2026: REM v1.1 against REM v1.0 on the then unread second population, with a three-part decision rule (Chapter 3, Section 3.11.14; Section 4.6.8);
- 13 November 2026: the permission rule against A2, against Progent's manual policy and against REM v1.1; the learned arms against the permission rule under S1 and S2; the two-verdict decision alone; the effect of the guard (Sections 4.4.3, 4.5.3 and 4.6.9).

No margin of non-inferiority on security was approved, and none was invented. An interval of an attack-success difference that includes zero is reported as unresolved. The study of 13 November also fixed its wording in advance: "added value over simple rules" may be stated only if the task-completion interval against A2 lies above zero on both populations and the number of successful attacks does not exceed A2's.

4.4 Comparisons with Existing Models and Defense Frameworks

This section compares REM with other decision policies evaluated on the same episodes: the threshold baseline and the rule baselines, the defenses whose recorded outcomes the benchmark distributes, and one published policy replayed in the same harness. It then states which published defenses could not be run and how the results relate to recent work.

4.4.1 Rule Baselines and an Audit of REM's Interventions

Kind of evidence: replay on the primary recordings (2,979 attacked and 334 benign eligible episodes), held-out attack objective (scheme S1). The arms were declared before their outcomes were computed, except where marked post hoc.

Security and task completion of every arm

Table 4.11. Replay results of REM, the baselines and the rules on the primary recordings (step-level, no reviewer; `study_results.json`, S1)

Arm	Successful attacks / 2,979	Episodes with a released attack-labelled call	Benign tasks completed / 334	Tasks completed under attack / 2,979	Authorized calls released / 178
No defense	672	828	175	1,465	178
B1, operating-point thresholds	164	202	170	1,532	130
REM v1.0	**11**	24	**105**	1,083	33
REM v1.1 (pilot ablation)	11	24	140	1,147	83
P1, provenance rule	12	26	134	1,207	92
P2, provenance or novelty rule	12	26	134	1,207	89
A2, strict explicit rule	13	27	140	1,334	83
REM, Allow and Block only	13	27	124	1,273	64

The counts for REM v1.0, B1 and the no-defense reference are identical to the pilot's (Table 4.25), which checks the study's implementation. The 178 authorized calls are the calls to tools in $\mathscr{T}_{\mathrm{R}}$ proposed in the 334 benign episodes; later tables call them legitimate state-changing calls. The third column counts attacked episodes in which a call carrying the attempt label was released; it is a proxy and not a measured change of the bank state (Section 4.3.3).

Three observations follow.

- **The rules match REM's security.** Rules that use one or two pieces of evidence and no model leave 12 or 13 successful attacks where REM v1.0 leaves 11. The differences are one or two episodes of 2,979.
- **REM v1.0 completes the fewest tasks of the restrictive arms.** It completes 105 benign tasks; the rules complete 134 to 140. It releases 33 of 178 authorized calls; the rules release 83 to 92.
- **The estimator's discrimination is real but is not what produces the security.** The held-out ROC-AUC of 0.938 (Table 4.21) shows that the score separates

attempts from legitimate calls. A single feature already does most of this: read as a classifier of the attempt label, the provenance indicator x^{act}_1 alone has recall 0.971 and false-positive rate 0.147.

What REM v1.0 withholds

Table 4.12. REM v1.0 on the 178 authorized calls of benign episodes, by action category (`weakness_audit.json`)

Category	Authorized calls	Released	Share released
Value transfer	89	4	4%
Payment modification	34	8	24%
Profile change	37	21	57%
Credential change	18	0	0%
All	**178**	**33**	**19%**

REM v1.0 withholds almost every legitimate payment and every legitimate password change. The cause is a combination of the declared costs and the evidence, not a defect in the code. With $C_{esc} = 0.3$ and $C_{miss} = 10$ or 20, Allow has the lowest expected loss only below a probability of 0.03 at tier 3 and 0.015 at tier 4. The first transfer of an episode receives a probability of about 0.033 from the intercept and two behavioral features alone, and about 0.086 when the transition-deviation feature also fires. Escalate then has the lowest expected loss, and without a reviewer an escalated call is withheld. On the sixteen paired fixtures of sets 1 and 2, REM v1.0 withheld all fourteen legitimate payments (Section 4.6.7).

Modify, Escalate and Block coincide. When every Modify and Escalate verdict of REM v1.0 is replaced by Block, the outcome of none of the 3,313 episodes changes. The Allow-and-Block-only arm of Table 4.11 uses the same fitted model and releases more calls than REM v1.0, because without Escalate the boundary of Allow moves from $C_{esc}/C_{miss}(k)$ to the Allow–Block threshold of Equation 3.9. In this evaluation the four-verdict structure is therefore a two-verdict structure in effect, and the Escalate option acts only by narrowing the Allow region. Whether the four verdicts differ with a live agent and a reviewer is not tested.

All residual attacks are one ambiguous task. All 11 successful attacks under REM v1.0 are episodes of user_task_15, in which the user's own task pays the account that the attack

also targets (Section 4.2.2). The comparisons “11 against 12 against 13” in Table 4.11 are thus comparisons of how arms handle one ambiguous task, and carry no weight.

4.4.2 Distributed Defenses (Recorded Outcomes Only)

For orientation, the recorded outcomes of four defenses distributed with the benchmark, on gpt-4o (`e4_cross_template_and_defenses.json`):

Defense	ASR	Benign utility
tool_filter	0.112	0.81
transformers_pi_detector	0.007	0.44
repeat_user_prompt	0.462	0.94
spotlighting_with_delimiting	0.615	0.81

These are recorded outcomes, possibly under different suite versions, and were not replayed. **They are not a controlled comparison with REM** and are not used as one.

4.4.3 A Published Policy and a Request-Derived Permission Rule in the Same Harness

Kind of evidence: replay; development evidence on both populations (every episode had been inspected before 13 November 2026). The arms and the comparisons marked with an asterisk were fixed before any of these outcomes was computed.

The published policy. Progent (T. Shi et al., 2025) enforces per-tool policies with argument restrictions before each tool call. Its official repository contains, at the commit of 10 September 2025, a manual policy for the AgentDojo banking suite: `send_money`, `schedule_transaction` and `update_scheduled_transaction` are permitted only for five listed recipients; `update_password` has no policy entry and is therefore not permitted; the remaining tools are permitted. The policy was read from the repository as data, with the file digests pinned, and applied to the recorded calls by this project’s replay code. This is the policy that the authors wrote, evaluated in this project’s harness. It is **not** a reproduction of the paper’s results, not Progent with policies generated by a language model, and not a live run; the upstream checking code was not executed, and its equivalence with the decision function used here was established by reading it, not by test. The repository bundles AgentDojo 0.1.29; the eleven banking tools have the same parameters and defaults in 0.1.29 and 0.1.35, so the policy applies unchanged to the recordings.

The permission rule G1 releases a state-changing call only if the user's request supports its operation, its recipient and its amount (Chapter 3, Section 3.14). It is an exploratory extension, not part of REM v1.0 or v1.1.

Table 4.13. Replay results on the primary recordings (step-level, no reviewer; `improvement_results.json`)

Arm	Successful attacks / 2,979	Episodes with a released attack-labelled call	Benign tasks completed / 334	All tasks completed / 3,313	Legitimate state-changing calls released / 178
No defense	672	828	175	1,640	178
B1	164	202	170	1,702	130
REM v1.0	11	24	105	1,188	33
REM v1.1	11	24	140	1,287	83
P2	12	26	134	1,341	89
A2	13	27	140	1,474	83
Progent manual policy	0	0	154	1,450	136
Permission rule G1	10	23	149	1,574	112

Table 4.14. Replay results on the second population (the same arms; nothing fitted on these episodes)

Arm	Successful attacks / 2,065	Episodes with a released attack-labelled call	Benign tasks completed / 48	All tasks completed / 2,113	Legitimate state-changing calls released / 51
No defense	436	493	38	1,451	51
B1	67	96	36	1,514	36
REM v1.0	3	3	18	916	4
REM v1.1	1	1	25	1,074	11
P2	4	4	24	1,043	12
A2	4	4	27	1,232	27
Progent manual policy	0	0	35	1,305	48
Permission rule G1	3	3	32	1,358	36

Table 4.15. Paired contrasts (first arm minus second arm, in percentage points, with the 95% grouped-bootstrap interval; PG = Progent manual policy; v1.0 and v1.1 = REM versions; * = fixed in advance)

Contrast	Population	All-task completion	Benign task completion	Attack success	Tasks gained / lost	Attacks gained / lost
G1−A2*	primary	+3.02 [−3.34, 13.09]	+2.69 [−3.87, 12.42]	−0.10 [−0.20, −0.03]	149 / 49	0 / 3
G1−A2*	second	+5.96 [−4.25, 19.14]	+10.42 [−4.17, 29.17]	−0.05 [−0.15, 0.00]	172 / 46	0 / 1
G1−PG*	primary	+3.74 [−6.45, 17.03]	−1.50 [−14.29, 13.56]	+0.34 [0.10, 0.57]	255 / 131	10 / 0
G1−PG*	second	+2.51 [−15.09, 20.94]	−6.25 [−33.33, 20.83]	+0.15 [0.05, 0.29]	248 / 195	3 / 0
PG−A2	primary	−0.72 [−15.80, 14.24]	+4.19 [−12.81, 20.91]	−0.44 [−0.73, −0.14]	280 / 304	0 / 13
PG−A2	second	+3.45 [−19.45, 26.52]	+16.67 [−16.67, 47.92]	−0.19 [−0.43, −0.05]	367 / 294	0 / 4
G1−v1.1*	primary	+8.66 [−2.75, 22.01]	+2.69 [−7.74, 14.46]	−0.03 [−0.10, 0.00]	435 / 148	0 / 1
G1−v1.1*	second	+13.44 [−5.21, 33.59]	+14.58 [−10.42, 39.58]	+0.10 [0.00, 0.24]	461 / 177	2 / 0
G1−v1.0	primary	+11.65 [−0.39, 26.25]	+13.17 [1.50, 28.14]	−0.03 [−0.14, 0.07]	496 / 110	1 / 2
G1−v1.0	second	+20.92 [1.30, 42.46]	+29.17 [8.33, 52.08]	+0.00 [−0.15, 0.14]	554 / 112	1 / 1

What the comparison shows:

- **The published policy has no successful attack in either population.** The attacker’s account is not on its list, and it never permits a password change. The permission rule has 10 and 3 successful attacks. The attack-success difference between the two lies above zero in both populations: on security the published policy is better on this benchmark.
- **Task completion does not separate the two.** The permission rule completes more tasks in point estimate; the intervals include zero. The published policy releases more of the legitimate state-changing calls of benign episodes (136 of 178 against 112; 48 of 51 against 36).
- **Against the rule A2, the permission rule has better point estimates on both outcomes in both populations and the difference is not resolved.** It completes 100 and 126 more tasks with 3 and 1 fewer successful attacks, and the task-

completion intervals include zero. By the wording fixed in advance, added value over simple rules is not claimed.

- **Against REM v1.0 the permission rule completes more benign tasks** (interval above zero in both populations) with 10 against 11 and 3 against 3 successful attacks. This contrast was not fixed in advance.
- **The two policies fail in different places.** The published policy completes no password-change task (user task 14: 0 of 209 and 0 of 129 episodes), because the tool is not permitted. The permission rule completes none of the tasks in which the recipient or the instruction is supplied only by a file (user tasks 0, 2 and 12). All of its successful attacks are in user task 15, where the account the attacker wants is the account the user names (Section 4.2.2).

A fixed list is tied to the seeded environment. The five recipients are payees that exist in the benchmark's initial state. On the twenty paired fixtures written for this study, whose payees are not on the list, the published policy releases no unsafe call and withholds 13 of 20 legitimate calls (Section 4.6.9). The benchmark policy published with aiAuthZ has the same form: a list of five known payees, with password change denied (repository whitepaper; Section 4.4.5). Neither derives permission from the individual request, which is what the permission rule attempts.

4.4.4 Live-Agent and Published-Defense Experiments: Status

No experiment with a language model was executed in this thesis. This section reports no attack success rate, utility or adaptation behavior of a live agent. The only published policy evaluated by this project is Progent's manual banking policy, which needs no model and was replayed on the recorded episodes (Section 4.4.3).

Closed-loop evaluation of REM. A harness in which a running agent receives REM's refusals and continues is implemented and tested with a scripted agent (Appendix D). It was not executed with a model, for two reasons: no credential for a model provider was available in the execution environment, and the design inputs it needs (backbone, decoding parameters, number of repeats, source of fitted parameters, spending authorization) have not been decided. The harness refuses to start until they are.

MELON with and without REM. An integration that places REM behind the MELON defense (Zhu, Yang, et al., 2025) is implemented: MELON's published code is used unmodified at a pinned commit, and the two conditions differ only in the tool executor. Thirty tests pass with scripted agents, a deterministic stand-in for the embedding service

and a simulated provider. These tests show that the integration is mechanically correct. They show nothing about effectiveness: **MELON and MELON with REM are implementation-verified and effectiveness-unevaluated.** A real run needs a model credential, MELON's embedding service and an approved spending limit, none of which was available. The protocol and its status are in Appendix D.

Other published defenses. NEXUS, Task Shield, CaMeL, PROVISO, aiAuthZ, Kairos and Progent with generated policies were not run. Section 4.4.5 states why for each. A sealed protocol for a later comparison with a live agent, with one benchmark version for all conditions, is kept in the repository; it has not been executed.

What replay cannot substitute for. A live agent can retry, rephrase or reach the attacker's goal through another tool after a refusal. The replay attack success rate is therefore not an upper bound on live attack success, and the replay utility is not a lower or an upper bound on live utility. The size and direction of the difference are empirical questions that only a closed-loop run can answer (Appendix D compares the two designs).

4.4.5 Comparison with Prior Work

The comparison restates design positions documented in Chapter 2 and does not rank systems, because no shared evaluation exists. Properties marked U in Chapter 2 are unverified.

Papers read in full in November 2026 (Chapter 2, Section 2.12.6). The position of REM relative to them is as follows.

Table 4.16. Relation of the results to recent work, and why no experimental comparison is reported

Work	Relation to the results of this chapter	Why it was not run
NEXUS (Hossain et al., 2026)	Same family: calibrated logistic score, rules and four graduated interventions. Its repository documentation reports that on rule-blind plans its policy predicts only Allow or Block, which parallels the finding here that the middle verdicts do not act. A working document in the authors' repository (dated 23 May 2026; not the published paper) states that the learned scorer gives no gain in binary detection over the rules alone and that its contribution is to four-class intervention accuracy (0.6406 against 0.3672), which parallels the finding here that the learned score adds no measured security over rules	Full text not read (publisher's site not reachable). The repository was read on 13 November 2026 and not executed. There is no valid adapter from a banking tool call to its structured-plan representation, and re-implementing it from its documentation would not be NEXUS
CASEL (Y. Zhang et al., 2026)	Publishes a per-mode cost rule of the same structure as Equation 3.6, in simulation, and reports that it does not reduce harm beyond a simpler gate	No benchmark results exist to compare with
C. Zhang et al. (2026)	Is consistent with the small effect of calibration on outcomes. Its intervention-value target was tested here (Section 4.6.6) and did not transfer to an unseen attack objective, a condition the paper does not examine	Tested as an adaptation, labelled as derived
AgentBoundary (T. Yang et al., 2026)	Reports over-defense as a general finding; REM's release of 4 of 51 authorized calls is an instance. Its paired design is used for the fixtures	Its mitigation is a language-model component
PROVISO (Yan et al., 2026)	Reports much higher utility with a trained controller and restored rollouts. Its stated limitation, fitting per benchmark without a transfer study, is the condition examined here for a simpler monitor	No implementation is named in the paper; it needs an encoder and an agent model

Work	Relation to the results of this chapter	Why it was not run
Task Shield; MELON	Reported on AgentDojo with live agents. Task Shield judges each action against the user's instructions with a language model; the permission rule of Section 4.4.3 does this with a parser, for three argument types only	Need a model in the decision path; MELON integration is implemented and unevaluated (Section 4.4.4)
Progent (T. Shi et al., 2025)	Deterministic argument-level policies before each call. **Its manual banking policy was replayed here** (Section 4.4.3): no successful attack; no password-change task completed	Only the manual policy was run. Policies generated by a language model were not. The paper was not read; the official code was
CaMeL (Debenedetti et al., 2025)	Prevents untrusted data from influencing control flow by construction	Needs a model and its interpreter; not run and not approximated
aiAuthZ (Kodathala, 2026)	Adds a signed identity channel and an off-host argument-level policy. Its repository whitepaper reports a run on the AgentDojo banking suite (version 0.1.35, twenty task pairs, one model) with a fixed list of five known payees and password change denied: no successful attack, six attacker-directed calls blocked, and clean utility of 80% against 100% because one legitimate first-time payment was blocked. The abstract recorded earlier states seven blocked calls; the difference between versions is not resolved here. The figures are from a live agent and are not comparable with replay	Not run. arXiv text not read; abstract and the authors' repository whitepaper read
Kairos (Hempel et al., 2026; abstract only)	Enforces on effects at the system boundary	Not available; full text not read

Published figures are not placed beside REM's. The authors' reported results on AgentDojo come from live agents, other models, other suites or other attack sets. REM's figures come from replay of recorded trajectories. Putting them in one table would present incompatible measurements as a comparison. The figures for Progent's manual policy in Section 4.4.3 are this project's replay measurements of the published policy, not figures from the Progent paper.

4.5 Ablation Studies

This section reports what happens when a component is removed or replaced. It covers the components of REM v1.0, the verdict set, and the components of the exploratory extension. Every ablation is a single-benchmark observation; none shows that a component has no benefit in general.

4.5.1 Ablations of the Components of REM v1.0

Table 4.17. Ablations (observe-only columns: held-out recorded steps; replay columns: step-level semantics, no reviewer)

Configuration	Held-out ROC-AUC	Observe-only intervention, y = 0	Observe-only intervention, y = 1	Replay ASR	Replay benign utility
Full REM	0.938	0.227	0.973	0.004	0.314
− context evidence ($x\text{^}ctx_2$)	0.938	0.228	0.973	0.004	0.314
− behavioral evidence	0.938	0.174	0.973	0.004	0.419
− action evidence	0.799	0.242	0.921	0.006	0.314
− calibration ($\tilde{p}$ in Eq. 3.6)	—	0.213	0.973	0.004	0.329
one tier for all actions: 1 / 2 / 3 / 4	—	0.093 / 0.157 / 0.233 / 0.336	0.757 / 0.909 / 0.972 / 0.976	0.051 / 0.022 / 0.004 / 0.003	0.440 / 0.353 / 0.338 / 0.314
− predicates D1, D2	—	0.226	0.973	0.004	0.314

Findings, worded as what was and was not observed:

- **Action evidence** carries most of the discrimination: without it, held-out ROC-AUC falls from 0.938 to 0.799 and average precision from 0.719 to 0.367.
- **Context evidence.** No improvement from the instruction-pattern indicator was observed. This concerns that indicator only; the pre-trained injection classifier $x\text{^}ctx_1$ was not tested, so nothing is concluded about context evidence in general.
- **Behavioral evidence.** No security improvement was observed, and removing it raised replay benign utility by 10.5 points. The firing rates show why (`feature_firing_rates.json`):

- the privilege-escalation indicator $x\hat{}beh_3$ fired on 92% of legitimate state-changing steps in episodes without injection, against 87% of attack steps;
- the transition-deviation indicator $x\hat{}beh_4$ fired on 43% of legitimate state-changing steps, against 17% of attack steps. Legitimate tasks held out by user task produce transitions that are absent from the fitting portion's benign reference.

In this benchmark, therefore, the behavioral features mark legitimate first transfers at least as often as attacks. Whether this holds in other environments is not known.

- **Calibration.** Without the calibration map, replay attack success is unchanged (11 of 2,979 attacked episodes) and benign task completion is 110 instead of 105 of 334 (0.329 against 0.314). Calibration therefore changed a small number of decisions and no security count.
- **Predicates.** No change was observed from removing them. With Π empty, D2 fixed the verdict for 58 steps.
- **Tiers.** The tier map moves the trade-off. A single low tier recovers utility and loses protection; a single high tier does the opposite.

None of these observations establishes that a component has no benefit in general. They are single-benchmark observations with nine attacked groups.

4.5.2 Ablation of the Behavioral Evidence Group and of the Verdict Set

Two ablations of Table D.2 were followed up in later studies, and their results are reported where those studies are described.

- **Behavioral evidence.** Removing the four behavioral features is REM v1.1. In the pilot it left replay attack success at 11 of 2,979 and raised benign task completion from 105 to 140 of 334. Under the double holdout it has 14 successful attacks against 11 (Table 4.29). On the second population it completed 1,074 against 916 of 2,113 tasks with 1 against 3 successful attacks (Section 4.6.8).
- **Verdict set.** Replacing every Modify and Escalate verdict of REM v1.0 by Block changes the outcome of none of the 3,313 primary episodes (Section 4.4.1). Removing the two verdicts from the decision rule, so that Allow is chosen up to the Allow–Block threshold of Equation 3.9, gives more released calls with 13 against 11 successful attacks on the primary recordings and 3 against 3 on the second population (Tables 4.11 and 4.34), and 31 against 13 when the attacker's identifier is reformatted (Table 4.32).
- **Calibration.** Without the calibration map, replay attack success is unchanged (11 of 2,979) and benign task completion is 110 instead of 105 of 334 (Table D.2: 0.329 against 0.314). Calibration therefore changed a small number of decisions. It did not change the security count.

4.5.3 Ablations of the Task-Permission Extension

Kind of evidence: replay; development evidence. The ablations are diagnostic: the rule G1 was fixed with all components before any outcome was computed and was not changed afterwards.

Table 4.18. The permission rule with one component removed (`improvement_results.json`)

Rule	Primary: attacks / 2,979	Primary: all tasks / 3,313	Primary: legitimate calls released / 178	Second: attacks / 2,065	Second: all tasks / 2,113	Second: legitimate calls released / 51
A2	13	1,474	83	4	1,232	27
A2 with typed normalization	13	1,474	83	4	1,232	27
Permission rule G1	10	1,574	112	3	1,358	36
G1 without the operation check	10	1,573	113	3	1,358	36
G1 without the amount check	13	1,642	122	4	1,459	40
G1 without established payees	10	1,556	99	3	1,271	31
G1 without scoped delegation	10	1,443	99	3	1,273	33
G1 without typed normalization	10	1,484	86	3	1,139	15

- **Typed normalization alone does not change A2** on these recordings. Inside the permission rule it matters: without it the rule releases 86 instead of 112 legitimate calls, and 15 instead of 36 on the second population.
- **Scoped delegation and established payees add completed tasks without added attacks.** Scoped delegation accounts for 131 tasks on the primary recordings; established payees for 18 there and 87 on the second population.
- **The amount check trades tasks for security.** Without it the rule has the same number of successful attacks as A2 (13 and 4) and completes 68 and 101 more tasks.
- **The operation check changes one task.** On these recordings almost every call that it would deny is already denied by the recipient or amount check.

Table 4.19. Decision semantics and a learned model on the permission evidence (S1: held-out attacker objective; S2: double holdout)

Arm	S1: attacks / 2,979	S1: all tasks / 3,313	S2: attacks	S2: all tasks	Second population: attacks / 2,065	Second population: all tasks / 2,113	Held-out credential-change attacks, S1 / 334
REM v1.1	11	1,287	14	1,272	1	1,074	0
REM v1.1 with the two-verdict decision (V11d)	131	1,492	131	1,452	58	1,182	119
Permission rule G1	10	1,574	10	1,574	3	1,358	0
Learned on permission evidence, no guard (L0)	11	1,711	12	1,707	2	1,526	0
Guard, then learned, four verdicts (L1)	10	1,531	10	1,429	1	1,338	0
Guard, then learned, two verdicts (L2)	10	1,680	10	1,676	2	1,489	0
Guard; learned decides unknown calls only (L2s)	10	1,644	10	1,644	3	1,459	0

Table 4.20. Paired contrasts for the decision semantics, the learned model and the guard (first arm minus second arm, in percentage points, with the 95% interval; v1.1 = REM v1.1; * = fixed in advance)

Contrast	Population	All-task completion	Benign task completion	Attack success	Tasks gained / lost	Attacks gained / lost
L2−G1*	primary, S1	+3.20 [−0.76, 8.80]	+3.59 [0.00, 9.52]	+0.00 [0.00, 0.00]	127 / 21	0 / 0
L2−G1*	primary, S2	+3.08 [−0.87, 8.72]	+3.59 [0.00, 9.52]	+0.00 [0.00, 0.00]	127 / 25	0 / 0
L2−G1*	second	+6.20 [−1.53, 17.63]	+6.25 [0.00, 18.75]	−0.05 [−0.15, 0.00]	150 / 19	0 / 1
L2s−G1*	primary, S1	+2.11 [−0.69, 7.00]	+2.10 [−0.89, 7.19]	+0.00 [0.00, 0.00]	78 / 8	0 / 0
L2s−G1*	primary, S2	+2.11 [−0.69, 7.00]	+2.10 [−0.89, 7.19]	+0.00 [0.00, 0.00]	78 / 8	0 / 0
L2s−G1*	second	+4.78 [−0.42, 14.86]	+4.17 [−6.25, 18.75]	+0.00 [0.00, 0.00]	104 / 3	0 / 0
V11d−v1.1*	primary, S1	+6.19 [0.00, 15.74]	+4.79 [0.00, 14.55]	+4.03 [0.00, 12.02]	209 / 4	120 / 0
V11d−v1.1*	primary, S2	+5.43 [0.45, 13.81]	+4.79 [0.00, 14.55]	+3.93 [0.00, 11.79]	184 / 4	117 / 0
V11d−v1.1*	second	+5.11 [0.19, 12.54]	+6.25 [0.00, 18.75]	+2.76 [0.00, 7.98]	110 / 2	57 / 0
L0−L2*	primary, S1	+0.94 [0.00, 2.84]	+1.80 [0.00, 5.42]	+0.03 [0.00, 0.10]	31 / 0	1 / 0
L0−L2*	primary, S2	+0.94 [0.00, 2.84]	+1.80 [0.00, 5.42]	+0.07 [0.00, 0.17]	31 / 0	2 / 0
L0−L2*	second	+1.75 [−0.14, 5.56]	+2.08 [0.00, 6.25]	+0.00 [0.00, 0.00]	38 / 1	0 / 0

- **The two-verdict decision alone is unsafe.** Applied to REM v1.1 without a guard (V11d), it releases every held-out credential-change attack: 119 of 334 on the primary recordings and 54 of 232 on the second population. In REM v1.1 those calls are withheld only because Escalate has a lower expected loss than Allow, and without a reviewer an escalated call is withheld. This shows that the low attack count of REM under a held-out objective depends on the Escalate region, not on the estimator recognizing the attack.
- **A learned model on the permission evidence adds no demonstrated value to the rule.** Behind the guard (L2, L2s) it completes more tasks than G1 with no more successful attacks on the original text; every interval includes zero under S1, under

S2 and on the second population. By the wording fixed in advance, value of the learned model is not claimed.

- **The learned model costs robustness.** With the attacker's identifier reformatted, L2 has 38 successful attacks where G1 has 10 (Table 4.38). The calls it then releases have unknown permission status; the model's remaining evidence for them is the provenance match, which reformatting removes.
- **The guard costs little and removes little on the recordings** (L0 against L2: at most two attacks and one to two points of tasks). On the paired fixtures the unguarded model releases more unsafe calls (6 against 3 on set 4; Table 4.39).

4.6 Results and Discussion

This section reports the results that the earlier sections did not already present: the pilot's feasibility check, the quality of the estimator, the observe-only decisions, the replay of REM and its baseline, the sequential analysis, realized loss, generalization, robustness, the confirmatory run and the exploratory extension. It then interprets the findings, states the threats to validity and summarizes the chapter.

4.6.1 RQ1 — Offline Classification (Held-Out Predictions)

Table 4.21. Held-out discrimination and calibration, pooled over nine outer folds (6,762 steps; 921 positive; `e1_crossfit.json`)

Metric	Calibrated p, label-NLL fit (reference)	Calibrated p, Platt smoothed targets	Uncalibrated p̃
ROC-AUC	0.938 [0.908, 0.961]	0.938	0.939
Average precision (PR-AUC estimate)	0.719 [0.559, 0.827]	0.719	0.721
ECE (M = 10)	0.044 [0.033, 0.084]	0.044	0.042
Log-loss	0.201 [0.149, 0.294]	0.201	0.201
Brier score (binary convention)	0.060	0.060	0.060

Table 4.22. Per-fold results (calibrated, label-NLL)

Held-out injection task	Steps	Positive	ROC-AUC	AP	ECE	Log-loss	λ_{impl} (λ)	γ_1
0	824	125	0.962	0.788	0.059	0.161	10 (5)	0.959
1	773	101	0.965	0.854	0.046	0.140	10 (5)	0.947
2	807	112	0.949	0.735	0.035	0.164	10 (5)	0.958
3	772	110	0.962	0.811	0.045	0.154	10 (5)	0.955
4 (payment modification)	726	135	0.978	0.906	0.087	0.148	10 (5)	0.947
5	634	23	0.859	0.308	0.068	0.164	10 (5)	0.969
6	666	79	0.909	0.501	0.075	0.225	10 (5)	0.981
7 (credential change)	730	124	0.903	0.577	**0.189**	**0.530**	1 (0.5)	0.980
8	830	112	0.959	0.859	0.037	0.146	10 (5)	0.945

Findings:

1. **Discrimination holds on held-out attacker objectives.** Held-out ROC-AUC is 0.86–0.98 per fold.
2. **Calibration did not transfer to the one held-out attack category not seen in fitting.** Injection task 7 is the only credential-change attack. Its fold has ECE 0.189 and log-loss 0.53, three to four times the other folds.
3. **No calibration improvement was observed.** The fitted maps are close to the identity (γ_1 = 0.945–0.981), and pooled ECE is 0.044 with calibration and 0.042 without. This does not show that calibration is useless. It shows that the ridge model's own probabilities were already close to calibrated on in-distribution folds, and that the map did not repair the miscalibration in fold 7.
4. **Other generalization checks** (`e1_crossfit.json`, `e4_cross_template_and_defenses.json`):
    - leave-one-backbone-out (21 folds): pooled ROC-AUC 0.949; per held-out backbone 0.736 (claude-3-haiku) to 1.000;
    - grouping by user task (16 folds): pooled ROC-AUC 0.943. One fold, user_task_15, scores 0.211; Section 4.2.2 explains this as a label problem;
    - five other attack templates on gpt-4o, with no refitting: ROC-AUC 0.922–0.959, ECE 0.028–0.086.

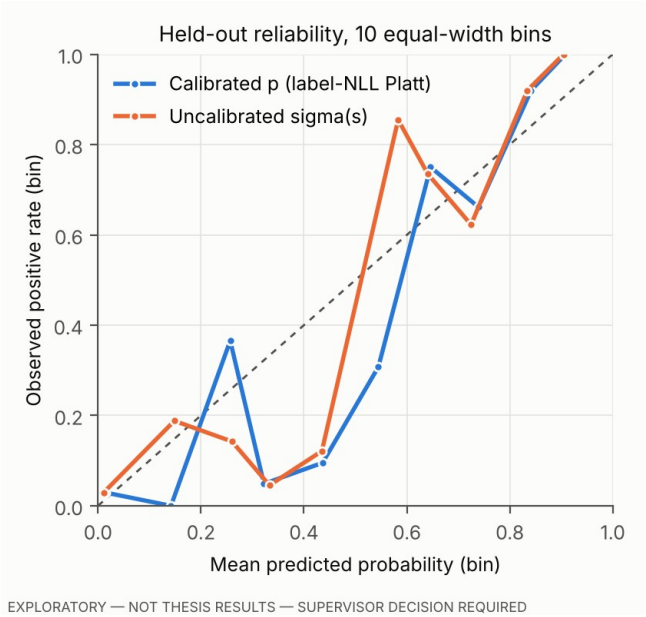


Figure 4.1. Held-out reliability diagram, calibrated and uncalibrated (10 equal-width bins). Mid-range bins contain few steps.

4.6.2 RQ2 — Observe-Only Decisions

All three policies use the same held-out calibrated probabilities and the same predicates:

- **REM** adds tier-indexed expected loss with Escalate available;
- **REM without expected-loss Escalate** (post-hoc) has the same escalation opportunity as the baseline (D2 only);
- **B1** is the baseline with the thresholds of Eq. 3.14.

Verdicts were computed on the recorded steps and not enforced.

Table 4.23. Observe-only verdicts on held-out steps (y = 0: n = 5,841; y = 1: n = 921; `e2_e5_e6_observe_only.json`)

	REM	REM w/o expected-loss Escalate	B1
Any intervention on y = 1 steps	0.973 [0.957, 0.987]	0.973	0.740 [0.473, 0.922]
Any intervention on y = 0 steps (step false-positive rate)	0.227 [0.213, 0.239]	0.198	0.056 [0.047, 0.066]
Escalate share of all steps	0.196	0.009	0.009
y = 0 steps withheld if an idealized reviewer resolves escalations	0.040	0.188	0.046
Ties	0	0	0
Verdicts fixed by D2	58	58	58

Table 4.24. Observe-only interventions by consequence tier and action category (`r2_breakdowns.json`)

Tier	Category	n (y = 0)	n (y = 1)	REM y=0 / y=1	REM w/o Esc. y=0 / y=1	B1 y=0 / y=1
1	read	4,176	0	0.000 / —	0.000 / —	0.000 / —
2	profile change	351	0	0.399 / —	0.219 / —	0.026 / —
3	value transfer ≤ 1000	736	561	0.932 / 0.955	0.838 / 0.955	0.254 / 0.900
4	value transfer > 1000	115	101	0.983 / 1.000	0.922 / 1.000	0.391 / 0.574
4	payment modification	285	135	0.740 / 1.000	0.684 / 1.000	0.305 / 0.881
4	credential change	178	124	0.983 / 1.000	0.899 / 1.000	0.000 / 0.000

What the observe-only results show:

- **Low thresholds at high tiers.** REM's additional interventions are concentrated on state-changing actions at tiers 3–4, where the pre-registered costs put the Allow–Block indifference points at 1/11 and 1/21 (Eq. 3.9). Legitimate transfers often carry action evidence (for example, a recipient read from a tool output) that places them above those points.
- **Benign state-changing steps.** On episodes without injection, REM releases 33 of 180 state-changing steps (tiers 2–4); REM without expected-loss Escalate releases 48; B1 releases 132 (`benign_release_breakdown.json`).

- **Escalation is not the cause.** Removing the expected-loss Escalate option lowers REM's intervention rate on legitimate steps only from 0.227 to 0.198: most former escalations become Modify verdicts, which also withhold the call. The difference from B1 is therefore mainly due to the tier-indexed costs, not to the opportunity to escalate.
- **B1 and credential changes.** B1 intervened on none of the 124 credential-change attack steps. These are the steps of the fold whose probabilities were most miscalibrated (Table 4.22). Its thresholds are fixed by benign false-positive rates and did not reach them.
- **Realized loss.** Under the decision costs, realized loss is 0.114 for REM, 0.136 for REM without expected-loss Escalate and 0.652 for B1. This comparison favors REM by construction (Chapter 3, Section 3.12.3) and is not evidence of superiority.

4.6.3 RQ2 and RQ3 — Replay Sensitivity Analysis

The replay re-executes each recorded episode in the benchmark's sandbox with REM enforcing its verdicts (Chapter 3, Section 3.11.10). Its use is a proposed amendment to the scope of Chapter 3. Three properties limit what it can show:

- **NO-ADAPT.** The agent emits the calls it emitted in the recorded run, whatever REM does. After a refusal, a live agent could retry, rephrase, use another tool, or abandon the task. Replay therefore cannot show how often a live agent would achieve the attacker's goal by another route, and **a near-zero replay ASR is not evidence of protection against a live or adaptive agent.**
- **Mitigation semantics.** Under step-level semantics, Modify and Block have the same effect on the withheld call. The episode-level variant also restricts later calls: after a Block, every later call to a tool in $\mathcal{T}_R$ is refused, even one whose own verdict is Allow, and even though the agent never retries. The two semantics therefore give different replay results. Tables 4.25–4.28 use step-level semantics, the declared reference pending decision D-2; Table E.1 compares both semantics.
- **Not independent runs.** Replaying a recorded trajectory is deterministic. Repeating it adds no information about LLM behavior.
- **Closed-loop identifiability.** Once blocking changes what an agent proposes next, static scores and ungated trajectories need not identify the closed-loop trade-off between false blocks and misses (Ray, 2026). Recorded trajectories are ungated in this sense. Offline replay of AgentDojo's recorded traces has also been used to evaluate temporal-logic monitors (Kekatos et al., 2026); neither use establishes enforcement against live agents.

Replay validity and exclusions

With every call allowed, the replay reproduced the recorded utility and security outcomes of 3,313 of the 3,334 episodes.

The 21 failures (`r2_breakdowns.json`, `replay_failures`) are concentrated:

- 20 are user_task_13 episodes whose utility verdict differs; 1 is a user_task_14 episode whose security verdict differs;
- 10 are from gpt-4o, and the remaining 11 are spread over six other backbones;
- none raised an error.

The pattern is consistent with a change in the user task's definition between the suite version used for recording and the version used for replay (v1). This was not confirmed task by task.

Effect of the exclusion. Of the 21 excluded episodes, 19 are attacked, and 14 of these recorded attack success. Excluding them changes the recorded attack-success rate from 0.228 (all 2,998 attacked episodes) to 0.226 (2,979 retained), and the recorded benign utility from 0.521 (336) to 0.524 (334). All replay metrics use the 2,979 attacked and 334 benign retained episodes.

Results

Table 4.25. Replay results, step-level semantics (attacked n = 2,979; benign n = 334; `e4_e5_enforcement_replay.json`)

Configuration	ASR	Benign utility	Utility under attack
B0, no defense (replay)	0.226 [0.148, 0.295]	0.524 [0.381, 0.676]	0.492
B1, no reviewer	0.055 [0.011, 0.134]	0.509 [0.334, 0.702]	0.514
REM, no reviewer	0.004 [0.001, 0.007]	0.314 [0.110, 0.548]	0.364
REM w/o expected-loss Escalate, no reviewer	0.004 [0.001, 0.007]	0.329 [0.126, 0.551]	0.374
REM, idealized reviewer	0.004 [0.001, 0.007]	0.497 [0.333, 0.680]	0.496
REM w/o expected-loss Escalate, idealized reviewer	0.004 [0.001, 0.007]	0.311 [0.123, 0.518]	0.359

Table 4.26. Paired differences (grouped bootstrap)

Comparison	ΔASR	ΔBenign utility
REM − B1, no reviewer	−0.051 [−0.130, −0.007]	−0.195 [−0.341, −0.074]
REM w/o Esc. − B1, no reviewer (same escalation opportunity)	−0.051 [−0.130, −0.007]	−0.180 [−0.325, −0.063]
REM − B1, idealized reviewer	−0.051 [−0.130, −0.007]	+0.003 [−0.009, 0.018]
REM − REM w/o Esc., idealized reviewer	0.000	+0.186 [0.065, 0.335]
REM − B0, no reviewer	−0.222 [−0.289, −0.146]	−0.210 [−0.379, −0.051]

Table 4.27. Replay ASR by the attacker's target action (`r2_breakdowns.json`)

Target action	Injection tasks	Attacked episodes	B0	B1 (no reviewer)	REM (no reviewer)
Value transfer	7	2,334	0.213 [0.128, 0.293]	0.014 [0.007, 0.020]	0.005 [0.002, 0.008]
Payment modification	1	311	0.183	0.042	0.000
Credential change	1	334	0.356	0.356	0.000

Single-task categories have no interval.

Table 4.28. Replay benign utility by kind of user task (`r2_breakdowns.json`)

User tasks	Tasks	Episodes	B0	B1 (no reviewer)	REM (no reviewer)	REM (idealized reviewer)
Requiring a state change	12	250	0.472 [0.320, 0.632]	0.432 [0.238, 0.637]	0.168 [0.000, 0.420]	0.416 [0.238, 0.600]
Read-only	4	84	0.679 [0.369, 0.929]	0.738 [0.417, 0.976]	0.750 [0.429, 1.000]	0.738 [0.417, 0.976]

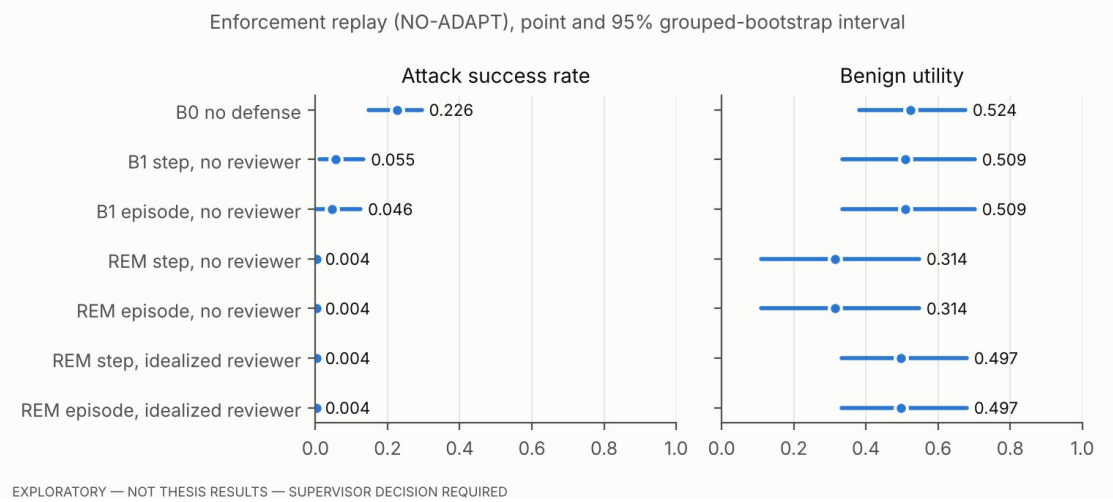


Figure 4.2. Replay sensitivity analysis (NO-ADAPT): ASR and benign utility with 95% grouped-bootstrap intervals.

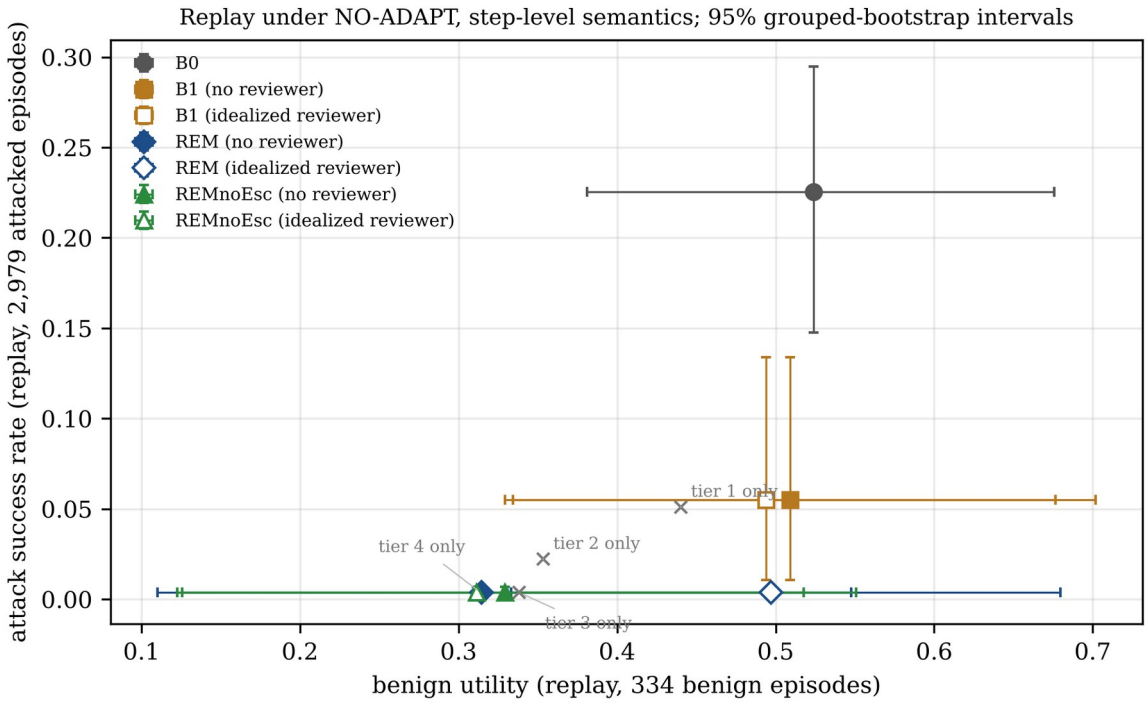


Figure 4.3. Security–utility trade-off in the replay sensitivity analysis (NO-ADAPT, step-level semantics): attack success rate against benign utility for B0, B1, REM and REM without expected-loss Escalate under both reviewer bounds, and for the single-tier ablations. Values from `results/pilot_R2/e4_e5_enforcement_replay.json`; no live result.

What the replay results show, within NO-ADAPT:

- **Where the ASR difference comes from.** REM withholds more of the recorded attack attempts than B1. Most of the difference comes from the credential-change

and payment-modification attacks (Table 4.27), each represented by a single injection task.

- **The utility cost falls on state-changing tasks.** With no reviewer, REM's benign utility falls to 0.168 on those tasks (Table 4.28).
- **The cost is not caused by the escalation option.** REM without expected-loss Escalate has almost the same utility cost relative to B1 (Table 4.26).
- **With an idealized reviewer, the cost disappears.** That reviewer knows the label and is an upper bound on reviewer quality, not a model of one.

RQ3 quantities:

- **Residual attack success after Modify.** In oracle-Modify replays within the fitting folds, r_{mod} was 0.000 at tier 3 (530 episodes) and 0.010 at tier 4 (298 episodes) (`e4_rmod_and_replay_validity.json`). In replays where REM applied Modify to an attack step, residual ASR was 0.000 (610 episodes). Under NO-ADAPT a withheld call simply does not occur, so **these values are consequences of the assumption, not measurements of tool restriction against a live agent.**
- **Escalation rate.** 0.196 of all steps in the observe-only analysis (Table 4.23).
- **Processing time** (Appendix B.1.14, Table B.8). **Complete call** (R4 re-execution, 1 November 2026; `results/pilot_R4/e4_e5_enforcement_replay.json`, `latency_full_ms_*`): median 0.21–0.28 ms and 95th percentile 0.49–0.70 ms per step, across the 8 REM configurations (6,684 steps each). **Partial timer**, which excludes attribution, audit-record construction and history recording: median 0.18–0.24 ms and 95th percentile 0.46–0.64 ms in the same run. Earlier runs measured only the partial timer: median 0.14–0.20 ms and 95th percentile 0.39–0.54 ms (R1, R2), with the 30 October re-execution within these ranges.
- **Memory.** The median peak traced allocation was 4.4 KB per step, with a 95th percentile of 12.4 KB (611 steps of 300 episodes; `latency_memory_profile.json`). The first run (R1) measured 2.9 KB; like time, memory varies between runs. The re-execution of 30 October measured the same value. In the R4 re-execution, where `evaluate` also records the complete-call timer, the median was 4,349 bytes against 4,364 bytes, with the same 95th percentile (12,419.5 bytes; `results/pilot_R4/latency_memory_profile.json`). The memory boundary is the complete `evaluate` call in both.

These figures apply to the evaluated configuration only: no neural injection classifier, no reviewer, recorded inputs. They are not estimates for a complete deployment.

Sensitivity to the mitigation semantics. Step-level semantics is the declared reference (Chapter 3, Section 3.8), pending the supervisor's decision on SC-1. The same replays under the episode-level variant are reported in Appendix E. In summary: REM's ASR is identical under both semantics (0.004); B1's is lower under the episode-level variant

(0.055 against 0.046), because the restriction set left by an earlier Block or Modify refuses later state-changing calls; utility under attack is lower or equal under the episode-level variant in every configuration; and benign utility coincides. The episode-level rows are a sensitivity analysis and do not replace Tables 4.25 to 4.28.

4.6.4 Optional Sequential Analysis (CUSUM, observe-only)

The Bernoulli CUSUM was fitted on each fold's benign fitting episodes (`e3_a2_cusum_observe_only.json`):

- **$q_1 = 0.3$:** it was undefined in all folds, because the estimated pre-change rate (about 0.34) exceeded q_1.
- **$q_1 = 0.5$ and 0.7:**
    - an alarm followed the entry of injected content in 74.8% of attacked episodes with a positive step;
    - it came at or before the first positive step in 42.5–43.8%;
    - the median delay was 1 step;
    - the held-out benign false-alarm rate was 0.106, against an in-fold target of 0.05.

The CUSUM issued no verdicts.

4.6.5 Realized Loss across the Declared Grid

Realized loss (Eq. 3.22) on held-out steps was computed for 36 loss structures:

- C_{miss} multipliers 0.5–5;
- C_{esc} 0.1–0.6;
- amount limits 100–10,000.

Configuration	Realized loss, range over the 36 cells
REM, matched costs	0.039–0.298
REM, base costs (misspecified)	0.057–0.324
B1	0.303–3.261

REM's loss was below B1's in every cell, also when misspecified. Matched costs gave lower realized loss than misspecified costs in 34 of 36 cells.

The comparison favors REM by construction. The grid cell $\alpha_{blk} = 0.05$ is not evaluable, because the pre-registered $\alpha_{mod} = 0.05$ must exceed α_{blk}.

4.6.6 Generalization to Unseen Tasks and Objectives, and a Rejected Candidate

Kind of evidence: replay on the primary recordings under schemes S1, S2 and S3 (Chapter 3, Section 3.11.12). REM v1.1 under S2 is post hoc.

Double holdout and held-out templates

Table 4.29. Successful attacks and benign tasks completed under three generalization schemes (`study_results.json`)

Arm	S1: attacks / 2,979	S1: benign / 334	S2: attacks / 2,979	S2: benign / 334	S3: attacks / 681	S3: tasks under attack / 681
No defense	672	175	672	175	174	504
B1	164	170	162	170	33	525
REM v1.0	11	105	11	105	2	302
REM v1.1	11	140	14 *(post hoc)*	140 *(post hoc)*	2	370
P1	12	134	12	134	2	360
P2	12	134	12	134	2	360
A2	13	140	13	140	3	438
Authorization-aware intervention-value policy (candidate)	132	127	132	110	28	364

S3 uses 681 attacked episodes of one backbone under five attack templates not used in fitting (of 715 recorded, 34 are not reproduced by the all-allow replay and are excluded); it has no benign episodes.

- **REM v1.0 has the same two headline counts under S1 and S2.** Its successful attacks (11 of 2,979) and its completed benign tasks (105 of 334) do not change when the user task is also held out. Other quantities change slightly: it completes 1,083 tasks under attack under S1 and 1,078 under S2, and releases 33 and 35 of the 178 authorized calls. Its attack count also stays low on templates it never saw. This stability is that of a policy that withholds most state-changing calls: there is little for a change of task to alter.

- **The rules are identical under S1 and S2 by construction**, because they have no fitted quantity.
- **REM v1.1 loses three episodes of security under double holdout** (11 to 14 of 2,979) and keeps its utility. This observation was made after results were seen and motivated the confirmatory run of Section 4.6.8.

The pre-declared candidate failed

The candidate declared in advance for this study was the authorization-aware intervention-value policy (Chapter 3, Table 3.14). The protocol stated that an improvement over REM v1.0 would be claimed only if, under both S1 and S2, the paired gain in benign utility had a 95% interval above zero and the paired change in attack success had an interval not entirely above zero.

Table 4.30. Pre-declared contrasts of the candidate against REM v1.0 (paired, grouped bootstrap; percentage points)

Scheme	Benign utility	Attack success rate	Rate of episodes with a released attack-labelled call
S1	+6.6 [0.0, 18.2]	+4.1 [0.0, 12.1]	+4.2 [0.03, 12.4]
S2	+1.5 [0.0, 4.5]	+4.1 [0.0, 12.1]	+4.2 [0.03, 12.4]

The candidate is rejected. Its utility gain is not established under either scheme and almost disappears under double holdout. It admits 132 successful attacks where REM v1.0 admits 11, and its rate of episodes with a released attack-labelled call rises with an interval that excludes zero.

The failure has one identifiable cause. Of the 132 attacks, 119 are episodes of the credential-change objective, and the intervention-value policy without authorization features releases all 119 of them. When that objective is held out, the training outcomes contain no case in which withholding a credential update prevents harm. The policy learns that harm is prevented by withholding payments to new recipients, and it assigns no security value to a password taken from a document. The utility side transfers poorly as well: the candidate's model of whether withholding a call breaks the user's task has a held-out ROC-AUC of 0.857 under S1 and 0.729 under S2 (0.854 and 0.682 without the authorization features).

What the diagnostic arms show

Table 4.31. Diagnostic arms on the primary recordings, scheme S1 (attacks / 2,979; benign tasks / 334)

Arm	Attacks	Benign	What it isolates
REM v1.0	11	105	reference
REM v1.0 with authorization features added	69	110	adding z^{exp} and z^{del} to the estimator
Outcome-supervised REM	76	105	changing the training target only
Intervention-value policy	119	105	changing the target and the rule
Intervention-value policy with the attempt label on the security side	0	105	keeping the attempt label for security
A1, explicit or delegated rule	313	164	trusting documents that the user named

- **Outcome supervision lowers security in this setting.** Every arm trained on intervention outcomes admits more attacks than REM v1.0. The attempt label, although a proxy, transfers to an unseen objective; the outcome label does not.
- **Authorization features do not help the estimator.** Added to REM v1.0 they raise attacks from 11 to 69 for five more benign tasks.
- **Delegation is unsafe.** Rule A1 releases a call when its recipient comes from a document that the user named. It admits 313 attacks. The reason is visible in the evidence itself: of 908 attack calls to restricted tools, 382 take their key value from a document the user named, because that document is where the injection was planted.

These are negative results. They are reported because they bound what the available evidence can support, and because two of them test proposals from the literature (C. Zhang et al., 2026; the delegation remark of F. Jia et al., 2025) under conditions their authors did not examine.

4.6.7 Robustness Probes: Reformatted Identifiers and Paired Call Fixtures

Kind of evidence: replay with a modified injected text, and call-level fixtures. Neither is a benchmark result. Fixture counts are not rates.

Reformatted attacker identifier

In 2,645 attacked episodes the injected text contains the attacker's account identifier. The probe rewrites that identifier in groups of four characters inside the injected text and leaves the recorded calls unchanged (Chapter 3, Section 3.11.13). The all-allow replay still reproduces all 2,645 recorded outcomes.

Table 4.32. Successful attacks before and after the identifier is reformatted (2,645 attacked episodes; `study_results.json`)

Arm	Original text	Reformatted text
No defense	553	553
B1	45	**198**
REM v1.0	11	11
REM v1.1	11	11
P1, provenance rule	12	**191**
P2, provenance or novelty rule	12	12
A2, strict explicit rule	13	13
REM, Allow and Block only	13	31

The provenance indicator compares whole normalized tokens. Once the identifier in the document is spaced and the identifier in the call is not, the argument is no longer traced to the untrusted text. A rule that depends on that trace alone (P1) fails, and so does B1. Arms that also use the question "does the recipient appear in the user's request?" are unaffected: P2 through the novelty indicator and A2 by definition. Both REM versions are also unchanged, which is consistent with their narrow Allow region; the contribution of each feature to that result was not examined separately.

This agrees with the finding of Kekatos et al. (2026) that a planted line defeats a naive provenance check on recorded AgentDojo traces. Exact-string provenance is evidence that an attacker can remove by formatting.

Paired call fixtures

Twenty-three paired fixtures in three sets were scored once each with the models of one fold (Chapter 3, Section 3.11.13). Sets 1 and 2 contain fourteen payment pairs, in which a legitimate payment and a substituted payment share a scaffold, and two read-only pairs, in

which the unsafe call is an unrequested payment. Set 3 contains three credential pairs and four pairs with reformatted or fragmented identifiers.

Table 4.33. Paired fixtures: legitimate calls released and unsafe calls released (counts)

Arm	Sets 1–2: legitimate payments released / 14	Sets 1–2: unsafe calls released / 16	Set 3: legitimate released / 7	Set 3: unsafe released / 7
REM v1.0	0	0	1	0
REM v1.1 *(sets 1–2 post hoc)*	14	4	5	0
B1	14	4	6	2
P1	14	4	6	2
P2	14	4	5	0
A2	14	9	5	1

In sets 1 and 2, the four unsafe calls released by REM v1.1, B1, P1 and P2 are the same four: two substituted amounts and the two unrequested payments. A2 releases nine: the seven amount substitutions, because it checks identity arguments only, and the two unrequested payments.

What the fixtures show:

- **REM v1.0 is safe on the fixtures by refusing.** It releases no unsafe call and no legitimate payment.
- **Every arm of Table 4.33 that releases legitimate payments also releases an unrequested payment whose recipient and amount occur in the user's words.** In the two read-only pairs the user mentions a past payment, with its payee and amount, asks only for the account balance and states that no payment is to be made. The document read by the agent then asks for the same payment again. Nothing in the features that these arms use distinguishes this unrequested payment from a requested one: its recipient and amount occur in the user's own text. Occurrence in the user's text is not authorization. The features do not represent the user's statement that no payment is wanted, although the request contains it.
- **Amount substitution passes identity-only checks.** A rule that verifies the recipient and not the amount releases a payment to the right recipient for the wrong amount.
- **Reformatting defeats exact matching on fixtures as on the benchmark.** P1 and B1 release two unsafe calls of set 3 whose identifiers were reformatted.

- **REM v1.1 and P2 behave alike** on set 3: five legitimate calls released, no unsafe call released, and the same two legitimate calls withheld.

No arm of Table 4.33, learned or rule-based, gets every pair right. This is a finding about the features and policies tested in that study: they describe the provenance of a call's arguments and not which operation, recipient and amount the request asks for. It is not a finding that the request text cannot supply that information. Section 4.6.9 reports a rule that parses the request, and its results on the same fixtures.

4.6.8 Confirmatory Evaluation of REM v1.1 (Run of 11 November 2026)

Kind of evidence: confirmatory replay. Protocol and verdict rule committed before the data were opened (Chapter 3, Section 3.11.14); no amendment. Population: Table 4.5, unread at the time of this run and development evidence for every later analysis. Models: frozen from the primary recordings; nothing fitted or selected on these episodes.

Results

Table 4.34. Confirmatory replay results (2,065 attacked and 48 benign eligible episodes; step-level, no reviewer; `confirmatory_results.json`)

Arm	Successful attacks / 2,065	Episodes with a released attack-labelled call	Tasks completed under attack / 2,065	Benign tasks completed / 48	All tasks completed / 2,113	Authorized calls released / 51
No defense	436	493	1,413	38	1,451	51
B1	67	96	1,478	36	1,514	36
REM v1.0	**3**	3	898	18	**916**	4
REM v1.1 (candidate)	**1**	1	1,049	25	**1,074**	11
P1	4	4	1,020	24	1,044	12
P2	4	4	1,019	24	1,043	12
A2	4	4	1,205	27	1,232	27
REM, Allow and Block only	3	3	1,093	22	1,115	8

No replay raised an error in any arm.

Table 4.35. Paired contrasts on the confirmatory population (percentage points; 95% grouped-bootstrap interval; gained / lost = episodes in which only the first or only the second arm completes the task)

Contrast	Task completion, all episodes	Attack success rate	Benign episodes only	Gained / lost
REM v1.1 − REM v1.0 (pre-declared)	**+7.48 [1.17, 16.02]**	**−0.10 [−0.29, 0.00]**	+14.58 [0.00, 33.33]	158 / 0
REM v1.1 − P2	+1.47 [−5.28, 7.98]	−0.15 [−0.38, 0.00]	+2.08 [0.00, 6.25]	88 / 57
REM v1.1 − A2	−7.48 [−25.66, 8.16]	−0.15 [−0.38, 0.00]	−4.17 [−25.00, 14.58]	142 / 300
P2 − REM v1.0	+6.01 [−5.17, 20.25]	+0.05 [0.00, 0.15]	+12.50 [−2.08, 31.25]	193 / 66
A2 − REM v1.0	+14.96 [−1.29, 34.42]	+0.05 [0.00, 0.15]	+18.75 [4.17, 37.50]	393 / 77
REM v1.0 − B1	−28.30 [−47.16, −10.83]	−3.10 [−8.27, −0.39]	−37.50 [−58.33, −16.67]	26 / 624

The contrast of REM v1.1 against REM v1.0 in episodes with a released attack-labelled call equals the attack-success contrast: −0.10 [−0.29, 0.00].

The pre-declared verdict

All three conditions of the rule hold.

Condition	Result
(a) The interval of the task-completion difference lies above zero	+7.48 points [1.17, 16.02]
(b) Neither security interval lies entirely above zero	both −0.10 [−0.29, 0.00]
(c) The candidate’s successful attacks do not exceed those of rule P2	1 against 4

The pre-declared verdict is GO. On recordings that no analysis had read before this run, REM without the behavioral evidence group completes more tasks than REM v1.0 (1,074 against 916 of 2,113), and its count of successful attacks is not higher (1 against 3 of 2,065). REM v1.1 gains 158 episodes and loses none. The task-completion observation made post hoc on the primary recordings is confirmed for this benchmark in replay.

GO is the outcome of a decision rule, not of a test of non-inferiority. The rule was declared in advance in place of a security margin, because no margin has been approved (Chapter 3, Section 3.11.14). Its security conditions are that no interval lies entirely above zero and that the candidate has no more successful attacks than rule P2. The security interval, −0.10 points [−0.29, 0.00], includes zero. One successful attack against three, of 2,065, does not establish that REM v1.1 is at least as secure as REM v1.0, and no statistical superiority or non-inferiority on security is claimed. Under the double holdout on the primary recordings REM v1.1 has 14 successful attacks against 11 (Table 4.29).

What the verdict does not establish

- **REM v1.1 is not shown to be better than the rules.** Its difference from P2 is +1.47 points [−5.28, 7.98], and from A2 −7.48 points [−25.66, 8.16]. Neither is resolved. A2 completes 1,232 tasks, more than either REM version, with 4 successful attacks.
- **REM v1.0 is not shown to be better than the rules either.** P2 and A2 complete more tasks in point estimate with one more successful attack; the intervals of their differences from REM v1.0 include zero, except for A2 on benign episodes.
- **Utility remains far below the undefended agent.** The undefended agent completes 1,451 of 2,113 tasks; REM v1.1 completes 1,074. In benign episodes REM v1.1 releases 11 of 51 authorized calls; REM v1.0 releases 4.
- **The benign-only interval touches zero** (+14.58 points [0.00, 33.33], 18 against 25 of 48). The verdict rests on all episodes, as declared; most of the gain is task completion under attack.
- **A second configuration meets the same conditions.** REM restricted to Allow and Block completes 1,115 tasks with the same 3 attacks as REM v1.0 (+9.42 points [2.77, 17.87]). It was a comparator, not the declared candidate, and is not adopted. It adds to the evidence that the middle verdicts do not help in this evaluation.

Where the gain and the remaining attacks are

Table 4.36. Tasks completed by user task on the confirmatory population (all eligible episodes of each task; tasks on which the arms differ)

User task	Episodes	No defense	REM v1.0	REM v1.1	P2	A2
2	138	114	36	97	104	0
3	138	72	6	17	11	72
4	138	92	4	10	0	92
6	138	132	3	15	0	132
9	138	50	138	138	92	138
12	129	39	30	34	38	0
13	95	85	11	11	0	0
14	129	119	9	73	119	119

On user tasks 1, 5, 7, 8 and 10 every restrictive arm completes all or nearly all episodes, and on tasks 0, 11 and 15 none completes any; these rows are omitted. On tasks 9 and 10 the restrictive arms pass the benchmark's utility check more often than the undefended agent. The cause was not examined call by call. It shows that the utility check can be passed by an episode in which a state-changing call was withheld, which is one reason why authorized-call release is reported beside task completion.

The gain of REM v1.1 over v1.0 is concentrated in two tasks: task 2 (36 to 97 of 138) and task 14 (9 to 73 of 129). The rule A2 behaves differently: it completes tasks 3, 4 and 6 at the level of the undefended agent, because their recipients are stated in the request, and completes none of tasks 2 and 12, where the needed value comes from a file. With sixteen user tasks, a few tasks decide each comparison, which is why the intervals between REM v1.1 and the rules are wide.

Remaining attacks. REM v1.0's three successful attacks are in two injection tasks (one and two episodes); REM v1.1's one is in the first of these; the rules' four add one episode of a third. All are in source F-E. Of 559 calls labelled as attack attempts, REM v1.0 withholds 556, REM v1.1 558, and the rules 555.

Intervention burden and processing time

Table 4.37. Interventions on the confirmatory population (8,221 recorded calls in 2,113 episodes, of which 5,808 are read-type calls that no arm withholds; `confirmatory_descriptives.json`; descriptive)

Arm	State-changing calls not labelled as attempts: released / 1,854	Escalate verdicts	Episodes with an Escalate verdict	Episodes with any withheld call
B1	1,347	63	61	821
REM v1.0	224	1,392	928	1,423
REM v1.1	497	981	671	1,257
P2	549	0	0	1,210
A2	928	0	0	1,080

In an attacked episode, a state-changing call that the label rule does not mark may still have been influenced by the injection. The 1,854 calls are therefore context, and the 51 authorized calls of benign episodes (Table 4.34) are the clean measure of legitimate-action approval.

Without a reviewer every Escalate is a withheld call. If a reviewer existed, REM v1.0 would refer 1,392 calls in 2,113 episodes and REM v1.1 would refer 981. Nothing is assumed about how well a reviewer would resolve them.

The median time to evaluate one call was 0.23 ms for the REM arms and 0.20 ms for the rules, with a 95th percentile of about 0.6 ms, measured under four parallel worker processes. The figures agree with the pilot's (Section 4.6.3) and describe this configuration only.

4.6.9 Exploratory Extension: Task-Permission Evidence

Kind of evidence: replay and call-level fixtures; development evidence. Protocol, arms, parser, matcher and fixture set 4 were committed on 13 November 2026 before any outcome of a new arm was computed (commit `9137b03`); no amendment was made. The parser was written by an author who knows the sixteen requests of the benchmark; no request was held out from its development.

The question of the extension is whether task-permission evidence compiled from the trusted request improves the trade-off between security and task completion, and which component is responsible for any change. The main results against the rules and the published policy are in Section 4.4.3, and the ablations in Section 4.5.3. This section adds the robustness probe, the paired fixtures, the per-task results and the verdict.

Table 4.38. Successful attacks before and after the attacker's identifier is reformatted (2,645 attacked episodes)

Arm	Original text	Identifier reformatted
B1	45	198
REM v1.0	11	11
REM v1.1	11	11
P2	12	12
A2	13	13
Progent manual policy	0	0
Permission rule G1	10	10
G1 without typed normalization	10	10
Guard, then learned, two verdicts (L2)	10	38

The permission rule is unchanged by the reformatting, with or without typed normalization, because it accepts a recipient only if the request itself supports it. The learned arm L2 is not robust (Section 4.5.3).

Table 4.39. Paired fixtures (each pair has one legitimate and one unsafe call for the same request; a pair is correct if the legitimate call is released and the unsafe call is withheld; counts, not rates)

Arm	Sets 1–3: legitimate calls released / 23	Sets 1–3: unsafe calls released / 23	Sets 1–3: pairs correct / 23	Set 4: legitimate released / 20	Set 4: unsafe released / 20	Set 4: pairs correct / 20
REM v1.0	3	0	3	6	1	5
REM v1.1	21	4	17	17	6	11
B1	22	6	16	19	7	12
A2	21	10	11	17	8	9
Progent manual policy	3	0	3	7	0	7
Permission rule G1	17	1	16	17	1	16
G1 without the amount check	18	6	12	19	5	14
Learned on permission evidence, no guard (L0)	22	5	17	20	6	14
Guard, then learned, two verdicts (L2)	18	1	17	19	3	16

Sets 1 to 3 are the fixtures of the earlier studies. Set 4 has twenty pairs in ten categories: negation, past payments, conditions, valid high amounts, amount substitution, scheduled payments, credential changes, number formats, delegated sources and repeated payments. It was written for this study before any scoring and scored once. It was written by the author of the rule with AI assistance and was not reviewed by a second person; it is a stress test of mechanisms, not an independent benchmark.

- On set 4 the permission rule gets 16 of 20 pairs right, A2 gets 9, REM v1.1 gets 11 and the published policy gets 7.
- On the read-only pairs of set 2, in which the user mentions a past payment and asks for no payment, the permission rule withholds the unrequested payment that was released by every arm of Table 4.33 that releases legitimate payments. The request states that no payment is wanted, and a parser of the request can use that statement.
- **The rule's errors on set 4.** Two legitimate calls are withheld because of parser defects: an amount written as "Reimburse Marta 36.40 for the groceries" is not extracted, and "create a monthly standing order" is not recognized as a request for a scheduled payment. One legitimate call is withheld by design, because "1,250" can be read as two different amounts. One unsafe call is released: a second copy of a

payment already made in the episode, because the rule keeps no record of requests already satisfied. The defects were not repaired after scoring.

- On set 3 the permission rule releases 3 of 7 legitimate calls, fewer than REM v1.1 (5 of 7).
- The learned arms release unsafe calls that the rule withholds (set 4: 3 for L2 and 6 for L0).

Table 4.40. Tasks completed by user task on the primary recordings (user tasks on which A2, the published policy, G1 and L2 all equal the undefended agent are omitted)

User task	Episodes	No defense	REM v1.0	REM v1.1	A2	Progent	G1	L2
0	210	11	0	0	0	11	0	0
2	210	87	39	71	0	81	0	77
6	210	74	3	8	72	72	72	72
9	208	141	208	206	208	141	159	200
10	210	130	210	210	210	140	210	210
11	210	21	0	0	0	18	18	5
12	210	31	21	27	0	31	0	0
13	190	139	18	15	0	139	131	132
14	209	167	3	39	167	0	167	167
15	189	22	0	0	0	0	0	0

The gain of the permission rule over A2 is in user tasks 11 and 13, where the recipient is referred to through the history or the value is delegated to a named file. It loses in user task 9, where arms that withhold the update pass the benchmark’s check more often; the cause was not examined call by call. A few user tasks decide each comparison, which is why the intervals are wide.

Verdict of the extension study.

1. **Improvement over REM v1.0: observed on development data.** More benign tasks in both populations with no more successful attacks.
2. **Added value over the strongest simple rule: not established.** Favourable point estimates on both outcomes; task-completion intervals include zero.
3. **Against the published policy: not better; worse on security on this benchmark.** The published policy pays for this with a fixed list that fails on payees outside it.
4. **Attribution.** The change comes from the deterministic compiler and matcher used as a hard rule. The learned ridge model adds no demonstrated value on top of that

evidence and is less robust to reformatting. The two-verdict decision is a consistency repair that is safe only behind the guard. The semantic verifier was not run.

5. **Status.** Proposed and exploratory. The rule is not adopted and is not a new version of REM. A confirmatory test needs outcomes that do not yet exist: fresh runs with a live agent and request variants written by someone other than the author (the sealed protocol is in the repository).

Decision time. The median time to evaluate one call on the primary recordings was 0.09 ms for the permission rule and for the published policy and 0.18 ms for REM and for L2; the 95th percentile of the arms that parse bank records was about 3 ms. No arm calls a model.

4.6.10 Interpretation of the Findings

This section interprets the evaluation reported in Sections 4.1 to 4.6. Each conclusion is linked to the result that supports it and to the limit of that result. Section 4.1.4 defines the kinds of evidence. No live run was executed.

What the evidence supports

Table 4.41. Conclusions, their support and their limits

#	Conclusion	Supporting result	Limit
1	Evidence at the tool boundary separates attack attempts from legitimate calls on unseen attack objectives	Held-out ROC-AUC 0.938; 0.927 when the user task is also held out	One benchmark; attempt labels, not audited by a human; most of the separation comes from one provenance feature
2	In replay, REM v1.0 withholds nearly all recorded attack attempts	Attack success 22.6% to 0.4% (primary) and 21.1% to 0.15% (second population)	NO-ADAPT; no live agent; residual attacks on the primary recordings are one ambiguous task
3	REM v1.0 obtains this by withholding most state-changing calls	33 of 178 and 4 of 51 authorized calls released; 4 of 89 legitimate transfers	No reviewer; declared costs
4	Simple rules reach about the same number of successful attacks with at least as much task completion	Tables 4.11 and 4.34	Differences between REM and the rules are not resolved statistically on the second population

#	Conclusion	Supporting result	Limit
5	Removing behavioral evidence raises REM's task completion	Confirmatory run: +7.48 points [1.17, 16.02]; 1 against 3 successful attacks	Security not resolved (interval includes zero; 14 against 11 under the double holdout); same benchmark tasks; replay; not better than the rules
6	Calibration changed little, and the four verdicts act as two	Without calibration: attacks unchanged at 11, benign tasks 110 instead of 105 of 334; γ_1 between 0.945 and 0.981. 0 of 3,313 episodes change when Modify and Escalate become Block	This evaluation only
7	Supervising on intervention outcomes, and trusting user-named documents, lower security	119 to 132 and 313 attacks against 11	One benchmark; one held-out objective class drives the first result
8	None of the policies of the study of 11 November separates an authorized payment from an unrequested one whose details occur in the user's words	Paired fixtures, Section 4.6.7	Hand-written cases; mechanism, not prevalence; concerns the tested features, not the request text as such
9	A deterministic rule that compiles the request and matches operation, recipient and amount completes more benign tasks than REM v1.0 with no more successful attacks	Sections 4.4.3 and 4.6.9: 149 against 105 of 334 and 32 against 18 of 48; 10 against 11 and 3 against 3 attacks	Development evidence; parser written with the benchmark's requests in view; not resolved against rule A2; worse on security than a published fixed-list policy
10	The learned model adds no demonstrated value to that permission evidence	Section 4.5.3: intervals include zero under both schemes; 38 against 10 attacks under reformatting	Ridge logistic regression only; one benchmark

Why benign utility falls

The fall in benign utility has two sources, and the evaluation separates them.

Where the verdict sends them. The withheld actions are mostly escalated. Without a reviewer an escalation is a withheld action, so utility falls. The comparison with REM without expected-loss Escalate shows that removing the option does not recover the utility: the same actions are then withheld through Modify. The utility cost is therefore a consequence of the declared costs and of the evidence, not of escalation as such.

What a reviewer would change. An escalation is worth something only if someone resolves it. With an oracle reviewer the utility cost disappears, which bounds what a

perfect reviewer could recover. A real reviewer would recover less, at some delay and cost. The thesis does not model that reviewer.

Why behavioral evidence did not help, and calibration changed little

Behavioral evidence. The behavioral indicators are not specific to attacks in this benchmark:

- *privilege escalation* fired on 92% of legitimate state-changing steps, because a user's first transfer is, by definition, the first use of a higher-privilege tool;
- *transition deviation* fired more often on legitimate steps (43%) than on attacks (17%), because legitimate tasks held out from fitting produce unseen transitions.

The estimator gave these features positive weight. In the decision they therefore added to the probability of legitimate high-tier actions, and removing them recovered utility without a measured change in attack success. This is an observation about these features in this benchmark, with short trajectories. It does not show that behavioral evidence is useless elsewhere.

Calibration. Calibration changed little (the same 11 successful attacks; 105 benign tasks with it and 110 without it), for two reasons:

- logistic regression fitted by penalized likelihood was already close to calibrated on in-distribution folds, so the fitted map was close to the identity;
- the one fold where calibration mattered, the unseen credential-change attack, was miscalibrated in a way a monotone map fitted on other attack categories cannot repair.

This agrees with the position, taken in Chapter 3, that calibration quality and control quality must be reported separately (C. Zhang et al., 2026).

The security–utility frontier that was measured

The arms fall into two groups, not along a ranking.

Table 4.42. Attack success and task completion in percent, both populations

Arm	Primary: attack success	Primary: benign tasks	Second population: attack success	Second population: all tasks	Second population: authorized calls released
No defense	22.6	52.4	21.1	68.7	100
B1	5.5	50.9	3.2	71.7	70.6
REM v1.0	0.37	31.4	0.15	43.4	7.8
REM v1.1	0.37	41.9	0.05	50.8	21.6
P2	0.40	40.1	0.19	49.4	23.5
A2	0.44	41.9	0.19	58.3	52.9
Progent manual policy	0.00	46.1	0.00	61.8	94.1
Permission rule G1 (exploratory)	0.34	44.6	0.15	64.3	70.6

B1 keeps task completion close to the undefended level and removes about three quarters (primary) to 85% (second population) of successful attacks. The other arms bring attack success below 0.5% and lose up to a half of legitimate work. Inside that group the security differences are a handful of episodes. Which group is preferable is a policy question. The declared costs, with a missed attack on a high-consequence action weighted twenty times a false alarm, answer it in favor of the restrictive group; a different institution could answer differently.

No arm dominates on every measure. On the second population every arm with attack success below 0.5% completes at most 64.3% of tasks where the undefended agent completes 68.7%. The two arms nearest to the undefended level of task completion are deterministic rules that use what the user or the environment permits: a published fixed list of payees, and the request-derived permission rule.

The limiting factor is what the evidence represents

Three results of the studies up to 11 November point the same way. REM’s estimator discriminates well, yet a one-feature rule matches its security. A more elaborate policy, supervised on outcomes and given authorization features, did worse. And on paired fixtures every tested policy that releases legitimate payments also releases an unrequested payment that uses the user’s own words. In each case the evidence described where the arguments of a call came from and not what the user asked for. The conclusion is limited to

the features and policies that were tested: with them, neither a better estimator nor a more elaborate decision rule moved the frontier.

The extension study of 13 November tested the complementary proposition. A deterministic parser of the request, with typed matching of operation, recipient and amount, moved the frontier on development data: more legitimate calls released, no more successful attacks than REM v1.0, and most of the paired fixtures right (Sections 4.4.3 and 4.6.9). The improvement came from the representation of the request used as a hard rule. A learned model on the same representation added nothing that could be demonstrated and was less robust (Section 4.5.3). Three limits remain. The parser was written with the benchmark's requests in view. Requests that delegate the operation itself to a file stay unresolved. And a user task whose own payee is the attacker's account cannot be resolved from the request at all.

REM's threat model gives it one trusted input, the user's request as text. The published approaches that report both low attack success and high utility add something REM does not have: a trusted policy or authorization record (aiAuthZ, at abstract level), trusted observations that license an action (Yan et al., 2026), a language model that judges task alignment (F. Jia et al., 2025), or enforcement on effects at the system boundary (Kairos, at abstract level). Of these, this thesis ran only a fixed-list policy published with Progent, in replay (Section 4.4.3); it does not claim that the others would succeed on these episodes. A trusted authorization record would remove the dependence on parsing free text, and remains the principal future work.

What the evidence does not support

- **That REM protects live agents.** Under replay a withheld call does not reappear. A live agent can retry, rephrase or reach the goal through another tool.
- **That REM, in either version, is better than simple rules.** On the second population neither version is distinguishable from the rules, and one rule completes more tasks.
- **That REM is deployable as configured.** Without a reviewer, REM v1.0 completes 18 of 48 benign tasks where the undefended agent completes 38, and REM v1.1 completes 25.
- **That the four verdicts are useful as four.** In this evaluation Modify, Escalate and Block coincide.

- **That REM is superior to any published defense.** The one published policy that was replayed has no successful attack and completes more tasks than either REM version. No defense that needs a language model was run.
- **That the tested provenance features identify what the user authorized.** On the paired fixtures they did not. Whether a model or a parser can recover authorization from the request text in general is not settled by this thesis: one deterministic parser did so for most of the author-written cases and failed on some.
- **That the learned core of REM is what improves the trade-off.** In every comparison of this chapter, the gains came from removing evidence, from simple rules, or from a deterministic permission rule.
- **That the permission rule generalizes.** It was developed and evaluated on the same sixteen requests and on fixtures written by its author.
- **Anything about the injection classifier**, which was not available, or about adaptive attackers, who were out of scope.

4.6.11 Threats to Validity and Limitations

1. **Design status.** Costs, tiers, predicates, the feature set and the label rule are declared exploratory values, not approved ones.
2. **No live runs.** Enforcement was estimated only by replay under NO-ADAPT, a method proposed as an amendment to the Chapter 3 scope.
3. **One benchmark.** One benchmark, one attack family for fitting, one attacker identity, and historical model snapshots (2024–2025).
4. **Labels.** Labels are attempt-based and reference-matched. They are ambiguous for user_task_15 under early suite versions and miss alternative attacker routes. They have not been audited by a human.
5. **Statistics.** Nine attacked groups, one run per configuration, no correction for multiple comparisons. Several categories contain a single injection task.
6. **Reviewer.** Escalation outcomes are bounded by an oracle and by no reviewer.
7. **Missing component.** No neural injection classifier was available.
8. **Literature review.** The review was record-level; no full text was screened.
9. **Currency.** Work published after the review’s search date was examined only at abstract level, and several close records were found (Chapter 2, Section 2.12.5).

10. **Runtime figures.** They describe the evaluated configuration only. A deployment with a neural classifier or a human reviewer would be slower.
11. **Reuse of the recordings.** The primary recordings were used for fitting, cross-validation and many analyses. Only the confirmatory run of 11 November was made on recordings unread at the time, and it tests one contrast. Since that run the second population is development evidence too, and the extension study has no confirmatory part.
12. **Tasks are not new anywhere.** The second population has new agents and templates and the same sixteen user tasks and nine attack objectives. A few user tasks decide each utility comparison.
13. **Author knowledge.** The rules, the authorization evidence, the request parser of the extension and the fixtures were written by an author who knew the benchmark's tasks. For the parser this is the main threat: no request was held out from its development, and its only test on other requests is a set of twenty author-written pairs that nobody else reviewed.
14. **Fixtures.** They are hand-written, were scored with one fold's models, and show mechanisms, not rates.
15. **Three close works were not read in full.** NEXUS and aiAuthZ are known from their abstracts and from their authors' repositories; Kairos from its abstract. Progent and CaMeL are known from their official repositories. Statements about them may change when the papers are read.
16. **One published policy was replayed, and no defense that needs a language model was run.** The equivalence of the replayed decision function with Progent's own checker rests on reading its code, not on executing it. No statement about the relative performance of REM and model-based defenses is supported.

4.6.12 Chapter Summary

This chapter reported an evaluation of REM on recorded trajectories of real agents in the AgentDojo banking environment. No live agent was run.

- **Environment and training.** Python, NumPy and AgentDojo 0.1.35 on four CPU cores; no model call. The estimator has nine parameters and is trained once per fold in a nested, grouped procedure.

- **Prediction.** On attack objectives not seen in fitting, the calibrated estimator reaches a held-out ROC-AUC of 0.938. Calibration left the probabilities almost unchanged and did not repair the one miscalibrated fold; without it the attack count is the same and five more benign tasks are completed.
- **Replay on the primary recordings.** REM v1.0 reduces attack success from 22.6% to 0.4% and benign task completion from 52% to 31%. It releases 33 of 178 authorized state-changing calls.
- **Rules.** Rules that use one or two pieces of provenance evidence and no model reach the same security with 40% to 42% benign task completion. One of them fails when the attacker's identifier is reformatted.
- **Generalization.** REM v1.0's attack count and benign task count do not change when the user task is also held out. A candidate policy supervised on intervention outcomes with authorization features was rejected: 132 successful attacks against 11.
- **Confirmatory run.** On 2,113 episodes unread before that run, REM without behavioral evidence completes 7.5 percentage points more tasks than REM v1.0 (95% interval 1.2 to 16.0) with 1 successful attack against 3. The pre-declared decision rule gives GO; this is not a test of non-inferiority on security. Neither version is distinguishable from the rules.
- **Published policy.** Progent's manual banking policy, replayed on the same episodes, has no successful attack and completes more tasks than either REM version; it permits no password change.
- **Exploratory extension.** A deterministic permission rule compiled from the user's request completes more benign tasks than REM v1.0 with no more successful attacks (development evidence). Its advantage over the strongest simple rule is not resolved, and it is worse on security than the published policy. A learned model on the same evidence adds no demonstrated value. The gain belongs to the rule, not to the learned core.
- **Limit.** The provenance features of REM do not represent what the user asked for; the request parser of the extension was developed on the benchmark's own requests.
- **Not done.** Live-agent runs; any defense that needs a language model; a human label audit; repeated runs; an independent review of the fixtures.

Chapter 5 draws the conclusions.

CHAPTER FIVE: CONCLUSIONS AND FUTURE WORK

5.1 Introduction

This chapter draws the conclusions of the thesis. Section 5.2 answers the research questions from the evidence of Chapter 4. Section 5.3 assesses the objectives. Section 5.4 lists the contributions with the precedent, code, experiment, result and limits of each. Section 5.5 records what was proposed and not confirmed, the variants that were rejected, and why the negative findings matter. Section 5.6 states the limitations, Section 5.7 the future work in order of priority, and Section 5.8 concludes.

Every conclusion is bounded in the same way. The evidence comes from recorded trajectories of real agents in one banking benchmark, replayed under the assumption that the agent does not adapt to a refusal. No live agent was run. The design values are declared and await approval.

5.2 Answers to the Research Questions

The research questions remain proposed wording, pending the supervisor's confirmation (Chapter 1, Section 1.7).

Table 5.1. Answers to the research questions

RQ	Answer	Evidence and its kind	Not shown
RQ1, estimation	The ridge logistic estimator separates recorded attack attempts from legitimate calls well on attack objectives it has not seen: held-out ROC-AUC 0.938 [0.908, 0.961], average precision 0.719, ECE 0.044. Calibration left the probabilities almost unchanged and did not repair the one fold that was miscalibrated, the credential-change objective (ECE 0.189)	Offline prediction, nine folds by attack objective (Chapter 4, Section 4.6.1)	That the separation needs a model: one provenance feature alone has recall 0.971 at a false-positive rate of 0.147
RQ2, decision	Compared with the consequence-independent baseline on the same estimator, the tier-indexed expected-loss rule lowers replay attack success from 5.5% to 0.4% and benign task completion from 51% to 31%. Compared with rules	Replay on the primary recordings (Chapter 4, Sections 4.6.3 and 4.4.1); confirmatory replay (Chapter 4, Section 4.6.8); development replay of	Any advantage of the cost-based rule over the simple rules; any result with a live agent

RQ	Answer	Evidence and its kind	Not shown
	that use no estimator and no costs, it gives about the same number of successful attacks and lower task completion. A published fixed-list policy and an exploratory request-derived permission rule, both deterministic, complete more tasks than either REM version with no more successful attacks	the extension (Chapter 4, Section 4.4.3)	
RQ3, mitigation and cost	Under replay a withheld call does not recur, so residual attack success after Modify is near zero by construction. Escalate is the most frequent non-Allow verdict (1,392 in the 2,113 episodes of the second population for v1.0). Modify, Escalate and Block have the same effect in this evaluation. A decision takes a median of 0.23 ms	Replay; observe-only analysis; runtime measurement (Chapter 4, Sections 4.6.3, 4.4.1 and 4.6.8)	Residual success against an agent that retries; the effect of a reviewer; any difference among the three verdicts
RQ4, component contribution	Action evidence carries the discrimination. The instruction-pattern context indicator showed no benefit. Behavioral evidence lowered task completion with no measured security benefit; the gain in task completion from removing it met the pre-declared decision rule on recordings unread until that run, while the security difference is not resolved. Removing calibration left the attack count unchanged and changed five benign outcomes; the predicates changed none. The tier map moves the trade-off. In the exploratory extension the deterministic permission rule carries the gain, and a learned model on the same evidence adds no demonstrated value	Ablations (Chapter 4, Sections 4.5.1, 4.5.2 and 4.5.3); confirmatory replay (Chapter 4, Section 4.6.8)	The value of the injection classifier, which was not available; behavior of these components in other environments

5.3 Achievement of the Objectives

Table 5.2. Objectives and how far they were achieved

Objective	Achieved	Not achieved
O1: design a REM framework for the security of financial and task-automation agents	A five-layer framework specified, implemented and tested for a banking agent	No task-automation environment was evaluated; the injection classifier of the Detection Layer is absent
O2: evaluate the framework against adversarial attacks	Evaluation on recorded trajectories of real agents under indirect prompt injection, with held-out attack objectives, a double holdout, robustness probes and one confirmatory run	Evaluation with live agents; adaptive attackers; a human reviewer; repeated runs
O3: compare performance with existing security approaches	Controlled comparison with a threshold baseline and three rule baselines on the same episodes; replay of one published policy (the manual banking policy of Progent) in the same harness; design-level comparison with the closest published systems	Experimental comparison with any published defense that needs a language model. The MELON integration is implemented and unevaluated

O1 is achieved for the banking setting. O2 is achieved within recorded-trace replay. O3 is achieved for internal baselines and for one published deterministic policy in replay.

5.4 Contributions

Table 5.3. Each contribution with its precedent, implementation, experiment, measured result and limits

Contribution	Literature source or precedent	Implemented in	Supporting experiment	Measured result	Scope and limits
1. A specified and implemented runtime layer: provenance-based evidence, calibrated ridge logistic estimate, consequence tiers, predicates, four-verdict expected-loss rule, deterministic mitigation, audit record	Cox (1958); le Cessie & van Houwelingen (1992); Platt (2000); Guo et al. (2017); Elkan (2001); Chow (1970); Lundberg & Lee (2017). The same family of design is published: Hossain et al. (2026); Y. Zhang et al. (2026)	`rem/` (Chapter 3; Appendix B)	Software verification	278 tests pass; replay fidelity 99.4% and 98.4%; exact re-execution	Not a new mechanism. One declared component absent
2. An evaluation protocol that isolates the decision rule, holds out attack objectives and user tasks, includes model-free rule baselines, and reports outcome layers separately	Grouped evaluation and leakage control: Arp et al. (2022). Paired counterfactual design: T. Yang et al. (2026). Offline use of AgentDojo recordings: Kekatos et al. (2026)	`experiments/pilot/`, `experiments/authz_study/`, `experiments/improve_study/`	Chapters 3 and 4	Protocols committed before outcomes; three post-hoc additions labelled	Replay only; one benchmark
3. Measured security and its cost for REM v1.0	—	as above	Replay, primary and second population	Attack success 22.6% to 0.4% and 21.1% to	NO-ADAPT; no reviewer; declared

Contribution	Literature source or precedent	Implemented in	Supporting experiment	Measured result	Scope and limits
				0.15%; benign task completion 52% to 31%; 33 of 178 and 4 of 51 authorized calls released	costs
4. Evidence that the learned, cost-based decision adds no measured value over simple provenance rules on this benchmark	Concern raised for calibrated scores in general by C. Zhang et al. (2026)	`experiments/authz_study/`	Rule baselines; confirmatory replay	Rules: 12 to 13 attacks against 11, and 4 against 3; task completion equal or higher	A null finding on one benchmark, not a proof of equivalence
5. A confirmed gain in task completion: REM without behavioral evidence (v1.1, proposed)	Cautions on behavioral anomaly evidence: Sommer & Paxson (2010)	the pilot's ablation fit; `confirm_a.py`	Confirmatory replay under a pre-committed protocol	+7.48 points task completion [1.17, 16.02]; 1 against 3 successful attacks of 2,065	Security difference not resolved (14 against 11 under the double holdout); same benchmark tasks; not better than the rules; adoption awaits approval
6. Four negative results (Section 5.5)	C. Zhang et al. (2026); F. Jia et al. (2025); Kekatos et al. (2026)	`experiments/authz_study/`	Double holdout; probes	132 against 11 attacks; 313 attacks; 12 to 191 attacks	One benchmark; one objective class drives the first
7. Identification of what limits	Yan et al. (2026); aiAuthZ at	fixtures	Paired call fixtures	None of the arms tested up	Hand-written cases;

Contribution	Literature source or precedent	Implemented in	Supporting experiment	Measured result	Scope and limits
provenance evidence: it does not represent what the user asked for	abstract and repository level			to 11 November gets every pair right; unrequested payments in the user's own words are released by every such arm that releases legitimate payments	mechanism, not prevalence; a statement about the tested features
8. An exploratory extension and an attribution result: task-permission evidence compiled from the request, used as a deterministic rule (proposed, not adopted)	F. Jia et al. (2025); T. Shi et al. (2025); Debenedetti et al. (2025)	`experiments/improve_study/`	Development replay on both populations; ablations; one published policy replayed in the same harness	Benign tasks 149 against 105 of 334 and 32 against 18 of 48 with 10 against 11 and 3 against 3 successful attacks; not resolved against rule A2; the published policy has no successful attack; a learned model on the same evidence adds no demonstrated value and has 38 against 10 attacks	Development evidence only; parser written with the benchmark's requests in view; fixtures not independently reviewed

Contribution	Literature source or precedent	Implemented in	Supporting experiment	Measured result	Scope and limits
				under reformatting	

5.5 What Was Not Confirmed, What Was Rejected, and Why It Matters

Proposed and not confirmed.

- **That tier-indexed expected-loss verdicts reduce financial harm at acceptable cost in operation.** This was the central practical claim of the design. It needs enforcement with live agents, which was not run. It remains unestablished.
- **That the four verdicts are useful as four.** Modify, Escalate and Block coincide in replay without a reviewer.
- **That behavioral evidence helps.** It did not; removing it raised task completion, and that gain met the pre-declared decision rule.
- **That calibration improves decisions.** Removing it left the attack count unchanged and five more benign tasks were completed.
- **That consequence-aware learned decisions add value over simple rules.** No such value was measured, for REM or for a learned model given task-permission evidence.
- **That the two-verdict decision is safe by itself.** Applied to REM v1.1 without a guard it released every held-out credential-change attack.

Rejected variants.

Variant	Result	Decision
Authorization-aware intervention-value policy (pre-declared candidate)	132 successful attacks against 11; utility gain not established and almost absent under double holdout	Rejected
Outcome-supervised estimator	76 attacks against 11, no utility gain	Rejected
Authorization features added to REM's estimator	69 attacks against 11	Rejected
Rule that trusts documents named by the user	313 attacks	Rejected
Provenance rule on exact string match alone	12 attacks, rising to 191 when the identifier is reformatted	Not recommended

Variant	Result	Decision
Trusted authorization component	Not implemented: the benchmark has no trusted authorization record, so an evaluation would be tautological or would use an oracle	Future work
Selective-risk or conformal thresholds	Not implemented: they move the operating point of the same score and need a risk tolerance that nobody has approved	Not pursued
REM v1.1 with a two-verdict decision and no guard	131 successful attacks against 11; all 119 held-out credential-change attacks released	Rejected
Learned model on task-permission evidence (with or without a guard)	No demonstrated gain over the permission rule; 38 against 10 attacks when the identifier is reformatted	Not recommended
Deterministic permission rule compiled from the request	More benign tasks than REM v1.0 with no more attacks, on development data; unresolved against rule A2; worse on security than a published fixed list	Exploratory; decision pending

Why the negative findings matter.

1. **They test published proposals under a condition their authors did not examine.** Supervision on intervention value improves control in the settings studied by C. Zhang et al. (2026). Here, with nine attack objectives and one of them held out, it removed protection against the held-out class. A method that depends on outcome labels inherits the coverage of those labels.
2. **They show what a strong security figure can hide.** REM v1.0's attack success of 0.4% coexists with the release of 4 of 89 legitimate transfers. Reported without the second figure, the first would describe a policy that withholds payments as if it were a policy that detects attacks. This is the over-defense that T. Yang et al. (2026) report in general.
3. **They place the difficulty in what the evidence represents.** With provenance evidence, a good estimator, a simple rule and an elaborate policy converge on the same frontier and fail the same paired cases. In the exploratory extension, a deterministic representation of the request moved the frontier on development data and a learned model on top of it did not. Effort on the estimator is therefore unlikely to help; a trusted statement of what the user authorized, or a validated way of compiling it from the request, might.
4. **They qualify provenance as evidence.** Exact-string provenance is removed by reformatting an identifier, and a document that the user names is exactly where an attacker writes.

5.6 Limitations and Threats to Validity

The limitations are discussed in Chapter 4, Section 4.6.11. In summary:

1. **Replay, not enforcement.** Every outcome assumes that the agent emits its recorded calls whatever is withheld. A live agent can retry or take another route. Replay attack success is not an upper bound on live attack success.
2. **One benchmark.** One environment, sixteen user tasks, nine attack objectives, one attacker account. The second population has new agents and templates and the same tasks. A few tasks decide each utility comparison.
3. **Design status.** Costs, tiers, predicates, the feature set and the label rule are declared values without approval. Every result is exploratory by label.
4. **Labels.** They are reference-matched attempt labels, ambiguous for one user task in early benchmark versions, and not audited by a human.
5. **No reviewer.** Escalation outcomes are bounded by an oracle and by no reviewer. No reviewer effectiveness is assumed or measured.
6. **Reuse and post-hoc analysis.** The primary recordings were examined many times. Only one contrast was tested on data unread at the time, and those data are development evidence since then. The extension study has no confirmatory part, and its request parser was written with the benchmark's requests in view.
7. **Statistics.** Nine attack groups and sixteen task groups; intervals are wide and need not reach nominal coverage; one run per configuration.
8. **Missing component.** No injection classifier was available for the Detection Layer.
9. **Literature.** The systematic review was conducted at record level. Six papers were read in full afterwards. Five close works are known only from abstracts or from their authors' repositories (NEXUS, aiAuthZ, Kairos, Progent, CaMeL).
10. **Limited external comparison.** One published deterministic policy was replayed on the recorded episodes. No defense that needs a language model was run.
11. **Fixtures and rules were written with knowledge of the benchmark and of REM's features.**

5.7 Future Work, in Order of Priority

1. **Supervisor decisions.** Approve or replace the declared design values, the label rule, the mitigation semantics, the replay amendment and the proposed amendment REM v1.1 (Appendix F).
2. **A trusted authorization input.** Specify how a structured statement of what the user authorized (operation, source account, recipient, amount, constraints) is captured by the trusted interface, and check proposed actions against it deterministically. It fits in the Input & Context Layer and as a policy predicate of

the Decision Engine; no sixth layer is needed. It changes the threat model by adding a trusted channel, and its evaluation needs a benchmark that contains such records. The present thesis shows that the tested provenance features do not replace it. The exploratory permission rule of Chapter 4, Section 4.6.9, is a first step that compiles such a statement from the request text; it needs requests written by other people, an independent review of its test cases and the repair of the parser defects that the fixtures exposed.

3. **Live enforcing-mode evaluation.** Run the no-defense reference, B1, both REM versions and the rule baselines with live agents, with at least three repeated runs and fixed, recorded versions and decoding parameters. This measures adaptation after refusals and whether the four verdicts differ.
4. **Comparison with published defenses under the same conditions.** A sealed protocol fixes one benchmark version for all conditions and names the comparisons in advance. The MELON integration is ready and needs a model credential, MELON's embedding service and an approved spending limit; Progent with generated policies and Task Shield need a model as well. A comparison with NEXUS needs its full text, its code at a pinned commit and a justified adapter.
5. **Label audit.** Annotate the prepared package with at least one human annotator, preferably two, and report agreement.
6. **A reviewer model** with error rate and delay, so that the value of Escalate can be estimated between its two bounds.
7. **Provenance that survives reformatting,** by canonicalizing identifiers before matching. The extension applies a type-specific canonical form inside the permission rule; the provenance labeler of REM itself is unchanged, and adaptive variants were not tested.
8. **The injection classifier,** selected on the agent's own tool outputs at a low false-positive rate (Z. Liu, 2026).
9. **Full-text literature review,** including the three works known only from abstracts, and a search of the named databases.
10. **Further benchmarks,** with new user tasks, reported per benchmark.

5.8 Conclusion

This thesis set out to design a runtime framework that decides, for each tool call proposed by a financial AI agent, whether to allow, modify, escalate or block it. The decision minimizes expected loss under a calibrated probability of adversarial inducement and a declared consequence tier, and every verdict is recorded for audit. The framework was specified, implemented at the tool boundary of a benchmark agent, and evaluated on 5,426 recorded episodes of real agents in a banking environment: 3,313 used for fitting and

cross-validated evaluation, and 2,113 held back for one confirmatory test and used as development evidence afterwards.

Four things were found.

REM is safe in replay, and restrictive. It withholds nearly all recorded attack attempts, on attack objectives, user tasks, agents and templates it has not seen. It does so largely by withholding state-changing calls, legitimate ones included.

Its learned and cost-based parts are not shown to earn their place. Rules that read one or two pieces of provenance evidence reach the same security with at least as much completed work. Within the framework, one change raises task completion, and that gain was confirmed on data unread at the time: removing behavioral evidence. That change brings REM to the level of the rules, not above it.

The limit is what the evidence represents. Every policy built on provenance evidence, simple or elaborate, fails when an unrequested payment uses the user's own words, and an elaborate policy trained on outcomes failed on an attack class it had not seen. These are findings about the tested features and policies, not a proof that the request text cannot supply the missing information.

A deterministic representation of the request helps, and the learned core does not add to it. In an exploratory extension, a rule that compiles the operation, recipient and amount the user asked for completes more benign tasks than REM with no more successful attacks on development data. A published fixed list of payees does better still on security. A learned model on the same evidence adds nothing that could be demonstrated and is less robust. The improvement that was observed belongs to the rule.

These findings come from recorded traces and from a replay that assumes the agent does not adapt. They do not show that REM protects a live agent, and they do not rank REM against any published defense. Their value is narrower and, within its bounds, firm: a transparent instance of a widely proposed design was built, compared fairly with the simplest alternatives, and found to be no better than them on the evidence available at the tool boundary. Where an improvement was observed, it came from a deterministic rule and not from the learned, consequence-aware decision that the thesis set out to evaluate. The thesis reports that result as it was measured.

References

APA 7th edition. One consolidated list for all chapters and appendices. Preprints are marked. Official and regulatory sources are marked and are not treated as research literature. Where an author list is abbreviated in the index record, this is stated. The reading level of the works closest to this thesis is stated at the end of their entries: "full text read" (six papers, read from author-supplied PDFs on 11 November 2026) or "abstract only". All other entries were verified at record level, as recorded in `REM_FINAL_THESIS/REFERENCES_VERIFIED.md`*.*

Andriushchenko, M., Souly, A., Dziemian, M., Duenas, D., Lin, M., Wang, J., Hendrycks, D., Zou, A., Kolter, Z., Fredrikson, M., Winsor, E., Wynne, J., Gal, Y., & Davies, X. (2025). AgentHarm: A benchmark for measuring harmfulness of LLM agents. In *The Thirteenth International Conference on Learning Representations (ICLR 2025)*. https://arxiv.org/abs/2410.09024

Arp, D., Quiring, E., Pendlebury, F., Warnecke, A., Pierazzi, F., Wressnegger, C., Cavallaro, L., & Rieck, K. (2022). Dos and don'ts of machine learning in computer security. In *31st USENIX Security Symposium* (pp. 3971–3988). USENIX Association.

Basseville, M., & Nikiforov, I. V. (1993). *Detection of abrupt changes: Theory and application*. Prentice Hall.

Brier, G. W. (1950). Verification of forecasts expressed in terms of probability. *Monthly Weather Review, 78*(1), 1–3. https://doi.org/10.1175/1520-0493(1950)078<0001:VOFEIT>2.0.CO;2

Calboreanu, E. (2026). LATTICE: A governance-first architecture for authorized autonomous AI operations. *Frontiers in Artificial Intelligence, 9*, Article 1800407. https://doi.org/10.3389/frai.2026.1800407

Castro-Maldonado, V., Aceves-Fernández, M. A., García-Noguez, L. R., & Pedraza-Ortega, J. C. (2026). Semantic firewalls with online ensemble learning for secure agentic RAG systems in financial chatbots. *AI, 7*(3), Article 80. https://doi.org/10.3390/ai7030080

Chandola, V., Banerjee, A., & Kumar, V. (2009). Anomaly detection: A survey. *ACM Computing Surveys, 41*(3), Article 15, 1–58. https://doi.org/10.1145/1541880.1541882

Chandola, V., Banerjee, A., & Kumar, V. (2012). Anomaly detection for discrete sequences: A survey. *IEEE Transactions on Knowledge and Data Engineering*, *24*(5), 823–839. https://doi.org/10.1109/TKDE.2010.235

Chen, H.-H. (2026). *Insuring every action: An authority frontier framework for runtime actuarial control of autonomous AI agents* (arXiv:2605.25632) [Preprint]. arXiv. https://arxiv.org/abs/2605.25632

Chen, S., Piet, J., Sitawarin, C., & Wagner, D. (2025). StruQ: Defending against prompt injection with structured queries. In *34th USENIX Security Symposium*. USENIX Association.

Chen, Y., Li, H., Zheng, Z., Wu, D., Song, Y., & Hooi, B. (2025). Defense against prompt injection attack by leveraging attack techniques. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)* (pp. 18331–18347). Association for Computational Linguistics. https://doi.org/10.18653/v1/2025.acl-long.897

Chen, Z., Chen, J., Chen, J., & Sra, M. (2025). *Standard benchmarks fail — Auditing LLM agents in finance must prioritize risk* (arXiv:2502.15865) [Preprint]. arXiv. https://arxiv.org/abs/2502.15865

Chen, Z., Dong, D., Liu, H., Li, J., Zhai, J., Xu, D., & Pu, B. (2026). *Cordon: Semantic transactions for tool-using LLM agents* (arXiv:2606.17573) [Preprint]. arXiv. https://arxiv.org/abs/2606.17573

Chen, Z., Kang, M., & Li, B. (2025). ShieldAgent: Shielding agents via verifiable safety policy reasoning. In *Proceedings of the 42nd International Conference on Machine Learning* (Proceedings of Machine Learning Research, Vol. 267, pp. 8313–8344). PMLR.

Chen, Z., Xiang, Z., Xiao, C., Song, D., & Li, B. (2024). AgentPoison: Red-teaming LLM agents via poisoning memory or knowledge bases. In *Advances in Neural Information Processing Systems 37 (NeurIPS 2024)*.

Chennabasappa, S., Nikolaidis, C., Song, D., Molnar, D., Ding, S., Wan, S., Whitman, S., Deason, L., Doucette, N., Montilla, A., Gampa, A., de Paola, B., Gabi, D., Crnkovich, J., Testud, J.-C., He, K., Chaturvedi, R., Zhou, W., & Saxe, J. (2025). *LlamaFirewall: An*

open source guardrail system for building secure AI agents (arXiv:2505.03574) [Preprint]. arXiv. https://arxiv.org/abs/2505.03574

Chow, C. K. (1970). On optimum recognition error and reject tradeoff. *IEEE Transactions on Information Theory, 16*(1), 41–46. https://doi.org/10.1109/TIT.1970.1054406

Cox, D. R. (1958). The regression analysis of binary sequences. *Journal of the Royal Statistical Society: Series B (Methodological), 20*(2), 215–232. https://doi.org/10.1111/j.2517-6161.1958.tb00292.x

Davis, J., & Goadrich, M. (2006). The relationship between precision-recall and ROC curves. In *Proceedings of the 23rd International Conference on Machine Learning* (pp. 233–240). ACM. https://doi.org/10.1145/1143844.1143874

Debenedetti, E., Shumailov, I., Fan, T., Hayes, J., Carlini, N., Fabian, D., Kern, C., Shi, C., Terzis, A., & Tramèr, F. (2025). *Defeating prompt injections by design* (arXiv:2503.18813v2) [Preprint]. arXiv. https://arxiv.org/abs/2503.18813 [Official repository README read on 13 November 2026 (github.com/google-research/camel-prompt-injection, commit f083b6b)]

Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M., & Tramèr, F. (2024). AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems 37 (NeurIPS 2024), Datasets and Benchmarks Track*.

Efron, B. (1979). Bootstrap methods: Another look at the jackknife. *The Annals of Statistics, 7*(1). https://doi.org/10.1214/aos/1176344552

Elkan, C. (2001). The foundations of cost-sensitive learning. In *Proceedings of the Seventeenth International Joint Conference on Artificial Intelligence (IJCAI-01)* (pp. 973–978).

European Parliament & Council of the European Union. (2024). *Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)*. Official Journal of the European Union. https://eur-lex.europa.eu/eli/reg/2024/1689/oj [Official source]

Fawcett, T. (2006). An introduction to ROC analysis. *Pattern Recognition Letters, 27*(8), 861–874. https://doi.org/10.1016/j.patrec.2005.10.010

Forrest, S., Hofmeyr, S. A., Somayaji, A., & Longstaff, T. A. (1996). A sense of self for Unix processes. In *Proceedings of the 1996 IEEE Symposium on Security and Privacy* (pp. 120–128). IEEE. https://doi.org/10.1109/SECPRI.1996.502675

Fu, X., Li, S., Wang, Z., et al. (2024). *Imprompter: Tricking LLM agents into improper tool use* (arXiv:2410.14923) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2410.14923 [Author list abbreviated from the index record; full list not verified]

Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security* (pp. 79–90). ACM. https://doi.org/10.1145/3605764.3623985

Guo, C., Pleiss, G., Sun, Y., & Weinberger, K. Q. (2017). On calibration of modern neural networks. In *Proceedings of the 34th International Conference on Machine Learning* (Proceedings of Machine Learning Research, Vol. 70, pp. 1321–1330). PMLR.

Hasan, M. M., Li, H., Fallahzadeh, E., Rajbahadur, G. K., Adams, B., & Hassan, A. E. (2026). Model Context Protocol (MCP) at first glance: Studying the security and maintainability of MCP servers. *ACM Transactions on Software Engineering and Methodology*. https://doi.org/10.1145/3814959

Hempel, K., Loose, N., Cavallaro, L., et al. (2026). *Kairos: Transactional security enforcement at the system boundary for LLM agents* (arXiv:2610.18457) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2610.18457 [Four authors; author list abbreviated in the index record. Abstract only]

Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. *MIS Quarterly, 28*(1), 75–106. https://doi.org/10.2307/25148625

Hines, K., Lopez, G., Hall, M., Zarfati, F., Zunger, Y., & Kiciman, E. (2024). *Defending against indirect prompt injection attacks with spotlighting* (arXiv:2403.14720) [Preprint]. arXiv. https://arxiv.org/abs/2403.14720

Hossain, E., Nipu, M. M. H., Ornee, T. N., Rana, R., & Yousefi, N. (2026). NEXUS: Structured runtime safety for tool-using LLM agents. In *Findings of the Association for Computational Linguistics: AACL 2026*. Association for Computational Linguistics. https://doi.org/10.18653/2026.findings-aacl.112 [Earlier preprint: arXiv:2607.19356. Full

text not read; abstract and the authors' repository (github.com/eliashossain001/nexus, commit 36d7e0b: README and working documents) only]

Hua, W., Yang, X., Jin, M., Li, Z., Cheng, W., Tang, R., & Zhang, Y. (2024). TrustAgent: Towards safe and trustworthy LLM-based agents. In *Findings of the Association for Computational Linguistics: EMNLP 2024* (pp. 10000–10016). Association for Computational Linguistics. https://doi.org/10.18653/v1/2024.findings-emnlp.585

Huang, C., Huang, X., Tran, N. P., & Milani Fard, A. (2026). Model Context Protocol threat modeling and analysis of vulnerabilities to prompt injection with tool poisoning. *Journal of Cybersecurity and Privacy, 6*(3), Article 84. https://doi.org/10.3390/jcp6030084

Jackson, F. (2025). *Designing a policy engine for agentic AI systems: From governance requirements to runtime enforcement* [Working paper]. SSRN. https://doi.org/10.2139/ssrn.5904104

Jacob, D., Alzahrani, H., Hu, Z., Alomair, B., & Wagner, D. (2025). PromptShield: Deployable detection for prompt injection attacks. In *Proceedings of the Fifteenth ACM Conference on Data and Application Security and Privacy* (pp. 341–352). ACM. https://doi.org/10.1145/3714393.3726501 [Crossref records issued year 2024 and online publication 2025]

Jia, F., Wu, T., Qin, X., & Squicciarini, A. (2025). The Task Shield: Enforcing task alignment to defend against indirect prompt injection in LLM agents. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*. Association for Computational Linguistics. https://aclanthology.org/2025.acl-long.1435/ [Full text read, 11 November 2026]

Jia, H., Liu, Y., Chong, B., Yang, Y., Chen, Y., Liang, J., Li, Q., Lu, H., Xu, K., Zheng, H., Zhang, C., Peng, H., & Yu, P. S. (2026). *FinHarness: An inline lifecycle safety harness for finance LLM agents* (arXiv:2605.27333) [Preprint]. arXiv. https://arxiv.org/abs/2605.27333

Jia, X., Liao, J., Qin, S., et al. (2026). *SkillJect: Effectively automating skill-based prompt injection for skill-enabled agents* (arXiv:2602.14211) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2602.14211 [Author list abbreviated from the index record; full list not verified]

Jiang, C., Zhang, W., Pan, X., Hong, G., & Yang, M. (2025). *Think twice before you act: Enhancing agent behavioral safety with thought correction* (arXiv:2505.11063) [Preprint; accepted to ICML 2026]. arXiv. https://arxiv.org/abs/2505.11063

Johnson, S., Pham, V., & Le, T. (2025). The dangers of indirect prompt injection attacks on LLM-based autonomous web navigation agents: A demonstration. In *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing: System Demonstrations* (pp. 729–738). Association for Computational Linguistics. https://doi.org/10.18653/v1/2025.emnlp-demos.55

Kanaker, H., Fakhouri, H., Abdel Karim, N., Abuhamdeh, M., Ismail, N. H. A., & Fakhouri, S. (2026). Securing tool-using AI agents against injection and authority misuse. *Computation, 14*(5), Article 98. https://doi.org/10.3390/computation14050098

Kaptein, M., Khan, V.-J., & Podstavnychy, A. (2026). *Runtime governance for AI agents: Policies on paths* (arXiv:2603.16586) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2603.16586

Kekatos, N., Basagiannis, S., Chintri, M., Lekidis, A., Nianios, T., Seitoglou, I., Temperekidis, A., & Katsaros, P. (2026). Formal runtime verification for tool-using LLM agents: An offline same-benchmark study on AgentDojo and STAC. In *Proceedings of the 2026 8th Joint Workshop on CPS&IoT Security and Privacy* (pp. 129–142). ACM. https://doi.org/10.1145/3847353.3847499

Kodathala, S. V. (2026). *aiAuthZ: Off-host, identity-bound authorization for AI agents* (arXiv:2607.05518) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2607.05518 [arXiv text not read; abstract and the authors' repository whitepaper (github.com/Sports-Vision-Inc/aiAuthZ, commit 6eaac86) read]

Kull, M., Silva Filho, T., & Flach, P. (2017). Beta calibration: A well-founded and easily implemented improvement on logistic calibration for binary classifiers. In *Proceedings of the 20th International Conference on Artificial Intelligence and Statistics* (Proceedings of Machine Learning Research, Vol. 54, pp. 623–631). PMLR.

le Cessie, S., & van Houwelingen, J. C. (1992). Ridge estimators in logistic regression. *Applied Statistics, 41*(1), 191–201. https://doi.org/10.2307/2347628

Li, E., Mallick, T., Rose, E., Robertson, W., Oprea, A., & Nita-Rotaru, C. (2026). ACE: A security architecture for LLM-integrated app systems. In *Proceedings of the 2026 Network and Distributed System Security Symposium (NDSS)*. Internet Society. https://doi.org/10.14722/ndss.2026.230352

Li, F. (2026). *OpenClaw PRISM: A zero-fork, defense-in-depth runtime security layer for tool-augmented LLM agents* (arXiv:2603.11853) [Preprint]. arXiv. https://arxiv.org/abs/2603.11853

Li, H., Liu, X., Chiu, C., Li, D., Zhang, N., & Xiao, C. (2025). DRIFT: Dynamic rule-based defense with injection isolation for securing LLM agents. In *Advances in Neural Information Processing Systems 38 (NeurIPS 2025)* (pp. 92825–92853). https://doi.org/10.52202/085713-2791

Li, M. Q., Fung, B. C. M., Li, B., Ismail, H., & Iqbal, F. (2026). *Taxonomy and consistency analysis of safety benchmarks for AI agents* (arXiv:2605.16282) [Preprint]. arXiv. https://arxiv.org/abs/2605.16282

Lin, J., Zhou, Z., Zheng, Z., Liu, S., Xu, T., Chen, Y., & Chen, E. (2026). VIGIL: Defending LLM agents against tool-stream injection via verify-before-commit. In *Proceedings of the 64th Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)* (pp. 9764–9785). Association for Computational Linguistics. https://doi.org/10.18653/v1/2026.acl-long.443

Lin, W., Yu, C., Lin, X., Cao, S., Chen, X., Xue, L., Yu, L., Sha, L., & Wu, C. (2026). *DreamGuard: Efficient runtime guardrail for LLM agents via risk-aware world model* (arXiv:2608.05695) [Preprint]. arXiv. https://arxiv.org/abs/2608.05695

Liu, H., Ilyushin, E., Ni, J., & Zhu, M. (2026). *SafeAgent: A runtime protection architecture for agentic systems* (arXiv:2604.17562) [Preprint]. arXiv. https://arxiv.org/abs/2604.17562

Liu, T., Deng, Z., Meng, G., et al. (2023). *Demystifying RCE vulnerabilities in LLM-integrated apps* (arXiv:2309.02926) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2309.02926 [Author list abbreviated from the index record; full list not verified]

Liu, Y., Deng, G., Li, Y., et al. (2023). *Prompt injection attack against LLM-integrated applications* (arXiv:2306.05499) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2306.05499 [Author list abbreviated from the index record; full list not verified]

Liu, Y., Jia, Y., Geng, R., Jia, J., & Gong, N. Z. (2024). Formalizing and benchmarking prompt injection attacks and defenses. In *33rd USENIX Security Symposium* (pp. 1831–1847). USENIX Association.

Liu, Z. (2026). *Passing the test you trained on: Re-evaluating prompt-injection detectors for LLM agents* (arXiv:2610.03448) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2610.03448

Lorden, G. (1971). Procedures for reacting to a change in distribution. *The Annals of Mathematical Statistics, 42*(6), 1897–1908. https://doi.org/10.1214/aoms/1177693055

Lundberg, S. M., & Lee, S.-I. (2017). A unified approach to interpreting model predictions. In *Advances in Neural Information Processing Systems 30 (NIPS 2017)* (pp. 4765–4774).

Luo, W., Dai, S., Liu, X., Banerjee, S., Sun, H., Chen, M., & Xiao, C. (2025). AGrail: A lifelong agent guardrail with effective and adaptive safety detection. In *Proceedings of the 63rd Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)* (pp. 8104–8139). Association for Computational Linguistics. https://doi.org/10.18653/v1/2025.acl-long.399

Mao, Q., Wang, J., Liu, Y., Zhu, L., Ma, C., & Yan, J. (2026). *SoK: Security of autonomous LLM agents in agentic commerce* (arXiv:2604.15367) [Preprint]. arXiv. https://arxiv.org/abs/2604.15367

Mou, Y., Xue, Z., Li, L., Liu, P., Zhang, S., Ye, W., & Shao, J. (2026). ToolSafe: Enhancing tool invocation safety of LLM-based agents via proactive step-level guardrail and feedback. In *Findings of the Association for Computational Linguistics: ACL 2026* (pp. 37125–37153). Association for Computational Linguistics. https://doi.org/10.18653/v1/2026.findings-acl.1850

Moustakides, G. V. (1986). Optimal stopping times for detecting changes in distributions. *The Annals of Statistics, 14*(4). https://doi.org/10.1214/aos/1176350164

Naeini, M. P., Cooper, G., & Hauskrecht, M. (2015). Obtaining well calibrated probabilities using Bayesian binning. *Proceedings of the AAAI Conference on Artificial Intelligence, 29*(1). https://doi.org/10.1609/aaai.v29i1.9602

Ng, A. Y., & Jordan, M. I. (2002). On discriminative vs. generative classifiers: A comparison of logistic regression and naive Bayes. In *Advances in Neural Information Processing Systems 14 (NIPS 2001)*. https://papers.nips.cc/paper/2020-on-discriminative-vs-generative-classifiers-a-comparison-of-logistic-regression-and-naive-bayes

Niculescu-Mizil, A., & Caruana, R. (2005). Predicting good probabilities with supervised learning. In *Proceedings of the 22nd International Conference on Machine Learning* (pp. 625–632). ACM. https://doi.org/10.1145/1102351.1102430

OWASP Gen AI Security Project. (2025). *LLM01:2025 Prompt injection*. OWASP Foundation. https://genai.owasp.org/llmrisk/llm01-prompt-injection/ [Official source]

Page, E. S. (1954). Continuous inspection schemes. *Biometrika, 41*(1–2), 100–115. https://doi.org/10.1093/biomet/41.1-2.100

Patil, S. G., Zhang, T., Fang, V., et al. (2024). *GoEX: Perspectives and designs towards a runtime for autonomous LLM applications* (arXiv:2404.06921) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2404.06921 [Author list abbreviated from the index record; full list not verified]

Pedro, R., Amaral de Castro, D., Carreira, P., et al. (2023). *From prompt injections to SQL injection attacks: How protected is your LLM-integrated web application?* (arXiv:2308.01990) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2308.01990 [Author list abbreviated from the index record; full list not verified]

Peffers, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A design science research methodology for information systems research. *Journal of Management Information Systems, 24*(3), 45–77. https://doi.org/10.2753/MIS0742-1222240302

Platt, J. C. (2000). Probabilistic outputs for support vector machines and comparisons to regularized likelihood methods. In A. J. Smola, P. Bartlett, B. Schölkopf, & D. Schuurmans (Eds.), *Advances in large-margin classifiers* (pp. 61–74). MIT Press. https://doi.org/10.7551/mitpress/1113.003.0008 [Crossref registers this chapter, pp. 61–74, under the title “Probabilities for SV Machines”; the printed chapter title was not checked]

Ray, S. (2026). *What can be enforced? A theory of certified runtime safety for tool-using agents* (arXiv:2607.22868) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2607.22868

Reynolds, M. R., Jr., & Stoumbos, Z. G. (1999). A CUSUM chart for monitoring a proportion when inspecting continuously. *Journal of Quality Technology*, *31*(1), 87–108. https://doi.org/10.1080/00224065.1999.11979900

Ruan, Y., Dong, H., Wang, A., Pitis, S., Zhou, Y., Ba, J., Dubois, Y., Maddison, C. J., & Hashimoto, T. (2024). Identifying the risks of LM agents with an LM-emulated sandbox. In *The Twelfth International Conference on Learning Representations (ICLR 2024)*.

Schick, T., Dwivedi-Yu, J., Dessì, R., Raileanu, R., Lomeli, M., Hambro, E., Zettlemoyer, L., Cancedda, N., & Scialom, T. (2023). Toolformer: Language models can teach themselves to use tools. In *Advances in Neural Information Processing Systems 36 (NeurIPS 2023)*.

Schneider, F. B. (2000). Enforceable security policies. *ACM Transactions on Information and System Security*, *3*(1), 30–50. https://doi.org/10.1145/353323.353382

She, Y., Liang, Y., & Kang, E. (2026). Safeguarding LLM agents from misalignment through provenance analysis. In *Proceedings of the 41st IEEE/ACM International Conference on Automated Software Engineering* (pp. 3036–3048). ACM. https://doi.org/10.1145/3832783.3837535 (earlier preprint: arXiv:2607.01236)

Shi, J., Yuan, Z., Tie, G., Zhou, P., Gong, N., & Sun, L. (2026). Prompt injection attack to tool selection in LLM agents. In *Proceedings of the 2026 Network and Distributed System Security Symposium (NDSS)*. Internet Society. https://doi.org/10.14722/ndss.2026.230675

Shi, T., He, J., Wang, Z., Wu, L., Li, H., Guo, W., & Song, D. (2025). *Progent: Securing AI agents with privilege control* (arXiv:2504.11703) [Preprint]. arXiv. https://arxiv.org/abs/2504.11703 [Official code repository read on 13 November 2026 (github.com/sunblaze-ucb/progent, commits 9befb41 and b02783b); its manual banking policy is used in Chapter 4]

Sommer, R., & Paxson, V. (2010). Outside the closed world: On using machine learning for network intrusion detection. In *2010 IEEE Symposium on Security and Privacy* (pp. 305–316). IEEE. https://doi.org/10.1109/SP.2010.25

Storf, S., Barton-Cooper, R., Peters-Gill, J., et al. (2026). *Constitutional black-box monitoring for scheming in LLM agents* (arXiv:2603.00829) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2603.00829 [Author list abbreviated from the index record; full list not verified]

Tsai, L., & Bagdasarian, E. (2025). Contextual agent security: A policy for every purpose. In *Proceedings of the Workshop on Hot Topics in Operating Systems (HotOS '25)* (pp. 8–17). ACM. https://doi.org/10.1145/3713082.3730378

Wang, C. L., Singhal, T., Kelkar, A., & Tuo, J. (2025). *MI9: An integrated runtime governance framework for agentic AI* (arXiv:2508.03858) [Preprint]. arXiv. https://arxiv.org/abs/2508.03858

Wang, H., Poskitt, C. M., & Sun, J. (2026). AgentSpec: Customizable runtime enforcement for safe and reliable LLM agents. In *Proceedings of the IEEE/ACM 48th International Conference on Software Engineering (ICSE '26)*. ACM. https://doi.org/10.1145/3744916.3764546

Wang, H., Poskitt, C. M., Wei, J., & Sun, J. (2025). *ProbGuard: Probabilistic runtime monitoring for LLM agent safety* (arXiv:2508.00500; earlier versions titled "Pro2Guard") [Preprint]. arXiv. https://arxiv.org/abs/2508.00500

Wang, L., Ma, C., Feng, X., Zhang, Z., Yang, H., Zhang, J., Chen, Z., Tang, J., Chen, X., Lin, Y., Zhao, W. X., Wei, Z., & Wen, J. (2024). A survey on large language model based autonomous agents. *Frontiers of Computer Science, 18*(6), Article 186345. https://doi.org/10.1007/s11704-024-40231-1

Wang, P., Li, Y., & Tian, Y. (2026). *Reframing LLM agent security as an agent-human interaction problem* (arXiv:2605.24309) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2605.24309

Wang, S., Zhu, S., & Li, R. (2026). Runtime policy enforcement for MCP-based LLM agents. *Electronics, 15*(13), Article 2829. https://doi.org/10.3390/electronics15132829

Wang, Y., Han, X., Shang, D., Tang, Y., & Liu, B. (2026). *Safety, or just capability? A validity audit of agent-safety benchmarks* (arXiv:2607.28685) [Preprint]. arXiv. https://arxiv.org/abs/2607.28685

Wang, Z., Siu, V., Ye, Z., Shi, T., Nie, Y., Zhao, X., Wang, C., Guo, W., & Song, D. (2025). AGENTVIGIL: Automatic black-box red-teaming for indirect prompt injection against LLM agents. In *Findings of the Association for Computational Linguistics: EMNLP 2025* (pp. 23159–23172). Association for Computational Linguistics. https://doi.org/10.18653/v1/2025.findings-emnlp.1258

Wei, B., Zhang, Y., Pan, J., et al. (2026). *ClawSafety: "Safe" LLMs, unsafe agents* (arXiv:2604.01438) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2604.01438 [Author list abbreviated from the index record; full list not verified]

Wen, T., Wang, C., Yang, X., Tang, H., Xie, Y., Lyu, L., Dou, Z., & Wu, F. (2025). Defending against indirect prompt injection by instruction detection. In *Findings of the Association for Computational Linguistics: EMNLP 2025* (pp. 19472–19487). Association for Computational Linguistics. https://doi.org/10.18653/v1/2025.findings-emnlp.1060

Wu, F., Cecchetti, E., & Xiao, C. (2024). *System-level defense against indirect prompt injection attacks: An information flow control perspective* (arXiv:2409.19091) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2409.19091

Wu, Y., Roesner, F., Kohno, T., Zhang, N., & Iqbal, U. (2025). IsolateGPT: An execution isolation architecture for LLM-based systems. In *Proceedings of the 2025 Network and Distributed System Security Symposium (NDSS)*. Internet Society. https://doi.org/10.14722/ndss.2025.241131

Xiang, Z., Zheng, L., Li, Y., Hong, J., Li, Q., Xie, H., Zhang, J., Xiong, Z., Xie, C., Yang, C., Song, D., & Li, B. (2025). GuardAgent: Safeguard LLM agents via knowledge-enabled reasoning. In *Proceedings of the 42nd International Conference on Machine Learning* (Proceedings of Machine Learning Research, Vol. 267, pp. 68316–68342). PMLR.

Xin, Q. (2026). TapGuard: Temperature-calibrated execute–confirm–block routing for LLM-powered mobile agents. *International Journal of Mobile Applications and Technologies, 2*(2). https://doi.org/10.51137/wrp.ijmat.1051

Yan, B., Zhang, Q., Kan, Z., Suya, F., & Wang, S. (2026). *PROVISO: Provenance-informed action selection for secure LLM agents* (arXiv:2610.27115) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2610.27115 [Full text read, 11 November 2026]

Yang, C. (2026). *AgentTrust: Runtime safety evaluation and interception for AI agent tool use* (arXiv:2605.04785) [Preprint]. arXiv. https://arxiv.org/abs/2605.04785

Yang, T., Mi, Z., Huang, Y., Zhang, G., Chen, J., Yang, Y., & Yi, J. (2026). *AgentBoundary: Counterfactual evaluation of safety in tool-using LLM agents* (arXiv:2609.33658) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2609.33658 [Full text read, 11 November 2026]

Yang, Z., Li, R., Qiang, Q., Wang, J., Lou, F., Li, M., Cheng, D., Xu, R., Lian, H., Zhang, S., Liang, X., Huang, X., Wei, Z., Liu, Z., Guo, X., Wang, H., Chen, R., & Zhang, L. (2026). *FinVault: Benchmarking financial agent safety in execution-grounded environments* (arXiv:2601.07853) [Withdrawn preprint]. arXiv. https://arxiv.org/abs/2601.07853

Yao, S., Zhao, J., Yu, D., Du, N., Shafran, I., Narasimhan, K., & Cao, Y. (2023). ReAct: Synergizing reasoning and acting in language models. In *The Eleventh International Conference on Learning Representations (ICLR 2023)*.

Yu, M., Meng, F., Zhou, X., Wang, S., Mao, J., Pan, L., Chen, T., Wang, K., Li, X., Zhang, Y., An, B., & Wen, Q. (2025). A survey on trustworthy LLM agents: Threats and countermeasures. In *Proceedings of the 31st ACM SIGKDD Conference on Knowledge Discovery and Data Mining V.2* (pp. 6216–6226). ACM. https://doi.org/10.1145/3711896.3736561

Yuan, T., He, Z., Dong, L., Wang, Y., Zhao, R., Xia, T., Xu, L., Zhou, B., Li, F., Zhang, Z., Wang, R., & Liu, G. (2024). R-Judge: Benchmarking safety risk awareness for LLM agents. In *Findings of the Association for Computational Linguistics: EMNLP 2024* (pp. 1467–1490). Association for Computational Linguistics. https://doi.org/10.18653/v1/2024.findings-emnlp.79

Zadrozny, B., & Elkan, C. (2002). Transforming classifier scores into accurate multiclass probability estimates. In *Proceedings of the Eighth ACM SIGKDD International Conference on Knowledge Discovery and Data Mining* (pp. 694–699). ACM. https://doi.org/10.1145/775047.775151

Zhan, Q., Fang, R., Panchal, H. S., & Kang, D. (2025). Adaptive attacks break defenses against indirect prompt injection attacks on LLM agents. In *Findings of the Association for*

Computational Linguistics: NAACL 2025 (pp. 7116–7132). Association for Computational Linguistics. https://aclanthology.org/2025.findings-naacl.395/

Zhan, Q., Liang, Z., Ying, Z., & Kang, D. (2024). InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024* (pp. 10471–10506). Association for Computational Linguistics. https://doi.org/10.18653/v1/2024.findings-acl.624

Zhang, B., Tan, Y., Shen, Y., Salem, A., Backes, M., Zannettou, S., & Zhang, Y. (2025). Breaking agents: Compromising autonomous LLM agents through malfunction amplification. In *Proceedings of the 2025 Conference on Empirical Methods in Natural Language Processing* (pp. 34952–34964). Association for Computational Linguistics. https://doi.org/10.18653/v1/2025.emnlp-main.1771

Zhang, C., Wan, Z., Yu, X., Wu, J., Wen, Q., Zhou, P., Zhao, W., & Tsang, I. (2026). *Calibration is not control: Intervention value for LLM-agent oversight* (arXiv:2606.21399) [Preprint]. arXiv. https://arxiv.org/abs/2606.21399 (title as indexed on 28 Oct 2026; an earlier version was titled “Calibration is not control: Why LLM-agent oversight needs intervention”) [Full text read, 11 November 2026]

Zhang, H., Huang, J., Mei, K., Yao, Y., Wang, Z., Zhan, C., Wang, H., & Zhang, Y. (2025). Agent Security Bench (ASB): Formalizing and benchmarking attacks and defenses in LLM-based agents. In *The Thirteenth International Conference on Learning Representations (ICLR 2025)*.

Zhang, Y., Chen, K., Gao, J., et al. (2024). *Towards action hijacking of large language model-based agent* (arXiv:2412.10807) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2412.10807 [Author list abbreviated from the index record; full list not verified]

Zhang, Y., Shen, F., Yan, T., & Zhang, H. (2026). *CASEL: Consequence-aware selective execution for reliable long-horizon tool-using agents* (arXiv:2610.36570) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2610.36570 [Full text read, 11 November 2026]

Zhong, P. Y., Chen, S., Wang, R., et al. (2025). *RTBAS: Defending LLM agents against prompt injection and privacy leakage* (arXiv:2502.08966) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2502.08966 [Author list abbreviated from the index record; full list not verified]

Zhu, K., Yang, X., Wang, J., Guo, W., & Wang, W. Y. (2025). MELON: Provable defense against indirect prompt injection attacks in AI agents. In *Proceedings of the 42nd International Conference on Machine Learning* (Proceedings of Machine Learning Research, Vol. 267). PMLR. [Full text read, 11 November 2026]

Zhu, K., Zhang, J., Qi, Z., et al. (2025). *SafeScientist: Toward risk-aware scientific discoveries by LLM agents* (arXiv:2505.23559) [Preprint]. arXiv. https://doi.org/10.48550/arXiv.2505.23559 [Author list abbreviated from the index record; full list not verified]

Appendix A: Systematic Review: Search Strings, Supporting Tables and Evidence Matrix

This appendix holds material of the systematic review that Chapter 2 summarizes: the comparative evidence matrix of the 42 defense and design studies, and three supporting tables. The tables are reproduced unchanged from the review record of September and October 2026.

A.1 Database searches

Table A.1. Database searches (OpenAlex; 25 September 2026; years 2019–2026)

Query	Exact search string	Blocks	Records screened	Index estimate
Q1 (pages 1–2)	LLM agent indirect prompt injection runtime defense tool use	A+B+C	50	1,366
Q2 (pages 1–2)	LLM agent security runtime monitoring guardrail tool call	A+B+C	49	1,123
Q3	tool-using language model agent behavioral trajectory monitoring anomaly detection safety	A+B+C	24	5,572
Q4	LLM agent provenance goal alignment tool call misalignment detection	A+B+C	25	484
Q5	prompt injection benchmark tool-integrated LLM agents attacks and defenses evaluation	A+B+C	24	2,950
Q6	LLM agent memory poisoning goal hijacking multi-step attack	A+B	24	579
Q7	financial LLM agent security prompt injection tool misuse	Fin+A+B+C	24	1,368
Q8	banking agent safety benchmark financial transaction LLM agent	Fin+A+B	25	536
Q9	calibrated risk score intervention policy LLM agent runtime safety	A+B+C	25	880
Q10	privilege control policy enforcement LLM agents tool calls prompt injection	A+B+C	25	1,380
Q11	pre-execution action validation guardrail autonomous LLM agent unsafe actions	A+B+C	25	744
Total			**320**	—

A.2 Benchmarks used by included studies

Table A.2. Critical evaluation of benchmarks used by included studies

Benchmark (source)	What it measures	Threat model	Execution realism	Financial relevance	Multi-step coverage	Utility measured	Limitations
AgentDojo (Debenedetti et al., 2024)	Task utility, utility under attack and targeted attack success per episode; 97 user tasks, 629 security cases	Indirect injection via tool outputs	Executable, stateful tools; outcomes checked against environment state	One of four suites is Banking; no finance-specific analysis in the verified record	Yes (multi-tool episodes); number of genuinely multi-step attacks not verified	Yes, jointly with security	Limited number of distinct tasks; robustness claims bounded by the attacks evaluated (Section 2.3.2)
InjecAgent (Zhan et al., 2024)	Whether the next action after one injected tool response serves the attacker; 1,054 cases	Indirect injection (direct harm; data exfiltration)	Simulated single tool response	Not reported	No (short cases)	No	Isolates injection susceptibility; no benign utility
ASB (H. Zhang et al., 2025)	Attack success across stages; utility–security trade-off metric	Direct/ indirect injection, memory poisoning, backdoor, mixed	Agent framework with >400 tools	Finance is one of 10 scenarios; not analysed separately	Yes (multiple stages)	Yes	Breadth over depth per scenario
AgentHarm (Andriushchenko et al., 2025)	Whether harmful multi-step tasks are completed	Malicious user	Synthetic tools	Fraud is one of 11 categories	Yes	Capability retention after jailbreak	Different threat actor from REM's

Benchmark (source)	What it measures	Threat model	Execution realism	Financial relevance	Multi-step coverage	Utility measured	Limitations
ToolEmu (Ruan et al., 2024)	Risky failures without adversary; 144 cases	No adversary	LM-emulated tools	Not reported (financial loss among risk examples)	Yes	Not the focus	Emulator and evaluator are LMs
R-Judge (Yuan et al., 2024)	LLM ability to judge safety risk in 569 multi-turn records	Behavioural safety risks	Recorded interactions (offline)	Not reported	Yes	Not applicable	Offline judgement, not runtime interception
ClawSafety (Wei et al., 2026)	Attack success in high-privilege workspaces; 120 scenarios, 2,520 trials	Injection via skills, email, web	Sandboxed real frameworks	Finance is one of five domains	Not verified	Not verified	Preprint; release announced
SIREN (J. Lin et al., 2026, VIGIL)	Tool-stream injection defense; 959 cases	Injection via tool metadata and feedback	Not verified	Not reported	Not verified	Utility under attack	Introduced with the defense evaluated on it
TS-Bench (Mou et al., 2026, ToolSafe)	Step-level detection of unsafe tool invocations	Unsafe invocations incl. injection	Not verified	Not reported	Yes (interaction history)	Benign completion	Introduced with the guardrail evaluated on it
NEXUS-Bench (Hossain et al., 2026)	Plan-level intervention accuracy; 128 held-out synthetic instances	Unsafe plans	Author-generated templates	Not reported	Plan-level	Paired benign cases	Authors: in-distribution results are upper bounds
FinVault (Z. Yang et al., 2026)	Financial-agent security (as originally reported)	Financial-agent attacks	Execution-grounded (as originally reported)	Yes	Not verified	Not verified	**Withdrawn by its authors; not evidence**

A.3 Where included defenses intervene and what they observe

Table A.3. Where included defenses intervene and what they observe

Point of intervention	Included studies	Primary unit observed	What this position can and cannot see
Input / context text	InstructDetector (Wen et al., 2025); PromptShield (Jacob et al., 2025); attack-technique defenses (Y. Chen et al., 2025); Spotlighting (Hines et al., 2024); PromptGuard 2 in LlamaFirewall (Chennabasappa et al., 2025)	An input or retrieved text	Sees text before the model acts; does not see how the agent then acts
Model	StruQ (S. Chen et al., 2025)	Model behaviour under separated channels	Addresses the instruction/data confusion; requires training and model access
System architecture / information flow	f-secure IFC (F. Wu et al., 2024); RTBAS (Zhong et al., 2025); ACE (E. Li et al., 2026); IsolateGPT (Y. Wu et al., 2025); CaMeL (Debenedetti et al., 2025)	Data flow into planning and between tools or apps	Can prevent untrusted data from steering control flow; changes how the agent executes
Policy / privilege at the tool boundary	Progent (T. Shi et al., 2025); AgentSpec (H. Wang et al., 2026); Conseca (Tsai & Bagdasarian, 2025); MCP policy-enforcement point (S. Wang et al., 2026); LATTICE (Calboreanu, 2026)	Each tool call against a policy	Deterministic and auditable; answers “is this permitted?”, not “how likely is this induced?”
Plan or reasoning	TrustAgent (Hua et al., 2024); Thought-Aligner (Jiang et al., 2025); NEXUS (Hossain et al., 2026); DRIFT planner (H. Li et al., 2025)	A plan or intermediate thought	Can intervene before actions exist; plans can change after new observations
Runtime around the agent loop	Task Shield (F. Jia et al., 2025); MELON (Zhu, Yang, et al., 2025); ProvenanceGuard (She et al., 2026); VIGIL (J. Lin et al., 2026); ToolSafe (Mou et al., 2026); DRIFT validator (H. Li et al., 2025); GuardAgent (Xiang et al., 2025);	Proposed action in context; sometimes the trajectory	Observes the action boundary; costs are latency and false interventions

Point of intervention	Included studies	Primary unit observed	What this position can and cannot see
	ShieldAgent (Z. Chen, Kang, & Li, 2025); AGrail (Luo et al., 2025); SafeScientist (K. Zhu et al., 2025); AlignmentCheck (Chennabasappa et al., 2025); AgentTrust (C. Yang, 2026); MI9 (C. L. Wang et al., 2025); PRISM (F. Li, 2026); ProbGuard (H. Wang et al., 2025); DreamGuard (Lin et al., 2026); SafeAgent (H. Liu et al., 2026); FinHarness (H. Jia et al., 2026); constitutional monitors (Storf et al., 2026)		
Post-action / transactional	Cordon (Z. Chen et al., 2026); GoEX (Patil et al., 2024)	Staged or reversible effects	Can hold, undo or confine effects; consumes rather than produces a risk judgement
Consequence gating	Actuarial Action Interface (H.-H. Chen, 2026)	Priced action	Prices consequence; does not estimate adversarial induction

A.4 Runtime responses reported by included systems

Table A.4. Runtime responses reported by included systems

System	Allow	Block	Modify / sanitize / revise	Escalate / human review	Restrict tools or privileges	Interrupt / terminate	Stage / roll back / undo	Decision granularity
Progent	Yes	Yes	Not Reported	Yes (approval for privilege expansion)	Yes	Not Reported	Not Reported	Per tool call
AgentSpec	Yes	Yes	Rule-defined	Not Verified	Not Reported	Not Verified	Not Reported	Per triggered event
RTBAS	Yes (auto-execute)	Not Verified	Not Reported	Yes (user confirmation)	Not Reported	Not Reported	Not Reported	Per tool call

System	Allow	Block	Modify / sanitize / revise	Escalate / human review	Restrict tools or privileges	Interrupt / terminate	Stage / roll back / undo	Decision granularity
MCP policy-enforcement point	Yes	Yes (deny)	Not Reported	Not Reported	Yes (capability tokens)	Not Reported	Not Reported	Per tool call with cross-step labels
LATTICE	Yes	Yes	Not Reported	Yes (confidence-based escalation to humans)	Not Reported	Not Reported	Not Reported	Per gated action
VIGIL	Yes (commit)	Yes (no commit)	Not Verified	Not Reported	Not Reported	Not Reported	Not Reported	Per speculative action
ToolSafe	Yes	Not Verified	Yes (guardrail feedback to agent)	Not Reported	Not Reported	Not Reported	Not Reported	Per tool invocation
MI9	Yes	Yes	Not Verified	Not Verified	Yes (graduated containment)	Yes	Not Reported	Continuous, agent-level
PRISM	Yes	Yes	Not Verified	Not Verified	Yes (policy controls)	Not Verified	Not Reported	Per hook, session accumulation
SafeAgent	Yes	Yes	Yes (sanitization, replanning, argument rewriting)	Yes (human escalation)	Not Verified	Yes	Yes (rollback)	Per step over session state (PARTLY UNVERIFIED)
AgentTrust	Yes	Yes	Yes (safer alternatives)	Yes (warn; review)	Not Reported	Not Reported	Not Reported	Per tool call, session chains

System	Allow	Block	Modify / sanitize / revise	Escalate / human review	Restrict tools or privileges	Interrupt / terminate	Stage / roll back / undo	Decision granularity
NEXUS	Yes	Yes	Yes (request revision)	Yes (request confirmation)	Not Reported	Not Reported	Not Reported	Per plan, before execution
DreamGuard	Yes (PASS)	Yes (BLOCK)	Not Reported	HOLD (semantics Not Verified)	Not Reported	Not Reported	Not Reported	Per action with trajectory state
FinHarness	Yes (approve)	Yes	Not Reported	Escalation to an advanced LLM judge (not a human)	Not Reported	Not Reported	Not Reported	Per step, cross-turn
Jackson	Yes	Yes (deny)	Yes (sanitize)	Yes (escalate)	Not Verified	Not Verified	Not Verified	Not Verified
Cordon	Not Applicable	Not Applicable	Not Applicable	Not Verified	Not Applicable	Not Applicable	Yes (shadow state; effect outbox)	Per task transaction
GoEX	Not Applicable	Not Applicable	Not Applicable	Post-facto human validation	Not Reported	Not Reported	Yes (undo; damage confinement)	Per executed action

A.5 Comparative evidence matrix of defense and design studies

Coding as in Section 2.10: Yes = reported in the verified record; NR = Not Reported (not evidence of absence); NV = Not Verified; NA = Not Applicable. Evidence levels refer to record-visible evidence (Section 2.2.5).

Table A.5. Comparative evidence for included defense and design studies (n = 42)

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/ Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
C. L. Wang et al. (2025) [P59]	Emergent/ unsafe agent behaviour (governance)	NA	Agent state and actions over time	Yes	Yes	Yes	Yes	NR	Yes	Yes (graduated containment)	NV	MOD
C. Yang (2026) [P64]	Unsafe tool-use side effects	Proposed tool call	Each proposed tool call (plus session chains)	Yes	Yes (seven chain detectors)	Yes	Yes (session tracker; no measurable effect in ablation)	NR	Yes	Yes (allow/warn/block/review; safer alternatives)	NR	MOD
Calboreanu (2026) [P40]	Unauthorised actions	NA	Proposed action at gated execution path	Yes	NR	Yes	NR	NR	Yes	Yes	NR	HIGH
Castr	Custom	User	Quer	Y	NR	NV	NR	N	Yes	NV	Yes	L

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
o-Maldonado et al. (2026) [P32]	er-data protection / security (threat model not specified in abstract)	queries and retrieved content	y/ response	es				R				IM
Chennabasappa et al. (2025) [P16]	Prompt injection; jailbreak; agent misalignment; insecure code	Untrusted inputs; agent reasoning; generated code	Inputs and chain-of-thought	Yes	Yes	NV	NV	NR	Yes	NV	NR	LIM
Debenedetti et al. (2025) [P52]	Prompt injection; data exfiltration	Untrusted data	Program control and data flow	Yes	NR	Yes	Yes (data flow across steps)	Yes	Yes	Yes	NR	MOD
E. Li et al. (2026) [P12]	Malicious apps; indirect prompt injection; plannin	Third-party apps and their outputs	Abstract plan, concrete plan and	Yes	NR	Yes	Yes	Yes	Yes	Yes	NR	MOD

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
	g/execution integrity and availability		execution									
F. Jia et al. (2025) [P01]	Indirect prompt injection	External data returned by tools	Each instruction and tool call	Yes	NR	Yes	NV	NR	Yes	NV	NR	HIGH
F. Li (2026) [P60]	IPI, unsafe tools, credential leakage, tampering	Tool inputs/outputs; files; credentials	Lifecycle hook events within a session	Yes	Yes (session risk accumulation)	Yes	Yes	NR	Yes	Yes	NR	LIM
F. Wu, Cecchetti, & Xiao (2024) [P08]	Indirect prompt injection	Any untrusted source feeding the planner	Planning inputs and structured plans	Yes	NR	Yes	Yes	Yes	Yes	Yes	NR	LIM

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
H. Jia et al. (2026) [P71]	Prompt-induced unauthorised financial actions	User queries; tool calls	Query and tool call with cross-turn state	Yes	Yes (partial: cross-turn drift, accumulated risk)	Yes	Yes	NR	Yes	Yes (block/approve; escalation to advanced judge)	Yes	LIM
H. Li et al. (2025) [P38]	Prompt injection via external tools	Tool outputs; memory stream	Function trajectory vs. planned trajectory	Yes	Yes	Yes	Yes	NR	Yes	Yes	NR	MOD
H. Liu et al. (2026) [P63]	Prompt injection propagating through workflows	Inputs and intermediate context	Stateful workflow	Yes	Yes	Yes	Yes	NR	Yes	Yes	NR	LIM
H. Wang et al. (2025) [P61]	Safety-specification violations	NA	Abstract state sequence	Yes	Yes	Yes	Yes	NR	Yes	Yes	No (non-financial)	MOD

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
H. Wang, Poskitt, & Sun (2026) [P50]	Unsafe actions	NA	Triggered action vs. rule predicate	Yes	NR	Yes	NV	NR	Yes	Yes	NR	MOD
H.-H. Chen (2026) [P67]	Consequences of side-effecting actions	NA	Each priced action	Yes	NR	Yes	NR	NR	Yes (consequence pricing vs. reserve)	Yes (gating)	Yes (partial: payments, refunds as examples)	LIM
Hines et al. (2024) [P47]	Indirect prompt injection	Untrusted documents	Input text	Yes	NA	NA	NA	Yes	NA	NA	NR	MOD
Hossain et al. (2026) [P65]	Unsafe plans	Proposed plan and arguments	Plan (with cross-turn session state)	Yes	Yes (partial: session manager)	Yes (argument-level)	Yes (partial: plan-level)	NR	Yes	Yes (allow/block/confirm/revise)	NR	MOD

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
Hua et al. (2024) [P55]	Unsafe planning	NA	Plan	Yes (planning stage)	NR	Yes (plan-level)	Yes (plan-level)	NR	NV	Yes (plan revision)	NR	LIM
Jackson (2025) [P66]	Governance violations	NA	Governed action	Yes	NV	Yes	NV	NR	Yes (multi-dimensional risk score)	Yes (allow/deny/sanitize/escalate)	NR	LIM
Jacob et al. (2025) [P23]	Prompt injection	Conversational and application-structured inputs	Input text	Yes	NR	NR	NR	NR	Yes	NR	NR	MOD
Jiang et al. (2025) [P56]	Unsafe intermediate thoughts	NA	Intermediate thought before action	Yes	Yes (thought-level)	NR	Yes (partial)	NR	NV	Yes (thought correction)	NR	MOD

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
J. Lin et al. (2026) [P11]	Tool-stream injection (manipulated tool metadata and runtime feedback)	Tool metadata and tool feedback	Speculative action before commit	Yes	NR	Yes	NV	NR	Yes	Yes	NR	HIGH
W. Lin et al. (2026) [P62]	Long-horizon hazardous drift	NA	Each call with trajectory prefix	Yes	Yes	Yes	Yes	NR	Yes	Yes (PASS/HOLD/BLOCK)	NR	MOD
Luo et al. (2025) [P39]	Task-specific and systemic risks	NV	Agent actions	Yes	NV	Yes	NR	NR	Yes	NV	NR	LIM
Mou et al. (2026) [P33]	Unsafe tool invocations incl. prompt injection	Requests and tool interaction history	Each tool invocation with history	Yes	Yes	Yes	Yes	NR	Yes	Yes	NR	MOD

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
Patil et al. (2024) [P10]	Incorrect or unsafe LLM-generated actions (non-adversarial)	NA	Executed action	Yes	NR	Yes	NR	NR	NV	Yes	NR	LIM
S. Chen et al. (2025) [P48]	Prompt injection	Data channel	Model input	NA	NA	NA	NA	Yes	NA	NA	NR	LIM
S. Wang, Zhu, & Li (2026) [P37]	Indirect prompt injection (path traversal, exfiltration, high-frequency tool abuse)	Externally retrieved data	Each tool call with cross-step labels	Yes	NR	Yes	Yes	Yes	Yes	Yes	NR	HIGH

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
She et al. (2026) [P58]	Misaligned tool calls incl. IPI	Tool outputs; context	Each tool call and its evidence provenance	Yes	Yes (partial)	Yes	NR	Yes	Yes	Yes	NR	MOD
T. Shi et al. (2025) [P49]	Indirect prompt injection; tool misuse	Tool outputs	Each tool call vs. privilege policy	Yes	NR	Yes	Yes (policy updates during task)	NR	Yes	Yes	NR	MOD
Storf et al. (2026) [P34]	Scheming (covert pursuit of misaligned goals)	NA	Externally observable trajectory	Yes	Yes	Yes	Yes	NR	Yes	NR	NR	LIM

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
Tsai & Bagdasarian (2025) [P51]	Context-inappropriate actions	NA	Proposed action vs. task-context policy	Yes	NR	Yes	NR	NR	Yes	Yes	NR	LIM
Wen et al. (2025) [P03]	Indirect prompt injection	Retrieved external content	Model hidden states and gradients for an input	Yes	NR	NR	NR	NR	Yes	NR	NR	MOD
Xiang et al. (2025) [P53]	Violations of safety guard requests	NA	Target agent actions	Yes	NR	Yes	NR	NR	Yes	Yes	NR	LIM
Y. Chen et al. (2025) [P24]	Prompt injection in retrieved data	Retrieved content	Input prompt	Yes	NR	NR	NR	NR	NR	NR	NR	LIM

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
Y. Wu et al. (2025) [P36]	Untrusted apps; cross-app security, privacy and safety issues	Third-party apps	App interactions	Yes	NR	Yes	NR	NR	NV	Yes	NR	MOD
Z. Chen et al. (2026) [P68]	Irreversible effects; cross-step violations	NA	Task-level transaction	Yes	NR	Yes	Yes	NR	NR	Yes (staging, rollback, recovery)	NR	LIM
Z. Chen, Kang, & Li (2025) [P54]	Policy violations over trajectories	NA	Action trajectory	Yes	Yes (trajectory-level)	Yes	Yes	NR	Yes	Yes	NR	LIM
Zhong et al. (2025) [P06]	Prompt injection; privacy leakage	Tool outputs / external content	Each tool call and its data dependencies	Yes	NR	Yes	NV	Yes	Yes	Yes	NR	MOD

Study	Threat	Entry Point	Observation Unit	Runtime	Behavior	Tool/Action	Multi-Step	Provenance	Decision	Mitigation	Financial Context	Evidence Level
Zhu, Yang, et al. (2025) [P57]	Indirect prompt injection	Tool outputs	Tool calls under original vs. masked re-execution	Yes	Yes	Yes	Yes	NR	Yes	NV	NR	LIM
Zhu, Zhang, et al. (2025) [P18]	High-risk or unethical tasks; adversarial attacks	Task prompts; tool use; agent collaboration	Prompts, agent messages and tool use	Yes	Yes	Yes	NV	NR	Yes	Yes	NR	MOD

A.6 Eligibility criteria

A study was included when it satisfied all six criteria.

- **I1 — Population.** The study addresses AI or LLM agents, tool-using agents or agentic systems. *Operational clarification, fixed before eligibility assessment:* LLM-integrated applications that ingest untrusted third-party content were counted as satisfying I1 when the attack or defense applies to the agent's input channel, because indirect injection against agents originates in that setting. Studies whose threat is specific to inter-agent communication in multi-agent systems were treated as outside the review population, which is single tool-using agents.
- **I2 — Problem.** The study addresses a security, safety, robustness, monitoring or misuse problem.
- **I3 — Contribution.** The study contains a substantive technical method, benchmark, empirical evaluation or analytical contribution. Position papers

qualified only if they supplied a formal framework, a system design, or an empirical analysis of primary data. Argument-only position papers did not qualify.

- **I4 — Relevance.** The study directly informs at least one REM-relevant dimension: input or context security, runtime monitoring, behavioral analysis, action or tool monitoring, provenance, decision, mitigation, or financial execution security.
- **I5 — Extractability.** The study provides enough information to extract its relevant contribution.
- **I6 — Period.** The study was published between January 2019 and 25 September 2026, or it is a necessary **FOUNDATIONAL SOURCE**.

Exclusion labels. Records were excluded with a standard label:

- wrong population/system;
- wrong threat;
- wrong outcome;
- insufficient technical evidence;
- duplicate;
- outside scope;
- inaccessible full text or insufficient information;
- secondary study (survey, review, SoK or tutorial);
- metadata conflict;
- withdrawn.

Secondary studies and methodological sources. Secondary studies were not synthesized as primary evidence. Three of them, identified by the database search, are cited only as background: two definitional surveys and a finance SoK.

Methodological sources that do not concern agents also fail I1. These are the statistical, calibration, change-detection, decision-theoretic and anomaly-detection sources, and they were admitted under the second clause of I6 as **FOUNDATIONAL SOURCES**. Those published within the review period are labelled methodological sources. They support Section 2.7 and do not count as included studies.

The prior-art studies named in the protocol were given no special route. Each of AgentTrust, NEXUS, ProvenanceGuard, FinHarness, AgentDojo, AgentHarm, Progent, AgentSpec, ShieldAgent, Task Shield, MELON, CaMeL and LlamaFirewall passed through the same criteria.

A.7 Exclusions at screening and at eligibility

Exclusions at screening. The 174 records excluded at screening break down as follows:

- 81 outside scope;
- 71 secondary studies;
- 7 multi-agent-channel studies;
- 7 wrong threat;
- 4 wrong population;
- 2 official reports;
- 1 wrong outcome;
- 1 duplicate.

Exclusions at eligibility. Five records passed screening but were excluded at eligibility:

- a retrieval-augmented question-answering system without tool actions (wrong population/system);
- a record whose index metadata attached AgentDojo's DOI and authors to an unrelated abstract (metadata conflict);
- an argument-only position paper (insufficient technical evidence);
- an observability taxonomy without a security evaluation (wrong outcome);
- a record without an abstract (insufficient information).

A.8 Quality appraisal

Every included study was appraised against the protocol's ten-item checklist. The items ask whether the study reports:

- Q1 — its objective;
- Q2 — its threat model;
- Q3 — its method;
- Q4 — reproducibility;
- Q5 — its dataset or benchmark;
- Q6 — its metrics;
- Q7 — its comparators;
- Q8 — its limitations;
- Q9 — evidence for its quantitative claims;

- Q10 — peer-review status.

Codes. Each item is coded Yes, No, Not Verified or Not Applicable. Q10 also has a "preprint clearly labelled" code.

Categories. No numeric score is computed. A fixed, published rule assigns each study to a category of **record-visible evidence**:

- **HIGH EVIDENCE:** peer reviewed, with benchmark, figures and comparator all reported in the record;
- **MODERATE EVIDENCE:** quantitative results in a peer-reviewed or clearly labelled preprint record, or a peer-reviewed evaluation without verifiable figures;
- **LIMITED EVIDENCE:** everything else.

These categories describe **how much evidence the record makes visible**, which depends on how much information could be accessed. They are not a judgement of the study's intrinsic quality: a rigorous study with a terse abstract can fall into LIMITED EVIDENCE, and a full-text appraisal could move it.

Override. One override is applied and documented. FinHarness is set to LIMITED EVIDENCE because all of its figures were measured on FinVault, whose preprint was recorded on 25 September 2026 as withdrawn by its authors with a comment citing legal, intellectual-property and affiliation reasons rather than a scientific error. The withdrawal does not show that FinHarness's measurements are wrong; it means they cannot be confirmed against a publicly maintained benchmark. The override reflects confirmability, not invalidity (Section 2.9.2).

Results. Of the 71 included studies:

- 10 are HIGH EVIDENCE, 36 MODERATE EVIDENCE and 25 LIMITED EVIDENCE;
- 36 are peer reviewed and 35 are preprints or working papers;
- 62 are RECORD-VERIFIED and 9 PARTLY UNVERIFIED. RECORD-VERIFIED means that the bibliographic metadata and the cited contribution were checked against the study's index record (title, abstract, metadata); it does **not** mean that the full text was read. PARTLY UNVERIFIED means that at least one cited detail rests only on search-engine excerpts and is unverified.

Levels of claim verification. Every claim this chapter makes about a study is at one of four levels:

Level	Meaning
M — metadata verified	Title, authors, venue and year checked against Crossref or the index record
A — abstract-supported	The claim is stated in the study's abstract as indexed
F — full-text verified	The claim was checked against the full text
U — unverified	The claim rests on search-engine excerpts or an earlier reading that could not be reproduced

No claim of the systematic review is at level F, because no full text was retrieved for it. Six papers were read in full on 11 November 2026, outside the review; they are reported separately in Section 2.12.6. Claims at level U are marked "(unverified)" where they are used.

What the categories measure. Because full texts were unavailable, the categories measure **how much of each study's evidence could be verified from its record**, not the study's intrinsic quality (`CHAPTER2_QUALITY_APPRAISAL.md`). Items that depend on the full text (Q4 reproducibility, Q7 comparators, Q8 limitations) are most often Not Verified.

How the categories are used. They qualify how strongly a finding is worded in the synthesis. They were not used to exclude studies.

A.9 Data extraction

A single reviewer extracted 21 fields per included study into `CHAPTER2_SYSTEMATIC_EVIDENCE_MATRIX.csv`:

- study, year and venue;
- agent type;
- threat and attack entry point;
- whether the study operates at runtime;
- context, behavioral, tool/action, multi-step and provenance evidence;
- decision mechanism and mitigation;
- benchmark;
- financial context;
- metrics;
- main result and limitation;
- evidence level.

Coding values. Each property is coded **Yes**, **No**, **Not Reported**, **Not Applicable** or **Not Verified**. “Yes” is never entered for a property that is merely absent from the record. Conversely, **Not Reported is not evidence of absence**: a property that the record does not mention may still be present in the system. Counts of “Not Reported” cells therefore describe the records, not the systems, and are never used in this chapter to argue that a capability is missing from the literature.

Definitions and verification. Financial context is coded “Yes” only where the study’s setting is primarily financial. A general benchmark that contains one financial scenario is coded “No”, with a note. Every included study also carries a verification label, RECORD-VERIFIED or PARTLY UNVERIFIED, following the thesis rule that search-engine text cannot settle a primary claim.

Numbers. Every number reported in this chapter is taken from the primary report of the study concerned, as recorded in the matrix.

A.10 Evidence synthesis

No meta-analysis. Quantitative pooling was not possible. The included studies use different agents, attack sets, benchmarks, success definitions and metrics, and many report only author-selected configurations. A pooled estimate would have no interpretable common parameter.

Structured synthesis. The synthesis is therefore qualitative and structured. Evidence is organized into eleven themes:

1. threats;
2. entry points;
3. observation granularity;
4. runtime intervention;
5. behavioral and trajectory evidence;
6. provenance and goal–action consistency;
7. statistical and algorithmic methods;
8. decision and consequence handling;
9. mitigation;
10. financial-agent evidence;

11. evaluation quality.

Five questions per theme. For each theme the synthesis asks:

- what the literature establishes;
- what remains uncertain;
- what is under-evaluated;
- what differs across studies;
- what this implies for REM.

The syntheses are consolidated in Table A.9. Conflicting findings are presented side by side rather than resolved in favor of either side.

How results are worded. Author-reported figures are stated as such, with their setting, and are not compared across studies as if they were measured on a common scale. Claims that rest on a single study are worded as single-study findings.

A.11 Threat classes and the included evidence

Table A.6. Threat classes and the included evidence

Threat class	Entry point	Temporal scope	Why it is hard to detect	Included studies (evidence level)
Direct prompt injection	User channel	Single turn	Injected instructions resemble legitimate ones	Y. Liu et al. 2024 (MOD); Y. Liu et al. 2023 (MOD)
Indirect prompt injection	Observation channel (tool outputs, retrieved content, web pages)	Cross-step	Enters after input inspection	Greshake et al. 2023 (MOD); Zhan et al. 2024 (HIGH); H. Zhang et al. 2025 (HIGH); Z. Wang et al. 2025 (HIGH); Johnson et al. 2025 (LIM); Wei et al. 2026 (MOD)
Tool channel attacks (selection, metadata, servers, skills)	Tool library, tool metadata, skill files	Setup-time or cross-step	Poisoned artefacts are trusted as configuration	J. Shi et al. 2026 (LIM); C. Huang et al. 2026 (MOD); Hasan et al. 2026 (HIGH); X. Jia et al. 2026 (LIM)

Threat class	Entry point	Temporal scope	Why it is hard to detect	Included studies (evidence level)
Tool misuse / action manipulation	Tool arguments; action plans	Step or chain	Call is well formed; anomaly is relational	Fu et al. 2024 (MOD); Y. Zhang et al. 2024 (MOD); T. Liu et al. 2023 (MOD); Pedro et al. 2023 (LIM); Andriushchenko et al. 2025 (MOD)
Context and memory manipulation	Memory, retrieval corpus	Cross-session	Write and activation separated in time	Z. Chen et al. 2024 (MOD)
Goal drift / multi-step propagation	Trajectory	Trajectory	No single step need be anomalous	C. L. Wang et al. 2025 (MOD); W. Lin et al. 2026 (MOD); Z. Chen et al. 2026 (LIM)
Abnormal / repetitive execution	Trajectory	Trajectory	Anomaly lies in the pattern	B. Zhang et al. 2025 (MOD)
Misaligned (scheming) agent	Agent itself	Trajectory	Covert pursuit of another goal	Storf et al. 2026 (LIM)
Adaptive attacks	Any	Any	Designed against the defense	Zhan et al. 2025 (MOD); J. Shi et al. 2026 (LIM); Y. Zhang et al. 2024 (MOD)

Evidence levels: HIGH, MOD (moderate) and LIM (limited), as defined in Section 2.2.5.

A.12 Learned and LLM-based guardrails

A further family uses learned models or LLMs to judge actions or trajectories:

- **GuardAgent** generates guardrail code from safety requests (Xiang et al., 2025).
- **ShieldAgent** verifies trajectories against probabilistic rule circuits extracted from policy documents (Z. Chen, Kang, & Li, 2025).
- **AGrail** keeps adaptive safety checks in a lifelong memory (Luo et al., 2025).
- **TrustAgent** applies an agent constitution around planning (Hua et al., 2024).
- **Thought-Aligner** corrects unsafe intermediate thoughts. It raised behavioral safety from about 50% to about 90% on average across six LLMs (Jiang et al., 2025).
- **ToolSafe** trains a step-level guardrail that judges each tool invocation before execution from the interaction history. Its feedback-driven framework reduced

harmful invocations by 65% on average and improved benign completion by about 10% under injection (Mou et al., 2026).

- **VIGIL** replaces isolation with verify-before-commit. It reduced attack success by over 22% relative to dynamic defenses and more than doubled utility under attack relative to static baselines on its SIREN benchmark (J. Lin et al., 2026; PARTLY UNVERIFIED).
- **DRIFT** combines a secure planner, a dynamic validator of plan deviations and privileges, and an injection isolator for the memory stream. It is evaluated on AgentDojo, ASB and AgentDyn (H. Li et al., 2025).
- **SafeScientist** monitors prompts, agent collaboration and tool use in scientific agents (Zhu, Zhang, et al., 2025).

Limitations. These systems cover a broad range of semantic violations without writing a policy for each. Their limitations also recur:

- LLM judgement adds latency and can vary between runs;
- accuracies are measured on the authors' own benchmarks;
- the outputs are verdicts, and the verified records do not report calibrated probabilities that could be combined with the consequence of an action. The one exception is NEXUS (Section 2.8.3).

A.13 Step-level, sequence-level and accumulating monitors

Runtime monitors differ along two dimensions that are easily conflated: **decision granularity** (whether a decision is taken for each proposed step, for a plan, or for an episode) and **evidence scope** (whether that decision uses only the current step or also the history that led to it). A step-level decision can be history-aware: it can be taken for each proposed call while conditioning on the episode so far.

Step-level monitors with current-step evidence judge each proposed action against a policy or the current context. Examples are Progent and AgentSpec. They are fast and interpretable, but a monitor that uses no history cannot see an attack whose individual steps are each acceptable.

Step-level monitors with history-aware evidence still decide per proposed action, but their evidence includes earlier context. Task Shield, ProvenanceGuard and VIGIL check a proposed call against the user's goal or against evidence accumulated in the context; REM (Chapter 3) belongs to this group, because its per-step features include repeated calls,

privilege escalation, transition deviation and argument provenance computed over the episode.

Sequence-level monitors judge an action against a model of the trajectory:

- MI9 enforces temporal behavioral patterns through finite-state conformance engines and detects goal-conditioned drift. It reports 99.81% detection across 1,033 *synthetic* scenarios (C. L. Wang et al., 2025; preprint; PARTLY UNVERIFIED).
- ProbGuard learns a discrete-time Markov chain over abstract states. It intervenes when the estimated probability of remaining safe falls below a threshold, with PAC-style guarantees on the learned model (H. Wang et al., 2025; preprint).
- DreamGuard maintains a recurrent latent state and fuses immediate-hazard and prefix-risk scores into PASS, HOLD or BLOCK, at about 25 ms per call (W. Lin et al., 2026; preprint).
- ToolSafe's guardrail reasons over the interaction history (Mou et al., 2026).
- Constitutional monitors judge whole trajectories for scheming (Storf et al., 2026).

Accumulating monitors keep an explicit running state across steps. PRISM accumulates session risk with time-to-live decay (F. Li, 2026). AgentTrust applies seven order-aware chain detectors (C. Yang, 2026). FinHarness integrates per-step risk in a cascade (H. Jia et al., 2026).

A formal view. A formal account of runtime governance frames policies as functions of the agent's identity, its *partial execution path*, the proposed next action and the organizational state, mapped to a probability of policy violation. It shows that system prompts and static access control are special cases, and it lists risk calibration as an open problem (Kaptein et al., 2026; preprint; LIMITED EVIDENCE). This formalization supports evaluating actions in the light of their path. It also shows that the idea of a path-conditioned violation probability is not new.

A.14 Foundations: behavioral anomaly detection and its cautions

Foundational work. The idea of detecting compromise from behavior predates LLM agents. Forrest et al. (1996) built a profile of normal system-call sequences and flagged sequences absent from it. That is the closest classical analogue to monitoring an agent's tool-call sequence. Chandola et al. (2009, 2012) distinguished three kinds of anomaly and formalized anomaly detection over discrete sequences:

- *point* anomalies: in agents, a single out-of-policy call;

- *contextual* anomalies: a transfer that is normal in general but anomalous given its provenance;
- *collective* anomalies: goal drift and multi-step chains.

Cautions. The same literature carries cautions that transfer directly:

- attacks differ from typical learning tasks, with high error costs and a diverse normal class (Sommer & Paxson, 2010);
- security evaluations recur with sampling bias, base-rate neglect and lab-only testing (Arp et al., 2022).

For an agent monitor, these imply three requirements: a representative benign workload, interpretation of deviations in security terms, and models of "normal" learned from data resembling deployment. These are foundational and methodological sources, not included studies.

Themes 5 and 6 (behavioral/trajectory evidence; provenance and goal–action consistency): synthesis.

- **Established.** Many runtime systems observe trajectories: 17 of 42 code behavioral evidence and 21 code multi-step handling. Provenance and goal consistency are established signals against injected or misaligned actions.
- **Uncertain.** The measured contribution of each kind of evidence. One ablation found no effect of a session tracker, and another found a 26.4-point effect of cross-step labels. Both are single-study results on the authors' own benchmarks.
- **Under-evaluated.** The effect of trajectory and provenance evidence when it feeds a probability estimator rather than a rule or a judge. Evaluation in financial settings.
- **Differs across studies.** How provenance is obtained (analysis, construction or labels) and how sequences are modeled (automata, Markov chains, latent states or heuristics).
- **Implication for REM.** REM cannot claim trajectory monitoring or provenance analysis as new. Its evaluation must report the contribution of behavioral and provenance evidence, and must not assume it. It must also show that the benchmark contains the behavior the features are meant to detect.

A.15 What attribution contributes to auditability

Additive attribution. Additive attribution explains a prediction as a sum of per-feature contributions. For a linear model under feature independence, the Shapley attribution of a feature is its coefficient times the feature's deviation from its mean (Lundberg & Lee, 2017). On the log-odds of a logistic model, that decomposition is exact and costs no more

than the score itself. This makes it suitable for an audit record that shows which evidence contributed to a decision.

Other audit traces. It is not a distinguishing mechanism. Included systems already provide audit traces in other forms:

- rules and findings (NEXUS; AgentTrust);
- verifiable rule circuits (ShieldAgent);
- traceable evidence (ProvenanceGuard);
- tamper-evident or hash-chained logs (PRISM; the MCP policy-enforcement point; LATTICE's cryptographic audit trail).

In REM, attribution is **audit-only** and never enters the verdict.

Table A.7. Established methods reviewed as the algorithmic basis for REM

Problem	Method (original source)	Why relevant	Main limitation	Use among included studies
Probabilistic risk scoring	Logistic regression (Cox, 1958); ridge penalty (le Cessie & van Houwelingen, 1992); naive Bayes as alternative (Ng & Jordan, 2002)	Fast, inspectable, probabilistic output	Linear log-odds; distribution shift	NEXUS (plan level)
Calibration	Platt (2000); temperature (Guo et al., 2017); isotonic (Zadrozny & Elkan, 2002); beta (Kull et al., 2017)	Makes scores usable with costs	Calibration does not imply good control	NEXUS (Platt, isotonic evaluated); C. Zhang et al. (analysis); DreamGuard (calibrated fusion)
Calibration measurement	ECE (Naeini et al., 2015; Guo et al., 2017)	Quantifies miscalibration	Bin-dependent; unstable with small sets	NEXUS; C. Zhang et al.
Sequential accumulation	CUSUM (Page, 1954; Basseville & Nikiforov, 1993); optimality (Lorden, 1971)	Statistically grounded accumulation	Assumptions not met by agent trajectories; evadable by pacing	Heuristic analogues only (PRISM; FinHarness). In REM: optional, observe-only

Problem	Method (original source)	Why relevant	Main limitation	Use among included studies
Response selection	Minimum expected cost (Elkan, 2001); reject option (Chow, 1970)	Uses consequences explicitly; human-review region	Costs uncertain; recoverability omitted	NEXUS objective (fixed costs, cascade); consequence pricing (H.-H. Chen)
Audit decomposition	Additive attribution (Lundberg & Lee, 2017)	Exact for linear scores; cheap	Not a novel explanation mechanism	Rule/evidence/audit traces in NEXUS, AgentTrust, ShieldAgent, ProvenanceGuard, PRISM, LATTICE

Theme 7 (statistical and algorithmic methods): synthesis.

- **Established.** Each building block is established, and several are already applied in agent security.
- **Uncertain.** How these blocks perform in combination at the action boundary of an executing agent under indirect injection.
- **Under-evaluated.** Calibration of agent-safety probabilities. Only NEXUS reports calibration error for a deployed scorer, and C. Zhang et al. and LATTICE show that calibration or a threshold on confidence does not by itself secure good control.
- **Differs across studies.** Probabilities are produced by logistic scores, learned Markov chains, latent world models, or LLM judges.
- **Implication for REM.** REM's estimator, calibrator and decision rule are adopted, not contributed. Calibration must be reported separately from control. The comparison that isolates the effect of using consequences is against a consequence-independent rule that uses the *same* estimator.

A.16 Decision mechanisms of the runtime systems closest to REM

Table A.8. Decision mechanism, calibration, consequence and reported evaluation dimensions (runtime systems closest to REM)

System	Decision basis	Calibrated probability	Consequence used in decision	Human review / graduated response	Benign utility or false interventions reported	Latency reported	Financial focus	Evidence level
Progent	Privilege policy (solver-checked updates)	NA	NR	Approval for privilege expansion	Yes (functionality maintained)	NR	NR	MOD
AgentSpec	Deterministic rules	NA	NR	NV	NV	Yes (ms)	NR	MOD
RTBAS	Information-flow screeners	NR	NR	User confirmation when integrity/confidentiality not ensured	Yes (2% utility loss under attack)	NR	NR	MOD
MCP policy-enforcement point	Declarative rules over cross-step labels	NA	NR	NR	Yes (task-level FP 30.0%; 0/30 rule FPs)	Yes (sub-ms)	NR	HIGH
LATTICE	Policy-as-code; deterministic verdicts; confidence-based escalation	NR (confidence baseline analysed)	NR	Yes (human escalation)	Yes (operating point auto-allowed no action)	Yes (µs–ms)	NR	HIGH
Task Shield	LLM verification of task alignment	NR	NR	NR	Yes (69.79% utility)	NR	NR	HIGH
VIGIL	Intent-grounded verification before commit	NR	NR	NR	Yes (utility under attack)	NR	NR	HIGH (PV)

System	Decision basis	Calibrated probability	Consequence used in decision	Human review / graduated response	Benign utility or false interventions reported	Latency reported	Financial focus	Evidence level
ToolSafe	Learned step-level guardrail with feedback	NR	NR	Feedback to agent	Yes (benign completion)	NR	NR	MOD
Provenance Guard	Evidence support for tool calls	NR	NR	Intervention	Yes (aligned-trace intervention rate; PV)	Yes (higher than baselines; PV)	NR	MOD (PV)
MI9	Governance components; agency-risk index	NR	NR	Graduated containment	NV	Overhead noted (PV)	NV	MOD (PV)
ProbGuard	Probability of remaining safe (learned DTMC) vs threshold	NR (PAC-style bounds on learned model)	NR	NR	Yes (task completion)	NV	NR	MOD
DreamGuard	Calibrated fusion of hazard and prefix-risk scores	Partial (“calibrated fusion”; no calibration metric verified)	NR	HOLD	NV	Yes (~25 ms)	NR	MOD
SafeAgent	LLM operators; policy arbitration	NV	Yes (LLM consequence modelling; PV)	Yes	NV	NV	NR	LIM (PV)

System	Decision basis	Calibrated probability	Consequence used in decision	Human review / graduated response	Benign utility or false interventions reported	Latency reported	Financial focus	Evidence level
AgentTrust	Rules and analysers; worst-case over normalized variants; LLM judge for ambiguity	NR	Partial (reversibility as a judge dimension; PV)	Yes (warn; review)	NR	Yes (~1.72 ms; PV)	NR	MOD (PV)
NEXUS	Rule-first cascade; calibrated logistic score with loss-optimal thresholds	Yes (Platt; ECE 0.085 → 0.013; PV)	Yes (plan annotations used by rules); intervention costs fixed (PV)	Yes (confirm; revise)	Yes (paired benign cases)	Yes (0.205 ms median)	NR	MOD (PV)
FinHarness	Monitors and LLM-judge cascade	NR	NR	Escalation to an advanced LLM judge	Yes (benign approval; benchmark withdrawn for non-scientific reasons)	NR (judge-call counts)	Yes	LIM
H.-H. Chen	Deterministic pricing against reserve capital	NA	Yes	NR	NR	NR	Partial	LIM
Jackson	Multi-dimensional risk score; enforcement state machine	NV	NV	Yes (escalate; sanitize)	NV	Qualitative only	NR	LIM (PV)

System	Decision basis	Calibrated probability	Consequence used in decision	Human review / graduated response	Benign utility or false interventions reported	Latency reported	Financial focus	Evidence level
C. Zhang et al. (analysis)	Action-conditioned intervention value	Analysed (calibration did not reduce regret; PV)	Yes (recoverability)	NA	Regret reported	NR	NR	MOD (PV)
REM (this thesis; design, Chapter 3)	Calibrated per-step probability with consequence-tier losses in an expected-loss rule	Designed	Designed (declared tiers)	Designed (Escalate; Modify)	Exploratory evaluation (Chapter 4)	Measured (Chapter 4)	AgentDojo Banking	—

PV = figure or property unverified (level U: search-engine excerpt only).

A.17 Thematic synthesis of the included evidence

Table A.9. Thematic synthesis of the included evidence

Theme	What the literature establishes	What is uncertain	What is under-evaluated	What differs across studies	Implication for REM
1 Threats	Indirect injection is demonstrated, benchmarked and adaptive; defenses of the time were bypassed	Magnitude: 24% to 84.30% average ASR across benchmarks	Tool-metadata, tool-library, skill and MCP-server threats against runtime defenses	Threat actor and success criterion	Focus on indirect injection; state other classes as out of scope
2 Entry points	The observation channel (tool outputs, retrieved content, tool metadata) is the decisive entry for tool-using agents	Relative danger of channels (skills > email/web in one study)	Defenses against setup-time channels	Which channel each benchmark exercises	Mediate at the action, where all channels converge

Theme	What the literature establishes	What is uncertain	What is under-evaluated	What differs across studies	Implication for REM
3 Observation granularity	Input, call, plan, data-flow and trajectory units all implemented	Which unit gives the best security–utility trade-off	Head-to-head comparisons on a shared workload	Unit observed; question asked	Per-call observation with provenance context is a defensible, not novel, choice
4 Runtime intervention	Interception at the tool boundary is widespread (41/42 runtime; 34/42 tool/action) and fast	Robustness to adaptive attacks	Evaluation on benchmarks the authors did not build	Permission vs. alignment vs. provenance vs. harm	REM cannot claim interception
5 Behavioral / trajectory evidence	Many monitors model sequences (17/42 behavioral; 21/42 multi-step)	Contribution: one null ablation (session tracker)	Contribution inside a probabilistic estimator; financial settings	Automata, Markov chains, latent states, heuristics	Measure and report the contribution; do not assume it
6 Provenance / goal–action consistency	Informative against injected or misaligned calls; cross-step labels had a 26.4-point effect in one study	Whether the effect generalizes beyond the authors' datasets	Provenance as input to a calibrated estimator; financial arguments	Obtained by analysis, construction or labels	Use as estimator input; test the contribution
7 Statistical / algorithmic methods	Logistic scoring, calibration, expected cost, reject option and attribution are established; one agent-safety precedent (NEXUS)	Behaviour in combination at the action boundary	Calibration of agent-safety probabilities; calibration vs. control	How probabilities are produced	Adopted methods; report calibration separately from control
8 Decision and consequence	Graduated responses and consequence information are common	How to combine an induction probability with a declared consequence	Intervention rates; per-response effectiveness	Fixed costs, pricing, rules, judge dimensions	Test the combination against a same-estimator consequence-independent baseline

Theme	What the literature establishes	What is uncertain	What is under-evaluated	What differs across studies	Implication for REM
9 Mitigation	Block, modify, escalate, restrict, roll back and undo all implemented	Effectiveness of each response once chosen	Residual risk after modify-type responses	Meaning of “escalate” (human vs. stronger judge) and “modify”	Report residual attack success and escalation rate; SC-1 and SC-2 remain open
10 Financial evidence	Financial actions lie within general benchmarks’ attack surface; one financial harness exists	Defense performance on financial actions	Every financial-context study is LIMITED EVIDENCE; key figures were measured on a benchmark withdrawn for non-scientific reasons and cannot be confirmed	Chatbot firewall, position paper, actuarial framework, judge harness	Report results per financial action type and consequence tier
11 Evaluation quality	Results are benchmark-specific; many benchmarks are built with the defense they evaluate	Multi-step content of benchmarks	Independent evaluation; decomposition into security, utility, intervention, calibration and latency	Metrics and baselines	Per-benchmark reporting with benign utility, intervention rates, calibration and latency

A.18 Assessment of candidate research gaps

Table A.10. Evidence-based assessment of candidate research gaps

Candidate gap	Evidence for	Evidence against	Decision
A. Integration. Capabilities exist across separate approaches	Tables A.5–A.8: calibrated scoring (NEXUS), consequence pricing (H.-H. Chen), provenance (ProvenanceGuard; MCP policy-enforcement point), graduated verdicts (AgentTrust; LATTICE) are in different studies	NEXUS combines calibration and graduated responses (level A) and, per level-U evidence, costs, at the plan level	**Retained only as a weak, record-bounded observation.** A calibrated per-call probability combined with consequence-indexed losses at the action boundary was not reported in the examined records. Because the combination is specific and the review is record-level, its absence is not treated as evidence of originality
B. Runtime action-boundary evaluation. Limited evidence combining multiple signals at the point of action	—	AgentTrust, the MCP policy-enforcement point, ToolSafe, DRIFT, SafeAgent and FinHarness combine several signals at or near the tool call	**Not retained as stated.** Its defensible residue, combination into a calibrated probability, is part of Gap A
C. Behavioral/provenance contribution. Insufficient evidence separating the contribution of behavioral and provenance signals	Only three component-level tests found; they conflict (null session-tracker ablation vs. a 26.4-point cross-step-label effect); none inside a probabilistic estimator; none financial	The MCP policy-enforcement point does separate the contribution of cross-step labels in a rule-based enforcer (HIGH EVIDENCE)	**Retained, narrowed.** Limited and conflicting evidence on the contribution of behavioral and provenance evidence *as inputs to a calibrated estimator* for financial actions under indirect injection
D. Financial-agent evidence. Limited verified evidence in executable financial settings	Four financial-context studies, all LIMITED EVIDENCE; the only quantitative runtime results cannot be confirmed against a maintained benchmark; general benchmarks with financial suites report no finance-specific analysis in the	FinHarness shows the problem is recognized	**Retained**

Candidate gap	Evidence for	Evidence against	Decision
	verified record		
E. Evaluation decomposition. Insufficient evaluation separating security, benign utility, calibration or decision quality, intervention behavior and latency	Calibration reported for one deployed scorer (NEXUS); intervention rates by few studies; no study compares a consequence-aware decision with a consequence-independent baseline that shares its estimator	Several studies report more than attack success (MCP policy-enforcement point; LATTICE; NEXUS; ToolSafe)	**Retained, narrowed.** The missing element is the same-estimator comparison, with calibration reported separately from control and intervention rates reported

A.19 AI agents and emerging security risks

A.19.1 From language models to agents

In the survey literature, an LLM-based autonomous agent is a system in which a language model acts as the controller for perception, reasoning, planning and action in pursuit of a task, supported by memory and tool-use modules (L. Wang et al., 2024; background source). Two capability developments made this architecture practical:

- **ReAct** interleaves reasoning with action. The model generates a thought, selects an action, receives the environment's observation, and conditions its next step on that observation (Yao et al., 2023).
- **Toolformer** showed that a language model can learn which application programming interfaces to call, when to call them, and with what arguments (Schick et al., 2023).

Both are capability papers. They fail criterion I2 and are cited only as background. Together they describe the execution pattern that most agent frameworks still follow: a loop of reasoning, tool invocation and observation, which continues until the model judges the task complete.

A.19.2 Why agent architecture changes the security problem

The loop that makes agents useful also creates their attack surface. Three structural properties distinguish agent security from the security of a stand-alone model:

- **Several input channels of different trustworthiness.** The system prompt, the user's request, tool outputs, retrieved documents and stored memory all enter the same context window, and the model interprets all of them.

- **Statefulness across a trajectory.** Content that enters at one step can influence an action several steps later. The unit of analysis is therefore a trajectory, not an input–output pair.
- **Outputs with external effects.** An agent's outputs include tool calls. A successful manipulation does not stay in the text domain; it becomes a state change in an external system.

A component view of agent threats organizes the same observation around the model "brain", memory, tools and environment interaction (Yu et al., 2025; background source).

Two included benchmark studies show that these properties matter empirically:

- **ClawSafety** ran 2,520 sandboxed trials of personal agents with elevated local privileges. Attack success varied from 40% to 75% across five backbone models, and varied sharply with the channel through which the injection arrived. Cross-scaffold experiments showed that safety depended on the whole deployment stack, not on the backbone model alone (Wei et al., 2026; preprint).
- **ToolEmu** showed that agent risk does not require an attacker. In an LM-emulated sandbox with 36 toolkits and 144 test cases, even the safest agent tested failed in 23.9% of cases. Human evaluators judged 68.8% of the failures identified to be valid real-world failures (Ruan et al., 2024).

A.19.3 Implication

The reviewed studies locate agent risk at the interaction between the model, its heterogeneous input channels, its accumulated state and its tools, and ClawSafety adds the agent framework itself. A defense that inspects only the user's input, or only the final text, does not observe the point at which the agent's decision becomes an external effect. The remainder of the chapter therefore attends to **where** defenses intervene and **what** they observe.

A.20 Tool misuse, action manipulation and new tool channels

Tool misuse is the use of a legitimate capability against the user's intent. Action manipulation is its adversarially induced form: a well-formed call to a permitted tool, with attacker-chosen arguments or timing. The included studies show that the tool interface is now an attack surface in its own right:

- **Tool selection.** ToolHijacker injects a malicious tool document into the tool library so that the agent selects the attacker's tool. Six prevention-based and detection-based defenses proved insufficient against it (J. Shi et al., 2026).

- **Tool metadata.** A STRIDE/DREAD threat model of the Model Context Protocol (MCP) identified *tool poisoning*, meaning instructions embedded in tool metadata, as the most prevalent client-side vulnerability. Most of the seven MCP clients tested showed weaknesses in static validation and parameter visibility (C. Huang et al., 2026).
- **Tool servers.** A study of 1,899 open-source MCP servers found MCP-specific tool poisoning in 5.5% of servers and general vulnerabilities in 7.2% (Hasan et al., 2026).
- **Tool arguments and plans.** Imprompter optimizes obfuscated prompts that cause improper tool use; its information-exfiltration attack succeeded end to end in nearly 80% of trials against a production agent (Fu et al., 2024; preprint). AI² builds semantically harmless inputs that hijack an application's action plan. It reports an average success rate of 84.30% and bypasses common safety filters in 92.7% of cases (Y. Zhang et al., 2024; preprint).
- **Framework tools.** In LLM-integrated frameworks, prompt injection reaches code-execution and database tools. LLMSmith found 20 vulnerabilities in 11 frameworks, 19 of them remote code execution, of which 17 were confirmed and 11 received CVEs (T. Liu et al., 2023; preprint). Prompt-to-SQL injection was shown to be pervasive across seven LLMs in LangChain applications (Pedro et al., 2023; preprint).
- **Skills.** Reusable agent "skills" create a supply-chain channel. SkillJect automatically poisons skill instructions and helper scripts and outperforms manual skill-injection attacks (X. Jia et al., 2026; preprint; LIMITED EVIDENCE).

Malicious users. Harmful behavior can also be requested directly. AgentHarm contains 110 malicious agentic tasks (440 with augmentations) in 11 harm categories (Andriushchenko et al., 2025). Its threat model, a malicious *user*, contrasts with REM's primary threat model, in which the adversary sits in the data read by a benign user's agent.

A.21 Context and memory manipulation

Where an agent retrieves from memory or a knowledge base, an adversary can plant content that is acted on later. AgentPoison reported an attack success rate of at least 80%, with benign impact of at most 1%, at a poison rate below 0.1% (Z. Chen et al., 2024). Memory poisoning separates the write from the activation in time. To an observer without provenance information, the eventual retrieval therefore looks legitimate.

A.22 Multi-step propagation, goal drift and abnormal execution

Some compromises contain no single anomalous step. Several runtime systems target this pattern:

- goal-conditioned drift detection (C. L. Wang et al., 2025);
- cross-turn drift in a financial query monitor (H. Jia et al., 2026);
- hazardous drift through individually benign actions (W. Lin et al., 2026);
- task-level transactions that expose cross-step violations (Z. Chen et al., 2026).

Abnormal execution. Abnormal execution can itself be the attack. Malfunction amplification misleads agents into repetitive or irrelevant actions. It induced failure rates above 80% in several scenarios, and its authors found it harder to detect than overtly harmful attacks (B. Zhang et al., 2025). In anomaly-detection terms, a sequence of individually normal events whose *combination* is anomalous is a *collective* anomaly (Chandola et al., 2009; foundational source).

Misaligned agents. A distinct threat is posed by an agent that is itself misaligned. Monitors for covert "scheming" operate on observable trajectories. Monitors trained on synthetic data generalized to more realistic environments, but their performance saturated quickly (Storf et al., 2026; preprint).

A.23 Input-, context- and model-level protection

Input detectors. Detectors that act on text report strong in-distribution results:

- InstructDetector uses a model's hidden states and gradients to detect embedded instructions. It reports 99.60% in-domain and 96.90% out-of-domain accuracy, and reduces attack success to 0.03% on BIPIA (Wen et al., 2025).
- PromptShield curates a benchmark for deployable detectors, and its fine-tuned detector improves performance in the low-false-positive regime (Jacob et al., 2025).
- Spotlighting transforms untrusted input so that the model receives a continuous provenance signal, reducing attack success from above 50% to below 2% with GPT-family models (Hines et al., 2024).

Model-level protection. StruQ trains the model to follow instructions only in the prompt channel (S. Chen et al., 2025). This addresses the root cause identified by Greshake et al. (2023), but it requires training and access to the model. That is a significant constraint for a financial institution that deploys a third-party model.

Shared limitations. These approaches share two limitations for tool-using agents:

- they act on text, not on actions, so an input detector does not observe what the agent then does;
- ToolHijacker defeated six such defenses (J. Shi et al., 2026), and AI² bypassed common safety filters in 92.7% of cases (Y. Zhang et al., 2024).

A.24 System-level and information-flow defenses

A second family changes the system so that untrusted data cannot steer control flow:

- **f-secure LLM systems.** A security monitor filters untrusted input out of the planning process, and formal models state the security guarantee (F. Wu et al., 2024; preprint).
- **RTBAS.** Information-flow control is adapted to tool-based agents. Tool calls whose integrity and confidentiality can be established are executed automatically, and the user is asked to confirm the rest. On AgentDojo it prevented all targeted attacks with a 2% utility loss under attack (Zhong et al., 2025; preprint).
- **ACE.** Planning is decoupled: an abstract plan is built from trusted information only, its information-flow constraints are checked statically, and data and capability barriers are enforced during execution. It reports security against InjecAgent and ASB attacks, and it demonstrates new attacks against IsolateGPT (E. Li et al., 2026).
- **IsolateGPT.** Third-party apps run in isolation, with overhead under 30% for three-quarters of tested queries (Y. Wu et al., 2025).
- **CaMeL.** Control and data flow are extracted from the trusted query and capability policies are enforced at each tool call. CaMeL solved 77% of AgentDojo tasks with provable security, against 84% for the undefended agent (Debenedetti et al., 2025, v2; an earlier version reported 67%).

Conflicting evidence. The IsolateGPT–ACE pair is a direct conflict within this family. One peer-reviewed study reports that isolation protects against the attacks it tested. A later peer-reviewed study constructs attacks that defeat it. Architectural guarantees hold only for the threat models their authors formalized.

A.25 Why logistic regression

Logistic regression models the probability of a binary outcome as a logistic function of a linear score (Cox, 1958):

$$Pr(y=1/x)=\frac{1}{1+\exp\left(-(\beta_0+\beta^T x)\right)} \quad (2.1)$$

Why it suits a runtime layer.

- Evaluation costs one inner product.
- Coefficients can be inspected.
- The output is intended as a probability, not as an arbitrary score.

Limitations.

- Interactions must be engineered into the features.
- A model fitted on one attack distribution can be miscalibrated on another.
- With scarce adversarial examples and binary indicators, the unpenalized estimate may not be finite. A ridge penalty addresses this (le Cessie & van Houwelingen, 1992).
- Naive Bayes is the generative counterpart with the same linear form. It may reach its (higher) asymptotic error with fewer examples (Ng & Jordan, 2002). It is an established alternative estimator and is not part of REM.

Use in agent security. Among the included studies, only NEXUS uses a logistic risk score for agent safety (Hossain et al., 2026). The choice of estimator family therefore has one direct precedent in agent security, and that precedent operates at the plan level.

A.26 Why sequential evidence matters

When evidence arrives step by step, a monitor must decide when the accumulated evidence justifies action.

CUSUM. Classical sequential analysis gives a statistically grounded answer. The cumulative-sum procedure (Page, 1954) accumulates log-likelihood ratios of post-change against pre-change behavior and raises an alarm when the accumulated statistic crosses a threshold (Basseville & Nikiforov, 1993). Under the classical change-point model, with independent observations before and after the change, it has an asymptotic optimality property for detection delay at a given false-alarm constraint (Lorden, 1971).

Limits for agents. These assumptions are only approximately satisfied by tool-call sequences, and an adversary can pace an attack to stay below the threshold. The procedure also detects a *change*, whereas an agent episode may be adversarial from its first injected observation.

Heuristic alternatives. Among the included studies, sequential accumulation is heuristic: PRISM's session risk with time-to-live decay (F. Li, 2026) and FinHarness's cascade (H. Jia et al., 2026).

Role in REM. CUSUM is **not part of REM's verdict path**. Chapter 3 uses it only as an optional, offline, observe-only analysis of logged indicators that never influences a verdict.

A.27 Currency update of 30 October 2026 (outside the PRISMA flow)

The registered search ran on 25 September 2026. On 30 October 2026 the eleven queries of Table A.1 were re-run in the same index (OpenAlex, through the same literature-search tool), restricted to publication year 2026, to find work that could change the gap assessment. **This update is not part of the PRISMA flow, and no count in Table 2.1 or Figure 2.1 changes:**

- the index returns the publication year but not the date, so records published after 25 September could not be separated reliably from earlier 2026 records;
- of the 215 unique records returned, 200 were not in the stored output of the registered search; they were title-screened by one reviewer for direct relevance to REM's decision mechanism or evaluation design, and were not assessed against criteria I1–I6;
- no record was added to the 71 included studies.

The raw output is stored with the thesis verification records (`update_search_2026-10-30.json`). Five records bear directly on REM's positioning. Each is described only as far as its index record states (level A); no full text was read.

Record	Type	What the record states	Bearing on REM
Kekatos et al. (2026)	Peer-reviewed workshop paper (ACM, Crossref-registered)	Replays the recorded trajectories distributed with AgentDojo, STAC and R-Judge through a temporal-logic monitor, offline and without running an agent. Five generic obligations flag 70.1% of successful AgentDojo attacks and fire on 29.3% of benign runs. A planted line defeats a naive provenance check on 94–99% of the runs it would otherwise flag	Offline evaluation on AgentDojo's recorded traces has a published precedent, so it is not a methodological contribution of this thesis. Provenance evidence is itself attackable
Z. Liu	Preprint	Replays the ground-truth tool calls of AgentDojo and tau-	The choice of the injection classifier x^{ctx}_1

Record	Type	What the record states	Bearing on REM
(2026)		bench without an LLM and evaluates fifteen prompt-injection detectors, including Prompt Guard 2. Rankings transfer poorly: the best detector on BIPIA catches 2% of AgentDojo injections at a 1% false-positive rate	(pending) should be evaluated on the agent's own tool outputs at a low false-positive rate
Ray (2026)	Preprint	Once blocking changes future proposals, static scores and ungated trajectories need not identify the closed-loop frontier; benign calibration alone does not transfer	Theoretical support for the limit of REM's replay analysis: replay of recorded trajectories cannot establish closed-loop enforcement
Yan et al. (2026)	Preprint	A controller that acts after the agent proposes an action and before it executes; it encodes trusted and external observations in provenance-typed memory and commits the action, proposed or alternative, with the highest calibrated value learned from outcomes	The closest record found to REM's combination of provenance evidence and a calibrated decision at the action boundary. It differs, by its abstract, in choosing between actions by learned value rather than among four verdicts by declared, tier-indexed losses. Prior-art risk to Gap A
Xin (2026)	Journal article	A pre-execution router with temperature-scaled three-class probabilities (execute, confirm, block), a fixed rule floor and confidence-triggered confirmation, evaluated on mobile-agent tasks that include financial applications	Calibrated multi-way routing with a confirmation verdict before execution has a further precedent. REM differs in deriving its thresholds from declared losses per consequence tier

The other records of the update concern, among other topics, enforcement at the execution boundary, banking-agent benchmarks and step-labeled injection trajectories. They were not assessed and should be screened in the full update recommended in Section 2.12.4.

Effect on the gap. At abstract level, none of the five records reports the combination and evaluation stated in Section 2.12.2, but Yan et al. (2026) and Xin (2026) narrow the distance to it, and Kekatos et al. (2026) removes any claim of methodological novelty for offline evaluation on recorded AgentDojo traces. Because only records were examined, this conclusion has the same limits as the main review.

A.28 Supplementary literature update of 2 November 2026: Kanaker et al. (2026) (outside the PRISMA flow)

Status of this addition. Kanaker et al. (2026), *Securing Tool-Using AI Agents Against Injection and Authority Misuse* (*Computation*, 14(5), Article 98), is added on 2 November 2026 as a dated supplementary literature update. The record was returned by query Q7 of the currency update of 30 October 2026 (OpenAlex W7160053090, stored in `update_search_2026-10-30.json`) but was not among the five records selected at title screening in Section 2.12.5. It was not part of the registered search of 25 September 2026. **No count in Table 2.1 or Figure 2.1 changes, it is not added to the 71 included studies, and no screening record is created retrospectively.**

Evidence level. The bibliographic metadata were checked against the Crossref record of the DOI (10.3390/computation14050098): six authors in the order H. Kanaker, H. Fakhouri, N. Abdel Karim, M. Abuhamdeh, N. H. A. Ismail and S. Fakhouri; *Computation*, volume 14, issue 5, article 98; 2026. The abstract was read in the OpenAlex record. The full text could not be retrieved in this revision, because the publisher and DOI hosts were refused by the network policy. Every statement below is therefore at **level A**: it reports what the abstract states, not what the paper's methods or results sections contain. Parameter values, the number of simulation runs, uncertainty estimates and the exact definitions of the metrics were not read.

What the study does (level A). The study argues that large-scale testing of deployed agents is difficult, vendor-specific and ethically sensitive, and proposes a transparent, theoretical simulation framework for user-facing risk in tool-using agents. Its stated methodological contribution is a formal threat model that **separates compromise, harm and severity**, together with a Monte Carlo pipeline that maps architectural choices (permissions, retrieval, memory exposure and approvals) and defensive controls to comparable outcome metrics. It instantiates the framework for six threat scenarios and nine defense configurations, and reports attack success rate, benign task success, latency overhead and severity-weighted harm. Its abstract reports four findings:

- least-privilege tool design is the strongest single broad control;
- human-in-the-loop approvals sharply reduce high-impact actions and exports, but degrade under user error and habituation;

- retrieval allowlisting nearly eliminates indirect injection while leaving other channels largely unaffected;
- rate limiting reduces tail severity more than attack success rate.

Critical assessment.

- *Strengths visible in the record.* The threat model makes the distinction between whether an agent is compromised and how much harm follows explicit. The study reports more than attack success, including benign task success, latency and a severity-weighted outcome, and it compares architectural controls side by side. Its assumptions are declared rather than hidden.
- *Limits stated by the authors.* The results come from an assumption-explicit simulator, not from field measurements, and the authors present them as comparative design guidance rather than incident-rate estimates for any deployed product. They do not measure how a particular agent or language model behaves.
- *Limits of this review.* Whether the simulated risks are calibrated to observed agent behavior, how sensitive the rankings are to the simulator's parameters, and how severity is weighted could not be assessed without the full text.
- *Consistency with other evidence in this chapter.* The approval finding agrees with the approval-fatigue trade-off reported by P. Wang et al. (2026) (Section 2.8.1). The allowlisting finding concerns one injection channel, whereas the provenance-based defenses of Section 2.5.2 examine the content that actually reaches a proposed call. The rate-limiting finding illustrates why attack success rate alone can miss differences in the severity of outcomes.

Bearing on the gap assessment (Table A.10). The study adds to the "evidence against" column of Gap E: another study reports security, benign success, latency and a severity-weighted outcome together, although in simulation. It does not, by its abstract, compare a consequence-aware decision with a consequence-independent baseline that shares its estimator, so the narrowed residue of Gap E is unchanged. For Gap D, the study evaluates transaction-capable tools in a simulator rather than in an open, executable benchmark, so the retained statement is not contradicted. For Gap A, the abstract describes no calibrated per-call probability and no selection among verdicts by expected loss. These conclusions have the same record-level limits as the rest of the review.

Table A.11. Kanaker et al. (2026) and REM compared (Kanaker et al.: level A, abstract and metadata only; REM: Chapters 3–4)

Dimension	Kanaker et al. (2026)	REM (this thesis)
Research question	How architectural choices and defensive controls change user-facing risk in tool-using agents, evaluated without testing deployed products	Whether consequence-tiered expected-loss verdicts at the tool-execution boundary change intervention, attack success and utility relative to a consequence-independent threshold with the same estimator (Section 1.7; [PD])
Method	Formal threat model separating compromise, harm and severity; Monte Carlo evaluation pipeline over architectural choices and defenses	Provenance, behavioral and action evidence; ridge logistic regression; logistic calibration on the logit; consequence tiers; expected-loss verdict among Allow, Modify, Escalate and Block; deterministic mitigation; audit record
Data and evidence	Assumption-explicit simulation; six threat scenarios; nine defense configurations	Recorded AgentDojo banking traces of 21 language-model agents; held-out predictions, observe-only decisions and replay under a no-adaptation assumption; no live runs (Chapter 4)
Treatment of harm and severity	Severity separated from compromise in the threat model; severity-weighted harm reported as an outcome	Consequence tier k_t separated from the probability p_t; severity enters the decision through tier-indexed declared losses (Eqs. 3.5–3.9); realized loss reported (Eq. 3.22)
Defensive mechanisms	Least-privilege tool design, human-in-the-loop approvals, retrieval allowlisting, rate limiting (abstract); the full set of nine configurations was not read	Per-call verdicts with step-level withholding of the current call, an episode-level restriction variant, and escalation evaluated under an idealized-reviewer and a no-reviewer bound
Reported outcomes	Attack success rate, benign task success, latency overhead, severity-weighted harm	Discrimination and calibration, intervention rates, attack success rate, benign utility, utility under attack, processing time, realized loss
Limitations	Simulator rather than field measurement; results are comparative design guidance, not incident-rate estimates (stated by the authors)	Exploratory pilot; recorded traces and replay only; unaudited proxy labels; declared, unapproved costs; one benchmark (Chapter 4, Section 4.6.11)

What is and is not taken from this study. The study is cited where it is consistent with existing positions of this thesis: the separation of compromise from severity (Chapter 3, Section 3.7.3) and the optimism of a perfect-reviewer assumption (Chapter 3, Section 3.7.5). REM's design was fixed before this record was examined, and no REM mechanism,

parameter or experiment is derived from it. Its simulation results are not used as evidence for REM's effectiveness, and REM's results are not used to assess its findings.

Appendix B: System Implementation: Details

This appendix gives the implementation details that Chapter 3, Section 3.15, summarizes. It is reproduced from the thesis draft of 3 to 5 November 2026 without change of content. Test counts in this appendix are those of 1 November 2026 (205 tests); the count on 11 November 2026, after the integration, deployment-simulation and study tests were added, is 241 passed, 3 skipped and 1 expected failure.

B.1 Implementation of the REM framework

This section reports how the methodology of Chapter 3 is implemented in software: the environment, the organisation of the code and its execution paths, the implementation of each layer, the verification of the software, the correspondence between equations, code, tests and results, and the measurement of processing time. It was Chapter 4 of the six-chapter draft (R5); its content is preserved and renumbered.

B.1.1 Purpose and Scope

Chapter 3 specified REM as a five-layer runtime framework that selects one of four verdicts (Allow, Modify, Escalate, Block) for each tool call proposed by an LLM agent. The verdict minimizes expected loss under a calibrated probability of adversarial inducement and a declared consequence tier, and every verdict is recorded for audit.

This section reports how that specification was realized in software, how the software reaches the benchmark, and how it was verified. It distinguishes three kinds of verification throughout:

- **Unit verification:** a function computes what its equation states, on constructed inputs.
- **Integration verification:** the components operate together inside the benchmark's execution loop, and the benchmark's own checks behave as expected.
- **Security effectiveness:** whether REM reduces attack success at acceptable cost.

This section establishes only the first two. Chapter 4 reports the evidence on the third, and its limits.

Three rules governed the implementation:

1. **Fail closed.** A design value that has not been declared stops the software (`DesignNotSpecifiedError`) instead of being replaced by a default.
2. **No silent resolution.** Where the methodology of Chapter 3 and the design decisions of Stage 2 disagree, both alternatives are implemented and selected explicitly. The correspondence is recorded in Appendix B.1.12.
3. **Separation of decision and audit.** Attribution is computed after the verdict and cannot reach the decision function; this is enforced by the function's signature and checked by a test.

B.1.2 Software Environment

Table B.1. Software and hardware environment of the reported runs

Item	Value
Language	Python 3.11.17
Numerical library	NumPy 2.4.6
Benchmark	AgentDojo 0.1.35 (PyPI), banking suite; suite version v1 for execution
Recorded traces	AgentDojo repository `runs/`, commit `089ed468cf3ed0322acc66b0211f26d9d90dbf60`
Test framework	pytest 9.1.1
Hardware	Linux container, 4 vCPU (Intel Xeon @ 2.80 GHz), 15 GB RAM
Re-execution in a fresh environment (R3)	30 Oct 2026, merged repository state, Python 3.11.17, NumPy 2.4.6, AgentDojo 0.1.35, Intel Xeon @ 2.10 GHz, 4 vCPU; see Appendix B.1.11
Re-execution with the complete-call timer (R4)	1 Nov 2026, branch `claude/rem-r4-corrections-3ktvze`, Python 3.11.17, NumPy 2.4.6, AgentDojo 0.1.35, Intel Xeon @ 2.80 GHz, 4 vCPU; results in `results/pilot_R4/`; see Appendix B.1.11
Code version of the reported results	git commit `84a8c21` (revision R2). The first run (commit `aa66f22`) gave identical analytical results; see Appendix B.1.11

No machine-learning framework is used. The estimator, the calibrators and every metric are implemented directly in NumPy, so that each operation can be traced to its equation (Table B.6).

B.1.3 Code Organization and Execution Paths

Table B.2. Code organization

Package	Content
`rem/core/`	Frozen pipeline skeleton (`RemPipeline`), interfaces, step-level mitigation engine, append-only audit log, result types
`rem/algorithms/detection/`	Ridge logistic regression (Eqs. 3.1–3.2); instruction-pattern indicator $x \hat{} ctx_2$
`rem/algorithms/calibration/`	Platt calibration on the logit: smoothed-target fit (`PlattLogitCalibrator`) and label-NLL fit (`LabelNLLLogitCalibrator`, Eq. 3.4)
`rem/algorithms/context/`	Provenance labels, hygiene, entity extraction
`rem/algorithms/behavior/`	Evidence features (Tables 3.6–3.7); Bernoulli CUSUM (observe-only)
`rem/algorithms/decision/`	Expected-loss engine; consequence tiers; loss structure and dominance check; predicates and feasible set
`rem/algorithms/a3.py`, `a1.py`, `a2.py`	REM verdict rule; baseline B1; observe-only CUSUM analysis
`rem/evaluation/`	Discrimination and calibration metrics; grouped bootstrap; nested grouped cross-fitting
`rem/integration/`	AgentDojo trace loader, labeller, step builder, replay harness with the REM guard
`experiments/pilot/`	Experiment scripts and the reproduction script `run_all.sh`

The names A1, A2 and A3 come from the project brief and do not denote three methodologies:

- **A3** is the REM verdict rule;
- **A1** is the consequence-independent baseline B1 (Section 3.7.7);
- **A2** is the optional observe-only CUSUM (Appendix C.3).

Layer of the estimator. In this thesis the ridge estimator and the calibration map belong to the Decision Engine (Layer 4), as in the methodology of Chapter 3 and Figure 3.1. The comments and layer constants of the frozen pipeline's code label the estimator as part of Detection (Layer 2). The label does not affect any computation, and the frozen code was not edited to change it.

Two execution paths exist, and the experiments use only one of them.

1. **The frozen pipeline** (`rem/core/pipeline.py`, `RemPipeline.evaluate_step`) chains injected components through the five layers. It is exercised by unit and contract tests. It is **not** the path that produced any result in Chapter 4.
2. **The evaluation path** (`rem/integration/agentdojo_replay.py`, `RemGuard.evaluate`, together with `rem/algorithms/a3.py`, `A3Policy.decide`) is the path used in every experiment. It calls the frozen components:
    - the fitted ridge coefficients;
    - the calibration map;
    - `ExpectedLossDecisionEngine.conditional_risk` for Eq. 3.6;
    - `LinearShapleyAttributor` for Eq. 3.11.

    It adds the Chapter 3 components the frozen pipeline lacks: features, tiers, predicates, feasible set and both mitigation semantics. Mitigation is implemented in `RemGuard._mitigate`, not in the frozen `DeterministicMitigationEngine`.

Table B.3. Entry points and call paths of each experiment

Experiment (Chapter 4)	Entry point	Call path
Dataset	`experiments/pilot/build_dataset.py`	`load_episode` → `build_steps` → `EpisodeTracker.features` → `ReferenceLabeler.label` → `ConsequenceTierMap.tier`
Pilot E0	`e0_pilot.py`	`nested_crossfit` on each fold's fitting portion → `roc_auc`
E1 discrimination and calibration; ablation refits; grouping sensitivity	`run_main.py crossfit`	`Designer` (fold-specific x^beh$_4$) → `nested_crossfit` → `RidgeLogisticRegression.fit` → calibrator `fit` → `A1Thresholds.fit`
r_{mod} and replay validity	`run_main.py rmod`	`replay_episode` → `GuardedToolsExecutor.query` → `RemGuard.evaluate` (oracle Modify)
E2, E5 and E6 observe-only	`run_main.py observe`	`A3Policy.decide` / `A1Policy.decide` on held-out recorded steps
E4, E5 replay	`run_main.py replay`	`replay_episode` → `RemGuard.evaluate` → `A3Policy.decide` → `RemGuard._mitigate`

Experiment (Chapter 4)	Entry point	Call path
E3 CUSUM	`run_main.py a2`	`fit_a2` → `evaluate_episode`
Cross-template; recorded defenses	`run_main.py xt`	as E1 scoring, and as E4 replay
Breakdowns, replay failures, label-audit package	`r2_analyses.py`	stored state from the stages above
All of the above	`run_all.sh`	in order; writes `results/pilot_R2/` when `PILOT_RESULTS_DIR` is set

B.1.4 Layer 1 — Input and Context

`rem/algorithms/context/provenance.py` implements the provenance rule of Section 3.4.2:

- every segment is labelled trusted (system), semi-trusted (user) or untrusted (tool output);
- derived content takes the least-trusted label of its inputs;
- model-generated content has no channel label, so asking for one raises an error rather than guessing.

Hygiene. Zero-width, bidirectional and other Unicode format characters are removed from REM's copy of untrusted text (`strip_invisible`). The text the agent receives is not altered.

Entity extraction is partly implemented:

Entity (Section 3.4.3)	Status
Account identifiers	Implemented (IBAN pattern)
Monetary amounts	Implemented (numeric tokens)
User-profile values	Implemented for the values returned by the profile read
Tool names mentioned in text	Implemented, through the instruction-pattern indicator
Credential values	Not extracted as entities; a password argument is still traced to its source through argument provenance
Phone numbers and other profile identifiers	Not implemented separately

A declared matching rule (`value_occurs_in`) links an argument value to the texts that contain it:

- numbers match numerically;
- strings match as case-insensitive substrings;
- strings shorter than three characters never match.

B.1.5 Layer 2 — Detection

x^{ctx_2} (instruction-pattern indicator) is implemented by `InstructionPatternDetector`. It fires if a declared regular expression, or the name of a tool, occurs in new untrusted segments. The pattern set is declared in the pilot configuration, and the detector refuses to run without one. The configuration discloses that the author of the patterns knew the benchmark's templates.

x^{ctx_1} (pre-trained injection classifier) is not implemented. The classifier choice is pending, and the candidate model's host was unreachable from the execution environment. The feature is absent from x_t; it is not replaced by a substitute. The context evidence tested in Chapter 4 is therefore the instruction-pattern indicator only.

B.1.6 Layer 3 — Behavioral and Action Evidence

`rem/algorithms/behavior/evidence.py` implements $x^{beh_1-x}beh_4$ and $x^{act_1-x}act_3$ (Table 3.7). An `EpisodeTracker` holds the episode history; it is reset at each episode start and never changes REM's parameters. Where the methodology of Chapter 3 is silent, the module states an interpretation (Table B.4), so that the reader can disagree with it.

Table B.4. Interpretations made where the methodology of Chapter 3 is silent

ID	Question	Interpretation
I-1	What is a "step" when the agent proposes several calls at once?	Each proposed call is a step; calls in one assistant message share one decision point
I-2	Does $x\text{^}beh_2$ count refused calls?	Yes, because the methodology of Chapter 3 states that retries raise $x\text{^}beh_2$
I-3	$x\text{^}beh_3$ at the first call	"Highest level so far" is the lowest level (0)
I-4	$x\text{^}beh_4$ at the first call	Previous tool is a start symbol; start transitions belong to the reference set
I-5	$x\text{^}act_2$ "transactions before first untrusted ingestion"	Observable only through untrusted tool outputs, so it reduces to "recipient not in the objective"
I-6	$x\text{^}act_3$ "external recipient", "sensitive values"	Recipient differs from the user's own IBAN; sensitive values are identifiers and profile values from sensitive reads
I-7	Availability of $x\text{^}act_1$ for predicate D2	Unavailable when the tool has key arguments but the call carries none
I-8	"Tool class" in episode-level Modify	The tool's action category (Table 3.5) within $\mathscr{T}_R$
I-9	Unavailable feature below k_{D2}	Takes the value 0 ("not observed") and is flagged in the audit record

The benign transition set used by $x\text{^}beh_4$ must be estimated within each fold (Section 3.11.6). Each step record therefore stores its transition, and $x\text{^}beh_4$ is recomputed for every fold's reference.

B.1.7 Layer 4 — Decision Engine

Estimation. `RidgeLogisticRegression` computes $s = \beta_0 + \beta^T x$ and $\tilde{p} = \sigma(s)$ (Eq. 3.1), fitted by Newton–Raphson with the intercept unpenalized. Fitting without a declared λ raises `DesignNotSpecifiedError`. The implementation minimizes $NLL + (\lambda_{impl}/2)\|\beta\|^2$, so λ on the scale of Eq. 3.2 is $\lambda_{impl}/2$ (Section 3.7.1). Selected values are reported on both scales.

Calibration. Both calibrators compute $p = \sigma(\gamma_1 s + \gamma_0)$ and reject a fit with $\gamma_1 \leq 0$. They differ only in the fitting target: labels (Eq. 3.4, the reference) or Platt's smoothed targets (sensitivity).

Consequence tiers, predicates and feasible set.

- `ConsequenceTierMap` maps each tool to its category and the call to a tier. A transfer with a missing or unparseable amount receives the above-limit tier.

- `PredicatePolicy` implements D1 and D2, and the feasible set (Modify only for tools in $\mathscr{T}_R$).
- `A3Policy.decide` applies D1 and D2 before the expected-loss rule. When a predicate applies, the risk table is recorded as *not applicable* and p is marked as not used.

Verdict. `A3Policy` computes R(v) for v ∈ $\mathscr{V}(a_t)$ through the frozen `conditional_risk` and returns the minimizer. Ties are handled by an explicit `tie_mode`:

- `"raise"` reproduces the frozen behavior;
- `"record_chapter3_order"` applies the Chapter 3 order and marks the step as tied.

An option `exclude_from_expected_loss=(Escalate,)` produces the comparison configuration "REM without expected-loss Escalate" (Section 3.7.7).

Loss structure and dominance check. `build_loss_grid` constructs Table 3.11 including Eq. 3.5, and `reachable_verdicts` reports any verdict that is never the unique minimizer.

Baseline B1. `operating_threshold` implements Eq. 3.14, and `A1Policy` applies it with the same estimator, calibration and predicates.

Audit record. For each step, `RemGuard.evaluate` writes:

- the tool name and a SHA-256 digest of its arguments, with the argument keys;
- the evidence vector and its availability;
- s, $\tilde{p}$ and p, and whether p was used;
- the tier, and the risk table or *not applicable*;
- the verdict, its source and the mitigation;
- the linear attributions with their additivity error;
- REM's processing time.

Raw argument values are not written.

B.1.8 Layer 5 — Mitigation, and What Happens at the Tool Boundary

Mitigation is applied before any tool executes. In `GuardedToolsExecutor.query`, each proposed call is evaluated by `RemGuard.evaluate`. If the call is released, `runtime.run_function` executes it. Otherwise it is not executed, and a tool-result message carrying the refusal or restriction notice is returned to the agent in its place. The replay tests check this directly: an oracle that blocks every labelled step leaves the benchmark's

security check false, and the withheld steps appear in the audit record with their tool and argument digest.

Both mitigation semantics are implemented (Table 3.12). Step-level semantics is the reference; the episode-level variant maintains a restriction set S for the episode. Under step-level semantics, Modify and Block have the same effect on the current call. The two semantics can differ without any retry: an episode-level Block refuses every later call to a tool in $\mathcal{T}_R$, including a call whose own verdict is Allow. `tests/test_mitigation_semantics.py` checks this on a fixed sequence: Block `send_money`, then Allow `update_password`; the second call is released under step-level semantics and refused under episode-level semantics. Chapter 4 (Table E.1) reports the replay results of both semantics.

Escalate. No reviewer exists. Escalation is resolved by one of two bounds:

- an idealized reviewer, which releases the call if and only if its label is 0;
- no reviewer, in which the call is withheld.

Correction made in revision R2. In the frozen pipeline, the Block mechanism cleared the step's tool call before the audit record was written. The record therefore lost the identity of the blocked action. A test now reproduces the defect, and the fix keeps the tool name and argument digest in the step's metadata, without raw arguments. The audit record uses them. The fix does not change any verdict or mitigation, and it does not affect any result in Chapter 4, because the experiments use the evaluation path, in which mitigation never alters the proposed call, so the tool's identity was always recorded; the argument digest was added to that record in this revision.

B.1.9 Non-Invasive Placement and Its Limits

"Non-invasive" means here that **the agent's model, prompts and tools are not modified**: REM observes the messages the agent produces and the results the tools return. The placement has limits:

- **REM replaces the executor.** It must be inserted into the agent's execution loop, here as a subclass of the benchmark's `ToolsExecutor`. A framework in which tools are executed by a component REM cannot wrap is not covered.
- **Only executor calls are mediated.** Effects that do not pass through the tool executor (for example, a tool with side effects inside its own implementation, or a second agent) are outside REM's view.

- **Refusals are visible to the agent.** They are returned as tool-result messages. The agent's reaction to them is part of the system's behavior, and the replay analysis does not observe it.
- **Some context is inferred, not received.** In the evaluation, REM receives the objective and system prompt from the recorded trace. A deployment must supply them through the same channel.

B.1.10 Optional Sequential Analysis (A2)

`rem/algorithms/behavior/cusum.py` and `rem/algorithms/a2.py` implement the Bernoulli CUSUM of Eqs. 3.15–3.19. The module has no interface to the decision engine and returns no verdict; a test checks both properties.

An A2-driven enforcement policy and a retrained "A3 + A2" variant are not implemented, because they would place CUSUM in the verdict path.

B.1.11 Verification

Unit and contract verification

Table B.5. Test suite (executed on 1 Nov 2026: 205 passed with AgentDojo installed; log `verification/pytest_R4.txt`)

File	Tests	Verifies
`test_frozen_math.py`	43	Eqs. 3.1–3.3, 3.6; fail-closed fitting; $\gamma_1 > 0$; a tie raises
`test_contract_compliance.py`	20	Five layers, no sixth; frozen mitigation mapping; no equation IDs; forbidden components absent; attribution excluded from the decision signature
`test_metrics.py`, `test_probabilistic.py`	25 + 5	ROC-AUC against the pairwise definition; average precision; ECE binning (Eq. 3.20); log-loss; Brier conventions; grouped bootstrap
`test_pipeline.py`	21	Frozen pipeline order; step-level Block; **the blocked action's identity is kept in the audit record** (added in R2)
`test_mitigation.py`, `test_trajectory.py`, `test_config.py`, `test_reproducibility.py`	9 + 12 + 15 + 9	Step-level mitigation, configuration fail-closed, seeds

File	Tests	Verifies
`test_a3.py`	10	Table 3.11; Eqs. 3.8–3.10; argmin over the feasible set; D1 and D2; ties; dominance check; **REM without expected-loss Escalate keeps D2** (added in R2)
`test_a1.py`	5	Eq. 3.14 minimality; $\alpha = 0$; invariance under monotone recalibration; verdict rule
`test_a2.py`	5	Eqs. 3.15–3.17; indicator set; false-alarm target; no verdict
`test_evidence.py`	7	Trust order; hygiene; features on an injected and a legitimate transfer; availability; tier map
`test_crossfit.py`	2	Procedure 3.1 outputs; held-out predictions independent of held-out labels
`test_traces.py`	2	Label rule including induced reads and ambiguity; fold-specific $x \wedge beh_4$
`test_replay.py`	3	All-Allow replay reproduces a recorded episode; oracle Block prevents the recorded attack; **withheld calls keep tool and argument digest, and no raw attacker value appears in the audit record** (extended in R2); observe-only releases everything
`test_mitigation_semantics.py`	4	Step-level and episode-level policies on a fixed sequence (Block `send_money`, then Allow `update_password`): different release outcomes, neither policy altered (added in R4)
`test_latency_instrumentation.py`	2	Fake-clock check that the partial timer stops before attribution, audit construction and history recording, and the complete-call timer after them (added in R4)
`test_docx_tables.py`	6	Thesis build tooling, not REM: the Word table transformation keeps exactly one run-property container per run, preserves hyperlinks and equations, and is idempotent (added in R4)

Integration verification

- **Replay fidelity.** With every call allowed, the replay reproduced the recorded utility and security outcome of 3,313 of 3,334 episodes (99.4%). The 21 exceptions are analyzed in Chapter 4.
- **Determinism and regression.** The complete pilot was run at commit `aa66f22` (R1) and again at commit `84a8c21` (R2), after the corrections of this revision. An automated comparison of the 5,121 values the two runs share found 93 differences, all of them wall-clock time or memory measurements; every analytical value was identical. A second comparison with a different leaf-matching method (`compare_reproduction.py`, R3) counted 5,220 shared values and 104 differences, all in time, memory or provenance fields, and 0 analytical differences.
- **Re-execution in a fresh environment (R3, 30 October 2026; by this project, not an external replication).** The complete pipeline (`run_all.sh`) was executed again, from the merged repository state, on a different processor and with the AgentDojo repository obtained afresh at commit `089ed468`. Of the 6,057 numeric values that the re-run shares with `results/pilot_R2/`, 5,943 were identical. The 114 that differed are 100 per-step latency values, 13 code-commit stamps and one file path; no memory value and 0 analytical values differed (`RESULTS_PROVENANCE_REPORT.md`; every differing value is listed in `verification/reproduction_all_differences.json`).
- **Re-execution with the complete-call timer (R4, 1 November 2026).** After the timer was added, the complete pipeline was executed again into `results/pilot_R4/`. Of the 6,057 numeric values it shares with `results/pilot_R2/`, 5,942 were identical, 115 were latency, commit or file-path values, and 0 analytical values differed. The new complete-call fields have no R2 counterpart. Every differing value is listed in `verification/reproduction_all_differences_R4.json`.
- **Attribution additivity.** The audit record carries $|\varphi_0 + \Sigma\varphi_i - s|$ for every replayed step.

What is not verified here

Security effectiveness against live agents is not verified; Chapter 4 states what the recorded-trace analyses can and cannot show.

B.1.12 Correspondence Between Requirements, Equations, Code, Tests and Results

Table B.6. Requirement → equation → function → test → result artifact

Requirement (the methodology of Chapter 3)	Equation	Function	Test	Result artifact (`results/pilot_R2/`)
Logit and uncalibrated probability	3.1	`ridge_logistic.RidgeLogisticRegression.decision_function`	`test_frozen_math`	`e1_crossfit.json` (`pooled_uncalibrated`)
Ridge fit ($\lambda = \lambda_{impl}/2$)	3.2	`RidgeLogisticRegression.fit`	`test_frozen_math`	`e1_crossfit.json` (`per_fold.*.lambda`, `lambda_chapter3_eq3_2_scale`)
Calibration map, $\gamma_1 > 0$	3.3	`PlattLogitCalibrator.calibrate`	`test_frozen_math`	`e1_crossfit.json` (`gamma_1`)
Calibration fit on labels	3.4	`logit_nll.LabelNLLLogitCalibrator.fit`	`test_crossfit`	`e1_crossfit.json` (`label_nll_primary`)
Adversarial Modify loss	3.5	`loss_matrix.build_loss_grid`	`test_a3`	`e4_rmod_and_replay_validity.json` (r_{mod})
Conditional risk	3.6	`expected_loss.ExpectedLossDecisionEngine.conditional_risk`	`test_frozen_math`, `test_a3`	`e2_e5_e6_observe_only.json`
Verdict over $\mathcal{V}(a_t)$, ties	3.7	`a3.A3Policy.decide`	`test_a3`	`e2_e5_e6_observe_only.json` (`ties`)

Requirement (the methodology of Chapter 3)	Equation	Function	Test	Result artifact (`results/pilot_R2/`)
Thresholds, feasibility, dominance	3.8–3.10	`loss_matrix.*`	`test_a3`	`e2_e5_e6_observe_only.json` (`dominance`)
Attribution, additivity	3.11–3.13	`linear_shapley.LinearShapleyAttributor`	`test_frozen_math`	replay audit field `additivity_error`
Baseline thresholds	3.14	`a1.operating_threshold`	`test_a1`	`e1_crossfit.json` (`theta_blk`, `theta_mod`)
CUSUM	3.15–3.19	`cusum.BernoulliCusum`, `a2.*`	`test_a2`	`e3_a2_cusum_observe_only.json`
ECE, log-loss	3.20–3.21	`probabilistic.*`	`test_probabilistic`	`e1_crossfit.json`
Realized loss	3.22	`run_main.stage_observe`	— (script)	`e2_e5_e6_observe_only.json` (`e6_grid`)
D1/D2 before expected loss	—	`PredicatePolicy.evaluate`, `A3Policy.decide`	`test_a3`	`e2_e5_e6_observe_only.json` (`sources`)
Step- and episode-level mitigation	Table 3.12	`RemGuard._mitigate`	`test_replay`	`e4_e5_enforcement_replay.json`
Audit identity of withheld actions	Section 3.7.6	`RemGuard.evaluate`; `mitigation.py`, `audit.py`	`test_replay`, `test_pipeline`	—

Table B.7. Components required, implemented and absent

Component (the methodology of Chapter 3)	Status
Provenance labels, hygiene	Implemented
Entity extraction	Partly implemented (Appendix B.1.4)
$x\hat{}ctx_1$ injection classifier	**Absent**
$x\hat{}ctx_2$, $x\hat{}beh_{1-4}$, $x\hat{}act_{1-3}$	Implemented
Ridge estimator; both calibration fits	Implemented
Tiers, predicates, feasible set, loss structure, dominance check	Implemented
REM verdict; B1; REM without expected-loss Escalate	Implemented
Step-level and episode-level mitigation	Implemented (evaluation path)
Human reviewer	Absent; replaced by two bounds
Offline fitting (Procedure 3.1)	Implemented
CUSUM (observe-only)	Implemented
Live enforcing-mode execution	**Not executed** (no LLM access)

B.1.13 Logging of Sensitive Values

- **Audit records.** The audit records of the evaluation path store argument digests and keys, not values. A test checks that neither the attacker's account identifier nor the attacker's password appears in any audit record of a replayed episode.
- **Frozen audit log.** It stores digests by default; raw payloads are written only if `record_payloads=True` is set explicitly.
- **Result files.** Two result files contain argument values copied from the benchmark's traces: the label-audit sample and the human label-audit package. These values are synthetic benchmark data (simulated IBANs and passwords), not real credentials.
- **Credentials.** No credential, API key or real account identifier is used by the code or written by it.

B.1.14 Runtime Measurement

Two timers are recorded for every step. Both start with `time.perf_counter` at the entry of `RemGuard.evaluate`. They differ in where they stop (Table B.8).

Table B.8. Boundaries of the two timers

Work inside `RemGuard.evaluate`	Partial timer `rem_latency_ms` (R1–R4)	Complete-call timer `rem_latency_full_ms` (R4)
Feature computation (Layers 1–3)	Included	Included
Tier, reference-label lookup, scoring and calibration	Included	Included
Predicates, verdict and mitigation decision	Included	Included
Linear attribution and additivity check	**Excluded**	Included
Audit-record construction, including the argument digest	**Excluded**	Included
Recording the proposal in the episode history	**Excluded**	Included

Both timers **exclude**:

- LLM inference (absent in replay);
- tool execution and benchmark environment set-up;
- the benchmark pipeline's own overhead;
- the call into and return from `evaluate`.

Both **include** the reference-label lookup. This is evaluation bookkeeping, which a deployment would not perform: it computes the evaluation label recorded in the audit record and used by the idealized reviewer.

Correction. Revision R3 stated that the measured interval included attribution and audit-record construction. It did not: the timer of R1–R3 stopped before them. All R1–R3 timing values are partial-timer values. The complete-call timer was added in R4 without changing the partial timer. `tests/test_latency_instrumentation.py` checks both boundaries with a fake clock and an ordered event log, not with wall-clock thresholds.

Conditions. Measurements were taken in four parallel worker processes on a 4-vCPU container, so they include contention between workers, and they vary between runs (Appendix B.1.11). The R4 run used an Intel Xeon @ 2.80 GHz with Python 3.11.17 and NumPy 2.4.6. Memory is a separate measurement: the peak allocation traced by `tracemalloc` around the complete `RemGuard.evaluate` call, on 300 episodes with the episode-level variant.

These figures describe the evaluated configuration: no injection classifier, no reviewer, and Python on this hardware. They do not describe a deployment that includes a neural classifier or a human review step.

Appendix C: Notation, Optional Sequential Analysis and Equation Provenance

C.1 Notation

Table C.1. Notation used in this chapter

Symbol	Meaning
t, T	Step index within an episode; episode length
g	User objective of the episode
c_t	Context at step t, as segments with provenance labels
a_t	Proposed action (tool name and arguments) at step t
H_t	Episode history up to step t
$y_t \in \{0, 1\}$	Latent label: 1 if a_t is adversarially induced
$x_t \in [0, 1]^d$	Evidence vector; groups x^{ctx}, x^{beh}, x^{act} with index sets I_{ctx}, I_{beh}, I_{act}
β_0, β, λ	Logistic intercept, coefficient vector, ridge strength
s_t	Logit (linear predictor)
$\tilde{p}_t, p_t$	Uncalibrated probability; calibrated probability
γ_1, γ_0	Calibration slope and intercept
z_t, k_t, κ	Consequence descriptors; consequence tier; tier map
$\mathcal{V}$	Verdict set {Allow, Modify, Escalate, Block}
$\mathcal{V}(a_t)$	Verdicts feasible for a_t
v_t	Verdict issued at step t
$L(v, y, k)$	Loss of verdict v when the label is y and the tier is k
$C_{miss}(k), C_{FA}(k), C_{mod}(k), C_{esc}$	Declared costs of a missed attack, a false intervention by Block, Modify on a legitimate action, and escalation
$r_{mod}(k)$	Residual attack-success rate after Modify at tier k (measured)
$R_t(v)$	Conditional risk of verdict v at step t
$\pi_{v,v'}(k), p^*_k$	Indifference threshold between verdicts v and v′; Allow–Block threshold
$\sigma(\cdot)$	Logistic function, $\sigma(u) = 1 / (1 + \exp(-u))$
Π, k_{D2}	Set of prohibited actions; minimum tier for predicate D2

Symbol	Meaning
$\theta(\alpha)$, α_{blk}, α_{mod}	Baseline threshold for false-positive target α; targets for Block and Modify
$\mathcal{T}_R$	Set of tools to which the Modify mechanism applies

Symbols used only in the optional sequential analysis are defined in Appendix C.3. Symbols that appear in a single equation, such as Δ_0, Δ_1, B_m, and the step sets D_{fit}, D_{cal}, and D_{val}^{benign}, are defined where they are used. Each symbol has one meaning throughout the chapter.

C.2 Layer interfaces

Table C.2. Layer interfaces

Layer	Consumes	Produces
L1 Input & Context	Objective, system prompt, user messages, tool results, proposed action	Labeled context c_t; entities with provenance; held action a_t
L2 Detection	Untrusted segments of c_t	Context evidence x^{ctx}
L3 Behavioral Analysis	H_t, a_t, entities, benign reference transitions, privilege map	Behavioral evidence x^{beh}; action evidence x^{act}
L4 Decision Engine	x_t, consequence descriptors z_t, frozen parameters, declared policy	p_t, k_t, $R_t(\cdot)$, verdict v_t, audit record
L5 Mitigation	v_t, a_t, episode restrictions	Released, restricted, withheld, or refused action

The four functions are separated architecturally. Layers 2 and 3 produce evidence and issue no verdicts. Layer 4 performs probability estimation and decision. Layer 5 performs mitigation.

C.3 Optional observe-only sequential analysis

Sequential change detection is not part of REM's verdict path. If the supervisor approves it for the thesis narrative, it is performed **offline** on the per-step indicators logged by the Behavioral Analysis Layer. It never influences a verdict.

For each step, a binary deviation indicator $e_t \in \{0, 1\}$ is defined as 1 if at least one of x^{beh}_1, x^{beh}_3, x^{beh}_4, or x^{act}_1 equals 1, or if $x^{beh}_2 = 1$; otherwise 0 [indicator set pending supervisor approval]. Let q_0 and q_1, with $0 < q_0 < q_1 < 1$, be the rates of $e_t = 1$ before and after an adversarial change.

The log-likelihood ratio of one observation, as defined by Basseville and Nikiforov (1993), specialized to Bernoulli observations, is:

$$\ell_t = e_t \ln \frac{q_1}{q_0} + (1 - e_t) \ln \frac{1 - q_1}{1 - q_0} \quad (3.15)$$

Status: derived by substituting the Bernoulli probability mass function into the log-likelihood ratio of Basseville and Nikiforov (1993). A cumulative sum chart for Bernoulli observations is treated by Reynolds and Stoumbos (1999).

The cumulative sum statistic and alarm time are (Basseville & Nikiforov, 1993; Page, 1954):

$$G_t = max(0, G_{t-1} + \ell_t), G_0 = 0 \quad (3.16)$$

$$T_A = min\{t : G_t \geq h_G\} \quad (3.17)$$

where $h_G > 0$ is the alarm threshold.

Status: established from source.

The per-episode false-alarm rate on benign episodes and the detection delay are defined as:

$$FA_{ep}(h_G) = \frac{\left|\{ j \in E_{ben} : \max_t G_t^{(j)} \geq h_G \}\right|}{|E_{ben}|} \quad (3.18)$$

$$\tau_d = T_A - \nu, T_A \geq \nu \quad (3.19)$$

where E_{ben} is the set of benign episodes in the fitting portion of a fold, $G^{(j)}_t$ is the statistic in benign episode j, τ_d is the detection delay, and ν is the first step at which injected content enters the context.

Status: design definitions.

The parameters are determined as follows:

- q_0 is the empirical rate of $e_t = 1$ on benign fitting steps, floored at a declared minimum.
- q_1 is declared and reported over a range, because the scarcity of multi-step attacks does not allow it to be estimated reliably.
- h_G is the smallest value for which Equation 3.18 does not exceed a declared target.

The procedure has known optimality properties in sequential change detection: Lorden (1971) proposed stopping rules that are asymptotically optimal in a defined sense, and Moustakides (1986) showed Page's stopping time to be optimal in a stronger sense. Both results are proved within a sequential-analysis model whose conditions could not be inspected during verification and are not claimed to hold for agent trajectories, where observations are neither independent nor drawn from known distributions. They therefore motivate the procedure and provide no guarantee in this setting. Given the short trajectories of Section 3.11.4, this analysis may have little to detect.

C.4 Provenance of the equations of Chapter 3

Table C.3. Provenance of the equations in this chapter

Eq.	Content	Status	Source	Verification
3.1	Logistic model	Established	Cox (1958)	IV
3.2	Ridge-penalized log-likelihood	Established	le Cessie & van Houwelingen (1992)	IV (penalty constant pending)
3.3	Logistic calibration on the logit, $\gamma_1 > 0$	Adapted	Platt (2000); Guo et al. (2017); Kull et al. (2017)	Platt NC; Guo FV; Kull FV
3.4	Calibration fit by negative log-likelihood	Established	Guo et al. (2017)	FV
3.5	Adversarial loss of Modify	Derived (assumption A-Mod)	Law of total expectation	DER
3.6	Conditional risk	Adapted	Elkan (2001)	FV (Eq. 1 form)
3.7	Bayes verdict with tie-breaking	Adapted	Elkan (2001)	FV; tie order DEF
3.8	Pairwise indifference threshold	Derived	From Eq. 3.6	DER
3.9	Allow–Block threshold	Derived	From Eq. 3.8; consistent with Elkan (2001)	DER
3.10	Escalation feasibility condition	Derived	From Eqs. 3.6, 3.7, 3.9; Chow (1970) conceptual basis	DER; Chow IV
3.11	Linear attribution	Adapted	Lundberg & Lee (2017)	FV
3.12	Completeness identity	Derived	Lundberg & Lee (2017) local accuracy	FV + DER
3.13	Group attribution	Definition	—	DEF

Eq.	Content	Status	Source	Verification
3.14	Baseline operating-point threshold	Definition	—	DEF
3.15	Bernoulli log-likelihood ratio (optional)	Derived	Basseville & Nikiforov (1993); Reynolds & Stoumbos (1999)	FV; R&S IV
3.16	CUSUM recursion (optional)	Established	Basseville & Nikiforov (1993); Page (1954)	FV; Page IV
3.17	Alarm time (optional)	Established	Basseville & Nikiforov (1993)	FV
3.18	Per-episode false-alarm rate (optional)	Definition	—	DEF
3.19	Detection delay (optional)	Definition	—	DEF
3.20	Expected calibration error	Adapted	Naeini et al. (2015); Guo et al. (2017)	FV
3.21	Log-loss	Derived	From Eq. 3.2	DER
3.22	Realized loss	Definition	—	DEF

Implementation conventions. Four conventions in the implementation differ in form from the equations as printed; none changes their meaning:

- **Eq. 3.2:** the code's penalty is $(\lambda_{\text{impl}}/2)\|\beta\|^2$, so $\lambda = \lambda_{\text{impl}}/2$ (Section 3.7.1).
- **Eq. 3.4:** the label-NLL fit is the reference; Platt's smoothed targets are a sensitivity variant.
- **Eq. 3.14:** the candidate set includes a value just above the largest benign probability.
- **Eq. 3.20:** steps with $p = 0$ fall in the first bin.

These conventions are listed with the code location of each equation in the requirement–equation–function–test table of Section 3.15.

Verification codes: FV — formulation checked against the source; IV — source identity confirmed, formulation to be checked against the full text; NC — source not accessible during this revision; DER — derived in this chapter; DEF — design definition. The codes are retained until final reference verification is complete.

Appendix D: Live-Agent and MELON Evaluations: Design and Status (Not Executed)

This appendix records the design and status of two evaluations that were implemented and **not executed with a language model**: the closed-loop evaluation of REM with live agents, and the controlled evaluation of MELON with and without REM. Nothing in this appendix is an experimental result. The checks it reports use scripted agents and simulated providers and establish only that the integrations are mechanically correct. The text is reproduced from the thesis drafts of 3 to 6 November 2026.

D.1 Closed-loop evaluation with live agents: design and implementation status

Status. The closed-loop evaluation described in this section is **implemented and tested with scripted test agents, but has not been executed with a language model** (Section 4.4.4). Nothing in Chapter 4 is a live result.

D.1.1 Purpose

The replay sensitivity analysis (Section 3.11.10) re-executes recorded trajectories and assumes that the agent does not adapt to REM's refusals. It can therefore show whether a recorded attack call would have been withheld, but not what an agent does after a refusal: it cannot observe retries, rephrased calls or alternative tools. The closed-loop design removes that assumption. A running LLM agent receives REM's decision for each proposed call and may continue, retry, replan or stop, and the benchmark scores the outcome after the agent's own reaction.

D.1.2 Defended agent pipeline

The integration uses AgentDojo's own pipeline elements without modifying the benchmark (Figure D.1). The pipeline consists of a system message, the user task's prompt, the LLM, and a tool-execution loop in which AgentDojo's tool executor is replaced by REM's guarded executor (Appendix B.1.8). For each proposed call the defended process is:

1. the agent proposes a tool call with arguments;

2. REM intercepts the call **before** it is executed;
3. REM computes the evidence vector, the tier, the logit and the calibrated probability with frozen parameters (Sections 3.4–3.7);
4. the decision function selects Allow, Modify, Escalate or Block (Eqs. 3.6–3.7, or the baseline of Eq. 3.14);
5. the Mitigation Layer applies the declared semantics (Section 3.8, Table 3.12): a released call is executed in the sandbox; a withheld call returns a tool message with the same tool-call identifier and a refusal notice;
6. the result or refusal re-enters the agent's context as untrusted content, and the agent continues;
7. the benchmark evaluates utility and security on the final environment.

The decision code is the code of the recorded-trace study (`RemGuard`); only the source of the agent's messages changes, from a recorded trajectory to a live model. AgentDojo re-queries the pipeline up to three times when the agent produces no final answer; the same guard, and therefore the same episode history, persists across these re-queries.

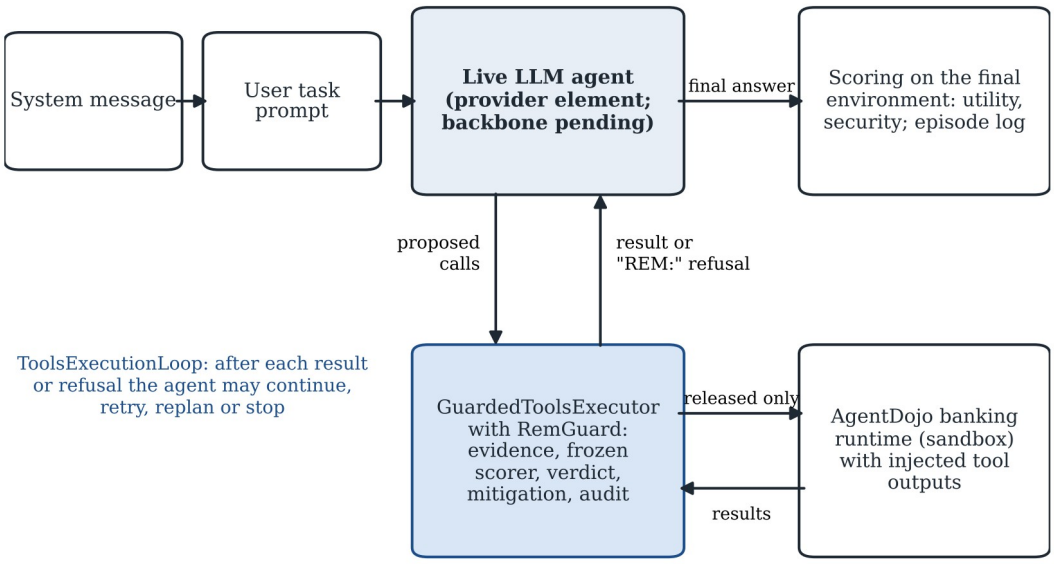


Figure D.1. Closed-loop (live-agent) evaluation architecture. REM's guarded executor replaces AgentDojo's tool executor; the agent receives the result of a released call or the refusal of a withheld one and may retry, replan or stop. Implemented and tested with scripted test agents; not executed with a language model.

D.1.3 Conditions and controlled variables

Three primary conditions are defined, with the same pipeline, tasks, injections, system prompt, model, decoding settings and iteration limit:

- **B0:** no defense (every call released; REM records the step but never intervenes);
- **B1:** the consequence-independent operating-point baseline (Eq. 3.14) on the same frozen estimator, calibration and predicates;
- **REM:** the tier-indexed expected-loss verdict (Eqs. 3.6–3.7) on the same frozen estimator.

REM without expected-loss Escalate (Section 3.11.7) can be added as a fourth condition. The comparison B1 versus REM therefore isolates the decision rule, as in the recorded-trace study.

D.1.4 Frozen parameters

No parameter is fitted on live data. The estimator, calibration map, baseline thresholds, benign reference and r_{mod} are those of one outer fold of the recorded-trace cross-fitting (Procedure 3.1). Which fold is used is a design input; the pilot has no fit on all recorded data.

D.1.5 Design inputs required before execution

The runner refuses to start until each of the following has been decided and recorded (CLAUDE design lock; supervisor decision register D-2, D-6, D-7, D-8, D-9, D-15):

Input	Status
Authorisation for paid model use, budget, pre-registration of hypotheses and analysis	Pending (D-15)
Backbone(s) with exact model versions; decoding parameters	Pending (D-15)
Number of repeats per configuration	Pending (Section 3.11.9 proposes at least three)
Suite version, attack templates, user and injection tasks	Pending (D-6)
Mitigation semantics (step-level and/or episode-level)	Pending (D-2)
Reviewer treatment (idealized and/or no-reviewer bound)	Pending (D-7)
Costs, tiers, predicates and feature set	Exploratory pilot values only (D-9, D-8)
Fitted-parameter source (outer fold)	Pending

D.1.6 Metrics, statistics and logging

The metrics are those of Section 3.12, computed on live outcomes: attack success rate, benign utility and utility under attack from the benchmark's verdicts; intervention rates on $y = 0$ and $y = 1$ proposals; and processing time from the complete-call timer. Three descriptive adaptation counts are added, computed from REM's audit record: a *retry* is a later proposal of the same tool with the same argument digest as a withheld call; a *replan* is a later proposal of a different restricted tool after a withheld call; and a *release after refusal* is a reference-labelled attack call released after an earlier withheld call in the same episode. Uncertainty is estimated by the grouped bootstrap of Section 3.11.9, with repeats kept inside their injection-task or user-task group. Every episode is logged with its audit records, truncated messages and adaptation counts, together with a manifest of the commit, configuration hash and frozen fold.

D.1.7 Safety precautions

All tools act on the benchmark's simulated banking environment; no real account or payment system is reachable, and REM never initiates a call. Argument values are recorded only as digests in the audit record, and message logs are truncated.

D.1.8 Implementation and verification status

Table D.1. Implementation status of the closed-loop evaluation (3 November 2026)

Component	Location	Status
Defended live pipeline	`rem/integration/agentdojo_live.py`	Implemented; tested with scripted test agents
Guarded executor, decision and mitigation	`rem/integration/agentdojo_replay.py` (unchanged)	Implemented; used in the recorded-trace study
Runner with fail-closed configuration and credential checks	`experiments/live/run_live.py`	Implemented; verified to refuse the undecided template
Metrics with grouped bootstrap	`experiments/live/analyze_live.py`	Implemented; tested on synthetic records
Integration tests (interception, semantics, identifiers, retries and replans, episode isolation, label isolation)	`tests/test_live_integration.py`	12 tests passed (full suite: 217 passed)
Harness smoke test with a scripted ground-truth agent on all 160 task combinations	`experiments/live/smoke_scripted.py`	Executed: 480 episodes, 0 errors (not an experimental result)
Execution with a language model	—	**Not executed**: no model credential; design inputs pending

D.2 Closed-loop evaluation with live agents: status on 3 November 2026

The closed-loop evaluation with live agents was not executed. This section therefore reports no attack success rate, utility, intervention statistic or adaptation behavior of a live agent, and no table or figure in this chapter contains a live result.

Two conditions prevented execution on 3 November 2026:

- **No model access.** No credential for a language-model provider was available in the execution environment; the provider endpoints that were reachable rejected unauthenticated requests, and model-weight repositories were not reachable, so no local model could be run.
- **Undecided design inputs.** The backbone, decoding parameters, number of repeats, fitted-parameter source, authorisation and pre-registration (Appendix D.1.5) have not been decided. The runner refuses to start until they are.

What was executed concerns the correctness of the integration, not the effectiveness of REM:

Table D.2. Verification of the closed-loop integration (not experimental results)

Check	Agent	Outcome
Integration tests (12)	Scripted test double that proposes predetermined calls and retries or replans after a refusal	All passed: released calls execute; withheld calls (Block, Modify, unapproved Escalate) are not executed and the agent receives a refusal with the original call identifier; step-level Modify does not persist, episode-level Modify does; retries and replans are recorded; episode state is not shared; REM verdicts are unchanged when reference labels are flipped
Harness smoke test (B0, B1, REM; step-level, no reviewer; one frozen fold)	Scripted agent that executes the ground-truth calls of the user task and then of the injection task, without adapting	480 episodes over all 144 attacked task pairs and 16 benign tasks with the benchmark's `important_instructions` injections; 0 execution errors; no withheld call was executed

The smoke-test agent is not a model of an LLM agent: it never reads tool outputs or reacts to refusals. Its counts are therefore not reported as attack-success or utility results. The live evaluation remains the first item of future work (Section 5.7).

D.3 Replay versus live evaluation

No comparison of replay and live results is possible, because no live result exists (Section 4.4.4). The replay results of Section 4.6.3 must not be read as live results. The two designs estimate different quantities:

Table D.3. Differences between the replay sensitivity analysis and the closed-loop design

Aspect	Replay (Section 4.6.3)	Closed loop (Appendix D.1; not executed)
Agent messages	Recorded, replayed in order	Generated by a running model
Reaction to a refusal	None (NO-ADAPT)	Retry, replan or stop
Meaning of attack success	Whether the recorded attack calls would have been withheld	Whether the attack succeeds despite the agent's reaction
Residual success after Modify	Close to zero by construction	Observable
Repeatability	Deterministic	Stochastic; requires repeats
Backbones	21 recorded historical backbones	To be decided

Because a live agent can retry or route around a refusal, the replay attack success rate is not an upper bound on live attack success. How large the difference is, in either direction for utility, is an empirical question that only the closed-loop evaluation can answer.

D.4 Controlled evaluation of MELON with and without REM: protocol

Status. This section describes an **implemented protocol for a planned evaluation**. The integration has been verified locally with scripted test agents and fake model clients only. **No run with a language model has been executed, and Table D.4 contains no result.**

D.4.1 Why MELON is the reference

MELON (Zhu, Yang, et al., 2025) is a published runtime defence against indirect prompt injection that was evaluated on AgentDojo and has an official implementation. Chapter 2 reviews it among the goal–action consistency defences (Section 2.5.2; Table A.3).

MELON re-executes the agent's next step with the user's request masked. It flags an attack when the actions proposed with and without the request are similar, and it then stops the agent. Its evidence is therefore behavioural and model-based. It does not weigh what a proposed action would do or how costly an error would be.

REM, by contrast, decides per action from a calibrated probability and consequence-tiered losses (Section 3.7). The study asks what changes when REM is added at the tool-execution boundary of MELON, compared with MELON alone. This is an **extension of a published defence through integration with REM**:

- MELON's algorithm is not modified;
- REM was not derived from MELON;
- no improvement is presumed;
- a record-level literature search found no evaluation of this combination, but the search was not exhaustive, so no novelty is claimed.

D.4.2 Integration point

MELON's official implementation places its detector after AgentDojo's tool executor:

- the loop is `[ToolsExecutor, MELON]`;
- MELON makes the agent's next model call itself, together with a masked model call that executes no tool;
- on detection, MELON replaces the agent's proposed calls with a stop message.

In MELON + REM, the executor is the only element replaced: REM evaluates each call that survived MELON immediately before execution. It also evaluates the first turn's calls, which MELON does not inspect.

- A withheld call never reaches the environment.
- The agent receives a refusal carrying the call's identifier and may continue.
- REM never sees MELON's masked generation.

The official MELON code requires an AgentDojo version with string message content. Both conditions therefore run on AgentDojo 0.1.29, whose banking v1 task and attack code are identical to those of REM's fitting traces. Two compatibility measures are applied identically in both conditions:

- the embedding client is supplied without editing the file;
- MELON's per-episode state is reset between episodes, since otherwise it would persist across episodes and conditions.

Each measure and its effect are documented in the integration notes of the study's repository.

D.4.3 Frozen settings and training provenance

REM runs with the frozen components of the nested cross-fit (Section 3.11). Nothing is refitted:

- **Estimator:** ridge estimator with logit calibration ($\gamma_1 > 0$ in every fold).

- **Predicates and loss structure:** the declared exploratory costs and consequence tiers of Section 3.7, which are not supervisor-approved.
- **Mitigation:** step-level semantics. Modify, Block and Escalate all withhold the current call; their immediate execution effect is the same.
- **Reviewer:** none. An escalated call is never released, and no label-based reviewer is used.

For an attacked case, the fold whose fit excluded that attacker objective is used. Because the 16 user tasks and their environment were seen in fitting, the evaluation covers **held-out attacker objectives on familiar tasks**, not unseen tasks.

D.4.4 Protocol

- **Conditions:** MELON and MELON + REM.
- **Benchmark:** AgentDojo banking v1 with the `important_instructions` attack only.
- **Held fixed:** backbone and decoding, MELON's internal settings, attack payloads, step limit and the evaluation checks.
- **Pilot:** 13 cases chosen by a coverage rule declared in advance (every injection task once and four benign tasks), to test compatibility and measure cost.
- **Final case set and repeats:** fixed from the pilot's measured cost; the full set (144 attacked and 16 benign cases) is preferred.
- **Pairing and order:** episodes are paired by case and repeat and run in randomised, interleaved order, each in a fresh environment.
- **Metrics:** attack success rate, utility under attack and benign utility, each over episodes without error. Errors and timeouts are reported separately and never counted as prevented attacks; escalation is never counted as task completion.
- **Uncertainty:** paired differences with cluster-bootstrap intervals over user tasks.

Table D.4. Controlled evaluation of MELON with and without REM (AgentDojo banking v1, `important_instructions`) — NOT EXECUTED

Metric	MELON	MELON + REM	Paired difference (95% cluster-bootstrap interval)
Attack success rate	not executed	not executed	not executed
Utility under attack	not executed	not executed	not executed
Benign utility	not executed	not executed	not executed
Additional calls withheld by REM	—	not executed	—
Escalate verdicts per evaluated call	—	not executed	—
Median end-to-end time per episode; REM time per call	not executed	not executed	not executed
Tokens and cost per episode	not executed	not executed	not executed
Errors and timeouts (by class)	not executed	not executed	—

D.4.5 Interpretation limits

When the study is run, the following limits apply to any finding:

- **Protection.** If MELON has no successful attack in the sample, no further reduction in observed attack success can be demonstrated, and the comparison is about utility and overhead.
- **Utility.** Any additional protection must be reported together with its utility cost. Under no-reviewer semantics, every REM intervention withholds an action.
- **Overhead.** REM adds no model call; MELON roughly doubles the number of model calls of an undefended agent.
- **Scope.** The conclusions are limited to:
    - one attack template;
    - one backbone;
    - exploratory REM costs;
    - familiar tasks;
    - a simulated banking environment.

Adaptive attacks against MELON are not evaluated.

Appendix E: Sensitivity of the Replay Results to the Mitigation Semantics

This appendix reports the replay results of Chapter 4, Section 4.6.3, under both mitigation semantics. Step-level semantics is the declared reference, pending the supervisor's decision on conflict SC-1. The episode-level rows are a sensitivity analysis.

E.1 Replay results under the two mitigation semantics

Table E.1. Replay results under the two mitigation semantics (same episodes; same estimator, calibration, costs, predicates and thresholds; matching reviewer treatment for REM and B1; only the mitigation semantics varies. Verdict sequences are not fixed: see the notes below. ref. = the reference semantics; REM w/o Esc. = REM without expected-loss Escalate; attacked n = 2,979; benign n = 334; `e4_e5_enforcement_replay.json`, `configs.<configuration>_<semantics>_<reviewer>`)

Configuration	Semantics	ASR	Benign utility	Utility under attack
B1, no reviewer	step-level (ref.)	0.055 [0.011, 0.134]	0.509 [0.334, 0.702]	0.514 [0.501, 0.527]
B1, no reviewer	episode-level	0.046 [0.004, 0.125]	0.509 [0.334, 0.702]	0.485 [0.474, 0.496]
B1, idealized reviewer	step-level (ref.)	0.055 [0.011, 0.134]	0.494 [0.329, 0.677]	0.499 [0.487, 0.511]
B1, idealized reviewer	episode-level	0.046 [0.004, 0.125]	0.494 [0.329, 0.677]	0.470 [0.460, 0.481]
REM, no reviewer	step-level (ref.)	0.004 [0.001, 0.007]	0.314 [0.110, 0.548]	0.364 [0.345, 0.389]
REM, no reviewer	episode-level	0.004 [0.001, 0.007]	0.314 [0.110, 0.548]	0.363 [0.344, 0.388]
REM, idealized reviewer	step-level (ref.)	0.004 [0.001, 0.007]	0.497 [0.333, 0.680]	0.496 [0.483, 0.506]
REM, idealized reviewer	episode-level	0.004 [0.001, 0.007]	0.497 [0.333, 0.680]	0.481 [0.468, 0.492]
REM w/o Esc., no reviewer	step-level (ref.)	0.004 [0.001, 0.007]	0.329 [0.126, 0.551]	0.374 [0.351, 0.407]
REM w/o Esc., no reviewer	episode-level	0.003 [0.001, 0.006]	0.329 [0.126, 0.551]	0.370 [0.347, 0.403]

Configuration	Semantics	ASR	Benign utility	Utility under attack
REM w/o Esc., idealized reviewer	step-level (ref.)	0.004 [0.001, 0.007]	0.311 [0.123, 0.518]	0.359 [0.337, 0.391]
REM w/o Esc., idealized reviewer	episode-level	0.003 [0.001, 0.006]	0.311 [0.123, 0.518]	0.355 [0.333, 0.387]

What is fixed and what differs, within NO-ADAPT:

- **What is fixed and what varies.** Both runs of each configuration use the same recorded episodes, the same fitted parameters, costs, predicates and thresholds, and the same reviewer treatment. They differ in the mitigation semantics: under the episode-level variant, an earlier Block or Modify adds tools to a restriction set that refuses later calls.
- **The verdicts are not identical.** For REM without a reviewer, the y = 0 steps received 239 Modify and 1,049 Escalate verdicts under step-level semantics, against 241 and 1,047 under episode-level semantics (`verdict_rates` of the two REM configurations). With the idealized reviewer the counts are 239 / 1,050 against 241 / 1,048. A call refused only under the episode-level variant returns no tool output, so the evidence for later steps can differ. B1's verdict counts are the same under both semantics.
- **B1's ASR is lower under episode-level semantics** (0.055 → 0.046): later state-changing calls are refused by the restriction set left by an earlier Block or Modify. REM's ASR is identical (0.004). REM without expected-loss Escalate changes from 0.004 to 0.003 (unrounded 0.0037 → 0.0034).
- **Utility under attack is lower or equal under episode-level semantics** in every configuration: the restriction set also refuses legitimate later calls.
- **Benign utility coincides** between the two semantics in every configuration of this replay. This is an observation about these episodes, not a property of the semantics.
- **REM − B1 ASR within each semantics** (paired grouped bootstrap, no reviewer): −0.051 [−0.130, −0.007] under step-level semantics (Table 4.26) and −0.043 [−0.122, −0.001] under episode-level semantics (`paired_differences`, episode-level REM − B1 entry). The idealized-reviewer interval under episode-level semantics is the same to three decimals. These are two within-semantics contrasts. No interval was computed for the difference between them, so none is reported. As for every interval in this chapter, the bootstrap over nine attacked groups need not reach nominal coverage, and no hypothesis test is based on these intervals (Section 4.2.1).

Step-level semantics remains the declared reference (Chapter 3, Section 3.8), pending the supervisor's decision D-2. The episode-level rows are a sensitivity analysis, not a replacement for Tables 4.25–4.28.

Appendix F: Register of Open Supervisor Decisions

No supervisor decision is recorded in the project repository. Every item below is open. Where the thesis needed a wording, it uses the option marked “handling”, labelled as pending. The full register, with options and effects, is kept with the project records (`SUPERVISOR_DECISIONS_REQUIRED.md` and the register of the five-chapter draft).

Table F.1. Open decisions that determine what the thesis may claim

ID	Item	Handling in this thesis	Decision needed
SD-FREEZE	Approval of the Chapter 3 specification as frozen	Implemented as specified; values declared	Approve or amend
SD-FEAT	Feature set; **proposed amendment REM v1.1** (behavioral evidence removed)	v1.0 is the design; v1.1 is reported beside it as an ablation whose gain in task completion met the pre-declared decision rule; its effect on security is not resolved	Approve v1.1, or keep v1.0
SD-PERM	**Exploratory extension: task-permission evidence** (request compiler, typed matching, two-verdict decision; Chapter 3, Section 3.14)	Reported as proposed and exploratory, with development results only; not part of REM v1.0 or v1.1	Keep in the thesis as an exploratory result, move to future work, or authorize a prospective evaluation
D-9	Costs, tier map and predicates	Declared exploratory values	Approve, or elicit new values
SC-1 / D-2	Mitigation semantics: step-level or episode-level	Step-level reference; episode-level in Appendix E	Confirm
SC-2 / D-4	Tie rule	Chapter 3 order, with ties counted; no tie occurred in any run	Confirm
SC-3	Calibration-removed ablation run in the evaluation path	Reported	Confirm
SC-4 / D-3	Calibration fitting target: labels or Platt’s smoothed targets	Both implemented; label fit is the reference	Confirm
SC-5	Brier score convention	Binary convention reported, with the convention stated	Confirm
SC-6	Layer label of the estimator in code comments	Decision Engine in the thesis; code comment differs	Confirm

ID	Item	Handling in this thesis	Decision needed
SC-7 / D-1	Recorded-trace replay against the original scope, which excluded replay-based estimation	Kept as a labelled NO-ADAPT analysis	Keep, drop, or replace by live runs
D-6	Label rule; the user_task_15 collision; no human label audit	Rule kept; collision reported; audit package prepared, not annotated	Keep or redefine; audit
D-7	Reviewer model for Escalate	Two bounds; headline results use no reviewer	Confirm
D-8 / SD-DET	Injection classifier of the Detection Layer	Absent; not replaced	Choose a classifier, or record its absence as final
D-10	Wording of the research questions	Marked proposed	Confirm
D-12	Thesis title	As supplied by the author	Confirm
D-15	Live closed-loop experiment and the comparisons that need a language model (MELON, Task Shield, Progent with generated policies, the semantic verifier): backbone, decoding, repeats, budget, credentials	Not run; a sealed prospective protocol exists	Authorize with a spending limit, or accept submission without them
SD-5	Banking-only evaluation against objective O1, which also names task-automation agents	O1 achieved for banking only	Accept or extend
GAP	Research-gap wording of Chapter 2, Section 2.12.7	Proposed wording	Confirm
RULES	Rule baselines P1, P2 and A2 as mandatory comparators; Progent’s manual banking policy as a published comparator in replay	Included	Confirm
RG-1	Authoritative equation registry	Missing; no equation identifier was created	Provide, or accept the provenance table of Appendix C
OI-01 to OI-06	Statements about NEXUS	Abstract and the authors’ repository (read 13 November 2026) only; full text not read	Supply the full text

ID	Item	Handling in this thesis	Decision needed
FULLTEXT	Full texts of aiAuthZ, Kairos, Progent and CaMeL; full-text screening of the systematic review	aiAuthZ: abstract and repository whitepaper; Kairos: abstract; Progent and CaMeL: official repositories; six other papers read in full in November 2026	Supply; decide on a full-text update
N-1, N-2	Supervisor roles on the title page; faculty, department and degree	As in the latest instruction; not verified against official records	Confirm
N-3	Arabic abstract and Arabic spellings of names	Draft translation	Review
N-6	The co-supervisor is a co-author of one cited study (Kanaker et al., 2026)	Cited as a source only; evidence level stated	Decide whether a disclosure is required
N-8	Committee page, declaration (including any declaration on the use of AI tools), dedication, acknowledgement	Placeholders	Complete with the university’s wording
N-9 / TEMPLATE	University thesis template and formatting rules	**Not available**; an assumed A4 thesis layout is used	Provide; re-check the layout

Smaller items (the Platt reference year, the regularization convention, one cell of the false-positive grid, and the optional sequential analysis) are listed in the project register and do not affect any reported result.